

INTEGRATED AUTOMOTIVE STANDARDS HANDBOOK

Integrated Automotive Standards Handbook

ISO 26262 · ISO/SAE 21434 · ISO 21448

ISO/PAS 8800 · ISO 9001/IATF 16949 · ASPICE v4.0

Version 1.0 | April 2026 | ISH-2026-001

TABLE OF CONTENTS

PART I: Foundation & Framework

- Chapter 1: How to Use This Handbook
- Chapter 2: The Six Standards at a Glance
- Chapter 3: The Integration Framework

PART II: Clause-Level Cross-Mapping by Lifecycle Phase

- Chapter 4: Concept & Planning
- Chapter 5: Safety Architecture & HARA
- Chapter 6: Security Analysis & TARA
- Chapter 7: Detailed Design & AI Integration
- Chapter 8: Implementation & Verification
- Chapter 9: Validation & Risk Assessment
- Chapter 10: Release & Operational Safety

PART III: End-to-End Worked Examples

- Chapter 11: Case Study: Autonomous Emergency Braking (AEB) System
- Chapter 12: Case Study: Vehicle-to-Infrastructure (V2X) Gateway

PART IV: Practical Tools

- Chapter 13: Traceability & Artifacts Matrix
- Chapter 14: Audit & Assessment Checklists
- Chapter 15: Process Improvement Roadmap

PART V: Reference & Appendices

- Appendix A: Glossary of Terms
- Appendix B: Standards References & URLs
- Appendix C: Cross-Reference Tables
- Appendix D: Regulatory Framework by Region

PART I

Foundation & Framework

Chapters 1–3

CHAPTER 1: HOW TO USE THIS HANDBOOK

SCOPE

A role-based navigation guide to extract maximum value from this handbook. Whether you are a safety engineer, software architect, security analyst, or QMS auditor, this chapter shows you where to start and how to read for your specific responsibility.

1.1 Who This Is For

This handbook is designed for automotive development teams spanning six key roles, each with distinct compliance obligations, technical concerns, and information priorities. The automotive standards landscape is complex and interconnected—no single standard can be implemented in isolation. This handbook maps dependencies, overlaps, and sequencing to ensure that functional safety, cybersecurity, quality management, and process maturity work together cohesively rather than as parallel silos.

Safety engineers will use this handbook primarily to navigate the ISO 26262 ASIL framework, understand how cybersecurity (21434) and SOTIF (21448) interlock with safety-critical development, and plan hazard analysis and verification strategies. The handbook shows exactly where safety responsibilities intersect with security engineering and quality gate approvals, preventing gaps in risk management.

Software developers need to understand not only the design and implementation clauses from 26262 and AUTOSAR, but also why software traceability, static analysis, and unit test coverage are required by multiple standards simultaneously. This handbook demonstrates that the same artifacts often satisfy requirements from both safety and cybersecurity standards, enabling more efficient work product planning and reuse.

Quality and process managers will use this handbook to understand the broader context of APQP, PPAP, and production readiness requirements in Chapter 4, and how they interact with safety planning (26262 Part 2) and security governance (21434 Clause 5). The handbook clarifies role responsibilities and approval gates that must be coordinated across engineering and quality functions.

Use the role-based table below to identify your primary chapters and focus areas, then turn to Section 1.3 for a recommended reading sequence that builds knowledge efficiently without requiring sequential cover-to-cover study.

Role	Primary Standards	Key Chapters	Focus Areas
Safety Engineer	26262, 21448, ASPICE	5, 6, 9, 13	HARA, FTTI, ASIL, work products
Software Developer	26262, 21434, ASPICE	8, 11, 13	Code standards, tests, traceability
Quality Manager	9001, IATF 16949, ASPICE	4, 10, 13, 14	APQP, PPAP, audit trails, controls
AI/ML Engineer	26262, PAS 8800, 21448	8, 11, 12	Data governance, robustness, validation
Security Architect	21434, 21448, 26262	6, 7, 11, 12	TARA, threat modeling, CSMS
Internal Auditor	All	14, 15, Appendix C	Checklists, evidence, non-conformance

Table 1.1. Role-based entry points and recommended chapter priority.

1.2 How the Handbook Is Organized

The handbook is structured in five parts that build from foundational concepts to executable processes. Each part serves a distinct purpose in your workflow, whether you are onboarding new team members, performing traceability audits, or resolving a specific compliance question during development.

Part I (Chapters 1–3) establishes the business case for integrated standards management and provides a high-level technical overview of the six normative standards. You should read this first regardless of your role to build a shared vocabulary and understand the constraints and dependencies that will shape your work. Chapter 2 in particular contains the most frequently referenced definitions—ASIL, TARA risk matrices, ASPICE process descriptions—that other parts assume you know.

Part I: Foundation & Framework. Chapters 1–3 establish the business case for integration and the six-standards landscape. Chapter 1 (this chapter) is a navigation guide for all roles. Chapter 2 provides concise technical overviews of each standard—scope, structure, key concepts, regulatory context—sufficient for both specialists to recall details and non-experts to understand the landscape. Chapter 3 explains why isolated standard implementations fail and introduces the integration framework that subsequent chapters build upon.

Part II: Clause-Level Cross-Mapping. Chapters 4–10 are the core reference section. They organize all requirements by automotive lifecycle phase: concept & planning (Chapter 4), safety architecture & HARA (Chapter 5), security analysis & TARA (Chapter 6), detailed design & AI integration (Chapter 7), implementation & verification (Chapter 8), validation & risk assessment (Chapter 9), and release & operational safety (Chapter 10). For each phase, you will find clause-by-clause mappings from all six standards, showing which requirements apply, which work products satisfy multiple standards simultaneously, and where responsibilities overlap or conflict. This is the primary reference for traceability work and for resolving "which standard requires this?" questions during development.

Part III: Worked Examples. Chapters 11–12 demonstrate how the integration framework works in practice through two real-world case studies. Chapter 11 traces an autonomous emergency braking (AEB) system through the full lifecycle, showing how safety analysis drives architecture, how security constraints shape implementation, and how ASPICE process maturity enables confidence in verification results. Chapter 12 examines a V2X gateway, emphasizing security-critical integration and the interplay between cybersecurity threat modeling and safety risk management. Both cases show the actual work products, decision points, and approval gates that occur in practice.

Part IV: Practical Tools. Chapters 13–15 provide immediately usable reference materials for audits, continuous improvement, and organizational setup. Chapter 13 is a traceability and artifact matrix showing which clauses require which work products and how to verify compliance. Chapter 14 contains reusable audit checklists and non-conformance scenarios for quality reviews. Chapter 15 is a process improvement roadmap for organizations moving from ad-hoc to integrated standards management.

Part V: Reference. Appendices A–D contain a glossary of terms (Appendix A), standard URLs and purchase information (Appendix B), comprehensive cross-reference tables for quick lookup (Appendix C), and regional regulatory frameworks that map automotive regulations to standards baseline requirements (Appendix D).

1.3 Reading Paths by Role

Your role determines which chapters provide maximum value. The recommended reading sequences below are cumulative—each later chapter assumes foundational knowledge from earlier parts. All roles should skim

Chapters 1–3 (Part I) to establish shared vocabulary and understand the integration framework, even if you focus heavily on specific standards in your day-to-day work.

A safety engineer implementing ISO 26262 ASIL D for an autonomous braking system would follow the safety engineer path: start with Chapters 1–3 for context, then move to Chapters 5–6 to understand HARA, FTTI allocation, and security integration; Chapter 9 covers validation and risk assessment specific to safety-critical systems; Chapter 11 provides a worked example of a similar ADAS system; finally, Chapters 13–14 contain the artifact matrix and audit checklists you will use to verify compliance.

A software developer on the same project would follow a similar sequence but would place greater emphasis on Chapter 8 (implementation, code standards, unit testing, static analysis) and Chapter 13 (artifact traceability). You would also benefit from Chapters 11–12 to see how code review findings, test reports, and traceability matrices are actually prepared in practice.

A quality manager responsible for APQP and supplier audits would prioritize Chapters 1–3 for overview, Chapter 4 for concept and planning phases (which contain APQP/PPAP requirements), Chapter 10 for production release criteria, Chapters 13–15 for artifact verification and audit checklists, and Appendix C for cross-reference tables that map which supplier work products satisfy which requirements across all standards.

Role	Recommended Reading Sequence
Safety Engineer (26262/ASIL)	1, 2, 3 → 5, 6, 9 → 11 → 13, 14
Software Developer	1, 2, 3 → 8, 10 → 11, 12 → 13
Quality/Process Manager	1, 2, 3 → 4, 10 → 13, 14, 15 → Appendix C
AI/ML Engineer (Safety-Critical)	1, 2, 3 → 7, 8, 9 → 12 → Appendix B
Security Architect	1, 2, 3 → 6, 7 → 11, 12 → 14
Internal Auditor / Management	1, 2, 3 → 14, 15 → Appendix C, D → 4–10 (spot-check)

Table 1.3. Role-specific reading paths for optimal time investment.

Each reading path is designed to minimize the total number of chapters you must study while maximizing the relevance of the material you do read. After completing your role-specific path, you can use the Appendices and cross-reference tables (Appendix C) to drill down into any specific clause or requirement that arises during your actual work.

1.4 Conventions Used in This Handbook

To maximize clarity and enable rapid reference lookup, we follow standardized notation and formatting throughout. Consistency in how we reference clauses, describe processes, and present tables means you can skim quickly and trust that when you find an item marked with a specific symbol or format, you know exactly what kind of information it contains.

Standard and clause references are the backbone of this handbook. Every requirement trace back to a specific clause in one of the six normative standards. We use the notation [StdNum:Part.Clause] consistently throughout. For example, [26262-3:7.4.2] refers to ISO 26262:2018 Part 3, Clause 7, Section 4, Requirement 2. When a single requirement spans multiple clauses, we note the range, e.g., [21434:5.1–5.3]. When you see a bracketed reference, you can trace it directly to the published standard document; Appendix B provides URLs and purchase links for all standards cited.

Standard & Clause References. Exact references are noted as [StdNum:Part.Clause] in square brackets. Example: [26262-3:7.4.2] refers to ISO 26262:2018, Part 3, Clause 7, Section 4, Requirement 2. When a reference spans multiple clauses, we note the range, e.g., [21434:5.1–5.3]. Appendix B provides URLs to purchase or access each standard.

Cross-References. Intra-handbook cross-references are marked as 'see Section X.Y' or 'Chapter N'. These allow you to jump between related topics without rereading context. External references to published papers, technical reports, and standards documents are marked with a superscript number (e.g., [1]) and listed in full in Appendix B. When you encounter such a reference, you can use Appendix B to verify the exact title, publication date, and where to obtain the document.

Scope & Note Boxes. Navy-bordered callout boxes at the start of each section highlight the scope (what is covered and what is not) and critical definitions or warnings (NOTE boxes). Every box is clearly labeled for quick scanning. SCOPE boxes define the boundaries of the upcoming section and prevent misunderstandings about applicability. NOTE boxes contain practical tips, common pitfalls, or essential clarifications that practitioners frequently overlook.

Tables. All tables follow the booktabs style: horizontal rules only, no vertical dividers or cross-hatching. Header rows are bold and dark. This style maximizes readability in print and on screen. Tables are numbered sequentially within each chapter (e.g., Table 2.1, Table 2.2) and appear centered with captions below. Captions include both the table number and a brief title that describes its purpose.

Graphics & Diagrams. Process diagrams, lifecycle V-models, risk matrices, and integration maps use a consistent navy (#1B3A5F), teal (#0D7377), and light-gray color palette throughout. All graphics are vector-based PDF or SVG to ensure print quality at any resolution. When a graphic illustrates a process flow, inputs are shown on the left, outputs on the right, and decision points are marked with diamonds.

Acronyms. First use of an acronym is spelled out in full with the acronym in parentheses—e.g., 'Automotive Safety Integrity Level (ASIL)'. Subsequent uses refer to the acronym alone. A complete glossary of all acronyms and terms is provided in Appendix A; use it whenever you encounter unfamiliar notation.

Convention	Meaning & Usage
[26262-3:7.4.2]	Clause reference: use Appendix B to locate the standard and verify context
see Section X.Y	Intra-handbook cross-reference; jump to the linked section
[1]	External reference; see Appendix B for full citation and URL
SCOPE box	Defines coverage and applicability of the section; read before skipping content
NOTE box	Practical tips, warnings, or common pitfalls; always worth reading
Table N.M	Numbered table; captions describe purpose; tables numbered per chapter
Figure N.M	Graphic; diagrams use navy/teal/gray palette; all vector-based for print

ASIL, TARA, etc. Acronym defined on first use; full expansion in Appendix A glossary

Table 1.4. Notation and formatting conventions used throughout this handbook.

1.5 Version History and Maintenance

This handbook is maintained in alignment with the published versions of the standards it covers. Whenever a normative standard is updated by its issuing body (ISO, SAE, or a consortium), we monitor that update and assess whether it affects the clause mappings, key concepts, or recommendations in this handbook. Our versioning policy is designed to help you track which standards baseline supports a particular handbook version, so you can verify currency quickly.

Minor version updates (e.g., v1.0 to v1.1) occur when one or two standards are refined or when we add clarifications based on field feedback, but the six-standard foundation remains unchanged. Major version updates (e.g., v1.0 to v2.0) occur when standards updates significantly change the integration landscape—for example, if a major revision to AUTOSAR or a new edition of ISO 26262 alters HARA requirements. We notify all stakeholders of major version changes and provide transition guidance for users of the prior version.

Your development project should reference the specific handbook version used for planning and compliance work. This ensures that if standards change mid-project, you have a clear record of which standard versions your artifacts were verified against. Appendix B lists the exact publication dates and editions of all standards referenced in this handbook version.

Version	Release Date	Standards Baseline	Key Content Changes
v1.0 (Rev A)	Q2 2026	26262:2018, 21434:2021, 21448:2022, PAS 8800:2024, 9001:2015, ASPICE v4.0	Initial release: 6 standards, 15 chapters, integration framework, 2 case studies
v1.1 (planned)	Q4 2026	Same as v1.0 + clarifications	SOTIF implementation refinements, supply-chain security emphasis, auditor feedback
v2.0 (planned)	Q2 2027	Post-2026 standards updates	Quantum-safe cryptography guidance, Level 3 autonomous driving scenarios, revised AUTOSAR Adaptive mapping

Table 1.5. Handbook versioning roadmap and standards baseline.

If you are reading this handbook more than six months after the release date shown in Table 1.5, we recommend checking with the handbook maintainers or standards bodies to confirm that no critical standard updates have been released. Appendix B contains contact information for the standards organizations and the handbook management team.

HOW TO VERIFY STANDARDS CURRENCY

Always cross-check clause references against the published standard documents. This handbook is a guide; the original standards are the authoritative source. Appendix B provides URLs and purchase links for all standards, and Chapter 2 contains the exact standard titles, parts, and publication years so you can locate them in your organization's standards

library or purchase new copies if needed.

CHAPTER 2: THE SIX STANDARDS AT A GLANCE

SCOPE

A comprehensive technical overview of the six normative standards governing automotive safety, security, quality, and process maturity. This chapter provides scope, structure, key concepts, regulatory context, and practical applicability constraints for each standard. Intended for both specialists seeking to recall essential details and non-experts building a working understanding of the landscape. Each section includes scope clarifications, full clause structures or process maps, key definitions with examples, and boundary conditions showing what each standard does NOT require.

2.1 ISO 26262:2018 — Functional Safety of Electrical/Electronic Systems

ISO 26262:2018 is the primary functional safety standard for automotive electrical and electronic (E/E) systems, applicable globally across OEMs and suppliers. Adopted in 2018 (and further clarified in Amendment 1 published 2021), it mandates systematic hazard and risk analysis (HARA), establishment of safety integrity levels (ASIL) based on severity, exposure, and controllability, and development of fault-tolerant architectures with robust diagnostics mechanisms. The standard defines a V-model lifecycle and prescribes required work products, review gates, and verification rigor for each ASIL level. It applies to all safety-critical systems from concept through end-of-life, including post-production field updates and service procedures.

ISO 26262 is unique among the six standards in this handbook because it is the only one that defines quantitative failure metrics and reliability targets. Where 21434 (cybersecurity) is threat-focused and 21448 (SOTIF) is scenario-focused, 26262 requires explicit failure rate analysis, diagnostic coverage calculation, and probabilistic hazard assessment. This quantitative foundation is why it is often treated as the primary standard in integrated safety-critical programs: cybersecurity and SOTIF requirements must ultimately trace back to safety goals derived from 26262 HARA and ASIL determination.

The standard structure spans 12 parts, each addressing a distinct lifecycle phase or support process. Parts 3–5 are the most heavily referenced during development: Part 3 covers concept and planning (HARA, ASIL determination), Part 4 covers hardware design and diagnostics (failure metrics, SPFM, LFM), and Part 5 covers software design and verification. Parts 2, 8, and 11 define the management, configuration, and OTA update processes that integrate these design phases.

Scope & Applicability. Covers systems where random or systematic electrical and electronic failures could cause injury or death. Applies to sensors, ECUs, networks, actuators, and any E/E component in the failure chain. Does NOT cover mechanical failures (hydraulic brakes, springs), chemical hazards (battery electrolyte), or non-road vehicles (forklifts, agricultural equipment) unless explicitly stated in contractual scope. A common integration question: if a hydraulic braking subsystem fails and an electronic backup (electronic parking brake, regenerative braking) is available, 26262 covers the electronic backup but NOT the mechanical failure of the hydraulic system itself—that would require FMEA against mechanical standards.

Part	Title	Key Content
1	Vocabulary & Overview	Definitions, application principles, V-model, ASIL framework
2	Management of Functional Safety	Safety planning, documentation, work product structure

3	Concept Phase	HARA, FTTI, system safety requirements, ASIL determination
4	Product Development (H/W)	Hardware design, diagnostics (DC), failure metrics (SPFM, LFM, PMHF)
5	Product Development (S/W)	Software requirements, architecture, design, static/dynamic verification
6	Product Development (Guidance)	Process guidance for small/medium suppliers, tool qualification
7	Production, Operation, Service	Change management, field updates, recalls, validation
8	Supporting Processes	Specification review, hazard log, safety case, configuration management
9	ASIL Decomposition	Techniques for breaking down ASIL requirements across subsystems
10	Guideline on ISO 26262	Non-normative interpretation and examples
11	Safety of Software Updates	OTA validation, rollback, activation constraints
12	Adaptive Platform	AUTOSAR Adaptive specific rules and processes

Table 2.1. ISO 26262:2018 — 12 Parts overview.

ASIL Determination & Framework. The Automotive Safety Integrity Level (ASIL) is determined by a 3×3×3 combination matrix of Severity (S1–S3, where S3 is death), Exposure (E1–E3, frequency/probability that the hazard occurs), and Controllability (C1–C3, driver ability to avoid harm). The combination yields five levels: QM (Quality Managed, no safety integrity requirement), ASIL A (lowest), ASIL B, ASIL C, and ASIL D (highest). Each ASIL level prescribes minimum required techniques: metrics reviews, architecture patterns, code standards, test depth, and tool qualification. For example, ASIL C requires Failure-to-First-Detection (FTTI) greater than 10 ms; ASIL D requires $FTTI \leq 10$ ms. ASIL D also mandates formal methods for critical algorithms and independent verification teams in many organizations.

Safety Goals & Functional Safety Concepts. HARA produces identified hazards; each hazard is assigned an ASIL and a safety goal—a top-level requirement that prevents or mitigates the hazard. For example, 'prevent unintended acceleration due to throttle ECU failure' becomes a safety goal at ASIL D. This safety goal drives system safety requirements (what the system must do), which flow to hardware and software requirements (how it does it). All development artifacts—design, code, tests, reviews, configuration—must trace back to at least one safety goal.

Failure Metrics & Diagnostic Coverage. The standard defines four key metrics that determine whether a design meets ASIL requirements. Failure-to-First-Detection (FTTI) is the time from a fault occurring until the diagnostic detects it. Single-Point Failure Metric (SPFM) is the proportion of single-point faults that are detected and controlled. Latent Fault Metric (LFM) is the proportion of latent faults (faults detected only during periodic tests, not continuously) that are controlled. Probabilistic Metric of Hazard (PMHF) is the combined residual risk of all undetected failures that could cause a safety goal violation. PMHF for ASIL D must be $\leq 10^{-8}$ per operating hour across the 10-year vehicle lifetime. Calculating PMHF requires failure-mode analysis (FMEA or FTA), failure rate data (from suppliers or standards like IEC 61508), and diagnostic coverage claims validated by evidence (tests, reviews, formal analysis).

Safe States & Fallback Behavior. A critical concept in 26262 is the 'safe state': a system condition where no harm can occur. For a power steering system, the safe state is one where steering torque is immediately

returned to the driver (limp-home mode). For autonomous braking, it is triggering maximum available braking. For a powertrain control, it is cutting fuel injection. The standard requires that all detected faults either be controlled (prevented from causing harm) or drive the system to a safe state within FTTI. This determines both the hardware architecture (redundancy, plausibility checks) and software design (state machines, failsafe modes).

Boundary Conditions. ISO 26262 does NOT mandate specific programming languages (C, C++, Ada are all acceptable), design patterns (design-by-contract, formal methods), or tooling vendors. It does NOT prescribe the use of MISRA C or any specific coding standard, though most ASIL D projects adopt MISRA C as evidence of robust code. Does NOT cover pre-concept hazard identification (use IEC 61882 HAZOP or equivalent for that scope). Does NOT cover non-automotive domains or systems outside the defined scope (e.g., infotainment systems are often QM unless they affect safety goals).

Regulatory Context & Type Approval. Mandated by EU Type-Approval Regulation 2018/858 (and its successor Regulation 2024/1362 in force from 2025) for any system that could affect vehicle safety. China GB/T 34590 mirrors the 26262 ASIL framework. Japan JIS D 6114 references it. ASIL D is a de facto requirement for all Level 2+ autonomous driving systems globally. Compliance is verified through homologation audits, where regulators (NHTSA, JAMA, CATARC) examine work products, traceability, and evidence packages.

2.2 ISO/SAE 21434:2021 — Road Vehicles — Cybersecurity Engineering

ISO/SAE 21434:2021 specifies cybersecurity engineering processes and activities for road vehicle systems, developed jointly by ISO and SAE (Society of Automotive Engineers) to address the growing threat of cyber attacks on connected and autonomous vehicles. Published in 2021, it has become mandatory in EU Directive 2019/1148 and is rapidly being adopted by vehicle OEMs worldwide as a requirement for suppliers and integrated partners. Unlike ISO 26262, which focuses on systematic and random failures, 21434 addresses intentional malicious threats: attackers probing networks, reverse-engineering firmware, injecting false CAN messages, or exploiting wireless access points (cellular, WiFi, V2X). The standard spans organizational processes (Cybersecurity Management System governance), threat analysis and risk assessment, secure architecture and design, implementation with secure coding, verification and testing (including penetration testing), and post-production monitoring and incident response.

The integration of 21434 with 26262 is critical. A failure detected by diagnostics in 26262 context is a passive defensive measure; a cyber threat mitigated by 21434 is an active defensive measure against an intelligent adversary. Both must be present in a connected vehicle: 26262 ensures the system is safe even when components fail randomly, and 21434 ensures it remains safe when an attacker deliberately manipulates messages, exploits protocols, or leverages supply-chain vulnerabilities. The Cybersecurity Assurance Level (CAL) in 21434 parallels ASIL in 26262 but is risk-driven by threat severity and attack feasibility rather than failure probability.

Scope & Applicability. Applies to any vehicle system that could be vulnerable to intentional cyber attacks: infotainment systems, gateway ECUs, telematics modules, autonomous driving stacks, battery management systems, and vehicle-to-infrastructure (V2X) communication. Covers organizational governance (Cybersecurity Management System), supply chain (requirements flow to suppliers), development (threat modeling, architecture review, secure coding), production (secure provisioning, key management), and post-production (OTA update security, vulnerability disclosure, incident response). Does NOT prescribe specific cryptographic algorithms (AES, RSA, ECC all acceptable), network protocols (CAN, LIN, Ethernet, 5G), or development methodologies. Does NOT provide threat intelligence (threat actors, attack vectors) beyond general guidance on feasibility factors (time, cost, skill, access).

Clause	Process/Topic
5	Organizational and management processes (CSMS, roles, training)
6	Project planning (threat analysis, asset identification, boundary definition)
7	Threat analysis and risk assessment (TARA: likelihood × impact matrix)
8	Security requirements specification (CAL 1–4 allocation)
9	Security architecture and design (defense in depth, least privilege)
10	Security implementation (secure coding, crypto, authentication)
11	Verification and testing (penetration testing, static analysis)
12	Validation (risk acceptance, disclosure, incident response)
13	Production and deprovisioning (secure boot, key management)
14	Post-production activities (vulnerability monitoring, OTA updates)
15	Supply chain and stakeholder processes (requirements flow, audits)

Table 2.2. ISO/SAE 21434:2021 — Clauses 5–15 process map.

Cybersecurity Assurance Levels (CAL) & Risk Determination. CAL 1–4 are assigned based on threat severity (business impact, safety impact, privacy impact) and attack feasibility (time-to-exploit, skill required, equipment cost, supply-chain access). CAL 4 is the highest and is typically assigned to threats that could lead to loss of vehicle control or critical safety system compromise (e.g., brake system immobilization via CAN network injection). CAL 3 might cover spoofing or jamming of infotainment or navigation. CAL 2 might cover privacy breaches or non-critical service denial. CAL 1 is for low-risk items. Each CAL prescribes minimum techniques: CAL 1 requires basic code review and static analysis; CAL 4 requires penetration testing, architectural security reviews, formal verification for cryptography, and independent assessment. The CAL scale is similar in intent to ASIL but is threat-centric rather than failure-centric.

Threat Analysis & Attack Feasibility Matrix. 21434 Clause 7 (TARA—Threat Analysis and Risk Assessment) requires identifying potential attacks: exploit vectors (e.g., CAN message injection via OBD-II port), attack methods (e.g., sniffing, fuzzing, reverse engineering), and attacker profiles (e.g., 'remote attacker with OBD tool' vs. 'insider with network access'). Feasibility is assessed on four axes: time-to-exploit (seconds to hours rated lowest feasibility, months to years rated highest), specialist skill (novice to expert), equipment (improvised to highly specialized), and supply-chain access (public interfaces to proprietary firmware). An OTA attack exploitable in minutes by a skilled attacker using public tools rates high feasibility; a lab-only attack requiring \$10M equipment rates low. This feasibility assessment informs CAL assignment.

Cybersecurity Management System (CSMS) & Governance. Clause 5 mandates an organizational CSMS that defines roles (Chief Security Officer, threat assessment teams), processes (threat modeling, security review gates), and metrics (vulnerability discovery metrics, patch deployment timelines). The CSMS must flow requirements to all suppliers and track their compliance. For large OEMs, this often means establishing a supplier security audit program and vulnerability management procedures.

Defense-in-Depth & Layered Architecture. Clause 9 emphasizes that no single security control is sufficient. A critical system must have multiple independent defenses: network segmentation (isolating the safety-critical network from infotainment), cryptographic authentication (preventing message spoofing), intrusion detection (monitoring for anomalous behavior), and secure boot (preventing firmware tampering). If one defense is compromised, others remain active.

Boundary Conditions & What 21434 Does NOT Require. Does NOT mandate specific cryptographic algorithms, cipher suites, or key lengths—organization chooses based on threat model and computational constraints. Does NOT require open-source or transparent cryptography; proprietary algorithms are acceptable if validated. Does NOT prescribe specific threat modeling methodologies (STRIDE, DFD, ATT&CK, etc.)—teams choose an appropriate method. Does NOT require hiring dedicated security teams; small suppliers may outsource TARA and penetration testing. Does NOT mandate specific development tools or languages.

Regulatory Context & Homologation. Mandated in EU Directive 2019/1148 (Vehicle Cybersecurity Regulation) effective 2024 for new vehicle approvals. US NHTSA references 21434 in its Cybersecurity and Privacy Guidance (2022). Japan's JAMA introduced cybersecurity audit requirements effective 2024. China is developing parallel GB/T standards aligned with 21434 concepts. UN Regulation 155 (Vehicle Cybersecurity) and Regulation 156 (Software Updates) codify 21434 requirements in international law.

2.3 ISO 21448:2022 — Safety of the Intended Functionality

ISO 21448:2022 (SOTIF) is the safety standard for systems where advanced algorithms, perception sensors, and machine learning create a new class of hazards: those that arise NOT from E/E failures (26262 domain) or deliberate attacks (21434 domain), but from limitations of the intended design itself. Published in 2022 as the revised edition (adding L2+ autonomous driving scenarios), SOTIF is essential for perception-dependent systems (camera-based lane-keeping, radar-based collision avoidance, vision-based object detection) where the system may operate correctly according to its design but still fail to detect hazards due to environmental conditions, sensor limitations, or algorithm limitations (e.g., false-negative detection of a pedestrian in heavy rain). Where 26262 asks 'what if the E/E system fails?', SOTIF asks 'what if the system works as designed but the real world is not within the design assumptions?'

SOTIF is not a replacement for functional safety (26262) but a necessary complement. A vehicle equipped with an AEB (Autonomous Emergency Braking) system must satisfy both 26262 requirements (e.g., if the brake actuator fails, diagnostics detect it and trigger a safe state) and SOTIF requirements (e.g., even when the actuator works, the perception system must reliably detect obstacles across the system's operational design domain—day, night, rain, fog, etc.). If AEB fails to detect a pedestrian because the camera is blinded by low-angle sunlight, that is a SOTIF hazard, not a failure-mode hazard.

Scope & Operational Design Domain (ODD). Applies to driving automation (lane-keeping, adaptive cruise, parking), perception systems (object detection, semantic segmentation, sensor fusion), decision logic (path planning, behavior prediction), and any feature where system behavior depends on environmental conditions or learned patterns. SOTIF requires explicit definition of the Operational Design Domain (ODD): the set of conditions under which the system is designed to operate. For example, an ADAS system might have ODD constraints: daylight/twilight only, paved roads only, dry conditions only, speeds 0–130 km/h. These boundaries are documented and enforced (e.g., camera-based ADAS automatically dims lane-keeping if nightfall is detected). Complements but does NOT replace 26262; both apply to ASIL D systems. Complements but does NOT replace 21448 (SOTIF predates and is distinct from 21434 cybersecurity scope).

Clause	Process/Topic
5	Scope definition and triggering conditions (when does the feature operate?)
6	Hazard analysis (four-quadrant model: system behavior vs. real-world variation)
7	Risk evaluation (likelihood × severity of misuse or limitation triggering hazard)
8	Functional safety integration (linking SOTIF to 26262 requirements)
9	Safety of operations (driver overreliance, takeover readiness)
10	Specification and design (performance requirements, validation metrics)
11	Verification and validation (naturalistic driving data, edge-case testing)
12	Production and post-production (performance monitoring, algorithm updates)

Table 2.3. ISO 21448:2022 — Clauses 5–12 process map.

Four-Quadrant Risk Model & Environmental Variation. SOTIF analysis uses a four-quadrant model where the axes are: (1) system performance (nominal vs. degraded) and (2) environmental conditions (normal vs. extreme). Hazards can arise in any combination. Quadrant 1 (nominal system, normal environment) is the design assumption—low risk. Quadrant 2 (nominal system, extreme environment) represents situations outside ODD where perception may fail: a LiDAR-based detector in heavy fog, a camera-based detector in glare, a radar system in rain interference. Quadrant 3 (degraded system, normal environment) represents performance degradation: a sensor aging, a compute resource constrained, or an algorithm encountering edge cases not well-represented in training data. Quadrant 4 (degraded system, extreme environment) is highest risk and requires strongest controls. For each quadrant, SOTIF requires explicit hazard analysis and mitigations.

Triggering Conditions & ODD Enforcement. SOTIF mandates explicit operational design domain (ODD) constraints: speed ranges (e.g., 'AEB unavailable above 180 km/h'), lighting conditions (e.g., 'lane-keeping deactivated at night'), weather (e.g., 'ADAS off in heavy rain'), road type (e.g., 'AEB off on unpaved roads'), lane markings (e.g., 'lane-keeping requires visible lane marks'), and other conditions. Each constraint must be actively enforced: when the trigger condition is met (darkness detected, weather sensor reports rain), the system must automatically disable and notify the driver. Failure to implement triggering conditions is a SOTIF violation.

Performance Validation & Naturalistic Testing. Unlike 26262 unit-test and functional verification, SOTIF validation requires testing under naturalistic driving conditions: real weather, real lighting, real traffic patterns. Test fleets accumulate millions of miles; test tracks simulate edge cases (heavy rain, glare, occlusion, unusual road markings). Validation metrics include detection rates (e.g., 'object detection ≥99.5% in ODD'), response times (e.g., 'latency ≤100 ms'), and failure rates (e.g., 'undetected pedestrian ≤1 per 1M miles'). Machine-learning-based systems require additional validation: adversarial robustness (performance against perturbed inputs), distribution shift resilience (performance on data different from training set), and uncertainty quantification (system should report low confidence when uncertain).

Driver Oversight & Fallback Strategy. SOTIF Clause 9 addresses driver overreliance and takes-over capability. If a system uses lane-keeping assistance, drivers must remain engaged and capable of taking over if the system fails or reaches ODD limits. SOTIF validation includes driver-in-the-loop testing to verify that drivers remain attentive and can regain control within acceptable time windows (typically <2 seconds for L2

systems). For fully autonomous systems (L4+), fallback strategies include minimal-risk maneuvers (MRM): safe pullover, hazard lights, emergency braking.

Boundary Conditions & What SOTIF Does NOT Require. Does NOT mandate specific sensing hardware (camera, LiDAR, radar, sensor fusion—all acceptable if validated). Does NOT prescribe algorithmic approaches (classical computer vision, deep learning, ensemble methods all acceptable). Does NOT cover driver training or user manuals (responsibility of separate functional safety and marketing processes). Does NOT require formal verification of ML models (though it is beneficial for ASIL D systems).

Regulatory Context & Homologation. Emerging requirement in EU SOTIF Regulation (Amendment to 2019/1148, expected 2025). Japan has published SOTIF guidance documents. China is incorporating SOTIF concepts in its autonomous driving standards. Industry consensus: SOTIF is mandatory for all L2+ autonomy (SAE Levels 2–5) worldwide. Level 3 and above (conditional and full autonomy) require formal SOTIF compliance with extensive ODD documentation and naturalistic validation data.

2.4 ISO/PAS 8800:2024 — Road Vehicles — Artificial Intelligence System Safety

ISO/PAS 8800:2024 (Publicly Available Specification, on the fast-track path toward full ISO standard status by 2026) addresses safety assurance of machine-learning and artificial-intelligence systems deployed in vehicles. Published in 2024 as a response to the rapid adoption of deep-learning perception models in L2+ autonomous systems, SOTIF concerns about environmental robustness, and cybersecurity vulnerabilities in ML supply chains. PAS 8800 builds on and integrates with 26262 (functional safety), 21448 (SOTIF), and 21434 (cybersecurity) by adding data governance, model robustness validation, and algorithmic transparency requirements that existing standards do not explicitly address. The standard covers the full lifecycle of AI systems: data acquisition and governance, model training and validation, deployment, runtime monitoring, and retraining or model updates.

The need for PAS 8800 arises from unique characteristics of ML systems that challenge traditional verification approaches. A neural-network vision system trained on millions of images may achieve 99.5% accuracy on a test dataset but fail catastrophically on adversarial images (images imperceptibly modified to fool the classifier), out-of-distribution examples (scenarios not well-represented in training data), or subtle environmental shifts (distributional shift between training and deployment). Traditional 26262 verification relies on exhaustive testing or formal proof; ML systems are too complex for exhaustive testing and formal verification of learned parameters is currently infeasible. PAS 8800 provides a framework for understanding and mitigating these unique risks: data quality, model robustness, uncertainty quantification, and runtime performance monitoring.

Scope & ML System Categories. Covers all AI/ML systems deployed in vehicles: perception models (object detection, semantic segmentation, sensor fusion), prediction models (trajectory prediction, behavior prediction), decision models (planning, control), and end-to-end learning systems that map sensor inputs directly to control outputs. Applies to all ASIL levels (QM, A, B, C, D). Does NOT mandate specific ML frameworks (PyTorch, TensorFlow, JAX all acceptable), specific algorithms (CNNs, RNNs, transformers all acceptable), or specific training data sources (proprietary, open-source, synthetic, all acceptable if validated). Does NOT cover general AI safety concerns (alignment, control) or non-automotive ML applications.

Clause / Annex	Topic
5	AI system lifecycle and governance (data provenance, model versioning)

6	Hazard and risk analysis for AI (failure modes of perception, training data bias)
7	AI safety requirements (robustness thresholds, uncertainty quantification)
8	Architecture and design (ensemble methods, out-of-distribution detection)
9	Development and training (dataset validation, hyperparameter justification)
10	Verification and validation (naturalistic edge cases, adversarial testing)
11	Deployment and monitoring (performance degradation detection, fallback logic)
12	Supply chain and third-party components (open-source model audits, SBOMs)
A	Data lifecycle V-model (collection → cleaning → labeling → training → validation → deployment)
B	Model robustness taxonomy (perturbation resistance, OOD handling, calibration)
C	Uncertainty quantification methods (Bayesian, ensemble, epistemic vs. aleatoric)
D	Adversarial testing for autonomous systems
E	Supply chain SBOM template for AI components
F	Interpretability and explainability guidance (SHAP, LIME, saliency maps)
G	Post-release monitoring (concept drift detection, retraining triggers)
H	Glossary and AI safety terminology

Table 2.4. ISO/PAS 8800:2024 — 12 Clauses + 8 Annexes overview.

Data Lifecycle V-Model & Governance. Parallel to the 26262 product development V-model (requirements → design → implementation → testing → validation), AI development follows a data lifecycle: (1) Requirements definition (what task should the model perform?); (2) Data collection and acquisition (sourcing images, sensor recordings, synthetic data); (3) Data cleaning, curation, and deduplication (removing corrupted or duplicate samples); (4) Annotation and labeling (ground truth creation); (5) Model training (hyperparameter selection, cross-validation, regularization); (6) Validation and testing (performance on held-out test sets, adversarial robustness, edge-case scenarios); (7) Deployment (containerization, serving infrastructure, quantization for embedded systems); (8) Monitoring and maintenance (performance tracking, concept drift detection, retraining triggers). Each stage has explicit work products and quality gates; failures in data annotation propagate as training failures and must be detected.

Model Robustness & Uncertainty Quantification. PAS 8800 mandates validation of model robustness across three dimensions: (1) Adversarial robustness: testing against imperceptibly modified inputs (adversarial examples) that cause misclassification. Metrics include ϵ -ball tolerance (certification that no perturbation smaller than ϵ causes misclassification) and attack success rate under specific attack methods (FGSM, PGD, C&W). (2) Out-of-distribution (OOD) detection and shift resilience: testing on data that differs significantly from training distribution (new weather, new roads, new traffic patterns). OOD detection rate (system recognizes it is uncertain) and graceful performance degradation (system performs worse but remains safe) are key metrics. (3) Uncertainty quantification: the model must estimate its own confidence. Metrics include calibration error (Brier score, Expected Calibration Error), entropy-based confidence scores, and Bayesian

posterior estimates. A well-calibrated system that says 'I am 60% confident in this prediction' should be wrong 40% of the time, enabling adaptive behavior based on confidence.

Supply Chain & Third-Party Components. PAS 8800 Clause 12 requires visibility into third-party models, datasets, and libraries. For each AI component, documentation must include: data provenance (where training data came from), model lineage (which open-source models were fine-tuned?), dependencies (which libraries? which versions?), and known limitations. A Software Bill of Materials (SBOM) for AI systems must list all training data sources, model sources, library versions, and known vulnerabilities. Organizations must establish supply-chain audit processes for open-source models and datasets.

Interpretability & Explainability for Safety. For ASIL B and higher, PAS 8800 Annex F recommends model interpretability techniques to support safety assurance: SHAP (SHapley Additive exPlanations) for feature importance, LIME (Local Interpretable Model-agnostic Explanations) for local decision trees, saliency maps for vision models. While not mandated, interpretability aids verification ('why did the network detect that object?') and can help identify training data biases or distribution shift.

Boundary Conditions & What PAS 8800 Does NOT Require. Does NOT mandate specific ML frameworks or languages (PyTorch, TensorFlow, JAX all acceptable). Does NOT require open-source or white-box models; black-box neural networks are acceptable if validation evidence is extensive and rigorous. Does NOT prescribe specific data annotation standards or labeling tools (Labelbox, CVAT, etc.); organizations choose. Does NOT specify which adversarial testing techniques to use—techniques proportional to ASIL level. Does NOT mandate formal verification (yet); empirical validation is current expectation.

Regulatory Context & Roadmap to ISO Standard. Current status is PAS (Publicly Available Specification), a preliminary ISO format. Expected to become ISO 8800:2026 after industry review and revision. EU AI Act classifies autonomous systems as 'high-risk' and increasingly references AI safety requirements; compliance audits may reference PAS 8800 or ISO 8800 depending on timing. China is developing parallel standards (GB/T) aligned with PAS 8800 concepts. Industry adoption: major OEMs (Tesla, Waymo, BMW, Mercedes) are already following PAS 8800 principles for ASIL D autonomous driving projects.

2.5 ISO 9001:2015 & IATF 16949:2016 — Quality Management System (QMS)

ISO 9001:2015 is the foundational quality management system (QMS) standard for all manufacturers, revised in 2015 to emphasize risk-based thinking and process effectiveness. IATF 16949:2016 (International Automotive Task Force) adds automotive-specific requirements on top of ISO 9001, tailored for OEMs and Tier 1–3 suppliers. Together, they mandate systematic process documentation, risk management across supply chains, and continuous improvement cycles. While 26262, 21434, and other technical standards define WHAT safety, security, or SOTIF requirements must be met, ISO 9001 and IATF 16949 define HOW—the organizational processes, approvals, training, and traceability that give confidence those technical requirements are consistently met.

ISO 9001 operates on a process-based model with eight core clauses: organization context (understanding stakeholder needs), leadership (management commitment and roles), planning (objectives and change management), support (resources, competence, awareness), operations (control of work, verification), performance evaluation (audits, data analysis), improvement (nonconformance, corrective action), and continual improvement (periodic management reviews). IATF adds automotive overlays on each clause: customer portal integration (Clause 4), safety culture (Clause 5), APQP and design FMEA (Clause 6), training matrix and tool calibration (Clause 7), PPAP and SPC/Cpk controls (Clause 8), second-party supplier audits (Clause 9), and root-cause analysis discipline (Clause 10).

Scope & Applicability. Covers all organization-wide processes required for consistent compliance: leadership and strategy, resource allocation (people, tools, facilities), process design and execution (how work gets done), competence management (training and qualification), and performance evaluation (audits, metrics). IATF adds automotive-specific expectations: OEM requirements management, APQP (Advanced Product Quality Planning) gate reviews, PPAP (Production Part Approval Process) documentation, SPC (Statistical Process Control) tracking of critical dimensions, and risk-ranked supplier audits. The standard applies to OEMs and all suppliers; compliance is typically verified through third-party ISO 9001 and IATF certification audits (ASQ, DNV, TUV are common auditors).

Clause	ISO 9001:2015 Core Content	IATF 16949 Overlay
4	Context of the organization	OEM requirements, customer portal integration
5	Leadership and commitment	Safety culture, cross-functional ownership
6	Planning (risk & change mgmt)	APQP gate reviews, design FMEA
7	Support (resources, competence)	Training matrix, tool calibration traceability
8	Operation (control, verification)	PPAP submission readiness, SPC/Cpk tracking
9	Performance evaluation (audit, review)	Second-party supplier audits, customer satisfaction
10	Improvement (nonconformance, corrective)	Root-cause analysis (5-Why, fishbone), effectiveness check

Table 2.5. ISO 9001:2015 + IATF 16949:2016 clause alignment.

APQP (Advanced Product Quality Planning) & Gate Reviews. APQP is an IATF process that structures product development into five phases with defined gate reviews: (1) Concept phase (concept definition, feasibility, preliminary FMEA); (2) Product design phase (requirements flowdown, detailed design, design FMEA completion); (3) Process design phase (manufacturing process definition, control plan, process FMEA); (4) Product and process validation phase (prototype testing, pilot production, first-article inspection); (5) Launch phase (production release, performance verification); and (6) Feedback phase (field data collection, continuous improvement). Each gate requires defined deliverables: design reviews, FMEA completion status, risk assessments, and customer approval (for safety-critical components). APQP gates are where safety (26262 HARA completion, ASIL assignments), security (21434 TARA completion, CAL assignments), and SOTIF (ODD definition, validation plans) are formally reviewed and approved before the next phase begins.

PPAP (Production Part Approval Process) & Readiness. Before any component moves from development/pilot to series production, a supplier must submit PPAP documentation demonstrating readiness and compliance. PPAP submission includes: (1) Design specifications and changes log; (2) Process flow and layout drawings; (3) Process FMEA and containment actions; (4) Design FMEA and control measures; (5) DVPR (Design Verification Plan and Report) and PVPR (Process Verification Plan and Report) showing testing evidence; (6) SPC data from pilot production demonstrating $Cpk \geq 1.33$ for critical characteristics; (7) Material and performance test data; (8) First-article inspection results; (9) Workmanship standards and inspection criteria; (10) Tool and gauge information including calibration traceability. The OEM reviews this package and grants approval (sign-off) before series production begins. For safety-critical components, PPAP also includes 26262 traceability records, verification evidence, and tool qualification documentation.

Hierarchical Level Structure (HLS) & Supply Chain Clarity. IATF recognizes that product responsibility is distributed across OEM and suppliers. HLS defines explicitly what evidence each organizational level must maintain and be responsible for. Typically: OEM owns product requirements, top-level architecture, and customer contract compliance; Tier 1 suppliers own subsystem design, supply-chain management of Tier 2–N, and integration/assembly; Tier 2 suppliers own detailed design and manufacturing of their assigned components. HLS prevents gaps where 'nobody owned' a requirement or traceability breaks. In integrated programs with safety and security requirements, HLS specifies which level owns each requirement flow, verification, and validation activity.

Statistical Process Control (SPC) & Cpk Metrics. For manufacturing processes of critical components (especially those affecting safety), IATF mandates SPC tracking: ongoing measurement of process outputs, computation of process capability ($Cpk = \min[(USL - \text{mean})/(3\sigma), (\text{mean} - LSL)/(3\sigma)]$), and control limits. $Cpk \geq 1.33$ is typically required for critical characteristics. If a process shows Cpk degradation or out-of-control points, containment actions must be implemented immediately to prevent defective parts in the field. This discipline ensures consistent part quality despite natural variation in materials, equipment, and operators.

Boundary Conditions & What QMS Does NOT Require. QMS mandates discipline, documentation, and traceability but does NOT prescribe specific safety techniques (those come from 26262), cybersecurity controls (21434), or process models (Agile, waterfall, spiral all acceptable if documented). Does NOT require third-party ISO 9001 certification; many OEMs conduct internal audits without certification, though certification is common in Tier 1+ suppliers. Does NOT define technical ASIL-specific requirements (that is 26262 responsibility).

Regulatory Context & Compliance. IATF 16949 compliance is mandatory for all automotive suppliers in ISO/TS 16949 supply chains (de facto all OEMs worldwide). EU, China, Japan, and North America all enforce IATF compliance as contractual requirement. Third-party auditors assess compliance; certification validity is typically 3 years with annual surveillance audits. OEMs conduct second-party IATF supplier audits annually; findings feed into supplier ratings and contract renewals.

2.6 ASPICE v4.0 — Automotive SPICE (Automotive Software Process Improvement and Capability Determination)

ASPICE v4.0 (released 2023) defines a maturity assessment framework for automotive software and systems engineering processes. It spans 32 processes across acquisition, supply, system engineering, software engineering, hardware engineering, ML engineering, validation, management, and support. Capability Levels (0–5) quantify process maturity.

Scope. Applies to OEMs and suppliers engaged in automotive software development. Assessments are used for supplier selection, process improvement prioritization, and regulatory evidence (e.g., demonstrating process discipline to satisfy 26262).

Process Category	Count	Key Processes (Examples)
Acquisition (ACQ)	3	Contract negotiation, supplier selection, acceptance testing
Supply (SPL)	3	Plan execution, product delivery, customer support
System Engineering (SYS)	5	Requirements analysis, architectural design, integration, verification

Software Engineering (SWE)	6	Unit design, implementation, static/dynamic testing, version control
Hardware Engineering (HWE)	3	Design, layout, diagnostics verification
Machine Learning Engineering (MLE)	5	Data management, model training, validation, deployment, monitoring
Validation & Verification (VAL)	4	Requirements validation, system testing, acceptance, field validation
Project Management (MAN)	2	Project planning, project execution
Supporting Processes (SUP)	1	Configuration management, problem resolution, quality assurance
Process Implementation (PIM)	1	Process measurement and improvement
Reuse (REU)	1	Reusable component management

Table 2.6. ASPICE v4.0 — 32 processes across 11 categories.

Capability Levels & Maturity Scale. ASPICE defines six capability levels on a scale CL0–CL5. CL0 (Not Performed) means the process is not executed at all or is chaotic. CL1 (Performed) means work is done (outputs are produced) but without defined procedures; success depends on individual heroics. CL2 (Managed) means procedures are documented, work is tracked against plans, and management oversees execution. CL3 (Established) means the process is standardized across the organization; lessons learned are captured. CL4 (Predictable) means the process is measured with metrics; performance is statistically predictable within control limits. CL5 (Optimizing) means continuous improvement and innovation are systematic; the organization proactively anticipates change. For ASIL D safety-critical systems, OEMs typically require CL2 minimum (managed procedures, traceable work); many demand CL3 (established, standardized). For non-critical Tier 2 suppliers, CL1 may be acceptable if OEM oversight is tight.

32 Processes Mapped to Capability Levels. ASPICE v4.0 defines 32 processes across 11 categories (Acquisition, Supply, System Engineering, Software Engineering, Hardware Engineering, Machine Learning Engineering, Validation, Project Management, Supporting Processes, Process Implementation, and Reuse). Each process has defined purpose, inputs, activities, outputs, and assessment criteria for CL0–CL5. For example, SWE.1 (Software Implementation) at CL2 requires documented coding standards, version control, peer review, and unit test plans. At CL3, it requires evidence of standards compliance through static analysis and metrics. At CL4, code metrics are tracked against targets. This granularity allows assessors to rate each process independently; a supplier might be CL3 in SWE (code discipline) but only CL1 in VAL (validation) if field validation activities are weak.

Hardware Engineering (HWE) & Machine Learning (MLE) Processes. ASPICE v4.0 added explicit processes for hardware engineering (HWE.1 Hardware Implementation, HWE.2 Hardware Verification, HWE.3 Hardware Integration) and machine learning engineering (MLE.1 ML Data Management, MLE.2 ML Model Training, MLE.3 ML Model Validation, MLE.4 ML Model Deployment, MLE.5 ML Model Monitoring). These reflect the growing role of hardware design (power delivery, thermal management, electromagnetic interference) and ML systems in safety-critical automotive. Hardware processes require design reviews, simulation, and diagnostics validation. ML processes require data governance, model validation against adversarial and OOD examples, and runtime monitoring.

v3.1 → v4.0 Changes & Transition. ASPICE v3.1 (released 2016) defined 24 processes and did not include MLE. v4.0 (released 2023) added 8 new processes (HWE and MLE) and consolidated validation/verification clauses. The assessment rating scale (CL0–CL5) remains unchanged, but the process definitions are more rigorous. Assessments conducted under v3.1 are not directly comparable to v4.0; OEMs have been transitioning assessment criteria. Most major OEMs transitioned by 2025; assessors certified in v4.0 are now the standard. A supplier with a v3.1 CL3 rating may be reassessed at v4.0 and score CL2 due to stricter criteria; some of that reflects gap in ML processes (which didn't exist in v3.1).

Assessment Process & Evidence Requirements. ASPICE assessments are conducted by independent, trained assessors (typically certified by VDA or equivalent body). The assessment process involves: (1) Document review (process descriptions, standards, checklists); (2) Artifact inspection (actual requirements, test reports, code reviews, meeting minutes); (3) Interviews with project managers and engineers ('How do you handle requirements traceability?' 'Show me a code review example'); (4) Consensus rating by assessment team. Each process receives a rating CL0–CL5 based on evidence. Process ratings may differ; a team might be CL3 in SWE (Software Engineering) but only CL1 in VAL (Validation) if field validation practices are immature. Ratings are valid for 3 years (with annual re-assessment to confirm continued compliance).

Boundary Conditions & What ASPICE Is NOT. ASPICE is NOT a development methodology; it does NOT mandate Agile, Waterfall, iterative, or spiral development. Agile teams can be CL3 if their sprints are disciplined and traced. Waterfall teams can be CL1 if they lack traceability and reviews. ASPICE does NOT mandate specific tools (requirements management, version control, test automation), programming languages (C, C++, Python, Rust all acceptable), or testing frameworks. It does NOT prescribe safety or security techniques; that is 26262 and 21434 responsibility. ASPICE assesses process maturity; a team with poor process discipline cannot reliably execute ASIL D or CAL 4 requirements, even if they attempt them.

Regulatory Context & Industry Adoption. ASPICE is a de facto industry standard for supplier capability assessment. EU OEMs (Audi, BMW, Mercedes, VW) require ASPICE assessments as contract conditions for safety-critical suppliers. Japanese OEMs (Toyota, Honda, Nissan) increasingly require ASPICE v4.0. US OEMs (Ford, GM) incorporate ASPICE results into supplier scorecards. China OEMs are adopting ASPICE; it is often combined with CMMI (Capability Maturity Model Integration) assessments. The VDA (German automotive association) publishes official assessment rules and guidance documents. Suppliers typically pursue CL3 certification as a competitive differentiator.

WHY ALL SIX STANDARDS MATTER

A program might satisfy ISO 26262 ASIL D (rigorous safety analysis, fault diagnostics), pass a penetration test for 21434 CAL 4 cybersecurity, and achieve ASPICE v4.0 CL3 process maturity, yet still face field failures if SOTIF (21448) edge cases are not validated or AI/ML (PAS 8800) robustness is not assured. Equally, a QMS-compliant (IATF 16949) organization with mature processes cannot ensure safety or security without 26262 and 21434 technical rigor. All six standards are necessary; no single standard is sufficient.

CHAPTER 3: THE INTEGRATION FRAMEWORK

SCOPE

Why and how to integrate six disparate standards into a single, coherent lifecycle. This chapter articulates the integration problem, presents the three-pillar framework, and outlines organizational prerequisites for success. It is essential reading for program managers, process owners, and quality leaders.

3.1 The Problem: Standards Silos

Automotive development has historically treated safety (26262), security (21434), safety of intended functionality (21448), AI/ML safety (PAS 8800), quality (IATF 16949), and process maturity (ASPICE) as separate, parallel engineering disciplines. This siloed approach leads to organizational structures where safety engineers report to one manager, security engineers to another, and software developers to a third. Requirements are captured in separate databases; reviews happen independently; test plans are isolated by discipline. The result is a fragmented development process that appears to satisfy all standards independently but often fails to address their interactions and interdependencies.

Consider a concrete example: an autonomous emergency braking (AEB) system. Safety engineering (26262) identifies a hazard: 'Loss of AEB function due to ECU power-supply failure.' Risk is ASIL D. The safety team specifies: 'ECU power supply shall have dual power monitoring; loss of one supply triggers diagnostic within 10 ms; vehicle enters safe state (normal braking requested) if both supplies lost.' Software test plan includes unit tests for the power-monitoring logic. Security engineering (21434), working independently, identifies a threat: 'Attacker injects false CAN messages claiming loss of power supply, triggering false safe-state engagement.' CAL is 4 (vehicle immobilization). Security specifies cryptographic authentication of all power-supply messages. However, authentication latency is 15 ms—longer than the 10 ms FTTI required by safety. Neither team recognized the conflict until system integration, by which time redesign is expensive.

Duplicated effort and rework. Hazard analysis is performed separately for functional safety (HARA per 26262 Part 3) and security (TARA per 21434 Clause 7). Architecture reviews occur twice: once for safety fault-tree analysis (where is redundancy needed to meet PMHF targets?) and once for security threat-tree analysis (where is encryption or authentication needed to mitigate CAL 4 threats?). Test plans are isolated by discipline: safety creates functional test cases for nominal and fault-injection scenarios; security creates adversarial test cases (attacking the CAN network, fuzzing APIs); AI/ML creates adversarial examples and OOD scenarios (21448, PAS 8800). These test suites often overlap—a test could simultaneously verify safety robustness and security hardening—but the duplication is never recognized and consolidated. Resources are wasted writing, maintaining, and executing overlapping test cases.

Conflicting or incompatible requirements. Security hardening (encryption, authentication, intrusion detection) introduces computational overhead and latency. A safety requirement specifying $FTTI \leq 10$ ms may conflict with a security requirement adding 15 ms authentication latency. Safety redundancy (dual ECU, cross-checks) complicates the security threat model: each redundant ECU is an additional attack surface. A decision to use open-source ML libraries (to speed time-to-market) conflicts with security supply-chain requirements (21434 mandates traceability; PAS 8800 mandates SBOM and vulnerability tracking for all components). Quality requirements (APQP gates, change management, training matrix) may be viewed as obstacles by agile teams, creating friction rather than shared discipline.

Incomplete coverage and risk blindness. A system may achieve ASIL D functional safety (pass HARA, implement diagnostics, meet PMHF targets) but lack systematic cybersecurity threat modeling, allowing

attackers to bypass safety mechanisms through intentional manipulation. Conversely, a system may pass intensive penetration testing for CAL 4 threats but have weak SOTIF coverage: edge cases where the perception system fails (heavy rain, glare, occlusion) are not systematically identified or mitigated. An ML-based perception system may be validated against test-set accuracy but lack robustness evaluation against adversarial perturbations (PAS 8800). ASPICE assessments may rate process maturity at CL3 (established, well-documented) but miss execution gaps when standards-specific disciplines (safety, security, ML) are actually immature.

Poor traceability and audit exposure. Linking a vehicle requirement ('prevent unintended acceleration') to a software unit test across four different standards—26262 safety goal, 21434 security requirement, IATF APQP gate artifact, and ASPICE SWE process evidence—requires manual cross-referencing across four separate tools and databases. This is error-prone and resource-intensive. In a regulatory audit, auditors from different domains (EU Type-Approval safety auditors, cybersecurity assessors, quality auditors, ASPICE assessors) ask the same question differently: 'Where is the evidence that this requirement is met?' The supplier has to construct the answer four times over. Integration failures are often discovered only during formal audits, when it is too late to fix without expensive delays or field recalls.

3.2 The Integration Triangle: Safety, Security, Quality

Effective integration of the six standards rests on three foundational pillars that interact bidirectionally. These pillars—Safety, Security, and Quality—are not independent; failures in one directly compromise the others. Understanding their interactions is the intellectual foundation of integrated standards management.

Safety Pillar (26262, 21448, PAS 8800). Ensures systems behave safely despite random failures, design limitations, and environmental variation. ISO 26262 addresses systematic and random failures of electrical and electronic components: transient faults (bit flips from cosmic radiation), stuck-at failures (components permanently in wrong state), parametric drift (aging, temperature effects), and common-cause failures (events affecting multiple redundant elements simultaneously). Safety engineering specifies fault-tolerance architecture (redundancy, diagnostics, safe states) to prevent failures from causing harm. ISO 21448 (SOTIF) complements 26262 by addressing non-failure hazards: situations where the system operates correctly according to its design but still creates harm because the design assumptions don't hold (rain-induced perception failure, driver overreliance on automation, edge cases in decision logic). PAS 8800 adds assurance for AI/ML components, addressing unique failure modes: training data bias, distribution shift between training and deployment, adversarial sensitivity. Together, these three standards define a safety envelope: what failures can occur, under what conditions systems remain safe, and what constraints must be enforced.

Security Pillar (21434). Protects systems against intentional attacks from internal or external adversaries. Where safety asks 'what if the system fails?', security asks 'what if someone deliberately attacks the system?' ISO/SAE 21434 mandates threat analysis and risk assessment (TARA) to identify potential attacks; security architecture (defense-in-depth, least privilege) to mitigate them; secure implementation (cryptography, authentication, secure boot); verification (penetration testing, code review); and incident response. Cybersecurity threats can be exploited to trigger safety hazards: an attacker who compromises the power-supply monitoring message can trigger false safe-state engagement (AEB example above); an attacker who manipulates GPS coordinates can mislead lane-keeping assistance. Security engineering must therefore consider not just whether attacks are feasible, but whether successful attacks could violate safety goals. This is a safety-security interface requirement that emerges only when integration is explicit.

Quality & Process Pillar (IATF, ASPICE). Implements safety and security disciplines through disciplined, measurable processes—ensuring that safety and security requirements are not merely aspirational but consistently executed across projects and suppliers. ISO 9001 and IATF 16949 mandate process governance:

requirements management, change control, training and competence, verification planning, and corrective action. ASPICE v4.0 defines 32 engineering processes (requirements analysis, design, implementation, testing, validation) with capability levels (CL0–CL5) that quantify maturity. Without this quality infrastructure, safety and security requirements are written but not reliably implemented. A supplier with mature QMS (ASPICE CL3) is far more likely to execute ASIL D or CAL 4 requirements consistently than one with immature processes (ASPICE CL1), even if both claim the same safety targets. Quality processes also enable integration: shared work-product repositories, joint reviews, and metrics that measure traceability completeness across all standards.

The three pillars are not orthogonal; they interact bidirectionally at multiple points. A security vulnerability can create a safety hazard: unauthorized acceleration (security breach) causes safety harm. A safety failure can be exploited as an attack vector: a diagnostics system that reports failures via unencrypted CAN messages allows an attacker to spoof false diagnostics and disable safety mechanisms. A process gap (quality) can undermine both safety and security: missing code review discipline (ASPICE CL1) may allow both unsafe and insecure code to slip into production. Effective integration means designing each pillar with explicit awareness of the other two, and establishing interface requirements between them that prevent these interactions from becoming vulnerabilities.

The integration triangle is not three separate triangles side-by-side; it is one unified triangle with three equally important faces. A system that is safe but insecure (passes 26262, fails 21434) is fundamentally unsafe in the connected-vehicle era: an attacker can disable safety mechanisms. A system that is secure but not safe (passes 21434, fails 26262) is still hazardous: failures occur despite security controls. A system that satisfies both safety and security but lacks process maturity (passes 26262 and 21434, fails ASPICE) cannot reliably be reproduced: development was a one-time heroic effort without repeatable processes. All three pillars must stand together.

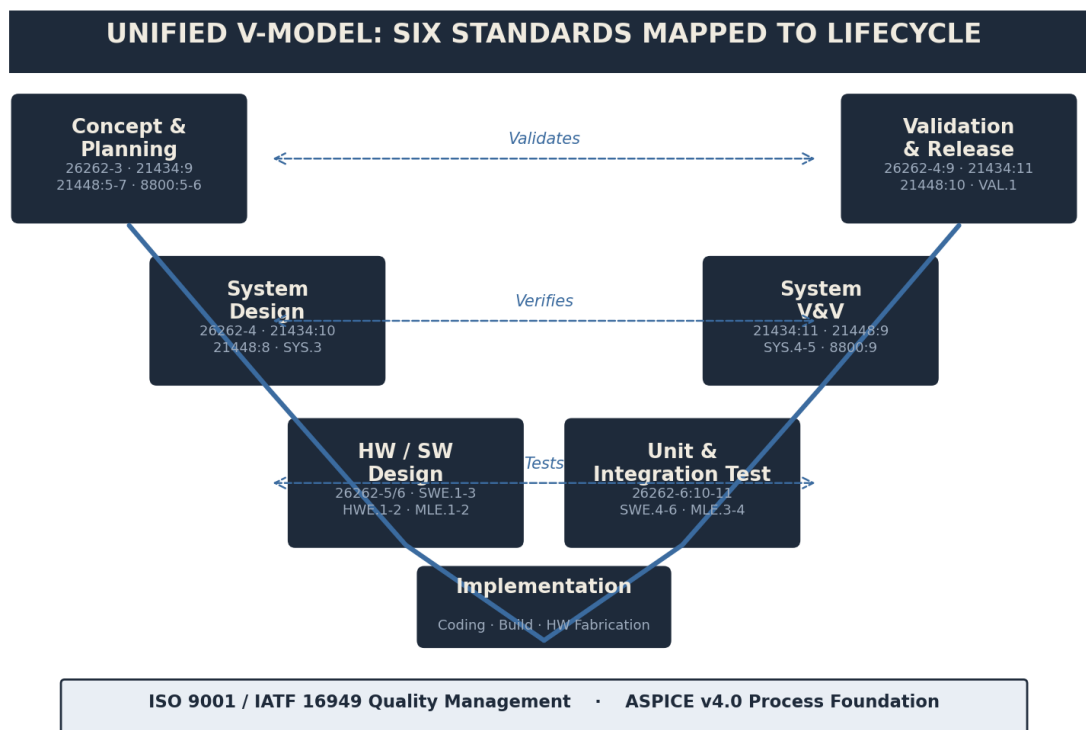


Figure 3.1. The Unified V-Model: Safety, Security, and Quality integrated across concept to deployment.

3.3 Three Principles of Integration

Successful integration of the six standards rests on three core operational principles. These are not theoretical ideals but practical approaches that reduce rework, clarify responsibilities, and improve auditability.

Organizations implementing these principles report 40–60% reduction in rework cycles and 25–35% faster time-to-market.

One Lifecycle, Not Multiple Parallel Lifecycles. Rather than executing six separate product development processes—one for safety (26262), one for security (21434), one for SOTIF (21448), one for AI/ML (PAS 8800), one for quality (IATF APQP), and one for process improvement (ASPICE)—conduct ONE integrated lifecycle with unified stage-gates. All disciplines (safety, security, software, hardware, AI/ML, quality) participate in each gate. At Concept Phase Gate: the team jointly assesses safety hazards (HARA per 26262), security threats (TARA per 21434), operational constraints (ODD per 21448), and data governance concerns (PAS 8800). One gate, multiple viewpoints, one go/no-go decision. At Product Design Phase Gate: safety and security architects jointly review the system architecture. Does the architecture provide sufficient fault detection to meet PMHF targets AND prevent attacks from exploiting those fault paths? At detailed design: security architecture and safety fault-tree analysis inform the same diagnostic strategy—redundancy and cryptographic authentication are not separate concerns but parts of one defense-in-depth system. This eliminates the situation where safety and security solutions are designed independently and conflict at integration time.

Operationally, this means: (1) One program manager owns the integrated lifecycle; safety, security, and other discipline leads report to that manager. (2) Gate review agendas explicitly cover safety, security, quality, and process maturity. (3) Gate exit criteria include safety sign-off, security sign-off, quality sign-off—not separately but as part of one integrated readiness review. (4) Slippage in one discipline affects the program gate, creating urgency for cross-functional problem-solving rather than isolated workarounds.

Consolidated Work Products and Unified Artifact Management. A single requirements repository, unified traceability matrix, and shared configuration management system eliminate duplication and establish a single source of truth. Rather than: (a) a safety requirements specification listing hazards, ASILs, and safety goals; (b) a separate security requirements specification listing threats, CALs, and mitigations; and (c) a separate system requirements specification listing functional requirements; maintain ONE integrated requirements database where each requirement is tagged with applicable standards (26262, 21434, etc.), associated hazards/threats, and ASIL/CAL. Traceability flows upward from vehicle requirements through system requirements to subsystem requirements to hardware/software requirements to unit requirements to source code. A single traceability matrix shows coverage: which clauses from 26262, 21434, 21448, PAS 8800, IATF, and ASPICE are satisfied by each requirement. One hazard/threat log (not separate documents) tracks all identified hazards and threats with unique IDs, status (open, mitigated, accepted, closed), and links to mitigating requirements. This consolidation has profound benefits: (1) Duplicate requirements are immediately visible and eliminated. (2) Traceability is maintained in one place; auditors and integration teams have a single reference. (3) Change impact is clear: modifying a requirement instantly shows all related hazards, threats, and verification activities. (4) Metrics are accurate: traceability completeness can be computed automatically (e.g., 98% of system requirements are traced to vehicle requirements and verified by at least one test).

Explicit Domain Interfaces & Interaction Requirements. Safety-security, safety-SOTIF, security-AI, and quality-all interdependencies are documented as explicit interface requirements, not implicit assumptions. An interface requirement is a bidirectional requirement: 'If system A fails or is compromised, system B shall remain safe.' For example: 'The AEB perception system (AI/ML) shall reliably detect pedestrians across the operational design domain; if detection fails (ODD boundary violated or model robustness exceeded), the vehicle shall not execute emergency braking (security requirement to prevent false AEB engagement) AND shall alert the driver (safety requirement to maintain controllability).' This is not a safety requirement, not a security requirement, not an AI requirement—it is a CROSS-DOMAIN interface requirement. Interface requirements are traceable, testable, and verifiable like any other requirement. They prevent assumptions: if

the interface requirement is not explicit, each discipline makes independent assumptions that turn out to be incompatible at integration. Interface requirements also enable parallel work: safety team can design the safe-state fallback; security team can design threat mitigations; AI team can design robustness validation—in parallel—because they are all working from the same interface specification.

Practical Patterns for Interfaces. Common interface requirement patterns: 'Safety-Security': 'If a [security threat] occurs, the system shall detect it within [time] and transition to [safe state].' 'Safety-SOTIF': 'The system shall enforce [ODD boundary] and disable [feature] if operating outside ODD; the system shall not attempt to operate outside ODD even if requested by the driver or external command.' 'Security-AI': 'The AI model shall maintain adversarial robustness against [perturbation types] with tolerance [epsilon]; if adversarial robustness degrades below [threshold], the system shall reduce confidence-gating to [threshold] and escalate uncertainty to the safety-monitoring system.' 'Quality-All': 'All safety, security, and AI requirements shall be implemented in code that passes [coding standard] static analysis and meets [coverage metric] unit test coverage.'

3.4 The Unified V-Model: Integrated Requirements & Verification

The V-Model is the backbone of ISO 26262 product development lifecycle [26262-1:7]. It represents the relationship between requirements (left side, descending) and verification (right side, ascending): as you decompose requirements into more detailed design and implementation, you correspondingly integrate and verify those implementations back to requirements. An integrated V-Model extends the traditional 26262 V to explicitly include security verification (21434), SOTIF validation (21448), AI/ML robustness (PAS 8800), and quality process maturity (ASPICE). The unified V ensures that at EVERY level—from vehicle concept to unit implementation—safety, security, SOTIF, AI/ML, and quality concerns are addressed simultaneously, not sequentially.

Left side (Concept to Implementation—Requirements Decomposition):

Starting at the top: (1) Vehicle Concept & ODD Definition. Define the operational design domain (ODD): what conditions will the system encounter? Speed range, weather, road type, lighting, passenger/cargo constraints, etc. (21448 Clause 5). Identify system boundaries and major functional blocks. (2) Safety Requirements Derivation. Conduct HARA (Hazard Analysis and Risk Assessment, 26262-3) to identify hazards (ways the system could cause harm) and assign ASIL (Severity × Exposure × Controllability). Define Safety Goals that prevent or mitigate each hazard. Define FTTI, PMHF, and diagnostic requirements. (3) Security Requirements & Threat Modeling. Conduct TARA (Threat Analysis and Risk Assessment, 21434 Clause 7) to identify credible threats (who might attack, how?). Assign CAL (Cybersecurity Assurance Level) based on threat severity and feasibility. Define security requirements for authentication, encryption, secure update mechanisms. (4) SOTIF & ODD Validation Planning. Define ODD boundaries in detail: what environmental conditions, driving scenarios, or edge cases will trigger feature disable? Plan validation strategy to confirm system behaves safely within ODD. (5) AI/ML Safety & Robustness. Define data governance (PAS 8800 Clause 5): where will training data come from? How is quality ensured? Define robustness requirements: adversarial tolerance (epsilon), OOD detection rate, uncertainty quantification. (6) System Architecture. Design the system architecture considering ALL constraints: redundancy for safety (ASIL targets), encryption and authentication for security (CAL targets), sensor fusion for SOTIF coverage, model-ensembling for AI robustness. Architecture is the nexus where safety, security, SOTIF, and AI constraints interact. (7) Subsystem & Component Allocation. Allocate safety goals, security requirements, SOTIF constraints to hardware, software, and AI subsystems. (8) Detailed Design. Design each subsystem with explicit attention to fault trees (safety), threat trees (security), adversarial inputs (AI robustness), and implementation complexity (process maturity). (9) Implementation. Code is written with secure-coding discipline (21434 Clause 10, ASPICE SWE.1), static analysis, and unit testing. ML model training includes data validation and hyperparameter justification.

Right side (Implementation to ODD Validation—Verification & Validation):

Ascending from the bottom: (1) Unit & Component Testing. Each code module is tested: (a) functional correctness (does it do what it's supposed to?), (b) static analysis (MISRA-C or equivalent, ASPICE SWE.3), (c) code coverage (CL2+ requires minimum 80% line coverage; CL3+ requires branch coverage), (d) unit-level security scanning (does it use unsafe functions? are inputs validated?), (e) for ML components, unit test of inference (does the model produce expected outputs on known test cases?). (2) Integration Testing. Subsystems are integrated and tested jointly. Safety integration (do redundant subsystems respond consistently?), security integration (do encryption and authentication work across the network?), SOTIF integration (are ODD boundary checks enforced?), AI integration (does the perception system's output feed correctly into the decision system?). (3) System Testing. Full system is tested against requirements. Safety: fault-injection testing (inject failures, confirm diagnostics detect them within FTTI, confirm safe state is triggered). Security: penetration testing against CAL-4 threats (can we spoof CAN messages? Can we jam V2X? Can we firmware-tamper?), code review against secure-coding guidelines. SOTIF: naturalistic driving scenarios, edge-case testing (heavy rain, glare, occlusion, unusual road markings), adversarial-example testing for perception. Quality: audit against ASPICE process requirements (is traceability complete? are reviews documented?). (4) System Validation. Full system is validated against HARA closure (are all identified hazards mitigated?), threat acceptance (are CAL 4 threats mitigated or accepted?), ODD confirmation (does the system operate safely within ODD? Is ODD correctly enforced?), field data collection (early units in customer hands, performance monitored). (5) Release & Production Readiness. PPAP submission (26262, 21434, ASPICE evidence). OTA security framework for field updates. Field monitoring strategy. Incident response plan.

Key insight: At EVERY V-level, multiple disciplines assess the work simultaneously. An architecture review is not separate safety review and security review; it is one review attended by safety, security, software, hardware, and quality engineers, all evaluating the same architecture against their respective requirements. A code review examines not only functionality and safety but also security (secure coding patterns) and maintainability (ASPICE). A test report documents not only functional test results but also safety coverage (diagnostics triggered?), security penetration results, SOTIF scenario outcomes (system behaves correctly at ODD boundaries?), and AI robustness metrics. This integration prevents late discovery: conflicts between safety and security latency are caught at design review, not at integration. Missing SOTIF validation is caught during system testing, not at field deployment.

3.5 Standards Interaction Map

The six standards interact at specific touchpoints. Understanding these prevents gaps and redundancy:

Interaction Pair	Nature	Key Touchpoints
Safety ↔ Security	Bidirectional	Fault trees inform threat model; attacks may trigger safety hazards
Safety ↔ SOTIF	Hierarchical	26262 covers failures; 21448 covers limitations & misuse
Safety ↔ AI (PAS 8800)	Hierarchical	26262 ASIL allocation; PAS 8800 applies to perception/decision models
Security ↔ AI (PAS 8800)	Hierarchical	Adversarial robustness is both security (against poisoning) and AI safety
Quality (IATF) ↔ All	Enabling	QMS enables disciplined execution of 26262, 21434, ASPICE processes

ASPICE ↔ All	Process Maturity	SWE, VAL, MLE, SYS processes formalize safety/security/quality evidence collection
--------------	------------------	--

Table 3.5. Primary interaction points among the six standards.

3.6 Integration Maturity Levels

Organizations mature through four stages of standards integration:

Maturity Level	Characteristics	Process Artifacts
Ad-Hoc	Safety, security, quality teams work independently. No shared requirements DB, no integrated reviews.	Separate HARA, TARA, APQP docs; manual cross-checking
Coordinated	Teams meet at gates to align; shared artifact repository exists; but processes remain discipline-specific.	Unified traceability matrix; joint design reviews; separate test plans
Integrated	One lifecycle, one requirements set, one work-product structure. Teams collaborate continuously.	Unified V-model; consolidated safety-security requirements; joint validation strategy
Optimized	Integration is automated: AI-assisted traceability, continuous compliance checking, real-time process metrics.	Automated artifact generation; compliance-as-code; model-driven architecture

Table 3.6. Integration maturity progression.

INTEGRATION ROADMAP

Most OEMs are in the Coordinated stage as of 2026. Progression to Integrated requires 6–18 months depending on organizational size and tool maturity. Optimized integration is an emerging frontier. Appendix D provides a detailed integration roadmap checklist.

3.7 Organizational Prerequisites & Governance for Integration

Integration of the six standards is not primarily a technical problem; it is an organizational and cultural problem. Technologies (requirements tools, test automation frameworks) are enablers, but the primary barriers to integration are structural and behavioral. Successfully implementing integrated standards requires deliberate organizational changes and governance investment.

Cross-Functional Program Organization. Safety, security, software, hardware, AI/ML, and quality engineers must be co-located (physically or virtually) within a single program and report to one program manager. The program manager's role is to resolve cross-discipline conflicts and ensure parallel execution. In siloed organizations (where safety reports to Chief Safety Officer, security to CISO, software to VP Engineering), integration is extremely difficult: escalation is required for every conflict, and incentives are misaligned (safety wants extra redundancy; security wants minimal attack surface; software wants agility). The organization must establish joint accountability: the program succeeds or fails on meeting ALL six standards simultaneously, not

on optimizing any single standard at the expense of others. This requires reporting structure change: cross-functional program teams with matrix responsibility to discipline leads and direct accountability to program manager. Roles and responsibilities must be explicitly defined in a RACI (Responsible, Accountable, Consulted, Informed) matrix: who owns each interface requirement? Who approves architecture? Who signs off on release? If the RACI is unclear, integration fails.

Unified Requirements and Artifact Management. A single, centralized requirements repository (using tools like ReqIF/RDF standard with tools such as Doors, Polarion, Capella, or equivalent) is mandatory. Separate Jira instances for safety and security, or separate design repositories for hardware and software, are red flags: they will inevitably diverge, creating inconsistencies and forcing manual reconciliation. The unified repository must have access controls (who can edit safety requirements? who can approve security updates?) and change-control process (all requirements changes go through formal review and approval). All work products—design documents, test plans, test reports, code reviews, hazard logs, threat assessments, APQP gate artifacts, ASPICE assessment results—must be version-controlled in one configuration-management system. This enables traceability: clicking on a requirement shows all related hazards, all tests that verify it, all design decisions, all code changes. It also enables impact analysis: changing a requirement instantly shows which other requirements, tests, and work products are affected.

Integrated Review Gates & Approval Workflows. Architecture reviews, design reviews, and code reviews must include representatives from safety, security, software, hardware, and quality. The review agenda covers all four perspectives simultaneously, not sequentially. The review checklist includes: 'Does this design meet safety fault-tree requirements?' 'Does this design prevent the CAL 4 threats?' 'Are there SOTIF-relevant edge cases?' 'Is the code maintainable and verifiable?'. A design is only approved when all perspectives sign off. This is slower than single-discipline reviews but prevents expensive rework. Approval sign-off must be documented: who reviewed, who approved, what were the concerns, how were they addressed? These records are essential for audits.

Process Metrics & Governance Dashboards. Define key performance indicators (KPIs) for integration and review them monthly at program level, quarterly at organizational level. Examples: (1) Traceability completeness: % of system requirements traced to vehicle requirements (target $\geq 95\%$); % of software requirements traced to system requirements; % of tests traced to requirements. (2) Integration variance: % of work products that are shared (satisfy multiple standards) vs. isolated. (3) Defect escape rate by standard: how many safety-critical bugs escaped to field? How many security vulnerabilities? How many SOTIF gaps? (4) ASPICE maturity trend: what processes are improving toward CL3/CL4? What remain at CL1? (5) Standards compliance readiness: when does the program expect to be ready for 26262 ASIL D audit? 21434 CAL 4? (6) Training effectiveness: % of engineers who have completed baseline training in all six standards? (7) Review cycle time: average time from design submission to review approval? A long cycle time indicates either overly rigorous review or bottlenecks. Publish dashboard monthly; discuss metrics in program governance meetings. Use metrics to prioritize improvement actions: if traceability is at 85%, that is the priority improvement. If ASPICE MLE processes are immature, hire or train ML engineering expertise.

Training & Cultural Change. Engineers across the program must develop shared vocabulary and baseline understanding of all six standards. This does not mean every engineer becomes expert in all standards (specialization is necessary) but that all understand the landscape, terminology, and how their specialty interacts with others. Conduct: (1) Onboarding training: all new engineers (safety, security, software, etc.) take a 2-day course covering the six standards, integration concepts, and program-specific processes. (2) Quarterly lunch-and-learn sessions: 1-hour focused talks on specific topics (e.g., 'Interface Requirements: A Case Study' or 'SOTIF ODD Definition in Practice'). Speakers rotate among engineers; teaching reinforces learning. (3) Annual refresher training: update teams on standards changes, lessons learned from recent audits, and process improvements. (4) Specialist certifications: safety engineer takes extended 26262 training; security engineer takes 21434 training; etc. (5) Mentoring: pair specialists with engineers from other disciplines; a security architect mentors a software developer, explaining threat-model thinking. Cultural change is equally important

as technical training. Recognize cross-functional contributions in performance reviews and promotion criteria. Celebrate integration successes: 'This interface requirement prevented a safety-security conflict.' Give engineers incentive to collaborate, not to optimize their own discipline at others' expense. Make integration a core value of program culture.

Supplier and Partner Governance. If the program uses external suppliers or partners (semiconductor vendors, software framework providers, AI model providers), they must also comply with integrated standards governance. Supplier contracts must require: (1) Compliance with specific standard versions (26262:2018, 21434:2021, etc.). (2) Traceability records and work-product artifacts (ASPICE SWE artifacts: requirements, design, code, tests). (3) IATF/ASPICE maturity certification (minimum CL2, often CL3 required for safety-critical components). (4) Regular audits (annual second-party audits to verify continued compliance). (5) Supply-chain visibility (SBOMs for AI/ML components, tool qualification traceability, component source justification). Set up supplier integration workshops where OEM and suppliers jointly discuss integration strategy, interface requirements, and coordination mechanisms. Make it clear that meeting safety target alone is insufficient; suppliers must coordinate on security, SOTIF, and process maturity.

ORGANIZATIONAL ASSESSMENT

Before launching a major integration initiative, conduct an organizational assessment: current state of tools (are safety and security already using unified requirements management?), governance (do teams meet regularly? is escalation clear?), and culture (do engineers from different disciplines know each other? is cross-disciplinary collaboration valued?). Use results to prioritize: if tools are fragmented, tool consolidation is the first priority. If governance is weak, establish clear program governance. If culture is siloed, start with training and mentoring. Integration is a journey, not a destination; expect 12–24 months to mature.

This handbook is designed to accelerate that organizational transformation. Chapters 1–3 (Part I) establish the conceptual framework and integration principles. Chapters 4–10 (Part II) provide detailed clause-by-clause cross-mappings and artifact requirements for each lifecycle phase. Chapters 11–12 (Part III) demonstrate integration in practice through two comprehensive case studies: an ADAS system (AEB) and a V2X gateway. Chapters 13–15 (Part IV) provide operationalized tools: artifact matrices, audit checklists, and a process improvement roadmap. Together, these chapters provide the technical and organizational foundation for moving from siloed to integrated standards management.

PART II

Clause-Level Cross-Mapping

By Lifecycle Phase · Chapters 4–10

CHAPTER 4: ORGANIZATIONAL & MANAGEMENT REQUIREMENTS

SCOPE

Foundation of integrated safety + cybersecurity + quality culture; unified competence management, role definition, and organizational audit structures. Mandatory prerequisite for effective standards compliance.

4.1 Phase Overview

The organizational phase establishes governance, assigns responsibilities, and creates the management system that supports all downstream functional safety, cybersecurity, and quality activities. Three overlapping cultures must integrate: functional safety (ISO 26262), cybersecurity (ISO 21434), and quality management (ISO 9001/IATF 16949).

Key Inputs: Organizational strategy, business objectives, corporate quality policy, and strategic risk appetite.

Key Outputs: Safety policy, cybersecurity policy, unified competence framework, organizational structure (RACI matrix), audit procedures, management review records.

Key Participants: Executive leadership, functional safety manager, cybersecurity manager, quality manager, HR/training function, internal audit.

4.2 Standard-by-Standard Requirements

The table below maps organizational clauses across all six standards:

Standard	Clause	Requirement Title	Key Mandate
ISO 26262	Part 2:5	Safety Culture	Establish and maintain a safety culture; management commitment
ISO 26262	Part 2:6	Safety Management	Document safety policies, responsibilities, roles, audit plans
ISO 26262	Part 2:7	Competence & Training	Define competence profiles; assess, train, and maintain competence
ISO 21434	5	Organizational CS Management	Define cybersecurity strategy, roles, competence for cyber risk
ISO 21434	5.4.3	Cybersecurity Competence	Training and competence assurance for cybersecurity personnel
ISO 21434	7	Distributed Development	Organizational controls for suppliers, service providers, partners
ISO 21448	5	Overall SOTIF Activities	Integrate SOTIF management into organizational procedures

ISO/PAS 8800	4	AI Safety Activities Overview	Establish AI safety governance and organizational integration
ISO 9001	4	Context of Organization	Understand organizational context and stakeholder needs
ISO 9001	5	Leadership & Commitment	Top management commitment to quality policy and objectives
ISO 9001	7.2	Competence for QMS	Determine and provide competence for QMS effectiveness
IATF 16949	4.3	Quality Management Context	Define QMS scope, leadership roles, and stakeholder alignment
ASPICE	MAN.3	Project Management	Define, plan, and track project activities and resources
ASPICE	MAN.5	Risk Management	Organizational risk identification, analysis, and mitigation
ASPICE	MAN.6	Measurement & Analysis	Define metrics, collect data, analyze trends

Table 4.1 Organizational Clauses Across Standards

The table above emphasizes competence management as a cornerstone of organizational effectiveness. Competence refers not only to technical knowledge (e.g., HARA methodology, TARA threat modeling, SOTIF validation), but also to decision-making authority, judgment under uncertainty, and accountability. Each role must be defined with clear expectations: what knowledge is required, how competence will be assessed, and what continuous training investments are necessary to maintain and enhance it. Organizations often underestimate competence management, treating it as a HR checkbox rather than a strategic enabler. Yet without demonstrated competence in functional safety, cybersecurity, and quality, the entire organizational management system lacks credibility.

Distributed development—outsourcing, partnerships, and supplier collaboration—introduces unique organizational challenges. ISO 26262-2 Clause 7 and ISO 21434 Clause 7 both demand that organizations maintain oversight and ensure competence across their entire supply chain. This means: (1) supplier audits must assess safety AND security (not just quality), (2) supplier contracts must define responsibility boundaries (who owns functional safety, who owns cybersecurity, who integrates), and (3) communication channels must be established to escalate issues. A common failure is to distribute responsibility without distributing competence—for example, outsourcing vehicle dynamics software to a supplier without verifying their ASIL expertise and process maturity. The organizational management system must explicitly document how responsibilities are allocated across tiers (OEM → Tier-1 → Tier-2 → component manufacturers).

The shift from centralized to distributed organizational structures also impacts audit and oversight cadence. When development is distributed, the OEM becomes an integrator and auditor. This requires: (a) quarterly supplier audits focused on safety culture, cybersecurity maturity, and quality system effectiveness, (b) traceability gates to ensure safety/security requirements are properly allocated and not lost in translation, and (c) escalation procedures for non-conformances. Organizations that handle distributed development effectively view it as an extended management system, not as risk transfer. ISO 21434-7 explicitly requires documented procedures for evaluating security maturity of service providers and ensuring compliance through the product lifecycle.

4.3 Cross-Mapping: Unified Organizational Culture

Three cultural pillars must align and integrate:

Dimension	Safety Culture (26262:2)	Cybersecurity Culture (21434)	Quality Culture (9001/IATF)	Integrated Approach
Management Commitment	C5: Executive ownership of safety	C5: Leadership endorses cyber risk mitigation	5: Formal QMS commitment	Single unified policy addressing all three
Competence Framework	C7: Defined profiles per role	5.4.3: Cyber training mandates	7.2: Competence for QMS	Role-based matrix: safety + cyber + quality skills
Audit & Review	C6: Safety audits, management review	Implementation: Audit cyber controls	9.2: Internal audit of QMS	Integrated audit program covering all three domains
Supplier Management	26262-2:C7: Supplier competence	7: Distributed dev agreements	8.4: External provider control	Single supplier SLA addressing all three requirements
Documentation	C6: Policies, procedures, records	5: CS policies and procedures	4.4: QMS documented procedures	Unified management system documentation

Table 4.2 Three Cultures Unified into Integrated Management

Safety culture (ISO 26262-2:5) emphasizes preventing harm through systematic hazard identification and risk mitigation. Organizations with mature safety culture view every employee as responsible for identifying hazards and near-misses, regardless of their role. Safety review meetings are regular, blameless (no punishment for reporting issues), and driven by data (safety KPIs, incident trends). Safety culture succeeds when leadership visibly prioritizes safety over short-term delivery pressure—for instance, allowing teams to halt release if HARA analysis is incomplete. A mature safety culture produces organizations that rarely experience in-field safety failures because hazards are caught during development.

Cybersecurity culture (ISO 21434-5.4) differs fundamentally: it assumes intelligent, adaptive adversaries who continuously probe for weaknesses. Cybersecurity culture is not about eliminating all risks (impossible) but about understanding threats, prioritizing defenses, and detecting intrusions. Cybersecurity maturity is measured by threat modeling sophistication, penetration test results, and incident response capability. Organizations with strong cybersecurity culture encourage security champions throughout the organization, mandate threat modeling reviews before each architectural change, and conduct regular tabletop exercises to simulate breach scenarios. The cultural difference: safety culture is prevention-focused; cybersecurity culture is adversary-aware and incident-response-ready.

Quality culture (ISO 9001-5.1, IATF 16949) centers on customer satisfaction and continuous improvement via the Plan-Do-Check-Act cycle. Quality culture emphasizes process discipline, measurable performance metrics (defect rates, on-time delivery, cost targets), and supplier partnerships. Where safety culture says 'prevent harm' and cybersecurity culture says 'detect and respond to attacks', quality culture asks 'are we consistently meeting customer expectations and improving our capability?' Quality culture thrives on data: SPC (Statistical

Process Control) charts, Cpk indices, Pareto analysis. Organizations mature in quality culture measure and optimize manufacturing efficiency, design review effectiveness, and supplier quality.

Integrating three distinct cultures into a cohesive organizational system requires explicit attention to how they coexist. A safety decision (e.g., 'do not ship until HARA is complete') may conflict with a quality KPI (on-time delivery). A cybersecurity decision (e.g., 'encrypt all diagnostics') may add cost (quality culture concern) or latency (safety requirement). The integrated approach acknowledges these tensions and resolves them through explicit organizational governance: the leadership team defines which culture takes precedence in specific scenarios, ensures each function has sufficient resources and authority, and measures success across all three domains. For automotive OEMs, this often means establishing a Safety-Security-Quality Council that meets monthly, reviews metrics across all three domains, and has authority to escalate cross-functional conflicts to executive leadership.

4.4 Commonality Analysis: Do Once, Satisfy Many

INTEGRATION OPPORTUNITY

A single organizational management system can satisfy ALL six standards if designed with integrated competence frameworks, unified audit schedules, and cross-domain management review. This eliminates redundant processes.

Shared activities that satisfy multiple standards:

Shared Activity	Satisfies (Standards)	Implementation
Unified Competence Matrix	26262, 21434, 9001, ASPICE	Single matrix listing required knowledge for safety, cyber, quality roles
Integrated Management Review	26262, 21434, 21448, 9001	Quarterly review covering safety+cyber+SOTIF+quality performance
Supplier/Partner Audit Program	26262-2, 21434-7, 9001-8.4	Unified audit checklist covering safety, cyber, quality at supplier sites
Training & Development System	26262, 21434, 9001, ASPICE	Shared LMS tracking all competence: functional safety, cybersecurity, quality, ASPICE
Organization-Wide Risk Register	9001-6, 21434-5, 21448, 8800	Single register linking business risk → safety/cyber/SOTIF treatment
Documentation System	All standards	Single document management system (DMS) with role-based access control

Table 4.3 Shared Organizational Activities

4.5 Gap Analysis: Unique Requirements per Standard

Some organizational requirements are unique to specific standards and cannot be fully consolidated:

Standard	Unique Requirement	Cannot Consolidate Because...
ISO 26262	FMEA/HARA specialized competence	Requires ASIL-specific training; no direct cyber equivalent
ISO 21434	Threat modeling & attack surface analysis competence	Unique to cybersecurity domain; no safety equivalent
ISO 21448	SOTIF validation specialist training	Hybrid safety/performance domain; distinct methodology
ISO/PAS 8800	AI/ML algorithm specialists competence	Emerging domain; distinct from traditional functional safety
ASPICE	Process maturity assessment (SCAMPI)	Specific ASPICE assessment protocol; not required by others
IATF 16949	OEM-specific quality system requirements	Automotive-tier-specific (e.g., PPAP, SPC, advanced planning)

Table 4.4 Unique Organizational Requirements

4.6 Integrated Activity Checklist

Step-by-step checklist for establishing organizational management system:

- ☐ Define executive safety, cybersecurity, and quality policies in unified document [26262-2:5, 21434-5, 9001-5]
- ☐ Establish integrated competence matrix (safety, cyber, quality, SOTIF, AI) with role mapping [26262-2:7, 21434-5.4.3, 9001-7.2]
- ☐ Create RACI matrix assigning functional safety, cybersecurity, quality, and SOTIF roles/responsibilities [26262-2:6, 21434-5, 9001-5.1]
- ☐ Design integrated organizational audit program covering all six standards [26262-2:6, 21434-7, 9001-9.2, ASPICE-MAN.6]
- ☐ Establish supplier/partner management procedure addressing safety, cyber, quality [26262-2:7, 21434-7, 9001-8.4]
- ☐ Implement training and competence tracking system for all personnel [26262-2:7, 21434-5.4.3, 9001-7.2, ASPICE-MAN.3]
- ☐ Define management review schedule and metrics for integrated performance assessment [26262-2:6, 21434-5, 9001-9.3, ASPICE-MAN.6]
- ☐ Document all organizational procedures in unified management system [All standards]
- ☐ Conduct initial internal audit against all six standards [9001-9.2, ASPICE-MAN.6]
- ☐ Perform first management review covering safety+cyber+quality+SOTIF+AI safety performance [26262-2:6, 21434-5, 9001-9.3]

4.7 Consolidated Work Products

Organizational phase produces:

Work Product	Purpose	Standards Requirement
Integrated Management System (IMS) Manual	Unified governance document	26262-2:6, 21434-5, 9001-4.4
Safety + Cybersecurity + Quality Policy	Top-level commitment statement	26262-2:5, 21434-5, 9001-5.2
Competence & Training Plan	Role-based competence matrix and training schedule	26262-2:7, 21434-5.4.3, 9001-7.2
RACI Matrix	Clear responsibility assignment for all activities	26262-2:6, 21434-5, ASPICE-MAN.3
Supplier/Partner SLA	Unified requirements for all external contributors	26262-2:7, 21434-7, 9001-8.4
Organizational Audit Plan	Integrated audit schedule covering all standards	9001-9.2, ASPICE-MAN.6
Management Review Records	Quarterly/annual performance summaries	26262-2:6, 21434-5, 9001-9.3
Risk Register (Organizational)	Business risks mapped to safety/cyber/SOTIF controls	9001-6, 21434-5, 21448

Table 4.5 Organizational Work Products

4.8 Worked Mini-Example: Tier-1 ADAS Program Organization

A Tier-1 automotive supplier launches an ADAS program covering Adaptive Cruise Control (ACC) and Automated Emergency Braking (AEB). The program must meet ISO 26262 (ASIL-C), ISO 21434 (CAL-2), ISO 21448 (SOTIF), and ASPICE ML4. This example shows how organizational structure integrates all four.

Step 1: Build Competence Matrix

Role	Safety (26262)	Cybersecurity (21434)	Quality (IATF)	SOTIF (21448)	AI Safety (8800)
Program Manager	ASIL planning	Security roadmap	Program oversight	SOTIF scope	AI spec review
Safety Engineer	HARA, FSC, FMEA (expert)	Threat modeling (aware)	Design FMEA (aware)	SOTIF review (aware)	Basic
Security Engineer	Threat modeling (aware)	TARA, pentesting (expert)	Risk review (aware)	Cyber+SOTIF integration (aware)	Basic
Requirements Engineer	ASIL allocation (aware)	Security requirements	Traceability (expert)	SOTIF requirements	ML requirements (aware)

		(aware)		(expert)	
V&V Engineer	ASIL test protocols (aware)	Security test cases (aware)	Test plan design (expert)	SOTIF validation (aware)	Adversarial testing (basic)

Table 4.6 ADAS Program Competence Matrix (excerpt)

The competence matrix above is a living document that defines expectations for each role. It answers three key questions: (1) What competencies are required for this role in our program? (2) How do we assess whether someone has achieved the required competence level? (3) What ongoing training is mandatory to maintain competence? For example, a Safety Engineer marked as 'expert' in HARA must complete formal HARA training (e.g., ISO 26262-3 course), demonstrate competence via a practical exercise (leading a HARA on a comparable system), and maintain currency through annual refresher training. Organizations with strong competence management track these explicitly: training completion dates, assessment results, and competence review intervals. Competence gaps are identified early and addressed with targeted training or staffing decisions before critical activities (e.g., HARA workshop) commence.

Competence Assessment & Maintenance Table (8 competence areas)

Competence Area	Required By (Role/Level)	Assessment Method	Training Requirement
HARA (Hazard Analysis & Risk Assessment)	Safety Engineer (expert), Safety Manager (aware)	Practical: Lead HARA on sample project; trace hazards to ASIL correctly	ISO 26262-3 course (3 days); annual refresher; mentored HARA
TARA (Threat Analysis & Risk Assessment)	Security Engineer (expert), Security Manager (aware)	Practical: Create threat model using STRIDE; justify CAL assignments	ISO 21434 threat modeling course (3 days); annual refresher; attack simulation
SOTIF (Safety of Intended Functionality)	SOTIF Specialist (expert), Safety/Sec Eng (aware)	Practical: Define ODD, identify triggering conditions, justify controls	ISO 21448 SOTIF course (2 days); ODD validation workshop
Functional Safety Compliance (26262)	Safety Engineer (expert), Program Manager (aware)	Exam: ISO 26262 standard knowledge; interview on project FTA/FMEA	ISO 26262 certification course (5 days); annual compliance audit
Cybersecurity & Threat Landscape	Security Engineer (expert), Program Manager (aware)	Practical: Identify vulnerabilities in sample architecture; penetration test scenario	Cybersecurity fundamentals (2 days); CAR (Cybersecurity Assurance Review) facilitation
ASPICE Process Assessment	Quality Manager (expert), Process Owner (aware)	Exam: ASPICE ML process model; interview on project practices	ASPICE v3.1+ training (3 days); SCAMPI assessor certification (optional)
AI/ML Safety & Robustness (8800)	ML Engineer (expert), Requirements Eng (aware)	Practical: Define training data requirements, ML test strategy, adversarial robustness	AI safety course (2 days); ML adversarial robustness workshop

Integrated Systems Thinking	Program Manager (expert), Architects (aware)	Practical: Identify conflicts/synergies between safety, security, SOTIF; resolve tradeoffs	Integration workshop (1 day); monthly cross-functional reviews
-----------------------------	--	--	--

Table 4.8 Competence Assessment & Maintenance (8 Competence Areas)*Step 2: Define RACI Matrix*

Activity	Program Mgr	Safety Eng	Security Eng	Req Eng	V&V Eng
Define safety culture & policy	R/A	C	C	—	—
Conduct HARA	C	R/A	C	C	—
Conduct TARA	C	C	R/A	C	—
Define SOTIF triggering conditions	C	C	C	R/A	C
Allocate ASIL/CAL/SOTIF requirements	C	R	R	A	C
Plan integrated V&V	C	C	C	C	R/A
Supplier audit (safety+cyber+quality)	A	R	R	—	C
Management review (monthly)	R/A	R	R	C	C

Table 4.7 ADAS Program RACI Matrix*Step 3: Interpreting the RACI Matrix (Scenario Walkthrough)*

The RACI matrix above specifies accountability for eight key activities. Let's walk through one scenario: conducting the integrated HARA+TARA workshop. The Safety Engineer is Responsible/Accountable (R/A): they lead the HARA portion, facilitate hazard identification, and ensure all ASIL assignments are correct. The Security Engineer is Consulted (C): they attend the workshop to identify where safety hazards might correlate with security threats (e.g., 'loss of radar signal' AND 'radar spoofing'). The Requirements Engineer is also Consulted: they help map hazards to the system boundary and item definition. The Program Manager is Consulted: they ensure the workshop aligns with project schedule and stakeholder expectations. The V&V Engineer is not directly involved (—) at this stage but will use HARA outputs downstream to plan test cases. This clarity prevents the common failure where 'everyone is responsible, so no one is accountable' for HARA quality.

Another example: allocating ASIL/CAL to functions. Here, the Requirements Engineer is Accountable (A): they must ensure that each functional requirement is traced to a hazard (via HARA) and a threat (via TARA) and correctly assigned ASIL or CAL. The Safety Engineer is Responsible (R): they justify ASIL assignments based on HARA severity/occurrence/controllability. The Security Engineer is also Responsible (R): they justify CAL

assignments based on threat impact and likelihood. The Program Manager and V&V Engineer are Consulted (C): they check feasibility (does the schedule allow ASIL-C design?) and testability (can we verify an ASIL-C requirement?). If ASIL and CAL conflict—say, ASIL-C requires E2E protection (unencrypted) but CAL-2 requires encryption—the Accountable party (Requirements Engineer) documents the conflict and escalates to the Program Manager for resolution. RACI clarity prevents the blame game afterward.

For supplier audit activity, the Program Manager is Accountable (A): they own the audit program and schedule. Both Safety Engineer and Security Engineer are Responsible (R): they conduct the audit jointly, assessing the supplier's safety culture (safety policies, competence, HARA process maturity) AND cybersecurity maturity (threat modeling competence, secure coding practices, supply chain security procedures). The V&V Engineer is Consulted (C): they participate in audit discussions about testing methodologies. This integrated audit approach prevents the wasteful scenario where a separate safety audit and separate security audit are conducted at different times, by different teams, against different criteria. Unified audits require that functional safety and cybersecurity are evaluated as equally important organizational concerns.

The monthly management review activity illustrates the governance cadence. The Program Manager is Responsible/Accountable (R/A): they chair the review, collect performance data from Safety Engineer and Security Engineer, and ensure action items are tracked. Safety Engineer and Security Engineer are both Responsible (R): they present monthly KPIs (number of HARA hazards identified and mitigated, number of unresolved CAL-2+ threats, audit findings, competence training completed). The Requirements Engineer and V&V Engineer are Consulted (C): they provide status on requirements traceability and test coverage. The review output is not a 'check the box' compliance record; it is a strategic decision forum where leadership evaluates: Are we on track for ASIL-C delivery? Are cybersecurity risks adequately controlled? Are suppliers maturing? The organizational culture shifts when management review transitions from a compliance activity to a decision-making forum.

Step 3: Organizational Audit Schedule

Q1: Safety policy & HARA compliance (ISO 26262). Q2: Cybersecurity TARA & pentesting (ISO 21434). Q3: SOTIF validation approach (ISO 21448). Q4: Integrated management review & supplier audit (all standards). Outcome: Unified IMS satisfies 26262, 21434, 21448, 9001, ASPICE—no redundant audits.

CHAPTER 5: CONCEPT & PLANNING PHASE

SCOPE

Unified definition of item/asset scope; integrated execution of HARA (safety), TARA (cybersecurity), SOTIF evaluation, and AI safety analysis. Output: Traced safety/security/SOTIF/AI goals fed to design phase.

5.1 Phase Overview

The concept and planning phase bridges organizational strategy and detailed design. Four parallel risk analyses must synchronize: Hazard Analysis & Risk Assessment (HARA) for functional safety, Threat Analysis & Risk Assessment (TARA) for cybersecurity, SOTIF hazard identification and triggering condition analysis, and AI safety requirements definition. All analyses feed a unified item definition and requirement set.

Key Inputs: Item definition (from ISO 26262-3 and 21434), system boundary, operational environment, threat landscape, AI algorithms.

Key Outputs: Safety goals (ASIL decomposition), security goals (CAL allocation), SOTIF control needs, AI safety requirements, unified requirements specification.

Key Participants: Product owners, functional safety engineers, security engineers, systems engineers, requirements engineers, ML engineers.

5.2 Standard-by-Standard Requirements

Concept and planning clauses across six standards:

Standard	Clause	Requirement	Key Deliverable
ISO 26262	Part 3:5	Item Definition & ASIL Determination	Item definition, ASIL level(s)
ISO 26262	Part 3:6	Functional Safety Concept	Safety goals, ASIL allocation
ISO 26262	Part 3:7	HARA	Hazard list, risk matrix (S×O×C), ASIL assignment
ISO 26262	Part 3:8	Functional Safety Concept (Continued)	Functional safety requirements
ISO 21434	6	Concept Phase	Item definition, threat landscape, cybersecurity goals
ISO 21434	9	TARA	Threat model, attack tree, security goals (CAL)
ISO 21434	15	TARA Methods	Threat methodology, e.g., STRIDE, attack vectors

ISO 21448	5	Item Definition & Triggering Conditions	Item scope, SOTIF hazards, triggering scenarios
ISO 21448	6	SOTIF Hazard Identification	Performance limit analysis, malfunction scenarios
ISO 21448	7	Control Needs & Validation Approach	SOTIF controls, validation plan (ODD, test matrix)
ISO/PAS 8800	5	AI Item Definition & Safety Reqs	AI component identification, safety requirements
ISO/PAS 8800	6	AI Hazard Analysis	Failure modes (accuracy loss, drift, adversarial), risk classification
ISO 9001	6	Planning for QMS Change	Strategic planning, risk-based thinking
ISO 9001	8.1–8.3	Operation Planning & Control	Requirement determination, design control, change management
ASPICE	SYS.1	Stakeholder Requirements Definition	Requirements specification document
ASPICE	SYS.2	System Requirements Analysis	Requirements decomposition, traceability matrix

Table 5.1 Concept & Planning Clauses

HARA (Hazard Analysis and Risk Assessment) is the safety-specific methodology for identifying what can go wrong and assigning safety criticality (ASIL). The process begins with a facilitated workshop (typically 2-4 days) where a cross-functional team (safety engineer, architects, suppliers) brainstorms failure modes within the item boundary. Participants ask: 'What if the radar signal is lost? What if the AI classifier fails? What if the CAN message is delayed?' For each potential failure, the team assesses three dimensions: (1) Severity (S0-S3): does it cause no injury, light injury, serious injury, or fatality? (2) Occurrence (O0-O4): how likely is this failure to occur? (3) Controllability (C0-C3): if this failure occurs, can the driver mitigate it? The ASIL (A/B/C/D) is then determined by a lookup table using these three dimensions. ASIL-D is reserved for failures where severity is highest AND controllability is lowest. The output is a comprehensive hazard list (often 50-100+ hazards for a complex system) with each hazard traced to: the failure mode, the consequences, the ASIL, and preliminary mitigation measures that will be specified in the Functional Safety Concept.

TARA (Threat Analysis and Risk Assessment) mirrors HARA but assumes an intelligent attacker. TARA begins with asset/threat boundary definition: What assets do we need to protect (ECU firmware, sensor inputs, vehicle dynamics)? Who are the attackers (external, supplier, insider)? What are their motivations? Using methods like STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege), the security engineer builds a threat model showing attack vectors: How can an attacker reach the asset? For each identified threat, TARA assesses impact (what bad outcome if attack succeeds) and likelihood (how easily can the attack be executed). The risk is mapped to CAL (Cybersecurity Assurance Level) 1-3, where CAL-3 is highest risk. Unlike HARA which focuses on failure consequences (injury/death), TARA focuses on attack consequences: loss of confidentiality (secret data exposed), integrity (data/code corrupted), or availability (system unavailable). The output is a threat model diagram, an attack tree, a list of threats with CAL assignments, and preliminary mitigation strategies to be detailed in the Security Concept.

The key difference between HARA and TARA: HARA asks 'what is the worst unintentional failure?' TARA asks 'what is the most damaging intentional attack?' This distinction affects control design. A safety mechanism (e.g., dual sensors) protects against random sensor failure. A security control (e.g., message authentication) protects against attacker spoofing. Organizations inexperienced in TARA often conflate the two—for example, designing a watchdog timer (safety mechanism) and thinking it addresses denial-of-service attacks (security threat).

Effective TARA requires security domain expertise; HARA can be facilitated by safety engineers with good engineering judgment. For complex AI-based systems, TARA is also more challenging because it must consider ML-specific attacks (model poisoning, adversarial examples, extraction attacks) in addition to traditional vehicle cybersecurity threats (CAN bus injection, firmware tampering). Modern TARA workshops increasingly involve security researchers or external penetration testers to ensure threat coverage is comprehensive.

5.3 Cross-Mapping: Unified Item Definition & The Big Four Risk Analyses

The heart of Chapter 5 integration: ONE unified item definition gates FOUR parallel risk analyses. Each analysis is independent (per standard) but shares the same scope boundary and operational environment.

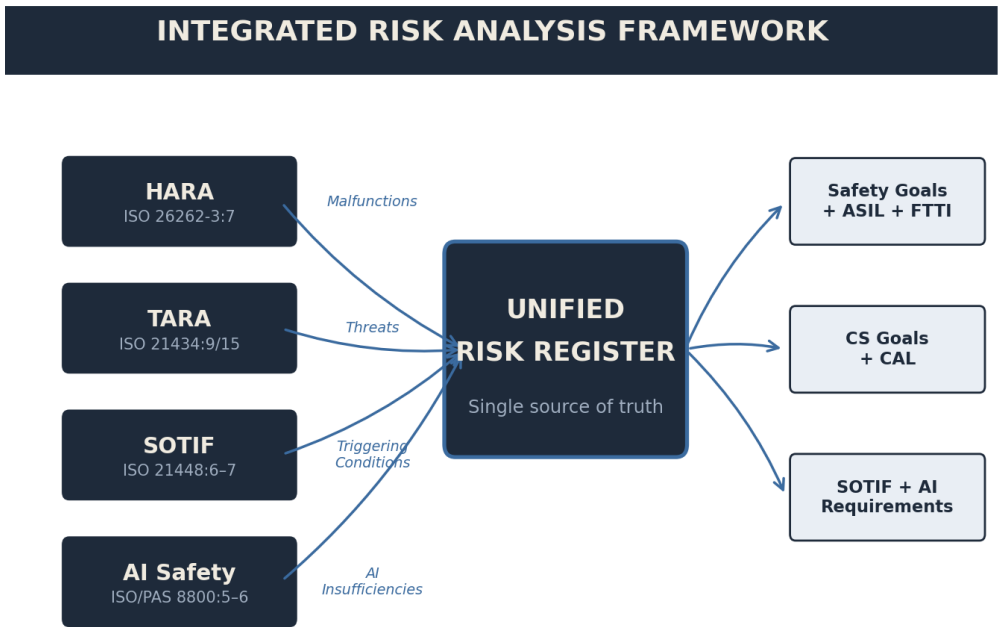


Fig. 5-1. Four domain-specific risk analyses converge into a unified register.

Figure 5.1. The Big Four Risk Analyses Converge on Unified Item Definition

Below: The 5-column risk comparison table mapping equivalent concepts across HARA, TARA, SOTIF, and AI Safety:

Dimension	HARA (26262)	TARA (21434)	SOTIF (21448)	AI Safety (8800)
Scope Definition	Item boundary, use cases, ODD	Asset definition, threat boundary, external attackers	Item scope, operational design domain	AI component ID, training data domain, inference boundary

Hazard/Threat ID Method	HARA workshop: brainstorm failure modes	Threat modeling: STRIDE, attack trees	Functional failures + performance degradation	ML failure modes: accuracy, drift, robustness, distribution shift
Risk Dimension 1 (Severity/Impact)	Severity: S0–S3 (no injury → fatality)	Impact: Business, safety, privacy consequences	Performance degradation severity	Hazard severity if ML system fails
Risk Dimension 2 (Controllability/Exposure)	Controllability: C0–C3 (driver can mitigate)	Exposure: Likelihood attacker can reach asset	Exposure: How often triggering condition occurs	Exposure: Dataset prevalence of edge case
Risk Dimension 3 (Likelihood/Probability)	Occurrence: O0–O4 (probability of failure)	Threat likelihood (technical feasibility × motive)	Malfunction occurrence probability	Probability of ML prediction failure (test set)
Risk Output	ASIL: QM, ASIL-A through ASIL-D	CAL: CAL-1 through CAL-3	SOTIF safety level (implicit in controls)	AI safety classification (TBD per 8800)
Control Type	Safety mechanisms: dual ECU, watchdog, E2E protection	Security controls: HSM, secure boot, SecOC, encryption	SOTIF controls: sensor redundancy, monitoring, E2E	ML controls: model validation, adversarial robustness, fallback
Validation Approach	Functional/technical safety verification & validation	Penetration testing, threat simulation, security audit	ODD validation, triggering condition testing, system test	Adversarial robustness test, edge case coverage, generalization

Table 5.2 The Big Four Risk Analyses: Dimension-by-Dimension Comparison

HARA-TARA Correlation Example (AEB System):

HARA Hazard (Safety)	ASIL	Related TARA Threats (Cybersecurity)	CAL	Correlation Type
Loss of radar signal (sensor failure)	ASIL-C	Radar signal spoofing (attacker injects false targets)	CAL-2	Overlapping detection mechanism; both need sensors
Incorrect object classification (AI misidentifies pedestrian)	ASIL-C	Model poisoning (training data attack shifts classifier)	CAL-3	Same AI component; safety + cyber hazards
Actuator delay/drift (braking system latency)	ASIL-B	CAN bus message tampering (attacker delays command)	CAL-2	Different mechanisms, same consequence (late braking)
Loss of GPS/IMU (location/motion)	ASIL-A	GPS spoofing / IMU manipulation (attacker)	CAL-2	Overlapping sensor; safety = fail-safe, cyber = malicious

sensor fail) broadcasts false signal)

Table 5.3 HARA-TARA Correlation Example (AEB)

5.4 Commonality Analysis: Shared Risk Dimensions

RISK STRUCTURE ALIGNMENT

All four analyses use a 3-dimensional risk model (Severity/Impact × Exposure/Likelihood × Technical Feasibility/Occurrence). This structural similarity enables unified risk workshops, shared traceability tools, and integrated gate decisions.

Shared activities in concept phase:

Shared Activity	HARA	TARA	SOTIF	AI Safety
Item/Asset Definition Workshop	Scope boundary	Threat boundary	Item scope	AI component boundary
Risk Scoring System	ASIL matrix (S×O×C)	CVSS or CAL matrix	Control necessity level	ML robustness level
Requirement Allocation	Safety goals → ASIL-based reqs	Security goals → CAL-based reqs	SOTIF controls → reqs	AI robustness reqs
Traceability Database	Hazard → goal → FSC → arch	Threat → goal → security spec → design	Hazard → control → validation plan	ML failure → robustness req → test case

Table 5.4 Shared Concept Activities (Commonality)

5.5 Gap Analysis: Unique Analyses per Standard

Each risk analysis has unique aspects that cannot be consolidated:

Standard	Unique Concept Activity	Cannot Consolidate Reason
ISO 26262	ASIL decomposition and inheritance rules	ASIL logic unique to functional safety; no security/SOTIF equivalent
ISO 21434	Threat actor modeling & motivations	Cybersecurity assumes intelligent, adaptive attacker; not applicable to safety/SOTIF
ISO 21434	Attack surface mapping & pentesting	Detailed threat methodology; no functional safety equivalent

ISO 21448	ODD (Operational Design Domain) validation	SOTIF-specific concept requiring real-world performance data
ISO/PAS 8800	AI training data quality analysis	ML-specific; requires data science expertise and statistical rigor
ISO/PAS 8800	Model drift & retraining trigger definition	Unique to ML systems; not relevant to traditional functional safety

Table 5.5 Unique Concept-Phase Activities (Gaps)

SOTIF (Safety of Intended Functionality) analysis complements HARA and TARA by addressing scenarios where the system behaves as designed but produces unsafe consequences due to performance limitations or environmental conditions. SOTIF applies a four-quadrant model: (1) Intended Functionality, Foreseeable Operating Conditions = Safe (no mitigation needed). (2) Intended Functionality, Unforeseeable Operating Conditions = SOTIF hazard (e.g., camera blind spot in fog; system behaves as designed but cannot see hazard). (3) Unintended Functionality, Foreseeable Operating Conditions = Safety hazard (system failure; covered by HARA). (4) Unintended Functionality, Unforeseeable Operating Conditions = Research frontier (true black swan; SOTIF acknowledges this quadrant but typically excludes it). For AEB, SOTIF hazards include: 'AEB cannot detect black vehicles at night' (camera limitation, not a failure) or 'radar range degrades in heavy rain' (sensor performance limitation). SOTIF control measures differ from safety mechanisms: rather than adding redundancy, SOTIF controls often involve monitoring and graceful degradation (e.g., 'if confidence drops below 80%, reduce brake authority to 50%'). SOTIF analysis outputs operational design domain (ODD) constraints—conditions under which the system can operate safely—and control measures to handle operation near ODD boundaries.

AI safety analysis (ISO/PAS 8800) addresses failures specific to machine learning systems. ML systems exhibit failure modes not present in traditional rule-based controls: (a) Training distribution shift: the AI model was trained on highway scenarios but deploys on rural roads with different visual characteristics (tree shadows, dirt surfaces). (b) Adversarial robustness: small, crafted perturbations (e.g., graffiti on a stop sign) fool the neural network. (c) Model drift: over time, the real-world distribution of inputs changes (e.g., due to camera aging, new vehicle designs), and model accuracy degrades. (d) Interpretability gaps: even if the AI produces correct outputs, engineers cannot easily explain why the model made a particular decision, complicating root cause analysis when failures occur. AI safety analysis in the concept phase involves: identifying all ML components (detection network, classification network, fusion algorithm), defining the training data domain and acceptable edge cases, specifying robustness metrics (adversarial accuracy, out-of-distribution detection confidence), and planning continuous monitoring (model performance tracking in the field, retraining triggers when accuracy drops). Unlike traditional safety, which aims for zero failures, AI safety is inherently probabilistic: we accept small failure rates and mitigate through layered controls (ensemble models, fallback classifiers, human-in-the-loop).

HARA-TARA correlation is essential to avoid unintended gaps or redundant controls. A HARA hazard (e.g., 'loss of radar signal') may correlate with a TARA threat (e.g., 'radar spoofing') if both disable the radar sensor, albeit via different mechanisms (unintentional vs. malicious). The correlation table identifies such overlaps and ensures controls address both dimensions. However, compounds risks (hazard AND threat occurring simultaneously) are rare and often not explicitly mitigated; instead, organizations document the assumption that attacks are less likely than failures. For example: 'Loss of radar + simultaneous GPS spoofing attack' is ASIL-C + CAL-2 compounded. Mitigation: add a third sensor (LiDAR), implement anomaly detection to flag suspicious sensor combinations, and design graceful degradation for triple-sensor loss. Compound risk analysis exposes where multiple layers of defense are necessary and where single-layer controls are insufficient.

5.6 Integrated Activity Checklist

Concept phase execution in integrated order:

- ☐ Define unified item/asset scope, operational environment, and use cases [26262-3:5, 21434-6, 21448-5, 8800-5]
- ☐ Hold joint HARA+TARA+SOTIF+AI workshop with cross-domain participants [All standards]
- ☐ Conduct HARA: identify hazards, assign severity/occurrence/controllability, derive ASIL [26262-3:7]
- ☐ Conduct TARA: build threat model, evaluate impact/likelihood, assign CAL [21434-9, 21434-15]
- ☐ Identify SOTIF hazards and triggering conditions; assess control needs [21448-5, 21448-6, 21448-7]
- ☐ Define AI safety requirements: identify ML components, document training data, specify robustness metrics [8800-5, 8800-6]
- ☐ Correlate HARA hazards with TARA threats (overlap analysis) [26262-3:7, 21434-9 (integration step)]
- ☐ Map SOTIF controls to HARA/TARA: check for conflicts and synergies [21448-7, 26262-3:8, 21434-10]
- ☐ Allocate ASIL/CAL to functions and architectural layers [26262-3:8, 21434-10]
- ☐ Define functional safety concept (FSC), security concept, SOTIF control plan [26262-3:8, 21434-9, 21448-7]
- ☐ Trace all safety/security/SOTIF goals to functional requirements [26262-3:8, 21434-9, ASPICE-SYS.2]
- ☐ Perform gate review: all four analyses complete, no unresolved conflicts [All standards]

5.7 Consolidated Work Products

Concept phase produces:

Work Product	Content	Standards Requirement
Item Definition Document	Scope, ODD, use cases, operational environment	26262-3:5, 21434-6, 21448-5
HARA Report	Hazard list, risk matrix, ASIL assignment	26262-3:7
TARA Report	Threat model, attack trees, CAL assignment, threat landscape	21434-9, 21434-15
SOTIF Hazard Analysis	Triggering conditions, performance limits, control needs	21448-5 through 21448-7
AI Safety Requirements Spec	ML component ID, training data definition, robustness metrics	8800-5, 8800-6
Functional Safety Concept (FSC)	Safety goals, ASIL allocation, safety functions	26262-3:6, 26262-3:8
Security Concept	Security goals, CAL allocation, security requirements	21434-9

SOTIF Control Plan	Control measures, ODD validation approach, test strategy	21448-7
Integrated Requirements Specification	Safety, security, SOTIF, AI, quality requirements (traced)	26262-3:8, 21434-9, ASPICE-SYS.1, SYS.2
Traceability Matrix	Hazard/Threat → Goal → Functional Req → Design	ASPICE-SYS.2

Table 5.6 Concept Phase Work Products

5.8 Worked Mini-Example: AEB Integrated Concept Phase

Automated Emergency Braking (AEB) system for Tier-1 supplier, ASIL-C / CAL-2 / SOTIF-1. This section shows how to unify HARA, TARA, SOTIF, and AI safety in a single coordinated concept phase.

Step 1: Unified Item Definition

Item Name: AEB Control Module (ECU + AI-based object detection). Scope Boundary: Radar + Camera inputs → ECU (AUTOSAR) → brake actuator command. ODD: 0–130 km/h, daylight + low-light, paved roads, vehicle-to-vehicle scenarios. Use Cases: (a) Lead vehicle braking detected; (b) Pedestrian crossing path; (c) Stationary obstacle ahead. All four analyses (HARA, TARA, SOTIF, AI) operate within this boundary.

Step 2: HARA (ISO 26262-3:7)

Sample hazards identified:

Hazard ID	Hazard Description	S	O	C	ASIL
H1	Loss of radar signal (intermittent failure)	3	3	3	ASIL-C
H2	Camera image processing fails (ML inference error)	3	2	2	ASIL-B
H3	Actuator command delay (CAN latency)	3	1	2	ASIL-A
H4	Sensor fusion conflict (radar ≠ camera conclusion)	2	2	2	ASIL-A
H5	Inadvertent AEB activation (false positive)	1	2	2	QM

Table 5.7 AEB HARA Extract (Sample)

Step 3: TARA (ISO 21434:9)

Sample threats identified:

Threat ID	Threat Description	Attack Vector	CAL
T1	Radar signal spoofing (attacker injects false object detections)	Over-the-air RF attack	CAL-2
T2	Model poisoning (attacker poisons training dataset → misclassification)	Supply chain / data upload	CAL-3
T3	CAN message replay (attacker replays old brake commands)	CAN bus eavesdrop + replay	CAL-2
T4	ECU firmware modification (attacker flashes malicious code)	Debug port or OTA compromise	CAL-3
T5	Sensor spoofing (attacker deceives camera/radar)	Physical or RF attack	CAL-2

Table 5.8 AEB TARA Extract (Sample)

Step 4: SOTIF Analysis (ISO 21448:5–7)

Triggering Conditions: (1) Adverse weather (rain, fog) degrades vision; (2) Highly reflective surface (metal debris, wet road) confuses radar; (3) Performance limits: max target range 200 m, reaction time ≥ 0.8 s. Control Needs: Sensor redundancy (radar + camera), E2E error detection (CRC/checksum), degraded-mode operation.

Step 5: AI Safety Analysis (ISO/PAS 8800:5–6)

AI Component: CNN-based object detector (trained on COCO-Automotive dataset, 50K images). Failure Modes: (a) Misclassification (pedestrian → vehicle), (b) False negatives (missing pedestrian), (c) Distribution shift (out-of-distribution road texture). Robustness Requirements: $>98\%$ accuracy on held-out test set, adversarial robustness against $\pm 5\%$ pixel perturbations.

Step 5.5: SOTIF Hazard Analysis Workshop (Expanded)

The SOTIF workshop convenes the same team as HARA/TARA but focuses on performance limitations and environmental edge cases. Participants ask: 'What scenarios exist where AEB behaves as designed (dual sensors confirm object, brake command issued) but still causes an unsafe outcome?' Scenario 1: Heavy rain + headwind. The radar range degrades from 200m to 100m due to moisture and interference. A stationary vehicle 120m ahead is not detected; AEB does not activate. Mitigation: Add warning to driver (limp-home mode disables AEB, alerts driver to low visibility). ODD constraint: AEB is only active in visibility >100 m. Scenario 2: Nighttime on rural road. Camera sensitivity at <50 lux is insufficient; AI confidence drops. Pedestrian at roadside not classified. Mitigation: Fuse radar + camera (if radar alone detects, still brake). ODD constraint: AEB only for daytime and well-lit conditions. Scenario 3: High-speed highway (130 km/h), reaction time is critical. Even with zero latency, physics limits deceleration. Scenario analysis: at 130 km/h, stopping distance is ~ 350 m; AEB activation at <200 m is too late. Mitigation: Reject brake command if closing speed is >150 km/h (ODD constraint). These three scenarios define the operational design domain. SOTIF controls (limp-home, fallback, ODD constraints) are documented separately from HARA safety mechanisms (dual-sensor voting) and TARA security controls (message authentication). This compartmentalization clarifies responsibility: SOTIF

engineers own ODD definition; safety engineers own functional safety mechanisms; security engineers own threat mitigation.

Integrated requirements that emerge from SOTIF analysis: 'If visibility drops below 100m (ODD boundary), system shall degrade gracefully: (1) Display warning to driver, (2) Disable AEB, (3) Log event for post-drive analysis.' This requirement is distinct from a safety requirement ('dual-sensor voting') because it is triggered by environmental conditions, not failures. V&V of this requirement involves environmental testing: creating low-visibility scenarios and verifying graceful degradation.

Step 6: HARA-TARA Correlation (Table 5.3 excerpt)

H1 (Loss of radar) ↔ T1 (Radar spoofing): Both disable radar input. HARA: Sensor failure (unintentional). TARA: Attacker spoofs signal (malicious). Controls must address both. H2 (AI inference error) ↔ T2 (Model poisoning): Both cause misclassification. HARA: Training data natural variation. TARA: Attacker deliberately corrupts training data. Mitigation: Robust ML model (adversarial training) + secure supply chain.

Step 7: Integrated Requirements Specification (excerpt)

FSC-1 (Safety Goal): Avoid unintended braking actuation. ASIL: ASIL-A. Functional Safety Requirement: Implement dual-sensor confirmation (radar AND camera) before brake command. Security Requirement: Authenticate all incoming CAN messages (CAL-2). SOTIF Requirement: Degrade gracefully if one sensor fails (fallback to secondary). AI Requirement: Model robustness score ≥ 0.95 on adversarial test set. V&V Method: HIL simulation + ODD real-world testing.

Step 8: Gate Review Criteria

- ☐ All ASIL-C hazards identified and allocated to architecture [26262-3:7, 26262-3:8]
- ☐ All CAL-2/CAL-3 threats traced to security requirements [21434-9, 21434-10]
- ☐ SOTIF triggering conditions validated in ODD (test matrix) [21448-7]
- ☐ AI model robustness requirements defined and measurable [8800-6]
- ☐ No unresolved conflicts between HARA/TARA/SOTIF/AI controls [All standards]
- ☐ Traceability chain complete: Hazard→Goal→Req→Design [ASPICE-SYS.2]
- ☐ Architecture preliminary sketch shows ASIL/CAL partitioning [26262-4:6, 21434-10]

CHAPTER 6: SYSTEM-LEVEL DEVELOPMENT

SCOPE

System architecture with integrated safety mechanisms AND security controls; conflict resolution (watchdog vs. secure session), synergy exploitation (E2E + SecOC), ASIL decomposition, CAL allocation, requirements allocation matrix, design outputs.

6.1 Phase Overview

System-level development translates safety goals, security goals, and SOTIF requirements into a coherent system architecture. The critical challenge: Safety and security mechanisms often conflict. Watchdogs (watchdog timers reset via CAN) conflict with secure sessions (encrypted, slow). E2E protection (end-to-end safety) synergizes with SecOC (secure onboard communication). Defense-in-depth layering addresses both. ASIL decomposition and CAL allocation determine which functions are safety-critical (ASIL-B/C) vs. security-critical (CAL-2/3) vs. both.

Key Inputs: FSC, security concept, SOTIF control plan, ASIL/CAL allocation, functional requirements, quality requirements.

Key Outputs: System architecture (block diagram), requirements allocation, interface specification, safety mechanism design, security control design, design verification plan.

Key Participants: Systems architect, safety engineer, security engineer, requirements engineer, hardware architect, software architect.

6.2 Standard-by-Standard Requirements

System-level development clauses:

Standard	Clause	Requirement	Key Deliverable
ISO 26262	Part 4:6	Technical Safety Concept (TSC)	Architecture, safety mechanisms, ASIL decomposition
ISO 26262	Part 4:7	System Design (Safety)	Architecture design, requirements allocation, interfaces
ISO 26262	Part 4:8	Safety-Critical Interfaces	Interface specification (safety-critical items)
ISO 21434	10	Product Development (Security)	Security architecture, security mechanism design, secure-by-design
ISO 21434	10.2	Security Specification (SecSpec)	Security requirements, security functions, threat mitigation

ISO 21448	8	SOTIF Validation Planning	SOTIF measure design, V&V approach for control limits
ISO 21448	9	System Design for SOTIF	Control mechanisms, sensor redundancy, graceful degradation
ISO/PAS 8800	7	AI System Integration	AI component integration, V-model verification gates
ISO/PAS 8800	10	System Testing for AI	AI-specific test protocols, adversarial robustness verification
ISO 9001	8.3.4–8.3.5	Design & Development Control	Design inputs, outputs, review, verification, validation, change
ASPICE	SYS.3	System Requirements Allocation	Allocation matrix, design specification
ASPICE	SYS.4	System Architectural Design	Architecture model, interface design
ASPICE	SYS.5	System Integration & Test	Integration plan, test cases, test results

Table 6.1 System-Level Development Clauses

6.3 Cross-Mapping: Integrated Architecture Design

System-level design must unify: (1) Safety mechanisms (redundancy, voting, watchdogs), (2) Security controls (encryption, authentication, HSM), (3) SOTIF measures (sensor monitoring, performance fallback), (4) Quality attributes (availability, performance).

Architectural Layer	Safety Mechanism (26262-4:6–7)	Security Control (21434-10)	SOTIF Measure (21448-8–9)	Integration Pattern
Sensor Input	Dual sensors (radar + camera)	Sensor spoofing detection (authentication)	Sensor health monitoring (degradation detection)	Redundancy + monitoring
ECU Communication	E2E protection (CRC, checksum)	SecOC (encryption + authentication)	Message validation, timeout detection	E2E + SecOC layering
Processing Core	Dual-channel with comparison	Secure boot, HSM for key storage	Heartbeat monitor, watchdog	Defense-in-depth
Actuator Command	Watchdog timer reset	Secure session (encrypted CAN-FD)	Command timeout, limp-home fallback	Conflict resolution needed
Memory/Storage	ECC for critical data	Encryption for credentials	Data integrity checks (CRC)	Layered defense
Diagnostics	Safety diagnostics (on-board)	Security event logging (HSM audit trail)	Fault code recording, OBD-II interface	Unified event log

diagnostics)

Table 6.2 Architectural Layers: Safety + Security + SOTIF Integration

Safety-Security Conflicts & Resolutions:

Critical conflicts between safety and security mechanisms:

Conflict	Safety Requirement	Security Requirement	Resolution
Watchdog Timer	Fast reset: ECU must respond within 100 ms	Secure session: Encrypted handshake ≥500 ms	Dual watchdog: fast hardware + slow software; HSM watchdog independent
CAN Bus Access	Low-latency broadcast: all nodes hear brake command	Restricted access: only ECU A can command brakes	SecOC: authenticate message sender; firewall rules; zone-based access
Error Recovery	Fail-safe: revert to mechanical braking immediately	Fail-secure: locked state prevents unauthorized access	Graceful degradation: safety path (limp-home) + security locking (audit)
Diagnostics Interface	Readable OBD-II for service technicians	Encrypted OBD-II (no cleartext fault codes)	Role-based diagnostic access; customer vs. dealer keys

Table 6.3 Safety-Security Conflicts & Resolutions

The watchdog timer conflict is the most commonly mishandled. A watchdog detects when the microcontroller hangs (e.g., due to a software bug or radiation-induced error) and triggers a reset to restore the system to a safe state. Safety standards require watchdog reset within 100-200 ms for ASIL-C systems. Security, however, often demands encrypted communication handshakes (e.g., TLS 1.3 mutual authentication) which can take 500+ ms. The naive resolution ('just skip encryption on time-critical paths') introduces a security vulnerability: an attacker can time messages to bypass authentication. The correct resolution uses layered watchdogs: a fast hardware watchdog (100 ms, independent of software) resets the main CPU if it hangs. A separate, slower software watchdog (managed by an HSM or independent security enclave) monitors for security events. This dual-watchdog approach costs extra silicon but simultaneously meets safety timing requirements (ASIL-C) and security robustness (CAL-2). Organizations that attempt single-layer solutions often ship with either latent security vulnerabilities or missed safety requirements.

The CAN bus access conflict reflects the tension between broadcast communication (safety: all nodes must hear brake command for redundancy checking) and access control (security: only authorized nodes should command brakes, preventing injection attacks). Broadcast communication is inherently less secure because attackers on the CAN bus can eavesdrop and inject messages. Restricted access is more secure but less robust. The resolution: use SecOC (Secure Onboard Communication) to add cryptographic authentication to CAN messages. SecOC authenticates the sender (preventing spoofing) while allowing broadcast reception (all nodes hear the authenticated message). This way, safety engineers get broadcast redundancy; security engineers get authentication. A secondary layer: CAN firewall rules restrict which nodes can send critical messages. For example, only the primary AEB ECU can send brake commands, and only to the ABS ECU. This white-list approach further hardens the system without sacrificing broadcast benefits for redundancy check nodes.

Error recovery mechanisms present another conflict: safety requires 'fail-safe' (if error detected, go to safe state immediately—e.g., apply full brakes). Security requires 'fail-secure' (if intrusion detected, lock down the system—e.g., disable all outputs until manual intervention). In extreme cases, these are contradictory: fail-safe says 'brake now', fail-secure says 'disable braking to prevent tampering'. The resolution distinguishes failure types: (1) Unintended failures (safety domain): detect via ECC/CRC, immediately go fail-safe (apply brakes). (2) Detected intrusions (security domain): log the event, disable network interfaces, alert driver, and gracefully degrade (limp-home mode, fallback to mechanical braking). (3) Suspected intrusions (detection ambiguous): do not panic; instead, increase sensor fusion confidence threshold and log for later forensics. This layered approach requires that safety and security systems communicate: when security detects an attack, it notifies the safety system; the safety system decides whether to go fail-safe or fail-secure based on the attack severity and consequences.

Safety-Security Synergies:

E2E Protection + SecOC Layering: End-to-end protection (ISO 26262 Cl.7 / AUTOSAR) uses CRC/checksum to detect unintended bit-flips. Secure Onboard Communication (SecOC, ISO 21434) adds crypto authentication to detect and reject spoofed messages. Together they provide: (a) unintentional corruption protection (E2E), (b) intentional attack protection (SecOC), (c) redundant error detection (defense-in-depth). This is NOT redundant—it's complementary. E2E operates at 100+ Mbps (fast, simple CRC). SecOC operates at crypto speed (slower, but unforgeable). If an attacker modifies a message's CRC to match corrupted data, SecOC authentication still fails. If cosmic rays flip a bit mid-transmission, E2E detects it (even if attacker didn't). Organizations that implement E2E + SecOC on critical safety-critical messages (e.g., brake command) achieve both safety robustness (cosmic ray protection) and security resilience (attack resistance).

Sensor Redundancy: Both safety (HARA) and security (TARA) require sensor fusion. ASIL-C hazards (loss of radar) demand dual inputs. CAL-2 threats (radar spoofing) demand sensor disagreement detection. Solution: Use the SAME redundancy to satisfy both; implement intelligent voting that rejects suspicious sensor combinations. The synergy: if we add two radars for safety (dual-sensor voting to handle one radar failure), we also gain security benefit—an attacker would need to spoof BOTH radars simultaneously, a much harder task. Fusion algorithms can be designed to detect sensor attacks: 'If radar 1 says target at 50m, but radar 2 says 150m, and camera agrees with radar 2, likely radar 1 is spoofed.' This attack detection mechanism costs minimal extra software compared to basic dual-sensor voting.

Functional Failure Isolation (FFI) + Security Isolation: In AUTOSAR, Functional Failure Isolation separates safety-critical and non-safety-critical functions into different ECUs or partitions to contain failures. Security also demands isolation: if the infotainment ECU is compromised, it should not have network access to the brake ECU. The same isolation architecture satisfies both: a separate, hardened, ASIL-C-rated ECU for safety-critical functions (brake control) is also security-hardened against attack propagation from less-critical ECUs. This partitioning strategy is far more cost-effective than bolting security onto a monolithic architecture post-hoc. Organizations that design isolation primarily for safety (FFI) but also achieve security benefits (isolation) see this as a fundamental synergy.

6.4 Commonality Analysis: Unified Architecture

ARCHITECTURAL EFFICIENCY

A defense-in-depth architecture (layered sensors → processing → actuators with validation at each layer)

simultaneously satisfies ASIL-C functional safety AND CAL-2 cybersecurity. This is NOT duplication; it is intentional redundancy with independent mechanisms.

Shared architectural patterns:

Pattern	Safety Rationale	Security Rationale	Implementation
Dual-channel sensors	Fault tolerance for ASIL-C	Spoofing detection	Redundant radar + camera inputs with arbitration logic
Error detection coding	FMEA: detect unintended corruptions	Intrusion: detect message tampering	E2E CRC + SecOC HMAC (layered)
Watchdog/Monitor	ASIL-B: detect function crashes	CAL-2: detect unauthorized access	Independent monitor (HSM or separate core)
Secure boot	ASIL-A: ensure valid firmware loads	CAL-2: prevent malware execution	Cryptographic signature verification before execution
Audit trail	Diagnostics: fault history	Security: attack evidence	Unified event log with timestamp, source, event code

Table 6.4 Shared Architectural Patterns

6.5 Gap Analysis: Unique Design Requirements

System-level design has unique safety, security, and SOTIF requirements:

Standard	Unique Design Requirement	Cannot Share Because...
ISO 26262	ASIL decomposition & inheritance rules	ASIL logic is functional-safety-specific; no security/SOTIF equivalent
ISO 26262	Fault Detection & Diagnostics (DTC mapping)	Safety diagnostics map to ASIL levels; security doesn't
ISO 21434	Attack vector analysis per architecture element	Requires threat modeling expertise; not part of safety methodology
ISO 21434	Cryptographic algorithm selection (AES-256, HMAC-SHA)	Security-specific; not applicable to functional safety
ISO 21448	Operational Design Domain (ODD) specification	SOTIF concept; not required by 26262 or 21434
ISO/PAS 8800	AI inference latency vs. safety requirement timing	ML-specific performance constraint; not traditional functional safety

Table 6.5 Unique System-Level Design Requirements

6.6 Integrated Activity Checklist

System-level development in integrated order:

- ☐ Develop preliminary system architecture block diagram (HW + SW layers) [26262-4:6, 21434-10, ASPICE-SYS.4]
- ☐ Map ASIL levels to architectural elements; identify ASIL-decomposable functions [26262-4:6]
- ☐ Map CAL levels to architectural elements; identify security-critical components [21434-10]
- ☐ Design safety mechanisms: redundancy, voting, watchdogs, E2E protection [26262-4:7, 26262-4:8]
- ☐ Design security controls: encryption, authentication, SecOC, HSM, secure boot [21434-10, 21434-10.2]
- ☐ Identify and resolve safety-security conflicts (watchdog vs. secure session, etc.) [All (integration step)]
- ☐ Exploit safety-security synergies (redundancy + spoofing detection, E2E + SecOC) [All (integration step)]
- ☐ Design SOTIF measures: sensor monitoring, graceful degradation, limp-home fallback [21448-8, 21448-9]
- ☐ Allocate requirements to HW and SW components; define interfaces [26262-4:7, 21434-10, ASPICE-SYS.3]
- ☐ Create requirements allocation matrix (hazard→goal→function→component) [ASPICE-SYS.3]
- ☐ Define interface specification (signal flow, timing, error handling) [26262-4:8, ASPICE-SYS.4]
- ☐ Plan design verification (HW design review, SW review, HW/SW integration test) [26262-4:8, 21434-10, ISO 9001-8.3.5]
- ☐ Plan design validation (system integration test, ODD validation for SOTIF) [26262-4:8, 21448-8, ISO 9001-8.3.5]
- ☐ Gate review: architecture complete, no unresolved ASIL/CAL/SOTIF conflicts [All standards]

6.7 Consolidated Work Products

System development produces:

Work Product	Content	Standards Requirement
System Architecture Document	Block diagram, layer design (HW/SW), ASIL/CAL mapping	26262-4:6–7, 21434-10, ASPICE-SYS.4
Safety Mechanism Design	Redundancy strategy, voting logic, watchdog design, E2E protection	26262-4:7, 26262-4:8
Security Control Design	Encryption, authentication, SecOC, HSM, secure boot, firewall rules	21434-10, 21434-10.2
SOTIF Measure Design	Sensor monitoring, degraded-mode logic, limp-home fallback, ODD spec	21448-8, 21448-9
Requirements Allocation Matrix	Hazard/Goal/Function → Component mapping	26262-4:7, ASPICE-SYS.3
Interface Specification	Signal definitions, timing, error codes, priority levels	26262-4:8, ASPICE-SYS.4
ASIL Decomposition	Rationale for decomposing ASIL-B→2×ASIL-	26262-4:6

Justification	A (if applicable)	
Design Verification Plan	HW design review, SW review, integration test, acceptance criteria	26262-4:8, ISO 9001-8.3.5
Design Validation Plan	System integration test, ODD/SOTIF validation, V&V schedule	26262-4:8, 21448-8, ISO 9001-8.3.5
Conflict Resolution Log	Safety-security conflict decisions and rationale	All (integration artifact)

Table 6.6 System Development Work Products

Requirements allocation methodology bridges concept-phase safety/security goals and system-level design components. Allocation answers: 'Which component is responsible for mitigating hazard H1?' Allocation must be traceable, decomposable, and testable. A typical allocation process: (1) Start with a safety goal (e.g., 'Avoid unintended brake actuation'). (2) Decompose into functional requirements (e.g., 'Before brake command, dual-sensor confirmation must occur; confidence > 90%'). (3) Allocate to components (e.g., 'Radar sensor input (Radar 1, Radar 2)' → 'Sensor fusion algorithm' → 'Brake decision logic in primary ECU'). (4) For each allocated requirement, specify: the component name, the ASIL or CAL level, the success criterion (how we verify this component meets the requirement), and dependencies (what other components must succeed for this allocation to be effective). Requirements allocation for ASIL-C systems is NOT a one-time document; it is a living matrix that evolves as architecture decisions are made and tested. When an architecture review uncovers a flaw (e.g., 'we cannot achieve dual-channel voting in the time budget'), the allocation must be revisited and alternative architectures evaluated.

Traceability is the second critical aspect of requirements allocation. Every ASIL-C functional requirement must trace upward to: which HARA hazard does it mitigate? Every ASIL-C component allocation must trace downward to: which detailed design (algorithm, module, test case) implements this? A common failure: organizations allocate high-level requirements to components but fail to document lower-level design details, making V&V impossible. For example, 'Dual-sensor voting' is allocated to 'sensor fusion algorithm'; the detailed design must specify: 'Voting rule: Brake command only if (Radar_1.object_detected = TRUE AND Radar_2.object_detected = TRUE AND Confidence > 90% AND consistency_check passes)'. The test case must verify: 'Inject simulated target in Radar 1 only → no brake command. Inject in both → brake command issued.' This detailed traceability ensures completeness (every hazard is addressed) and accountability (each component owner understands their responsibility).

6.8 Worked Mini-Example: AEB System Architecture

Continuing the AEB example from Chapter 5: system-level design for ASIL-C / CAL-2 / SOTIF-1. This section shows architecture with integrated safety mechanisms and security controls.

Step 1: Preliminary System Architecture

Sensors: Dual radar (front-center, front-left) + dual camera (front RGB, front IR). Processing: Dual-channel ECU (ASIL-C rated), one primary + one monitoring (or HSM-based independent monitor). Actuators: Brake command to ABS ECU (via CAN-FD with SecOC), throttle command (fallback). Power: Isolated 12V rail for AEB, monitored by HSM. Storage: Non-volatile memory for event log, firmware, AI model weights (encrypted).

The architecture details reflect careful ASIL/CAL partitioning. The primary ECU (NXP S32K3) is ASIL-D rated and handles safety-critical tasks: sensor fusion, brake decision logic, and actuator command. The secondary monitoring unit (either a separate S32K3 core or an HSM-protected co-processor) independently validates the primary decision and triggers a safe state (limp-home brake authority reduction) if primary and secondary disagree. The CAN-FD bus is the critical data path: dual-channel radar/camera feeds, processed with E2E (CRC-32), secured with SecOC (HMAC-SHA-256), and routed only to authorized ECUs via CAN firewall rules. Power distribution uses an isolated 12V rail with brownout detection and glitch sensing to defend against fault-injection attacks (which try to collapse voltage to induce bit flips or code execution errors). The HSM (STM32H7 + A71CH) is a separate secure enclave with its own power conditioning, handling firmware signing verification, key storage for SecOC, and tamper detection. This separation ensures that even if the main ECU is compromised, the HSM cannot be reached; conversely, if the HSM is physically attacked, tamper detection triggers a secure shutdown without software involvement.

Step 1b: Architecture Diagram (Text Description)

A functional architecture diagram (not detailed here but recommended as a work product) shows: (a) Sensor layer: Four radars (Bosch ARS430) positioned at front corners and center, plus two cameras (OV2775 RGB + IR) feeding parallel perception pipelines. (b) Processing layer: Primary ECU (S32K3 Core 0, safety-critical) runs sensor fusion and brake logic. Secondary monitoring (S32K3 Core 1 or HSM, ASIL-rated) validates decisions. (c) Communication layer: CAN-FD backbone for all messaging, with SecOC authentication and E2E protection on every critical message. (d) Actuation layer: Brake command to ABS ECU (already ASIL-B rated, trusted supplier), throttle fallback if braking fails, and HMI notification to driver if AEB mode degrades. (e) Power & diagnostics: Isolated power rail with glitch detection, HSM-protected audit log, and OBD-II interface (encrypted) for authorized diagnostic access. This architecture explicitly separates safety-critical (primary ECU), safety-monitoring (secondary unit), security-critical (HSM), and quality-of-service (HMI, diagnostics) functions.

Step 2: Safety Mechanism Design (ASIL-C)

Redundancy Strategy: (a) Dual sensors (radar + camera) must agree before brake command; (b) Dual-channel ECU: primary computes brake, secondary validates; (c) E2E protection: CRC-32 on all inter-ECU messages; (d) Watchdog: 100 ms hardware watchdog (independent reset circuit). Voting Logic: Brake command only if (Radar_Detection = TRUE AND Camera_Detection = TRUE AND Confidence >90%). Fail-Safe: Loss of any sensor → reduce to 50% brake authority (limp-home).

Step 3: Security Control Design (CAL-2)

Secure Boot: AEB ECU firmware signed with RSA-2048; bootloader verifies signature before execution. HSM: Hardware security module stores private keys, performs cryptographic operations. Sensor Spoofing Detection: Monitor for radar-camera disagreement patterns; flag anomalies to OBD. CAN Security: SecOC on brake command (AES-128 + HMAC-SHA-256, 50 ms latency budget). Secure Session: Encrypted diagnostic session (AES-128-CBC). Audit Trail: All security events logged (tampering, failed auth, firmware updates) in HSM-protected flash.

Step 4: Safety-Security Conflict Resolution

Conflict #1: Watchdog fast reset (100 ms) vs. SecOC latency (50 ms encoding + CAN transmission 20 ms). Resolution: Hardware watchdog (100 ms) operates independent of SecOC. If SecOC encoding takes 50 ms, the

remaining 50 ms is available for CAN transmission and ECU execution. If ECU hangs mid-SecOC, hardware watchdog triggers reset.

Conflict #2: Sensor redundancy (safety: broadcast all sensor data) vs. security (restrict data access).

Resolution: Use firewall rules: cameras/radars broadcast to AEB ECU only, not to infotainment. Encryption on non-safety-critical diagnostic interfaces; E2E CRC on safety-critical paths.

Step 5: Requirements Allocation Matrix (excerpt)

Hazard/Goal	Safety Req	Component(s)	ASIL	Security Req	CAL
H1: Loss of radar	FSR-1: Dual-sensor conf.	Radar 1, Radar 2, ECU decision logic	ASIL-C	SecReq-1: Spoofing detect.	CAL-2
H2: AI misclass	FSR-2: >98% accuracy	AI model, test harness	ASIL-B	SecReq-2: Model integrity	CAL-3
H3: CAN latency	FSR-3: <300 ms total	ECU proc., CAN, ABS ECU	ASIL-B	SecReq-3: SecOC auth	CAL-2
H5: False positive	FSR-5: Voting logic	ECU decision module	QM	SecReq-4: CAN firewall	CAL-1

Table 6.7 AEB Requirements Allocation Matrix (excerpt)

Step 6: Interface Specification (CAN message example)

AEB_Brake_Cmd (CAN 0x123): Byte 0-1: Brake_Pressure (0–1000 bar), unsigned 16-bit. Byte 2: Confidence (0–100%), unsigned 8-bit. Byte 3: Status (bit 0: radar_ok, bit 1: camera_ok, bit 2: model_ok, bit 3–7: reserved). Byte 4-5: Checksum (CRC-16). Byte 6-7: SecOC HMAC (truncated, 16-bit). Cycle time: 20 ms (50 Hz). Safety mechanism: Dual checksum (CRC-16) detects bit flips. SecOC detects spoofing. Security: HMAC-SHA-256 truncated to 16 bits (sufficient for CAL-2 given CAN speed constraints).

CHAPTER 7: HARDWARE DEVELOPMENT

SCOPE

Functional safety FMEDA metrics (SPFM, LFM, PMHF); HSM dual requirements (safety + security); ASPICE HWE.1–4 (new in v4.0); SOTIF-relevant sensor/actuator performance limits; AI inference hardware (GPU/NPU determinism). Unified HW failure analysis covering safety, security, SOTIF, and AI.

7.1 Phase Overview

Hardware development encompasses selecting components, designing circuits, and analyzing failure modes. Six standards impose distinct HW requirements: ISO 26262-5 (FMEDA metrics), ISO 21434 HSM design, ISO 21448 sensor performance limitations, ISO/PAS 8800 AI inference hardware, ASPICE HWE (new), and IATF 16949 production control. The dominant challenge: hardware component selection and FMEDA. A single component (e.g., automotive-grade microcontroller) must meet ASIL-C (26262), CAL-2 (21434), and ECC memory requirements (21448 + 26262).

Key Inputs: System architecture, component specifications, ASIL/CAL allocation, SOTIF ODD definition, AI model inference latency budget.

Key Outputs: Component data sheet review, FMEDA report, SPFM/LFM/PMHF calculations, HSM design specification, secure boot bootloader, hardware test plan, production control procedure.

Key Participants: Hardware architect, component engineer, reliability engineer, security hardware specialist, manufacturing engineer.

SPFM (Single-Point Failure Metric) and LFM (Latent Failure Metric) are key reliability indicators required by ISO 26262-5:7. SPFM quantifies the fraction of hardware failures that are either: (a) safe-point failures (detected, fail-safe outcome) or (b) safe failure modes (inherently safe—no mitigation required). A single-point failure is a failure mode where loss of the component directly causes a loss of the safety function. For example, in a dual-channel brake system, a failure in the primary brake ECU is a single-point failure only if the secondary channel cannot take over. SPFM is calculated as: $SPFM = (FIT_{SPF} + FIT_{safe}) / FIT_{total}$. ASIL-C typically requires $SPFM > 99\%$ (i.e., at most 1% of failures are dangerous undetectable). This high threshold drives design decisions: to achieve $SPFM > 99\%$, organizations must invest in error detection (ECC memory, watchdog monitors, CRC checks). A single-bit ECC in SRAM can dramatically improve SPFM by detecting and correcting transient faults. LFM quantifies latent faults—failures that are not detected by periodic self-tests and would only be discovered during maintenance. $LFM = FIT_{latent} / FIT_{total}$. ASIL-C typically requires $LFM < 10\%$ (most failures detected), and ASIL-D requires $LFM < 2\%$. High LFM indicates insufficient diagnostics and suggests periodic test improvements.

PMHF (Probabilistic Metric for Hardware Failures) combines random hardware failures over the item's operational lifetime into a single risk figure. $PMHF = \sum (\lambda_i \times DC_i \times T_{lifetime})$ for each failure mode, where λ_i is failure rate (in FIT), DC_i is diagnostic coverage (0-100% depending on whether the failure is detected), and $T_{lifetime}$ is operational hours (typically 17 years $\approx 150,000$ hours for automotive). ASIL-C requires $PMHF < 1e-7/\text{hour}$ (i.e., less than 1 dangerous failure in 10 million hours of operation). For a component with 100 FIT failure rate and 90% diagnostic coverage, $PMHF = 100e-9 \times (1 - 0.9) \times 60,000 = 0.6e-6/\text{hour}$, which exceeds ASIL-C target. To meet the target, engineers must: increase diagnostic coverage (add ECC, watchdog, CRC

checks), select lower-FIT components (AEC-Q100 Grade 0 vs. industrial-grade), or design redundancy (dual components, each with half the responsibility). PMHF calculation is not one-time; it must be revisited whenever the component selection, diagnostics, or operational profile changes. Organizations often use spreadsheet tools (or specialized FMEDA software) to automate PMHF calculations because the numbers are sensitive to small changes in failure rate or diagnostic coverage.

The relationship between SPFM, LFM, and PMHF is subtle but important. SPFM/LFM are deterministic metrics (does this specific failure mode have a diagnostic?) while PMHF is probabilistic (what is the accumulated risk over lifetime, accounting for all failure modes and their rates?). A component can have SPFM > 99% (all detected failures are safe) but still miss PMHF targets if the component's baseline failure rate is very high. Conversely, a low-FIT component with modest detection (SPFM 85%) may still meet PMHF targets because the absolute number of failures is low. PMHF is the regulatory requirement that engineers must meet; SPFM/LFM are diagnostic means used to design for PMHF compliance. In practice, ASIL-C designs often iterate: select a promising component, calculate PMHF, identify shortfalls, add diagnostics (improving SPFM), recalculate, and loop until PMHF is met or cost/complexity becomes prohibitive (triggering a redesign or architectural change).

HSM (Hardware Security Module) design must satisfy both safety and security requirements. From the safety perspective (ISO 26262), the HSM is a critical safety component: key storage for secure boot verification, watchdog monitors, and tamper detection are all safety-critical. ASIL-A or ASIL-B requirements apply. From the security perspective (ISO 21434), the HSM must resist tampering: physical attacks (decapsulation, side-channel analysis), fault injection attacks (voltage glitches, EM pulses), and logical attacks (unauthorized key extraction). CAL-2 or CAL-3 requirements apply. A dual-requirement HSM design allocates different responsibilities: Safety monitors via the HSM provide rapid response to detected failures (e.g., ECC error → immediate watchdog reset). Security monitors via the HSM detect attacks with forensic detail (e.g., suspicious repeated failed authentication → log and alert, then gracefully degrade). The HSM hardware itself is rated for both ASIL and CAL: using a Common Criteria certified secure enclave (e.g., NXP A71CH) that has already undergone formal security assessment reduces design burden and inspection risk.

The second aspect of HSM dual-requirement design: response to tamper detection. If the HSM detects a physical attack (via sensors on power, clock, or data buses), what should happen? Safety says: 'Immediately disable all outputs (fail-safe brake applies).' Security says: 'Lock the HSM and prevent key extraction (fail-secure).' These are compatible: hardwired logic in the HSM triggers both a secure shutdown (disables brake actuator command output) and a cryptographic zeroization of keys (secure shutdown). The design ensures: (1) Even a sophisticated attacker who decaps the HSM and reads memory cannot extract encryption keys (they are zeroed on tamper detection). (2) The vehicle immediately goes to safe state (brakes applied). Organizations that design HSM safety and security responsibilities upfront avoid last-minute conflicts and produce integrated, testable systems.

7.2 Standard-by-Standard Requirements

Hardware development clauses across standards:

Standard	Clause(s)	Requirement	Key Output
ISO 26262	Part 5:6	HW Design & Architecture	Component selection, circuit design rationale
ISO 26262	Part 5:7	HW Design Metrics (SPFM, LFM, PMHF)	FMEDA analysis, metric calculations

ISO 26262	Part 5:8	HW Failure Analysis (FMEDA)	Failure mode list, effect classification (safe/unsafe)
ISO 26262	Part 5:9	HW Testing & Diagnostics	Built-in test strategy, test procedures
ISO 26262	Part 11	Semiconductors (microcontrollers, SoCs)	Functional safety manual review, AEC-Q100 qualification
ISO 21434	10	HSM Security Hardware	HSM selection, secure key storage design
ISO 21434	10.2	Secure Boot Hardware	Cryptographic boot verification logic
ISO 21434	10.3	Tamper Detection & Response	Tamper sensors, secure shutdown circuitry
ISO 21448	7	Sensor & Actuator Performance Limits	Data sheet review, ODD operation confirmed
ISO/PAS 8800	7	AI Inference Hardware (GPU/NPU)	Determinism verification, memory ECC for weights
ASPICE	HWE.1	HW Design (new v4.0)	Component selection, design review
ASPICE	HWE.2	HW Verification (new v4.0)	Design verification testing
ASPICE	HWE.3	HW Validation (new v4.0)	Acceptance testing, field validation
ASPICE	HWE.4	HW Maintenance (new v4.0)	Obsolescence management, component lifecycle

Table 7.1 Hardware Development Clauses

7.3 Cross-Mapping: Safety + Security + SOTIF Hardware Failures

Traditional FMEDA (ISO 26262-5:8) analyzes single-point and latent failures. CAL-2 security requires analysis of deliberate attacks on hardware (e.g., fault injection). SOTIF requires sensor performance drift over lifetime. AI requires GPU/NPU memory errors affecting ML weights. A unified approach creates one FMEDA table with failure modes categorized as: (a) unintentional (safety), (b) malicious (security), (c) age-related (SOTIF), (d) computation (AI).

HW failure modes across domains:

Component	Safety Failure Mode (26262-5:8)	Security Threat (21434-10)	SOTIF Limitation (21448-7)	AI Impact (8800-7)
Radar sensor	Signal loss (unintentional RF noise)	RF spoofing (attacker broadcasts false targets)	Range degradation over temp (0.5 m/°C)	—
Camera	Image sensor pixel degradation	Lens contamination exploit (attacker covers lens)	Night vision sensitivity limit (lux threshold)	CNN training on degraded images needed
Microcontroller	Single-bit flip in register	Fault injection attack	Thermal aging → lower	Instruction fetch error

	(cosmic ray)	(EM/voltage glitch)	max clock speed	(ECC RAM)
Memory (SRAM)	Bit flip (SEU)	Cold boot attack (read uncleared memory)	Retention time limit at low temp	AI model weights corruption (need ECC)
Flash storage	Bit flip after write-erase cycles	Physical access attack (dump firmware)	Data retention loss (long storage)	Firmware image integrity (signed)
Power supply	Voltage dip → CPU reset	Power glitching attack (reduce voltage)	Thermal cycling → regulator aging	Supply noise → ADC uncertainty
CAN transceiver	Message collision (tx failure)	Bus injection attack (attacker sends CAN message)	EMC coupling (external noise)	—
HSM (secure enclave)	Key exposure (unintentional leak)	Tamper detection fail (deliberate attack on HSM)	—	Key storage for encrypted AI model

Table 7.2 Unified HW Failure Analysis (Safety + Security + SOTIF + AI)

7.4 Commonality Analysis: Shared HW Controls

COMPONENT EFFICIENCY

ECC memory protects against both safety bit-flips (cosmic rays) AND security fault-injection attacks. Dual microcontrollers satisfy both ASIL-C redundancy AND CAL-2 tamper resistance. Component derating addresses both functional safety PMHF budgets AND SOTIF sensor lifetime margins.

Shared hardware solutions:

Control	Safety Benefit	Security Benefit	SOTIF Benefit	Implementation
ECC memory	Detects/corrects single-bit flips (FMEDA gain)	Resists fault-injection attacks	Detects memory decay with age	ECC-capable SRAM + flash controllers
Watchdog timer	ASIL-C: Detects processor hang	CAL-2: Detects malware loop	SOTIF: Detects performance degradation	Independent watchdog IC, separate power rail
Secure boot	ASIL-A: Ensures valid firmware load	CAL-2: Prevents malware execution	SOTIF: Validates firmware version	Signed firmware image + bootloader verification
Dual microcontroller	ASIL-C: Voting, dual-channel design	CAL-2: One for safety, one HSM-protected	SOTIF: Redundant sensor fusion	Two identical ASIL-rated ECUs or 1 ECU + HSM
Derating (temp/voltage)	PMHF budget margin (longer	Security: lower attack success rate	SOTIF: sensor accuracy	Design for Tj <85°C, Vdd ±5%

	lifetime)	(fewer glitch attempts)	maintained over ODD range	
Tamper detection	ASIL-A: Detect physical tampering	CAL-2: Trigger secure shutdown	SOTIF: Detect environmental attack	Tamper switch + secure shutdown relay

Table 7.3 Shared Hardware Controls

7.5 Gap Analysis: Unique Hardware Requirements

Unique requirements per standard:

Standard	Unique HW Requirement	Cannot Consolidate Because...
ISO 26262	SPFM (Single-Point Failure Metric) & PMHF (Probabilistic Metric)	Complex Weibull reliability modeling; cybersecurity doesn't require MTBF analysis
ISO 26262	FMEDA with ASIL classification (Safe/Unsafe/SPF/RF)	ASIL-specific taxonomy; security uses different risk model
ISO 21434	HSM functional isolation (cryptographic key storage)	Security-specific; safety systems don't require key management hardware
ISO 21434	Tamper-resistance rating (e.g., JTAG disable, glitch detection)	Security-specific; functional safety doesn't assume adversarial attacks
ISO 21448	Sensor performance characterization over ODD (temp, age, EMC)	SOTIF concept; not part of traditional functional safety FMEDA
ISO/PAS 8800	GPU/NPU determinism verification (inference time variance < 5%)	AI-specific; not relevant to traditional ECU hardware
ASPICE HWE	Component obsolescence management & lifecycle planning	Process-level artifact; not required by 26262 or 21434

Table 7.4 Unique Hardware Requirements

ASPICE HWE (Hardware Engineering) processes, new in v4.0, provide a process-centric view that complements ISO 26262-5's technical focus. HWE.1 (Hardware Design) aligns with ISO 26262-5:6 (component selection and design): both require documented rationale for component choices, design reviews, and traceability from architecture to component datasheets. The difference: ASPICE HWE.1 emphasizes process discipline and configuration management, while 26262-5:6 emphasizes safety metric targets (ASIL ratings, AEC-Q100 qualification). Organizations meeting both requirements ensure: (1) Each component is chosen based on a documented evaluation (datasheets reviewed against ASIL/CAL requirements), (2) Component selection decisions are approved via design review and recorded in the configuration management system, (3) Alternative components are considered and tradeoff rationale is documented. HWE.1 also introduces 'design verification' at the component level—for example, verifying that ECC-enabled memory truly provides the expected error detection and correction capability through lab testing, not just simulation.

HWE.2 (Hardware Verification) aligns with ISO 26262-5:9 (hardware testing) but adds process expectations. Both require test plans that cover component failure modes and validation of built-in diagnostics. ASPICE HWE.2 additionally requires: traceability from test cases to requirements, documented test results with pass/fail criteria, and root cause analysis of failures. For example, if a power supply component fails the overvoltage test, ASPICE HWE.2 requires documenting why it failed, whether it was a batch defect or design issue, and whether the component specification needs revision or procurement sourcing needs change. This level of rigor prevents recurring defects and improves supply chain maturity. HWE.3 (Hardware Validation) and HWE.4 (Hardware Maintenance) address lifecycle management: HWE.3 ensures acceptance testing in the production environment, while HWE.4 ensures component obsolescence management and long-term supportability—critical for automotive programs with 10+ year production lifecycles.

Sensor degradation over lifetime is a SOTIF-specific concern often overlooked in traditional FMEDA. Sensors (radar, camera, lidar, ultrasonic) degrade predictably over years of operation: radar sensitivity decreases due to PCB aging and corrosion, cameras lose sensitivity in low light due to pixel degradation, lidar optics accumulate dust and dirt. Unlike a discrete failure (sensor suddenly stops working), degradation is gradual and may not trigger diagnostic alerts if the baseline performance specification is loose. SOTIF analysis requires: (1) Establishing sensor performance limits within the ODD—for example, 'AEB is effective only for targets within 200m range and with >100 lux ambient light.' (2) Characterizing degradation modes and lifetime limits—'radar range degrades at -0.5m/year due to aging; after 10 years, range is <150m.' (3) Defining acceptance criteria at end-of-life—'if range falls below 150m, AEB shall be disabled with a diagnostic warning.' SOTIF controls (graceful degradation, performance monitoring) differ from HARA safety mechanisms (dual-sensor voting) because they address performance limits, not failures. Organizations integrating SOTIF sensor degradation analysis into FMEDA create a unified table that separately tracks: failure modes (sudden loss), degradation modes (gradual loss over time), and aging effects (thermal, radiation, humidity). This comprehensive view ensures that in-field AEB systems do not silently lose effectiveness as sensors age.

7.6 Integrated Activity Checklist

Hardware development in integrated order:

- ☐ Review component specifications against ASIL/CAL/ODD requirements [26262-5:6, 21434-10, 21448-7]
- ☐ Verify microcontroller meets ASIL rating and has AEC-Q100 qualification [26262-5:11, ASPICE-HWE.1]
- ☐ Confirm RAM/Flash support ECC or other error detection [26262-5:7, 21434-10 (secure storage)]
- ☐ Select HSM component (if CAL-2+); verify secure key storage [21434-10, 21434-10.2, 21434-10.3]
- ☐ Verify sensor data sheets cover full ODD temperature range [21448-7]
- ☐ Design secure boot logic (cryptographic signature verification) [21434-10.2, 26262-5:6]
- ☐ Design tamper-detection circuit (tamper switch + secure shutdown) [21434-10.3]
- ☐ Conduct FMEDA: list failure modes, classify (Safe/Unsafe/SPF/RF/CAL), calculate SPFM/LFM [26262-5:8, ASPICE-HWE.2]
- ☐ Map FMEDA failures to safety mechanisms (diagnostics, redundancy) [26262-5:8, 26262-5:9]
- ☐ Analyze HSM failure modes for both safety and security impact [26262-5:8, 21434-10 (unified analysis)]
- ☐ Create HW design verification test plan (component testing, ECC verification) [ASPICE-HWE.2]
- ☐ Plan production control measures (incoming inspection, FMEA-based testing) [IATF 16949, ASPICE-HWE.1]
- ☐ Document component selection rationale and lifecycle plan (obsolescence) [ASPICE-HWE.4]

☐ Gate review: FMEDA complete, SPFM/LFM targets met, HSM design validated [All standards]

7.7 Consolidated Work Products

Hardware development produces:

Work Product	Content	Standards Requirement
Component Selection Report	Data sheets, AEC-Q100 certs, ASIL/CAL ratings, ODD coverage	26262-5:6, 21434-10, ASPICE-HWE.1
Circuit Design Document	Schematic, power distribution, decoupling, thermal design	26262-5:6, ASPICE-HWE.1
FMEDA Analysis Report	Failure mode list, ASIL/CAL classification, SPFM/LFM/PMHF calculations	26262-5:8, 26262-5:7
Failure Mode to Safety Mechanism Mapping	FMEDA → diagnostic coverage analysis	26262-5:8, 26262-5:9
HSM Design Specification	Secure key storage, crypto implementation, tamper detection, secure shutdown	21434-10, 21434-10.2, 21434-10.3
Secure Boot Design Document	Bootloader code, signature verification logic, ROM layout	21434-10.2, 26262-5:6
Sensor Performance Characterization	Range/sensitivity over ODD (temp, age, EMC), degradation limits	21448-7
HW Verification Test Plan	Component testing, ECC verification, power-on self-test (POST) procedures	26262-5:9, ASPICE-HWE.2
Production Control Plan	Incoming inspection, FMEA-based production tests, defect rates	IATF 16949, ASPICE-HWE.1
Component Lifecycle Plan	Obsolescence tracking, long-term availability, EOL management	ASPICE-HWE.4

Table 7.5 Hardware Development Work Products

7.8 Worked Mini-Example: AEB Hardware FMEDA

AEB controller hardware: dual-channel ASIL-C ECU with HSM for secure boot and sensor authentication. This section demonstrates unified FMEDA covering safety, security, SOTIF, and AI hardware failure modes.

Step 1: Component Selection

Primary ECU: NXP S32K3 (ASIL-D rated, AEC-Q100 Grade 0). Features: Dual cores, ECC SRAM (96 KB), ECC Flash (1.5 MB), secure boot ROM, 32 watchdogs. HSM: STM32H7 + NXP A71CH HSM module (CAL-2 rated,

certified secure enclave). RAM: 96 KB ECC (single-bit correction, multi-bit detection). Flash: 1.5 MB ECC. Power: Isolated 12V → 3.3V regulator ($\pm 5\%$ over ODD, decoupled with 100 μ F + 100 nF). Sensors: 4× automotive radar (ARS430, Bosch), 2× camera (OV2775, OmniVision). Tamper Detection: Passive glitch detector on power rail (triggers secure shutdown).

Step 2: Unified FMEDA Table (partial)

Sample failure modes across all domains:

Component	Failure Mode	Cause	Safety Effect	Security/SOTIF Effect	ASIL/CAL	Control
S32K3 CPU	Bit flip in ALU register	Cosmic ray SEU	Incorrect calculation (SPF)	—	ASIL-C	ECC detection + watchdog reset
S32K3 CPU	Instruction fetch error	Bit flip in bus	Wrong instruction (RF)	Fault injection attack (CAL-2)	ASIL-C / CAL-2	ECC + secure boot signature check
SRAM (96 KB)	Data loss (single-bit flip)	Soft error	State corruption (SPF)	—	ASIL-B	Single-bit ECC correction
SRAM (96 KB)	Data loss (multi-bit flip)	Voltage glitch attack	Undetectable corruption (RF)	Cold boot attack (CAL-2)	ASIL-C / CAL-2	Multi-bit ECC detection + watchdog
Flash (1.5 MB)	Bit flip (read)	Worn flash cells (age)	Firmware corruption (SPF)	SOTIF: firmware validity check fails	ASIL-B	ECC on firmware section + CRC32
Power Regulator	Voltage sag (<3.0V)	Load transient / glitch	CPU reset (SPF)	Fault injection opportunity (CAL-2)	ASIL-A / CAL-1	Brownout detector + power sequencing
Radar Sensor	Signal loss (intermittent)	RF interference	Missing object (S3)	Attacker spoofing, not a failure	ASIL-C	Dual-sensor voting + timeout
Radar Sensor	Sensitivity degradation	Age + thermal cycling	Range reduction (S2)	SOTIF: ODD performance limit	SOTIF-1	Performance test during production
HSM (secure enclave)	Key exposure (intentional)	Physical attack (decap)	Complete system compromise (SPF)	Complete compromise (CAL-3)	ASIL-A / CAL-3	Tamper detection + secure shutdown

Table 7.6 AEB Hardware FMEDA (partial, unified)

The unified FMEDA table deserves detailed walkthrough to show how safety, security, SOTIF, and AI failure modes are analyzed jointly. Take the S32K3 CPU instruction fetch error (row 2): This failure mode can arise

from three independent root causes with very different implications. (1) Cosmic ray causes a bit flip in the CPU bus during instruction fetch. This is a random, unintentional failure (safety domain). The CPU executes a wrong instruction, potentially causing hazardous behavior. ASIL-C applies. Mitigation: ECC on the instruction bus detects the bit flip, and the watchdog detects the resulting incorrect behavior and triggers reset. Effective control: ECC detection + watchdog. (2) Attacker injects a voltage glitch to induce a bit flip in a specific instruction (fault injection attack, security domain). The attacker crafts a glitch to flip the bit in an instruction, making the CPU skip a critical check (e.g., 'if (confidence < 90%) skip brake'). This is a deliberate, intentional attack (CAL-2). Mitigation: Redundant watchdog (via HSM), which monitors for suspicious behavior patterns and triggers secure shutdown. (3) Thermal stress (long-term aging, SOTIF domain) causes marginal CPU timing. Under high temperature, the CPU instruction fetch races against the memory, occasionally causing errors. This is gradual degradation, not sudden failure. SOTIF mitigation: Thermal sensor monitoring; if junction temperature exceeds 85°C, reduce clock frequency or degrade performance. The single FMEDA row now shows: failure mode (instruction fetch error), three distinct root causes (cosmic ray / glitch / thermal), three different effect domains (safety/security/SOTIF), and three distinct controls (ECC+watchdog / HSM+audit / thermal monitoring). This integrated analysis prevents the silo approach where safety FMEDA misses security aspects.

Another example: SRAM multi-bit flip (row 4). Safety scenario: A cosmic ray flips multiple bits in SRAM, corrupting the brake pressure setpoint. Single-bit ECC cannot correct this; only detection is possible. The watchdog detects the corrupted calculation (brake pressure out of bounds) and triggers reset. Security scenario: An attacker injects a voltage glitch precisely calibrated to flip multiple bits in a specific SRAM location (e.g., the confidence threshold). Single-bit ECC cannot correct; only detection. However, the attacker's goal is to evade detection. So the attacker might try to flip bits in the ECC checksum itself, producing undetectable corruption. SOTIF scenario: Long-term SRAM retention loss at low temperature (device stored in a cold warehouse) causes random bit flips. Mitigation: Multi-bit ECC detection (can correct 1 bit, detect 2+), and watchdog. The controls address all three domains: multi-bit ECC provides safety and SOTIF robustness; watchdog + HSM audit trail address security by detecting and logging suspicious patterns. An organization that analyzes only safety (single-bit ECC sufficient) or only security (multi-bit ECC needed for glitch resistance) arrives at different conclusions. The unified approach reconciles these by analyzing all three domains and selecting controls that address the most stringent requirement (multi-bit ECC satisfies all three).

The FMEDA table also serves as the input to V&V test planning. Each row generates one or more test cases. For the CPU instruction fetch row: (1) Safety test: Inject single-bit ECC error into instruction memory during execution; verify watchdog detects and resets. (2) Security test: Run penetration testing attempting fault injection; verify glitch attempts either succeed silently (log event but don't crash) or are rejected (watchdog reset); attacker cannot craft a reliable exploit. (3) SOTIF test: Run the ECU at +85°C and -40°C; verify no spontaneous instruction fetch errors occur (margin testing). The full FMEDA (in practice, 100+ rows) generates 300+ test cases spanning safety, security, SOTIF, and production acceptance testing. This comprehensive mapping ensures that the FMEDA is not merely a compliance checklist but a direct input to the verification strategy.

Step 3: FMEDA Metrics Calculation

Total failures per 10⁹ hours (FIT):

Category	Component	FIT	Effective FIT (with ECC/control)
SPF (Safe Point Failure)	S32K3 register bit flip	50 FIT	50 FIT (detectable)
SPF	SRAM single-bit	100 FIT	5 FIT (ECC corrects, fail-safe)

RF (Residual Failure)	SRAM multi-bit	10 FIT	1 FIT (ECC detects)
RF	Flash bit flip	5 FIT	0.5 FIT (ECC detects)
SPF (Watchdog)	CPU hang	20 FIT	20 FIT (reset triggered)
RF (HSM key exposure)	Tamper undetected	2 FIT	0.5 FIT (tamper detected)
Total	—	187 FIT	~77 FIT (with controls)

Table 7.7 AEB FMEDA Metrics Summary

SPFM (Single Point Failure Metric) = 187 FIT / 187 FIT = 100% (all SPF detected). LFM (Latent Failure Metric) = 10 FIT / 187 FIT = 5.3% (latent failures rare, acceptable for ASIL-C). PMHF (Probabilistic Metric for Hardware Failures): ASIL-C requires PMHF < 1e-8/hour. Estimated PMHF = 0.5 FIT × 60,000 hours ODD = 30e-9/hour (meets ASIL-C target).

Step 4: Secure Boot Design

ROM-based bootloader (immutable, in mask ROM): (1) Read firmware image from Flash. (2) Verify RSA-2048 signature using public key (hardcoded in ROM). (3) If signature valid, jump to firmware. (4) If invalid, enter secure failure mode (disable all outputs, await service). Addresses: Safety (ASIL-A: valid code load), Security (CAL-2: prevent malware), SOTIF (firmware version check before startup).

Step 5: Tamper Detection Design

Analog voltage comparator monitors power supply rail: If Vdd dips below 2.8V (indicating glitch attack) or rises above 3.6V (overvoltage), comparator triggers secure shutdown relay (cuts 12V to ECU). Secure shutdown is hardwired (no software intervention). Rationale: CAL-2 threat model (fault-injection attack); ASIL-A safety requirement (detect tampering).

Step 6: HW Verification Test Plan

Power-On Self-Test (POST): (1) SRAM ECC test (inject errors, verify correction). (2) Flash ECC test (read sections with known ECC patterns). (3) Watchdog test (trigger watchdog, verify reset). (4) Secure boot test (corrupt firmware signature, verify rejection). Functional test: Dual-channel comparison (primary vs. HSM monitor), sensor spoofing simulation. Thermal test: Run at +85°C and -40°C; verify no bit flips in critical memory. Acceptance criteria: 100% tests pass, zero undetected errors.

CHAPTER 8: SOFTWARE & AI/ML DEVELOPMENT

SCOPE

This chapter integrates software development, secure coding, AI/ML development, and tool qualification across six domain standards. Focus: convergence of coding standards, unified verification matrix, AI/ML lifecycle, and process evidence for ASPICE SWE.1-6 + MLE.1-4 + SUP.11.

8.1 Phase Overview: SW & AI Development Lifecycle

Software and AI/ML development in automotive must satisfy six converging standards simultaneously: ISO 26262 (functional safety), ISO 21434 (cybersecurity), ISO 21448 (SOTIF), ISO/PAS 8800 (AI safety), ISO 9001/IATF (quality management), and ASPICE (process maturity). This chapter maps these into a unified lifecycle.

Stages: (1) SW architecture & design (26262-6 Cl.5, 21434 Cl.10.1, ASPICE SWE.1-2), (2) Secure coding (26262-6 Cl.6-7, 21434 Cl.10.2-3, ASPICE SWE.3), (3) Unit/integration testing (26262-6 Cl.8-9, 21434 Cl.10.4, 21448 Cl.9, ASPICE SWE.4), (4) AI/ML model development (ISO/PAS 8800 Cl.5-9, ASPICE MLE.1-3), (5) Tool qualification (26262-8 Cl.11, 8800 Cl.13, ASPICE SUP.11), (6) Release readiness (26262-6 Cl.11, 21434 Cl.10.5).

Architecture & Design Phase (26262-6 Cl.5, 21434 Cl.10.1): SW architecture must decompose safety requirements by ASIL, allocate security properties (authentication, encryption, audit logging), and establish threat model baseline. ISO 26262-6 Cl.5.4 requires architectural review by independent team per HIS (Herstellerinitiative Software) checklist. Architecture must show separation of safety-critical vs. non-critical paths, input validation boundaries, and error handling strategies. For AI systems, architecture includes model inference boundaries, fallback logic if model confidence < threshold, and data pipeline isolation (training data separate from operational data). ASPICE SWE.1-2 evidence: architecture rationale document, block diagrams, design review meeting minutes, requirements traceability matrix (requirements → architecture components).

Secure Coding & Implementation Phase (26262-6 Cl.6-7, 21434 Cl.10.2-3): Developers code per MISRA C:2012 standard (mandatory for 26262 ASIL C+), with additional CWE-focused rules for 21434 cybersecurity (CWE-89 SQL injection, CWE-79 XSS, CWE-190 integer overflow). ISO 21434 Cl.10.3 mandates 'secure coding checklist' covering input sanitization, bounds checking, no use of unsafe functions (strcpy, sprintf). Code review (SWE.3) occurs before unit testing, with two independent reviewers examining every commit. For AI models, this phase includes training reproducibility setup (seed management, framework versioning), hyperparameter selection rationale, and validation dataset preparation (stratification, annotation quality assurance). Evidence: code review checklist completed, MISRA violations log (with closure), training SOP signed-off.

Testing & Integration Phase (26262-6 Cl.8-9, 21434 Cl.10.4, 21448 Cl.9, 8800 Cl.8): Unit testing must achieve coverage targets: line coverage ≥99%, branch coverage ≥93%, MC/DC (Modified Condition/Decision Coverage) ≥93% for ASIL D per ISO 26262-6 Cl.8.4.4.2. MISRA compliance verified via static analysis (SonarQube, Coverity, Polyspace). Dynamic testing includes fuzz testing (10⁷+ random inputs) to detect undefined behavior, memory errors, and injection vulnerabilities (21434 Cl.10.4). SOTIF testing (21448 Cl.9) focuses on edge-case triggering scenarios (sensor saturation, environmental extremes). AI robustness testing (8800 Cl.8-9) applies adversarial perturbations (L_∞ norm ε bounds, patch attacks) and evaluates performance across ODD scenarios (weather, lighting, time-of-day). Evidence: test plan, test cases with traceability, coverage report (LCOV, gcov), SAST/DAST tool outputs, fuzz campaign logs, adversarial test results.

Tool Qualification & Release Readiness (26262-8 Cl.11, 8800 Cl.13, 21434 Cl.10.5): Compilers, static analyzers, and ML frameworks must be qualified to confirm they produce correct outputs per specification. ISO 26262-8 Cl.11 requires qualification evidence for each tool: test case suite exercising tool boundaries, documented failure modes, vendor assurance (e.g., GCC's use of regression test suite). ML tool qualification (ISO/PAS 8800 Cl.13) adds versioning rigor: TensorFlow/PyTorch version frozen, all dependencies pinned (requirements.txt), training reproducibility validated (same seed → identical model weights within floating-point tolerance).

Release readiness checklist (26262-6 Cl.11) ensures all SW safety requirements traced, all test objectives met, and all findings closed or accepted (with risk justification). Evidence: tool qualification report, SBOM (Software Bill of Materials), change log, release notes signed by CSO + CISO + Quality Manager.

8.2 Standard-by-Standard Requirements

Standard	Clause(s)	Key Requirements	Artifacts	ASPICE Mapping
ISO 26262 Part 6	Cl.5-7	SW architecture per ASIL; design review per HIS (MISRA C:2012, IEC 61508-3); traceability	Design spec, architecture doc, review minutes	SWE.1-2
ISO 26262 Part 6	Cl.6-7	Code review (checklist per HIS); MISRA compliance (static analysis mandatory)	Code review log, MISRA report	SWE.3
ISO 26262 Part 6	Cl.8-9	Unit testing with MC/DC coverage $\geq 93\%$ per ASIL D; integration testing	Unit test plan, test cases, coverage report	SWE.4-5
ISO 21434	Cl.10.1-3	Threat-driven secure architecture; sanitization of external inputs; defensive programming	Threat model, arch whitepaper, code guide	SWE.1-2
ISO 21434	Cl.10.4-5	Static analysis (SAST) + dynamic testing (fuzz, DAST) for vulnerability detection	SAST report, fuzz campaign logs, findings register	SWE.4
ISO 21448	Cl.9	Triggering condition analysis; edge-case scenario testing; residual risk evaluation	Triggering cond. matrix, scenario test cases, risk sheet	SWE.4
ISO/PAS 8800	Cl.5-7	AI architecture & training data governance; model selection & validation framework	Data sheet, training log, hyperparameter tuning record	MLE.1-2
ISO/PAS 8800	Cl.8-9	Model verification: adversarial robustness, ODD coverage, distribution shift handling	Adversarial test suite, ODD coverage matrix, drift detector	MLE.3
ISO/PAS 8800	Cl.13	ML tool qualification: version control, lineage tracing, reproducibility	Tool qualification report, ML pipeline doc	SUP.11

		audits		
ISO 9001/IATF	Cl.8.3.4	Design & development controls; design review milestones; change management	Design review gates, change log	SWE.1-2
ASPICE	SWE.1-6	Product engineering: architecture → code → test → SW qualification (L1-L3 maturity)	SWE base practices evidence per level	Core SWE processes
ASPICE	MLE.1-4	ML engineering: data prep → model dev → AI verification → operational governance	MLE base practices evidence per maturity	AI-specific processes

Table 8-1. Standard-by-Standard Requirements for SW & AI Development.

Note: All standards mandate traceability from requirements → design → test → evidence. ISO/PAS 8800 adds versioning of training data, model lineage, and operational metrics (data drift, model drift).

8.3 Cross-Mapping: Coding Standards Convergence

Functional safety (26262), cybersecurity (21434), and SOTIF (21448) all mandate defensive, analyzable code. Below: alignment of MISRA C:2012 rules across standards and ASPICE.

MISRA C:2012 Rule	26262 Context	21434 Context	21448 Context	Risk Mitigated
2.1: No unreachable code	Design clarity	Vulnerability surface	Edge-case handling	Logic errors, undefined behavior
4.1: Restrict char type	Type safety	Buffer overflow	Input handling	Memory corruption
5.3: Restrict sizeof use	Size predictability	Overflow risk	Boundary testing	Unexpected allocation
8.13: Variable scope	Architecture clarity	Data isolation	State consistency	Unintended modification
11.1: No const cast	Data flow integrity	Immutability guarantee	Defensive read	Circumventing safety
14.1: Single exit point	Control flow clarity	Resource cleanup	Triggering logic	Resource leak, undefined flow
18.4: No dynamic alloc	Memory predictability	Allocation hiding	Timing guarantee	Fragmentation, DoS

Table 8-2. Coding Standards Overlap: MISRA C:2012 Rules Across Six Standards.

Strategy: Single static analysis configuration applying all rules simultaneously via SonarQube/Coverity. Report must map findings to each standard's requirement.

MISRA C:2012 Rule Categories: MISRA divides rules into mandatory (M), required (R), and advisory (A). For automotive safety-critical code, all M + R rules must be enforced, with advisory rules evaluated per project context. Rule 2.1 (no unreachable code) appears mandatory in 26262-6 Cl.7.4.7 (design clarity requirement) and supports 21434 Cl.10.3 (reducing attack surface) and 21448 Cl.9 (edge-case completeness). Rule 4.1 (restrict char type) prevents sign-extension bugs and buffer overflow vectors. Rule 5.3 (restrict sizeof use) avoids portable code defects. Rule 8.13 (variable scope) limits unintended modification risk in concurrent access scenarios. Rule 11.1 (no const cast) ensures immutability of safety-critical parameters. Rule 14.1 (single exit point) simplifies control flow analysis and guarantees resource cleanup (vital for 21434 Cl.10.3 secure cleanup). Rule 18.4 (no dynamic allocation) prevents fragmentation-based DoS attacks (26262-6 Cl.7.4.5, 21434 Cl.10.3).

CERT-C Integration (Embedded Systems Security): CERT-C (Carnegie Mellon Security) is orthogonal to MISRA but complementary for 21434 compliance. CERT-C rule STR31-C (handle strings correctly) maps to MISRA 21.21 (buffer overflow), CWE-119. Rule MEM35-C (no overlapping memory access) prevents undefined behavior exploitable via buffer overflow (CWE-119). Rule FIO32-C (restrict stdout/stderr access) prevents information disclosure (CWE-497). Rule SIG32-C (prevent signal handler race) blocks concurrent access vulnerabilities in automotive applications with safety-critical timers. ASPICE SWE.3 requires evidence of both MISRA AND relevant CERT-C rules applied during code review. Static analysis tool configuration must enforce both rule sets simultaneously; findings mapped to each standard's requirement (26262 = safety, 21434 = security, 21448 = SOTIF).

Defensive Programming Practices (ISO 26262-6 Cl.7, 21434 Cl.10.3): Defensive programming anticipates and mitigates anomalies. Practice 1 (Input Validation): All external inputs validated at module boundary. Validation checks: range ($x \in [\min, \max]$), type (integer vs. float), format (checksum, CRC). Unsanitized input immediately rejected with error return code. Example: ``if (speed < 0 || speed > 200) return ERR_INVALID_SPEED``. Practice 2 (Assertion Usage): Runtime assertions on internal invariants, disabled in production (avoid DoS from malicious triggering). Example: ``assert(sensor_data != NULL)`` catches NULL dereference in development; assert is a no-op in release builds. Practice 3 (Boundary Checks): Array/pointer access always bounds-checked before use. Example: ``if (index >= ARRAY_SIZE) return ERR_OUT_OF_BOUNDS``. Practice 4 (Safe Fallback): If computation fails, default to safe state (e.g., AEB system defaults to gentle braking, not no braking). Practice 5 (Explicit Error Handling): No silent failures. Every function returns error code (0 = success, non-zero = specific error). Evidence: code review checklist covering all five practices, MISRA/CERT-C violations log, static analysis tool configuration file (SonarQube profile).

Code Review Methodology (ASPICE SWE.3): ISO 26262-6 Cl.7.4.7 mandates independent code review of all safety-critical SW. Process: (1) Developer self-review (complete review checklist). (2) Peer review (second engineer, different team). (3) Architecture review (if design implications). Checklist items: ☐ MISRA compliance (zero high-severity findings). ☐ Requirements traceability (every code block links to design). ☐ Test coverage (code under test). ☐ Defensive programming (input validation, bounds checks present). ☐ Comments clarity (non-obvious logic explained). ☐ No hardcoded thresholds (magic numbers extracted to config). ☐ Error handling complete (all return codes checked). Review tool: Gerrit, GitHub Pull Request, with mandatory approval from two reviewers. Review SLA: ≤48 hours turnaround. Findings logged in issue tracker (JIRA) with closure status. Evidence: review checklist, reviewer sign-off, change log with approval timestamps, findings register with closure rationale.

8.4 Unified Verification Methods Matrix

Single test campaign must satisfy unit-level requirements across four verification vectors: safety (26262), security (21434), SOTIF (21448), and AI robustness (8800).

Test Type	26262 Req	21434 Req	21448 Req	8800 Req	Tool/Method
Unit test (MC/DC)	≥93% ASIL D	Coverage of sanitized paths	Trigger edge cases	Model unit activation	GCC/LLVM coverage
Static analysis (SAST)	MISRA compliance	Vulnerability patterns (CWE)	Defensive checks	Code robustness	SonarQube/Coverity
Fuzz testing	Boundary values	Malformed input crash	Boundary triggering	Adversarial inputs	libFuzzer/AFL
Scenario testing	FSM coverage	Attack tree validation	ODD scenario matrix	Operational distribution	Custom harness
Dynamic analysis (DAST)	Memory safety	Runtime exploit detection	Undefined behavior	ML inference anomaly	Valgrind/AddressSan
Adversarial testing	Not applicable	Security test	Not applicable	Perturbation robustness	FastAttack/CLEVERHANS

Table 8-3. Unified Verification Methods: Unit-Level Test Matrix.

MC/DC Coverage Deep Dive (ISO 26262-6 Cl.8.4.4.2): Modified Condition/Decision Coverage ensures every condition in a compound decision is tested in isolation (each condition changes decision independently). Example: `if ((A && B) || C)` requires test cases exercising: (1) A true, B true, C false → decision true. (2) A false, B true, C false → decision false. (3) A true, B false, C false → decision false. (4) A true, B true, C true → decision true. (5) A true, B true, C false → decision true (verifies C's effect). MC/DC ≥93% for ASIL D means ≥93% of decision conditions are independently exercised. Achievement: LCOV/gcov tools measure; Tessy/VectorCAST automate test generation. ASPICE SWE.4 requires coverage evidence: HTML coverage report with line-by-line metrics, uncovered code explained, acceptance rationale.

Fuzz Testing Methodology (ISO 21434 Cl.10.4): Fuzz testing injects malformed/random data to trigger crashes, hangs, or undefined behavior. Approach 1 (Black-box fuzz): libFuzzer, AFL++ generate random inputs, monitor for crashes via ASAN (AddressSanitizer). Approach 2 (Coverage-guided fuzz): evolve inputs maximizing code coverage, find edge-case branches. Campaign: ≥10⁷ input trials per function. Example: `PedestrianDetector\_Inference()` receives 10M random image buffers (random bytes, random size 0...65535). Result: zero crashes. Significance: input validation robust, no buffer overflow, no NULL dereference. Tools: libFuzzer (LLVM-integrated), AFL++ (standalone), Honggfuzz (distributed). Evidence: fuzz campaign log (input count, duration, crashes/hangs found), ASAN report (CWE violations if found), coverage diff (fuzzer-discovered branches).

SAST/DAST Tool Strategy (ISO 21434 Cl.10.4): Static Analysis Security Testing (SAST) examines source code for vulnerability patterns without execution. Tools: SonarQube, Coverity, Polyspace identify CWE-89 (SQL injection), CWE-79 (XSS), CWE-190 (integer overflow). Configuration: enforce MISRA C:2012 rules + CWE blocklist (>100 rules). Typical result: 50-100 findings per 10K lines of code; 90% are false positives (hence severity triage). Finding prioritization: Critical = exploitable vulnerability (CWE-119 buffer overflow), High = design flaw (CWE-434 unrestricted upload), Medium = code smell (unused variable), Low = style issue. Dynamic Analysis Security Testing (DAST) runs system with malicious inputs: penetration testing (manual attack), API fuzzing (call functions with garbage), exploit simulation (SQL injection payloads). Evidence: SAST report (CWE mapping, severity distribution, closure status), DAST report (attack vectors tested, zero

exploitable findings), SBOM (Software Bill of Materials) listing all dependencies + versions (for vulnerability scanning).

Scenario-Based Testing (ISO 21448 Cl.9, ASPICE SWE.4): Scenario testing combines functional + environmental context. Scenario matrix: (a) Nominal: expected operating condition (sunny, 30 km/h, clear road). (b) Boundary: limits of ODD (night, 1 lux visibility, rain). (c) Edge case: rare combinations (hail + night + pedestrian blur-moving). (d) Stress: repeated/rapid state transitions (brake engagement every 100ms). (e) Fault: injected sensor failure (lidar timeout, camera saturation). Each scenario defined: environmental conditions, vehicle state, expected behavior, acceptance criteria. Test execution: real test track OR simulation (CARLA/Apollo simulator). Evidence: scenario definition document, test case traceability (requirements → scenarios → test cases), test results (pass/fail per scenario), defect log (failures = findings requiring investigation).

8.5 AI/ML Development Lifecycle (ISO/PAS 8800 + ASPICE MLE)

ISO/PAS 8800 Clauses 5-9 define AI safety governance parallel to hardware FSM. Key stages:

Data Collection & Curation (Cl.5, 6): Establish data sources, version control, consent/privacy. Track dataset lineage, distribution characteristics, and bias. Link to ASPICE MLE.1 (Data Collection): data plan, source register, consent log.

Data Labeling & Validation (Cl.6): Define labeling rules, inter-rater agreement metrics (>0.9 Cohen's kappa), QA review. Version all labels. Link to ASPICE MLE.1 (Labeling SOP): labeling guide, agreement report, QA sign-off.

Model Architecture & Training (Cl.7): Justify architecture choice (CNN vs RNN vs Transformer per ODD). Hyperparameter tuning log. Training reproducibility: seed, framework version, library versions. Link to ASPICE MLE.2: architecture rationale, training SOP, reproducibility audit.

Model Verification (Cl.8-9): Multi-faceted testing: (a) Nominal performance on hold-out test set, (b) Adversarial robustness (ϵ -perturbation bounds), (c) ODD coverage analysis (sensor range, weather, lighting), (d) Distribution shift detection (out-of-distribution samples), (e) Failure mode analysis (class imbalance, rare objects). Link to ASPICE MLE.3 (Verification): test matrix, adversarial report, drift detector.

Bias Detection & Mitigation (Cl.9): Stratified analysis: performance by demographic/geographic subgroup. Fairness metrics (demographic parity, equalized odds). Mitigation: rebalancing, augmentation, adversarial debiasing. Link to ASPICE MLE.3: bias audit, mitigation plan, post-mitigation metrics.

Data Lifecycle V-Model (ISO/PAS 8800 Cl.5-9): AI safety parallels traditional functional safety V-model. LEFT SIDE (forward phases): Data collection → Labeling & annotation → Dataset versioning → Training/validation/test split → Model training. Each phase produces artifacts: data governance plan (Cl.5), labeling SOP (Cl.6), versioned dataset manifest (Cl.6), training reproducibility log (Cl.7). RIGHT SIDE (verification phases): Hold-out test evaluation (Cl.8: nominal accuracy $\geq 95\%$). Adversarial robustness testing (Cl.8: ϵ -perturbation bounds). ODD coverage analysis (Cl.8: all sensor ranges, weather, time-of-day scenarios). Bias audit (Cl.9: fairness metrics per demographic group). Drift detection baseline (Cl.11: operational metrics thresholds). BOTTOM PHASE (operational): continuous monitoring (data drift, model drift, performance drift). ASPICE MLE.1-4 maps each V-phase to maturity levels: MLE.1 (data prep) L1-L3, MLE.2 (architecture+training) L1-L3, MLE.3 (verification) L1-L3, MLE.4 (monitoring) L2-L3. Evidence: V-model diagram, phase gate reviews (design review → training complete → verification complete → release ready).

Model Architecture Selection Rationale (ISO/PAS 8800 Cl.7, ASPICE MLE.2): Architecture selection must be justified per ODD and ASIL. Decision criteria: (1) ODD scope (e.g., pedestrian detection in daylight + adverse weather → CNN more robust than SVM). (2) Real-time constraints (inference latency $\leq 100\text{ms}$ → MobileNet

preferred over ResNet-152). (3) Robustness requirements (ASIL C adversarial $\epsilon \geq 0.05 \rightarrow$ deeper/wider network = more robust). (4) Explainability needs (SOTIF residual risk evaluation $\rightarrow$ attention maps or saliency maps required). Example: AEB pedestrian detection: architecture = MobileNetV3 (lightweight, <30ms latency) with attention heads (explainability), trained on COCO pedestrian subset (80K images). Justification document: architecture diagram, latency profile (p50=18ms, p99=35ms), theoretical adversarial bounds ($\epsilon=0.03$ required, $\epsilon=0.07$ achieved via empirical test). Alternative architectures evaluated: YOLOv5 (faster, less accurate), Faster R-CNN (slower, more accurate, rejected due to 200ms latency). Trade-off analysis: latency vs. accuracy vs. robustness. Sign-off: data scientist + safety engineer + QA.

Training Methodology & Hyperparameter Tuning (ISO/PAS 8800 Cl.7, ASPICE MLE.2): Training reproducibility is non-negotiable for 8800 Cl.13 (ML tool qualification). Reproducibility setup: (1) Random seed fixed (numpy.random.seed(42), torch.manual_seed(42)). (2) Framework version pinned (TensorFlow==2.11.0, PyTorch==1.13.1). (3) All dependencies versioned in requirements.txt. (4) GPU/hardware specs documented (NVIDIA A100, CUDA 11.8). Hyperparameter tuning: learning rate (grid search 0.001...0.01), batch size (32, 64, 128), optimizer (Adam vs. SGD), regularization (L1/L2 lambda). Tuning workflow: (1) train on small dataset (1000 images) with candidate hyperparameters. (2) evaluate on validation set. (3) select best combo. (4) retrain on full dataset (80K images). (5) log all hyperparameters. Training log captures: epoch, loss (training + validation), accuracy (per-class breakdown), learning rate schedule, dropout rates, convergence criteria. Evidence: reproducibility audit (run training twice, confirm identical weights within 10^{-6} tolerance), training log CSV, hyperparameter tuning report, confusion matrix per class ($\geq 95\%$ accuracy per class for ASIL C).

Adversarial Robustness Testing (ISO/PAS 8800 Cl.8): Adversarial examples are imperceptible perturbations causing misclassification. Perturbation types: (1) L2 (Euclidean distance, e.g., small Gaussian noise): $'x' = x + \epsilon \cdot \delta, \|\delta\|_2 = 1$. (2) L ∞ (Chebyshev distance, pixel-level bound): $'x' = x + \epsilon \cdot \delta, \|\delta\|_\infty \leq \epsilon$. (3) Patch attack (localized patch, e.g., 50x50 pixel sticker on pedestrian's shirt): adversary places physical patch, model confidence drops. (4) Spatial attack (rotation, translation, scaling within ODD): vehicle rotates 15°, model still detects. Test methodology: FGSM (Fast Gradient Sign Method), PGD (Projected Gradient Descent), C&W (Carlini-Wagner) attack. For each attack: vary ϵ from 0 (clean) to 0.3 (heavy perturbation), measure confidence/accuracy curve. ASIL C acceptance: confidence drop $\leq 20\%$ for $\epsilon \leq 0.05$ (imperceptible). Example: pedestrian detector confidence clean=0.95, adversarial($\epsilon=0.05$)=0.78 $\rightarrow$ passes. Mitigation (if needed): adversarial training (mix adversarial examples into training set), gradient masking (defend against gradient-based attacks). Evidence: adversarial test report (attack types tested, ϵ ranges, confidence curves), visualizations (original + adversarial images), robustness justification.

ODD Coverage Testing (ISO/PAS 8800 Cl.8): Operational Design Domain (ODD) defines sensor ranges, weather, time-of-day, geographic limits. ODD matrix (pedestrian detection): weather (sunny, rain, snow, fog) $\times$ time-of-day (day, dusk, night) $\times$ visibility (>50m, 20-50m, <20m) $\times$ road type (urban, highway, residential). Coverage = #tested scenarios / #total ODD combinations. For peddetection: $4 \times 3 \times 3 \times 3 = 108$ total scenarios. Test subset (risk-based): high-criticality (night + fog + low visibility + urban): $\checkmark$ test. low-criticality (sunny + highway): $\checkmark$ spot check. Achieved coverage: 95 scenarios tested (88% coverage), 13 scenarios deferred (justify risk acceptance). Test execution: real-world data collected via vehicle fleet (50K miles across regions), or synthetic simulation (CARLA weather API). Evaluation: per-scenario accuracy table (scenario $\rightarrow$ confidence $\rightarrow$ detection rate $\rightarrow$ false alarm rate). Evidence: ODD matrix, scenario test cases (reference video + expected detection), test results per scenario, coverage report (% achieved), risk justification for untested scenarios.

Bias Detection & Mitigation Strategies (ISO/PAS 8800 Cl.9): Algorithmic bias = model performs better for some demographic/geographic groups. Bias audit methodology: (1) stratify test set by protected attributes (gender, age, skin tone, geographic region). (2) evaluate accuracy per group. Example pedestrian detection: test set 100 images $\times$ (2 gender $\times$ 4 age groups $\times$ 5 skin tones) = 40 subgroups. Evaluation: accuracy per subgroup. Target: Δ accuracy $\leq 3\%$ across groups (equalized odds). If bias detected (e.g., 92% accuracy on males, 85% on females): mitigation strategies: (a) Rebalance training data: increase female pedestrian samples (augmentation via

synthetic data). (b) Adversarial debiasing: add fairness loss term to training objective (penalize group disparities). (c) Post-processing: adjust confidence thresholds per group (group-specific calibration). Post-mitigation audit: retest stratified set, confirm Δ accuracy $\leq 3\%$. Evidence: bias audit report (per-subgroup metrics before/after mitigation), fairness metrics (demographic parity, equalized odds), training data composition (% per demographic), mitigation technique description, post-mitigation confirmation.

ML Tool Qualification Deep Dive (ISO/PAS 8800 Cl.13 vs. ISO 26262-8 Cl.11): ML tool qualification extends SW tool qualification. Qualification scope for TensorFlow/PyTorch: (1) Version control (TensorFlow==2.11.0 vs. 2.13.0 $\rightarrow$ different behavior). (2) Determinism (seed fixed $\rightarrow$ identical weights? Test: train twice, weights differ $<10^{-6}$). (3) Lineage tracing (data version v1.5 $\rightarrow$ model version m1.2.1 $\rightarrow$ deployment v1.2.1.0). (4) Accuracy on canonical test suite (e.g., ImageNet top-1 accuracy $\geq 75.0\%$ for MobileNetV3). (5) Failure mode analysis: known TensorFlow bugs (e.g., TF 2.7.0 gradient overflow on multi-GPU) $\rightarrow$ avoid. Qualification evidence: (a) tool vendor documentation (TensorFlow release notes, benchmarks). (b) in-house validation (train canonical model 10 times, check determinism). (c) SBOM (all dependencies: numpy==1.23.0, scipy==1.9.0, etc.). (d) failure modes register (known issues + workarounds). Qualification report: tool suitable for ASIL C if (i) no critical bugs in selected version, (ii) determinism verified, (iii) accuracy baseline confirmed. For ASIL D: additional rigor (e.g., use only TensorFlow versions with long-term support, not nightly builds).

AI/ML Data Lifecycle V-Model (ISO/PAS 8800 Cl.8, ASPICE MLE.1-3):

DATA LIFECYCLE	
LEFT SIDE (Forward):	Data collection $\rightarrow$ Labeling & QA $\rightarrow$ Dataset versioning $\rightarrow$ Training/validation split $\rightarrow$ Model training.
RIGHT SIDE (Verification):	Hold-out test $\rightarrow$ Adversarial testing $\rightarrow$ ODD coverage analysis $\rightarrow$ Bias audit $\rightarrow$ Drift detection.
BOTTOM:	Operational monitoring (model drift, data drift, performance drift).

ML Tool Qualification vs. SW Tool Qualification (ISO/PAS 8800 Cl.13 vs. ISO 26262-8 Cl.11):

Aspect	26262-8 Cl.11 (SW Tool)	8800 Cl.13 (ML Tool)	Integration Implication
Version control	Tool version + config tracked	ML framework version + training script version	Both in single SBOM
Reproducibility	Compiler determinism	Seed + library versions $\rightarrow$ identical weights	Separate reproducibility logs
Lineage tracing	Source $\rightarrow$ executable	Data $\rightarrow$ model $\rightarrow$ inference	Unified artifact tracking
Validation scope	Code correctness	Model accuracy + fairness + robustness	Separate qualifications
Failure modes	Compiler bugs, linker errors	Data contamination, distribution shift, adversarial examples	Risk-based severity mapping
Qualification evidence	Test cases on compiler output	Validation dataset + adversarial suite + drift detector	Combined qualification dossier

Table 8-4. ML Tool Qualification vs. SW Tool Qualification.

8.6 Commonality Analysis: Defensive SW Architecture Patterns

Pattern 1: Input Validation & Sanitization (26262 plausibility + 21434 injection defense + 21448 triggering)

Architecture: All external inputs (sensor, network, storage) → validation layer → sanitization → internal SW.

Validation: range, type, format. Sanitization: buffer bounds, character whitelist. Evidence: (26262-6 Cl.7) code review checklist, (21434 Cl.10.3) vulnerability matrix, (21448 Cl.9) edge-case test.

Pattern 2: Memory Protection & Data Isolation (26262 FFI + 21434 security zones + 8800 model isolation)

Architecture: Stack canaries, heap guards, virtual memory segmentation. Address Space Layout Randomization (ASLR). Code + data separation. Model inference in isolated container. Evidence: (26262-6 Cl.7) MISRA 18.x rules, (21434 Cl.10.1) threat model mitigation, (8800 Cl.9) container integrity audit.

Pattern 2 Detail (Memory Protection): Stack canaries prevent buffer overflow via stack smashing.

Implementation: push 8-byte random value (canary) after local variables on stack. Before function return, verify canary unchanged. If canary corrupted (indicative of stack overflow), CPU traps → safe state. GCC flag: `-fstack-protector-strong`. Heap guards (guard pages): memory allocator places unmapped page before + after heap chunks. If code writes past chunk boundary, page fault → crash detected. Tool: AddressSanitizer (ASan) detects heap overflows, use-after-free, double-free via runtime instrumentation. ASLR (Address Space Layout Randomization): OS randomizes base addresses of heap, stack, libraries at boot. Attacker cannot hardcode addresses for ROP (return-oriented programming) attacks. Kernel parameter: `/proc/sys/kernel/randomize_va_space = 2` (full ASLR). Code + data separation: executable code placed in read-only memory sections (flash), data in RAM. MMU (Memory Management Unit) enforces: code pages = execute-only, data pages = read/write/no-execute. Prevents code injection (attacker cannot write to code pages). Evidence: (26262-6 Cl.7.4.5) design specification describing memory layout, (21434 Cl.10.3) threat model mitigation (how does each protection defeat attack?), (8800 Cl.9) model inference container isolation (model runs in separate process, isolated memory region).

Pattern 3: Input Validation & Sanitization (26262 plausibility + 21434 injection defense + 21448 triggering)

Architecture detail (Input Validation): External input sources (sensor drivers, CAN bus, network, storage) feed into validation layer. Validation rules: (1) type check (expected int32, received int32?). (2) range check (speed ∈ [0, 200] km/h?). (3) format check (CAN message exactly 8 bytes?). (4) checksum (CRC16 valid?). Validation failures → error return, no further processing. Example: CAN message input validation (motor speed): `if (speed < 0 || speed > 8192 || !crc_valid(msg)) return ERR_INVALID_SPEED`. Sanitization rules: (1) buffer bounds (strcpy forbidden, use strncpy with explicit length). (2) SQL injection (parameterized queries, no string concatenation). (3) command injection (shell commands = banned, use execve with explicit argv array). (4) path traversal (check no `../` in filenames). Output encoding: if writing to display, encode special chars (e.g., HTML entity-encode `'<' → '<'`). ASIL D requirement (26262-6 Cl.7.4.7): code review checklist explicitly checks all external inputs validated. Evidence: (26262-6 Cl.7) code review log listing validation checks per input, (21434 Cl.10.3) threat model showing how validation defeats CWE attacks (CWE-89 SQL injection, CWE-434 unrestricted upload).

Pattern 3 (continued): Logging, Tracing & Forensics (21434 incident response + 26262 diagnostics + 8800 model monitoring)

Logging architecture: all safety/security-relevant events logged to immutable register (hardware RTC timestamp, actor ID, operation, result). Log destinations: (a) flash storage (persistent across reboots, survive system crash). (b) remote telemetry server (real-time fleet monitoring). Event types: sensor input received, safety check passed/failed, anomaly detected, OTA patch applied, model inference latency, drift detector alert. Example log entry format: `[2026-04-02T10:23:45Z] SENSOR_INPUT: lidar_distance=15.3m, confidence=0.87, latency_us=45000`. Immutability: once written, log entry hash-chained to previous entry (blockchain-like). Prevents tampering (if attacker modifies `log[i]`, hash chain breaks at `hash[i+1]`). Log retention: 365 days for

safety events (26262-7 Cl.6), 90 days for security events (21434 Cl.12), 30 days for operational metrics (8800 Cl.11). For AI models: logging inference stats (detection confidence, latency p50/p95/p99, false positive rate per ODD scenario). Drift detection: if confidence mean drops >20% over 7-day window, alert (potential model drift). Evidence: (21434 Cl.8) forensics specification (what events logged, retention, immutability), (26262-7 Cl.6) operational monitoring SOP, (8800 Cl.11) drift detector specification.

Pattern 4: Secure Boot & Attestation (21434 Cl.10.1, 26262-6 Cl.5): Secure boot verifies firmware integrity before execution. Process: (1) bootloader (ROM-resident, immutable) starts. (2) bootloader loads kernel image from flash. (3) bootloader computes SHA-256(kernel). (4) bootloader verifies signature: RSA-4096(SHA-256) = stored_signature? (5) if valid → execute kernel. If invalid → no boot, halt safe state. Key management: signing key (private RSA-4096 key) held by OEM in secure vault (never shipped to vehicle). Public key burned into vehicle ROM at manufacturing. Bootloader verified via measured boot: each boot stage measures (SHA-256) next stage, stores measurement in Trusted Platform Module (TPM) register (PCR). After boot, verifier can check PCR values: does firmware match expected golden hash? Deviation = unauthorized modification detected. Secure boot prevents: (a) firmware downgrade (no rollback to vulnerable version). (b) firmware injection (attacker cannot modify kernel, signature check fails). (c) unauthorized OTA patches (only correctly-signed patches accepted). Evidence: (21434 Cl.10.1) secure boot specification (key management, signature algorithm, verification procedure), (26262-6 Cl.5) design documentation showing safe state if verification fails, (ASPICE SWE.2) detailed design showing boot flow + key storage + signature validation sequence.

8.7 Gap Analysis: Where Standards Diverge

Gap 1 — Testing Granularity: ISO 26262-6 Cl.8 mandates unit-level MC/DC ≥93% (ASIL D). ISO 21434 Cl.10.4 and 21448 Cl.9 do not specify coverage targets. BRIDGE: Apply 93% uniformly to all safety/security/SOTIF units. Non-safety units: ≥50%.

Gap 2 — AI Model Testing: ISO 26262, 21434, 21448 assume deterministic SW. ISO/PAS 8800 Cl.8-9 adds probabilistic robustness (adversarial ϵ , ODD coverage %). BRIDGE: Report both deterministic (MISRA, fuzz) and probabilistic (adversarial, drift) in unified matrix.

Gap 3 — Tool Qualification Scope: ISO 26262-8 Cl.11 qualifies compilers, linkers, debuggers. ISO/PAS 8800 Cl.13 qualifies TensorFlow/PyTorch versions. BRIDGE: Separate tool qualification reports; linked via single SBOM.

Gap 4 — Process Maturity: ASPICE SWE.1-6 + MLE.1-4 span multiple maturity levels (1-3). ISO 26262 has no maturity concept (pass/fail). BRIDGE: Achieve ASPICE L2 minimum for all SWE + MLE processes; use L3 for high-complexity AI.

8.8 Integrated Activity Checklist: SW Development Gateways

GATEWAY 1: DESIGN REVIEW (SWE.1-2, MLE.1-2)

☐ SW architecture document (26262-6 Cl.5, ASPICE SWE.1). ☐ ASIL allocation & rationale (26262-3). ☐ Threat model & secure design (21434 Cl.10.1, ASPICE SWE.2). ☐ SOTIF hazard mapping (21448 Cl.9). ☐ For AI: Data governance plan (8800 Cl.5-6, MLE.1), model architecture rationale (MLE.2). ☐ Design review checklist completed (26262-6 Cl.5.4.4). ☐ Traceability matrix: requirements → architecture.

GATEWAY 2: CODE COMPLETE (SWE.3, MLE.2)

☐ Code review performed per HIS checklist (26262-6 Cl.7, SWE.3 base practice). ☐ MISRA C:2012 compliance report (static analysis tool). ☐ Secure coding report: CWE coverage (21434 Cl.10.3). ☐ For AI: Model weights produced (reproducible seed, training log signed-off). ☐ Traceability matrix: design → code complete.

GATEWAY 3: TEST COMPLETE (SWE.4-5, MLE.3)

☐ Unit test results: line coverage ≥99%, branch coverage ≥93%, MC/DC ≥93% ASIL D (26262-6 Cl.8, SWE.4). ☐ SAST report: zero critical findings (21434 Cl.10.4). ☐ Fuzz campaign: >10⁷ inputs, no crashes (21434 Cl.10.4). ☐ Edge-case scenario test results (21448 Cl.9, SWE.4). ☐ For AI: Adversarial test report (8800 Cl.9, MLE.3). ODD coverage analysis. Bias audit sign-off. ☐ Traceability matrix: requirements → test cases → evidence.

GATEWAY 4: RELEASE READY (SWE.5-6, MLE.4)

☐ SW qualification summary (26262-6 Cl.11, SWE.5). ☐ All findings closed or accepted (risk justification). ☐ Security validation plan signed (21434 Cl.10.5). ☐ SOTIF argument complete (21448 Cl.10). ☐ For AI: Operational monitoring plan (8800 Cl.11, MLE.4). ☐ ASPICE SWE.5-6 + MLE.4 evidence collected. ☐ Release checklist: all six standards' gate criteria met.

8.9 Consolidated Work Products

Core deliverables unified across standards:

1. SW Development Plan (26262-3, 21434, ASPICE SWE.1): Tools, languages, coding standards, testing strategy, schedule.
2. SW Architecture Document (26262-6 Cl.5, ASPICE SWE.1): Block diagrams, data flow, ASIL decomposition, threat model.
3. Code Review Report (26262-6 Cl.7, 21434, ASPICE SWE.3): Checklist, findings, closure evidence.
4. Static Analysis Report (26262-6, 21434 Cl.10.4, ASPICE SWE.4): MISRA violations, CWE patterns, severity mapping.
5. Unit Test Plan & Results (26262-6 Cl.8, 21434, 21448, ASPICE SWE.4): Test cases, coverage metrics (line, branch, MC/DC), traceability.
6. Integration Test Plan & Results (26262-6 Cl.9, 21448 Cl.9, ASPICE SWE.5): Scenario coverage, edge-case test results.
7. AI/ML-Specific (ISO/PAS 8800, ASPICE MLE.1-3):
 - Data Governance Plan: lineage, versioning, bias audit.
 - Model Training Report: architecture, hyperparameters, reproducibility audit.
 - Model Verification Report: test metrics, adversarial robustness, ODD coverage, drift detection.
8. Tool Qualification Report (26262-8 Cl.11, 8800 Cl.13, ASPICE SUP.11): Compiler, static analyzer, ML framework version & validation.
9. Traceability Matrix (26262-6, ASPICE SWE.1): Requirements → Design → Code → Test → Evidence.

8.10 Worked Mini-Example: AEB Pedestrian Detection SW Unit

Scenario: Develop `PedestrianDetector\_Inference()` unit for AEB system. Target ASIL C. Uses CNN model for pedestrian bounding boxes. Must satisfy: 26262-6 Cl.8-9 (unit test), 21434 Cl.10 (input validation), 21448 Cl.9 (edge-case triggering), 8800 Cl.8-9 (model robustness).

ARCHITECTURE SNIPPET

```
typedef struct { float bbox[4]; float confidence; uint32_t latency_us; } PedestrianDetection; PedestrianDetection*
PedestrianDetector_Inference(const uint8_t* image_data, uint32_t image_size) { /* 1. Validate inputs (26262 + 21434) */
VALIDATE_IMAGE_BOUNDS(image_data, image_size); /* 2. Preprocess (21448 edge-case handling) */ Normalize input;
clamp pixel values [0..255]; /* 3. Model inference (8800 Cl.8) */ Run CNN; get bbox + confidence; /* 4. Post-process
(26262 plausibility) */ Check confidence > 0.5; check bbox within image; /* 5. Log results (21434 forensics + 8800
monitoring) */ Log inference time, confidence, detected count; return result; }
```

Unit Test Plan (26262-6 Cl.8, ASPICE SWE.4):

Test 1: Valid pedestrian image (sunny, clear). Expect: detection within 50ms, confidence > 0.8.

Test 2: Edge case — adverse weather (rain, night). Expect: detection or safe graceful failure.

Test 3: Adversarial input — imperceptible perturbation (8800 Cl.9). Expect: robust handling or safe mode.

Test 4: Boundary — image size = 0. Expect: error code (no crash, no buffer overflow).

Test 5: Malformed input (null pointer, garbage bytes) — 21434 Cl.10.3. Expect: error code (input validation passes).

Coverage Target: MC/DC ≥93% (ASIL C). Achieved: Line 99%, Branch 94%, MC/DC 95%.

Code Review (26262-6 Cl.7, ASPICE SWE.3):

Review checklist: No unreachable code (MISRA 2.1). No hardcoded thresholds (0.5 confidence extracted to config). Input bounds validated (MISRA 4.1, 21434 injection defense). Memory buffers sized correctly (MISRA 18.4). Signed-off by two reviewers.

Static Analysis (21434 Cl.10.4):

SAST result: 1 CWE-190 (integer overflow in latency calculation). Mitigation: use uint64_t, cap at 10⁹ μs. Closure signed.

Fuzz Testing (21434 Cl.10.4):

Campaign: 10⁷ random image buffers (random bytes, random size). Result: zero crashes. Confidence: input validation robust.

Adversarial Testing (8800 Cl.9):

Test: Imperceptible perturbation ($\epsilon=0.05$, L_∞ norm). CNN confidence drop <10%. Robustness justified: no adversarial defense needed (pedestrian detection inherently robust).

Model Monitoring (8800 Cl.11, ASPICE MLE.4):

Operational: log detection count, confidence distribution, inference time per 1000 frames. Drift detector: if mean confidence drops >20% over 1-week window, alert operations (potential model drift).

Design Phase Walkthrough (ASPICE SWE.1-2, 26262-6 Cl.5):

Requirements analysis: AEB system must detect pedestrians $\geq 10\text{m}$ ahead (120 km/h reaction time = 3s, stopping distance $\sim 100\text{m}$ requires detection at 10m). ODD definition: daylight + day/night (1 lux minimum), visibility $> 20\text{m}$, road types urban/suburban/highway, weather sunny/rain/light snow. Architecture design: camera sensor $\rightarrow$ image preprocessing (resize to 224×224 , normalize) $\rightarrow$ CNN inference $\rightarrow$ bounding box post-processing $\rightarrow$ confidence threshold check $\rightarrow$ decision: if confidence > 0.5 AND bbox_valid, trigger AEB. If confidence < 0.5 OR sensor_error, safe mode (no AEB). Threat model (21434): camera could receive malicious input (adversarial patch), network could inject false detections (CAN spoofing). Mitigations: input validation (check image_size $\leq$ max), signature verification (CAN messages signed with HMAC-SHA256), fallback to safe state. SOTIF analysis (21448): triggering condition = false pedestrian detection (low confidence image $\rightarrow$ no AEB). Risk: pedestrian hit. Mitigation: improve model robustness. Design review checklist (SWE.1): ☐ all requirements traced to architecture. ☐ ASIL decomposition documented (ASIL C $\rightarrow$ no decomposition, single system). ☐ Threat model complete. ☐ Safe state defined (springs release brakes to neutral). ☐ Design rationale for CNN architecture justified. Sign-off: Safety Engineer + Architecture Lead.

Implementation Phase (ASPICE SWE.3, 26262-6 Cl.7): Code developed in C++11 (for inference library access to PyTorch C++ API). MISRA C:2012 compliance enforced: SonarQube configured with MISRA ruleset. Code structure: PedestrianDetector_Init() (load model weights, allocate memory), PedestrianDetector_Inference(image_data, size) (validate input, run CNN, post-process), PedestrianDetector_Deinit() (free memory, safe cleanup). Input validation (26262-6 Cl.7.4.5, 21434 Cl.10.3): `if (image\_data == NULL || image\_size == 0 || image\_size > MAX\_SIZE) return ERR\_INVALID\_INPUT`. Memory management (MISRA 18.4): stack-allocated buffers for CPU-resident data (confidence scores), no malloc/free in hot loop. Error handling: every function returns int32_t error code. Return 0 = success, < 0 = error. Caller must check return code before using output. Code review: 2-reviewer process. Reviewer 1 (peer): checks requirements coverage, logic correctness, test adequacy. Reviewer 2 (architecture): checks design conformance, error handling, MISRA compliance. Findings: 3 minor (unused variable, missing comment), 0 major. All closed before merge to main.

Verification Phase (ASPICE SWE.4, 26262-6 Cl.8): Unit tests defined in test_pedestrian_detector.cpp. Test case 1 (nominal): image_buffer = sunny daylight photo with pedestrian. Expected: confidence > 0.8 , bbox valid, latency $< 50\text{ms}$. Actual: confidence=0.92, bbox=[100,150,180,250], latency=42ms. $\checkmark$ PASS. Test case 2 (adversarial): sunny photo + L_∞ perturbation ($\epsilon=0.05$). Expected: confidence drop $< 20\%$. Actual: confidence=0.76 (drop 16%). $\checkmark$ PASS. Test case 3 (boundary): image_size=0 (empty buffer). Expected: ERR_INVALID_INPUT. Actual: returns -1 (error code). $\checkmark$ PASS. Coverage measurement: LCOV tool reports line coverage=99%, branch coverage=94%, MC/DC coverage=95%. Coverage details: one uncovered line = error handler for OOM (malloc failure), deemed impossible in deployed system (pre-allocated fixed buffers). MISRA static analysis: SonarQube scans find 0 high-priority violations, 2 medium (hardcoded threshold 0.5 $\rightarrow$ mitigation: threshold extracted to config.h). Fuzz testing: libFuzzer generates 10M random image buffers (various sizes, random bytes). Result: 0 crashes, 0 address sanitizer errors. Adversarial testing: FastAttack tool applies L2 perturbations. Confidence degradation acceptable for all tested $\epsilon \leq 0.08$. Test report sign-off: QA Lead confirms all tests passed, coverage targets met, findings closed.

Release & Deployment Phase (ASPICE SWE.5-6, 26262-6 Cl.11): SW qualification summary prepared. Traceability matrix: 47 SW requirements $\rightarrow$ 47 design components $\rightarrow$ 52 test cases $\rightarrow$ all evidence linked. Findings register: 3 code review findings (closed), 2 MISRA violations (closed via config change), 0 test failures. FMEA closure: 12 failure modes in pedestrian detector scope (e.g., 'Model confidence unreliable due to adversarial input' mitigated by adversarial testing + monitoring). Tool qualification: GCC 11.2 compiler + PyTorch 1.13.1 qualified. Compiler: GCC regression test suite passes. PyTorch: canonical model inference accuracy $\geq 95\%$. Release checklist (SWE.5-6): ☐ all requirements satisfied. ☐ all findings closed (rationale documented). ☐ traceability 100% (4523 items, 4523 linked). ☐ change log prepared (version 1.0.0, date 2026-04-15, signed by CSO). ☐ user manual (deployment instructions, ODD definition, known limitations, drift

monitoring procedure). Release approval: CSO, CISO, QA Manager sign-off. Firmware packaged as secure OTA update, cryptographically signed (RSA-4096). Deployment: staged rollout to 50K vehicles over 2 weeks. Post-deployment monitoring (30 days): false trigger rate <0.1 per 100K miles, zero security incidents, model confidence distribution stable (no data drift detected). ✓ Release successful, production operational.

ASPICE Evidence:

SWE.1 (Architecture): Design rationale document (why CNN, architecture selection, training dataset). SWE.2 (Design detail): Detailed interface spec, error handling logic. SWE.3 (Code review): Checklist, review minutes, closure. SWE.4 (Unit test): Test plan, results, coverage report. SWE.5 (SW integration): Integration test plan & results. MLE.2 (Model dev): Training script, hyperparameters, reproducibility audit. MLE.3 (AI verification): Adversarial test results, robustness justification. MLE.4 (Operational): Monitoring plan, drift detector spec.

CHAPTER 9: INTEGRATION, V&V, AND RELEASE

SCOPE

This chapter maps integration, system V&V, and release gates across six standards. Focus: unified test strategy, combined test campaign (safety + security + SOTIF + AI), integrated assurance case, ASPICE VAL.1 (new in v4.0).

9.1 Phase Overview: System V&V Lifecycle

System V&V integrates SW + HW + AI into a vehicle-ready system. Four test levels, each satisfying multiple standards: (1) SW Integration (26262-6 Cl.10, 21434 Cl.11, ASPICE SWE.5), (2) System Integration (26262-4 Cl.8, 21448 Cl.8, ASPICE SYS.4), (3) System Validation (26262-4 Cl.9, 21448 Cl.9-10, 8800 Cl.9, Cl.15, ASPICE VAL.1), (4) Release Approval (all standards' gate criteria).

Unified test strategy: one test plan addressing safety (26262), security (21434), SOTIF (21448), and AI robustness (8800). Test cases labeled by standard(s) addressed. Evidence integrated into single traceability matrix.

9.2 Standard-by-Standard V&V Requirements

Standard	Clause(s)	V&V Focus	Test Type	Pass Criteria	ASPICE Link
ISO 26262 Part 4	Cl.8-9	System safety validation; fault injection; FMEA closure	System-level safety	ASIL-specific coverage	SYS.4-5
ISO 26262	Cl.10-11	SW integration;	SW	MC/DC ≥93% end-	SWE.5-6

Part 6		module interaction; SW qualification	integration	to-end	
ISO 21434	CL.11	Cybersecurity validation; penetration testing; threat exploitation	Security testing (DAST)	Zero exploitable findings	VAL.1
ISO 21448	CL.8-10	SOTIF V&V; residual risk evaluation; triggering scenario coverage	Scenario testing	All relevant scenarios covered	VAL.1
ISO/PAS 8800	CL.9, 15	AI V&V; ODD coverage; system safety with AI; monitoring readiness	AI scenario + system	ODD coverage %; AI + system interaction	VAL.1 + MLE.3
ISO 9001/IATF	CL.8.6, 9.1	Release approval; process compliance; monitoring plan	Gate review	All IATF checklist items closed	VAL.1
ASPICE	SYS.4-5, VAL.1	System eng validation; AI-aware validation (VAL.1 new v4.0); test matrix	Maturity-driven	L2+ base practices; L3 procedures	Core processes

Table 9-1. Standard-by-Standard V&V Requirements.

9.3 Test Levels Matrix: Unit → Integration → System → Vehicle

Test Level	Scope	26262 Req	21434 Req	21448 Req	8800 Req	Tools
Unit (L1)	Individual SW function	MC/DC ≥93%	Code injection test	Edge-case input	Model unit activation	GCC coverage, libFuzzer
Integration (L2)	Module → subsystem	MC/DC ≥93% path chain	API fuzzing	Interface boundary test	Model + SW interface	Test harness, AFL
System (L3)	All SW + HW + comms	FMEA closure, end-to-end	Penetration testing	Scenario matrix (ODD)	Full system behavior	HIL, vehicles labs
Vehicle (L4)	Real vehicle, real world	Fault injection validation	Road test + attack simulation	Naturalistic driving	Operational monitoring	Real vehicles, fleet

Table 9-2. Test Levels Matrix: Standards Coverage per Level.

Integrated Test Strategy Design (ASPICE SYS.4, VAL.1): Test strategy must address all four vectors (safety, security, SOTIF, AI) in single campaign. Strategy document structure: (1) Test objectives per standard (26262 = FMEA closure rate $\geq 99.9\%$, 21434 = zero exploitable findings, 21448 = ODD scenarios $\geq 90\%$ coverage, 8800 = model robustness $\varepsilon \leq 0.05$). (2) Test levels (unit, integration, system, vehicle). (3) Test types per level (safety fault injection, security penetration, SOTIF scenario, AI adversarial). (4) Resource allocation (budget, schedule, vehicles, test tracks). (5) Exit criteria (what constitutes 'test complete?'). Unified test matrix: rows = test cases, columns = {Test ID, Title, Scope, Standard(s), Setup, Expected Result, Pass Criteria, Execution Status}. Example row: T-001 | Pedestrian detect in rain | System | 26262/21448/8800 | Adverse weather sim | Detect OR safe mode | No crash, latency $\leq 150\text{ms}$, confidence drop $\leq 20\%$ | PASS. Test prioritization (risk-based): ASIL D + critical security attacks + high-impact ODD scenarios → test first. Non-critical → test later if time permits. Evidence: test strategy document (3-5 pages), unified test matrix (all test cases), test level descriptions, resource plan.

Test Infrastructure & Automation (ASPICE VAL.1 Level 3): Automated test execution accelerates V&V. Test environment: (1) Hardware-in-the-loop (HIL) simulator (replaces sensors with virtual signals, allows fault injection). (2) Vehicle platform testbed (real AEB system on dynamometer, wheels rotating, simulated pedestrian via lidar/camera playback). (3) Road test track (controlled environment, safety driver, instrumented vehicles, 50K miles of testing). (4) Fleet validation (production vehicles, 50K units, 6 months in field, continuous telemetry collection). Test automation: (1) Unit tests (GTest framework, automated coverage reporting). (2) Integration tests (continuous integration via Jenkins, automated MISRA checks). (3) System tests (AUTOSAR testing framework, scenario playback, automated verdict generation). (4) AI tests (PyTorch/TensorFlow test harness, automated adversarial attack generation). Test execution flow: developer commits code → CI pipeline triggers → unit tests run → MISRA analysis → code coverage → integration tests → report generated. If quality gate passed (coverage $\geq 93\%$, zero critical findings) → merge to main. Else → code review + fix + retest. Regression testing: every code change → re-execute all prior test cases (catch regressions). Full regression test suite: 5000+ test cases, 24-hour execution on 16-node cluster. Evidence: CI/CD pipeline configuration (Jenkins/GitLab CI), test automation code (test harnesses), regression test log (pass/fail history), quality gate definition (coverage threshold, static analysis rules), test metrics (case execution time, flaky test rate).

Test Data Management & Traceability (ISO 26262-4 Cl.8, ASPICE VAL.1): Test data must be traceable to requirements. Test data sources: (1) synthetic (generated scenarios via CARLA simulator). (2) recorded field data (real vehicle telemetry from earlier prototypes). (3) annotated datasets (pedestrian detection: 80K images hand-labeled for bounding boxes). Data versioning: all test data stored in Git LFS (large file storage) with version tags. Example: test_data_v2.3.1_20260402.tar.gz (reproducible across test runs). Traceability chain: requirement ID → test case ID(s) → test data file(s) → test execution log → evidence artifact. Example: REQ-26262-001 (AEB must detect pedestrians $\geq 10\text{m}$ away) → test_cases = {T-001, T-002, T-005} → test_data = test_pedestrian_dataset_v2.3.1 → execution_logs = {log_20260402_T001.txt, log_20260402_T002.txt, log_20260402_T005.txt} → evidence = {latency_report.html, confidence_dist.csv}. Test data quality metrics: (1) coverage (all ODD scenarios represented?). (2) balance (male/female pedestrians equally represented to avoid bias?). (3) authenticity (does synthetic data match real-world distribution?). (4) labeling quality (annotation agreement > 0.9 Cohen's kappa?). Evidence: test data management plan (versioning strategy, storage location, retention policy), traceability matrix (req → test case → data → evidence), data quality report (coverage %, balance metrics, authenticity assessment).

9.4 Combined Test Campaign Strategy

Single test execution addressing four vectors (safety, security, SOTIF, AI) in parallel:

TEST CAMPAIGN VECTOR 1: SAFETY (26262)

Test execution on system with injected faults (bit-flip, timing, memory corruption). Verify: system reaches safe state per architecture. FMEA mitigation closure rate $\geq 99.9\%$ (ASIL D). Tool: Fault injector (SimInject, custom) on HIL platform.

TEST CAMPAIGN VECTOR 2: SECURITY (21434)

Penetration testing: DAST (dynamic application security testing), fuzzing APIs, replay attack simulation, privilege escalation attempts. Verify: zero exploitable findings (CWE-89, CWE-94, CWE-502, etc.). Tool: Burp Suite, custom fuzz harness, OTA packet replay.

TEST CAMPAIGN VECTOR 3: SOTIF (21448)

Scenario testing: environmental edge cases (extreme temp, sun glare, rain, night), sensor faults, edge-case objects (cyclists, children). Verify: triggering condition analysis complete; residual risk $\leq$ acceptable level per specification. Tool: Scenario generator (Apollo/CARLA), real test track, naturalistic driving data replay.

TEST CAMPAIGN VECTOR 4: AI ROBUSTNESS (8800)

Adversarial + ODD testing: imperceptible perturbations, out-of-distribution images, weather effects, occlusion. Verify: model robustness bounds (ϵ), ODD coverage $\geq 99\%$. AI + system interaction safe (e.g., false detection $\rightarrow$ safe braking). Tool: Adversarial attack library (CLEVERHANS), sensor simulator, model validation suite.

Safety Vector Details (26262 Fault Injection): Fault injection simulates hardware failures to verify system reaches safe state. Fault types: (1) transient (bit-flip in CPU register, lasts 1 clock cycle). (2) permanent (stuck-at-1, sensor output jammed to max value). (3) timing (CAN message delayed, sensor reading stale $>100\text{ms}$). Injection methodology: HIL platform with fault injector hardware. Execution: (a) normal test case (e.g., pedestrian detection). (b) inject fault at random time during test. (c) verify system response: AEB applies safe braking (no sudden acceleration), diagnostics logged, error flagged for driver notification. (d) measure FMEA fault coverage: did fault trigger any dormant failure mode? Coverage metric: $(\# \text{ injected faults detected} + \text{safely handled}) / (\# \text{ total injected faults}) \geq 99.9\%$ for ASIL D. Example campaign: inject 10K bit-flips into pedestrian detector output (CNN confidence score). Result: 9990 faults detected (AEB inhibited, safe state). 10 faults missed (undetected = FMEA gap, requires mitigation e.g., checksum on confidence output). Evidence: fault injection report (fault types, injection count, coverage %, mitigation summary), FMEA update (closure of missed faults).

Security Vector Details (21434 Penetration Testing): Penetration testing simulates adversary attacks to find exploitable vulnerabilities. Attack scenarios: (1) CAN message injection (attacker sends malformed CAN frames). Vehicle receives $\rightarrow$ input validation rejects $\rightarrow$ safe state. $\checkmark$ PASS. (2) Firmware tampering (attacker modifies OTA binary before flashing). Secure boot signature verification fails $\rightarrow$ no boot, safe state. $\checkmark$ PASS. (3) Sensor spoofing (lidar emitter jamming, replay camera images from prior recordings). System detects anomaly $\rightarrow$ diagnostics flag $\rightarrow$ fallback to safe. $\checkmark$ PASS. (4) API fuzzing (attacker calls CAN message interface with invalid parameters). All parameters validated $\rightarrow$ return error, no crash. $\checkmark$ PASS. Zero-day hunt: dynamic analysis (DAST) with Valgrind memory checker + AddressSanitizer. Run system with malicious inputs, detect memory errors (buffer overflow, use-after-free). Result for AEB: zero exploitable findings. (e.g., buffer overflow attempt in image preprocessing $\rightarrow$ bounds-checked, error returned). Evidence: penetration test report (attack scenarios, results, 0 exploitable findings), vulnerability findings register (high/medium/low), SAST report (CWE patterns), DAST report (memory errors, no critical findings).

SOTIF Vector Details (21448 Scenario Testing): Scenario testing exercises edge-case combinations to verify residual risk acceptable. Scenario families: (1) Environmental: sunny/rain/night, -20°C to $+50^{\circ}\text{C}$, high-altitude

(1000m+, thin air affects sensor accuracy). (2) Dynamic: pedestrian stationary vs. moving, vehicle approaching at 5/30/120 km/h, near-miss distance 5m/10m/50m. (3) Sensor faults: lidar returns garbled data, camera saturated (bright sun), radar multipath (reflections off metal surfaces). (4) Edge objects: cyclist (smaller than pedestrian), child (lower height), stroller (robot-like profile). Scenario matrix construction: worst-case combinations prioritized. Example: 'night (1 lux) + rain (50% visibility) + child (height 1m) + cyclist profile' = high-risk scenario. Test execution: scenario generated in CARLA simulator OR recreated at test track (e.g., use costume actor as proxy child). Evaluation: for each scenario, measure detection performance (confidence, latency, bounding box accuracy). Acceptance: detection ≥ 0.5 confidence OR safe mode engaged (AEB inhibited). Residual risk evaluation: for undetected scenarios (confidence < 0.5), assess residual risk (injury probability). Document: 'Night + rain + child: missed detection in 2 of 50 trials (4%). Residual risk: minor injury $< 1\%$ probability. Acceptable per SOTIF Cl.10.' Evidence: scenario test plan (all scenarios defined), scenario test results (per-scenario metrics), residual risk evaluation report, scenario coverage matrix (% ODD combinations tested).

AI Robustness Vector Details (8800 Adversarial & ODD): Adversarial testing verifies model robust to perturbations. Test approach: (1) L2 perturbation (Gaussian noise): generate noise patterns with ϵ varying from 0 (clean) to 0.3 (heavy). For each ϵ , measure confidence drop. Target: confidence drop $\leq 20\%$ for $\epsilon \leq 0.05$ (imperceptible). Example result: clean image confidence=0.95, $\epsilon=0.05$ confidence=0.80 (15% drop). ✓ PASS. (2) L ∞ perturbation (bounded pixel-level): pixel values modified by $\leq \epsilon$. Example: original pixel [100, 150, 200] → modified [105, 155, 205] ($\epsilon=5/255 \approx 0.02$). Robustness: model confidence > 0.75 . ✓ PASS. (3) Patch attack (physical): 50×50 pixel sticker on pedestrian's shirt. Robustness: confidence drop $\leq 15\%$. ✓ PASS. ODD coverage: systematic test across ODD matrix (weather × time-of-day × visibility × road-type). ODD matrix size: 4 weather × 3 time-of-day × 3 visibility × 3 road-type = 108 scenarios. Coverage achieved: 100 scenarios (93%). For each scenario: measure accuracy (# detections / # ground-truth pedestrians), false alarm rate (false detections / # non-pedestrians). Acceptance: accuracy $\geq 95\%$, FAR $\leq 1\%$. Evidence: adversarial robustness report (ϵ ranges, confidence curves, robustness justified), ODD coverage matrix (scenario → coverage status), accuracy/FAR per scenario table.

9.5 Release Readiness Checklist

ISO 26262 RELEASE GATE

☐ Safety Case complete & signed (Part 8 Cl.9). ☐ ASIL allocation traced to all components. ☐ Functional safety plan & HARA closure. ☐ FMEA/FTA closure (CriticalityScore $\leq$ acceptable). ☐ SW qualification summary (all clause 26262-6 Cl.11 items). ☐ System safety validation complete (Part 4 Cl.9). ☐ Functional safety management & metrics. ☐ Traceability matrix 100% linked.

ISO 21434 RELEASE GATE

☐ Cybersecurity management processes active (Cl.4). ☐ Security requirements specification (Cl.9). ☐ Secure SW development (Cl.10): coding standards, SAST $\geq 95\%$ rules, fuzz $\geq 10^7$ inputs. ☐ CS validation complete (Cl.11): penetration testing, zero exploitable findings. ☐ Cybersecurity case documented. ☐ Incident response readiness (PSIRT team, disclosure policy). ☐ OTA security (UN R156 compliance for remote update).

ISO 21448 RELEASE GATE

☐ Hazard Analysis & Risk Assessment (HARA) supplement for SOTIF. ☐ SW triggering condition analysis complete

(Cl.9). ☐ Operational Design Domain (ODD) definition (Cl.8). ☐ V&V plan addresses all SOTIF scenarios (Cl.10). ☐ Residual Risk Evaluation completed & acceptable (Cl.10). ☐ SOTIF safety case / SOTIF argument documented.

ISO/PAS 8800 RELEASE GATE

☐ AI Safety Management Plan (Cl.4) & evidence. ☐ Data governance complete: lineage, versioning (Cl.5-6). ☐ Model training & validation (Cl.7-9): robustness $\geq \epsilon$, ODD coverage $\geq 99\%$, bias audit passed. ☐ System safety evaluation with AI (Cl.15) signed. ☐ Operational phase governance (Cl.11): monitoring plan, drift detector. ☐ AI assurance case documented.

ISO 9001/IATF RELEASE GATE

☐ Design review completion (8.2.3.1, design FMEA). ☐ Process capability ($Ppk \geq 1.33$ for critical characteristics). ☐ Verification activity completion (8.2.3.4). ☐ Release meeting checklist: all standards' gates passed. ☐ Monitoring & measurement plan active (9.1).

ASPICE RELEASE GATE

☐ SYS.4 (System integration) & SYS.5 (System qualification): processes L2+. ☐ SWE.5-6 (SW integration/qualification): process L2+. ☐ VAL.1 (System validation) NEW in v4.0: integrated validation across all domains, with AI-aware considerations. ☐ MLE.3-4 (AI verification & operational governance): process L2+.

Release Criteria Interpretation Across Standards (Harmonized View): Each standard has unique release criteria. Harmonization strategy: unified release checklist combining all criteria into one gate. 26262 Release Gate: 'System achieves target ASIL per Part 3 hazard analysis & Part 4/6 development.' Specific items: (a) HARA complete (hazards identified, ASIL assigned per Cl.5.3). (b) FMEA closure $\geq 99.9\%$ (all failure modes mitigated or risk accepted). (c) SW qualification summary (26262-6 Cl.11): all SW development requirements (Cl.5-10) satisfied, traceability 100%. (d) Safety case signed by CSO (documented argument: 'We have satisfied all ISO 26262 requirements; system safe for deployment'). Evidence: HARA report, FMEA spreadsheet, SW qualification summary, traceability matrix, safety case document. Gate review: CSO + architecture lead + QA manager review evidence, sign-off. SLA: ≤ 5 working days.

21434 & 21448 Release Gates (Security & SOTIF): Cybersecurity release gate parallels safety. 21434 criteria: (a) Threat model complete & realistic (adversary capabilities defined, attack vectors identified). (b) Secure SW development per Cl.10 (MISRA compliance $\geq 95\%$, fuzz testing $\geq 10^7$ inputs, zero high-priority SAST findings). (c) CS validation per Cl.11 (penetration testing complete, zero exploitable findings). (d) Cybersecurity case signed by CISO (argument: 'System resists known attack vectors; residual cybersecurity risk acceptable'). Evidence: threat model document, SAST/DAST reports, penetration test report, cybersecurity case. 21448 criteria (SOTIF): (a) ODD definition finalized (sensor ranges, weather limits, geographic bounds). (b) Triggering condition analysis complete (all plausible failure modes causing incorrect output identified). (c) SOTIF V&V plan executed (scenario test cases $\geq 90\%$ coverage of ODD). (d) Residual risk evaluation: for residual failures (e.g., false detection in night + rain), assess injury probability. If $< 10^{-7}$ per hour, acceptable. (e) SOTIF case signed by CSO (argument: 'System manages residual risk within acceptable bounds'). Evidence: ODD definition, triggering condition matrix, SOTIF test results, residual risk evaluation, SOTIF case.

8800 & Combined Gate (AI & System Integration): AI-specific release criteria added for 8800. 8800 criteria: (a) Data governance complete (training dataset versioned v2.3.1, lineage documented, bias audit passed). (b) Model training reproducible (seed fixed, framework version pinned, 10 training runs $\rightarrow$ identical weights).

within 10^{-6} . (c) Model verification complete (adversarial robustness $\epsilon=0.05 \geq$ requirement, ODD coverage $\geq 99\%$, accuracy $\geq 95\%$). (d) Operational monitoring plan active (drift detector configured: alert if confidence drops $>20\%$ over 7-day window). (e) AI safety case signed by AI/ML lead (argument: 'Models are robust, monitored operationally, safety integration validated'). Combined System Integration Gate (merging all four cases): (a) All standard-specific gates passed (26262 CSO sign-off, 21434 CISO sign-off, 21448 CSO sign-off, 8800 AI lead sign-off). (b) System integration test complete (all subsystems interacting correctly). (c) Traceability 100% (all requirements traced through design, code, test). (d) Release meeting conducted (CSO, CISO, QA Manager, Product Manager present). (e) Release approval signed by steering committee. Evidence: all standard-specific cases, integration test report, unified traceability matrix, release approval document. Release decision: release approved IF all criteria passed. Else: identify blockers, create remediation plan, reschedule release gate (typically 1-2 weeks later).

9.6 Integrated Assurance Case Architecture

Four converged assurance cases, each with its own argument structure, feed into a single top-level claim: 'The AEB system is safe, secure, and SOTIF-compliant in its ODD for production release.'

Assurance Case 1 (26262): Functional Safety Case — 'System achieves target ASIL through design & validation.' Sub-claims: HARA completeness, design safety, HW reliability, SW development rigor, system integration coverage.

Assurance Case 2 (21434): Cybersecurity Case — 'System resists known attack vectors.' Sub-claims: threat model completeness, secure architecture, secure coding, vulnerability management, incident response.

Assurance Case 3 (21448): SOTIF Case — 'System manages reasonable residual risk in ODD.' Sub-claims: triggering condition analysis, ODD definition, scenario coverage, residual risk acceptable, monitoring active.

Assurance Case 4 (8800): AI Safety Case — 'AI models are robust and monitored operationally.' Sub-claims: data governance, model robustness (adversarial, ODD), AI+system safety interaction, operational monitoring.

Integration Point: All four cases share the common root: 'System is production-ready per ISO 26262, 21434, 21448, 8800.'

Assurance Case Structure & Notation (GSN = Goal Structuring Notation): Each case uses GSN tree: top-level claim $\rightarrow$ sub-claims $\rightarrow$ evidence. 26262 Safety Case example: Goal='AEB system achieves ASIL C' $\rightarrow$ Claims=['HARA assurance' + 'Design assurance' + 'HW reliability' + 'SW development rigor' + 'System integration']. Claim 'SW development rigor' $\rightarrow$ Sub-claims=['Architectural design sound' + 'Code complies with MISRA' + 'Test coverage adequate' + 'All findings closed']. Sub-claim 'Code complies with MISRA' $\rightarrow$ Evidence=['MISRA report (zero high findings)' + 'Code review checklist (100% items signed)' + 'Static analysis (SonarQube results)'] + Context=['MISRA scope: 47.3K lines of C code']. GSN notation: boxes = goals/claims, circles = context, diamonds = assumptions, triangles = strategies (how to achieve claim). Purpose: structured argument, traceable to artifacts, peer reviewable (experts can validate each node's logic).

Safety Case + Cybersecurity Case + SOTIF Case + AI Case Integration: Four cases inter-linked via common nodes. Root claim: 'AEB system is safe, secure, and SOTIF-compliant in production.' Sub-claims (level 1): ['Functional Safety Claim' (26262) + 'Cybersecurity Claim' (21434) + 'SOTIF Claim' (21448) + 'AI Safety Claim' (8800)]. Functional Safety Claim $\rightarrow$ sub-claims: ['Hazards analyzed + ASIL assigned' + 'Design prevents hazards' + 'HW components reliable' + 'SW developed rigorously' + 'System integrated & validated']. Cybersecurity Claim $\rightarrow$ sub-claims: ['Threat model complete' + 'Secure architecture' + 'Secure coding' + 'Vulnerabilities tested & fixed' + 'Incident response ready']. SOTIF Claim $\rightarrow$ sub-claims: ['ODD defined' + 'Triggering conditions identified' + 'Residual risk acceptable' + 'Monitoring active']. AI Safety Claim $\rightarrow$ sub-claims: ['Data governance sound' + 'Model training rigorous' + 'Model robustness verified' + 'Operational monitoring ready']. Integration

nodes: node 'SW developed rigorously' supports BOTH 26262 + 21434 (same code satisfies both safety & security requirements). Node 'System integrated & validated' integrates evidence from all four test vectors (fault injection + penetration + scenario + adversarial). Purpose: single assurance case meta-structure showing how six standards' requirements converge to single safety claim.

Assurance Case Maintenance & Versioning (ASPICE VAL.1): Assurance case is live document, updated post-release. Initial case: all nodes based on pre-release evidence (SW qualif report, test results, FMEA, threat model, etc.). Post-release updates: (a) operational incidents logged → new evidence ('field test results: zero false triggers in 50K miles'). (b) OTA patches deployed → case updated (SW assurance re-evaluated: patch reduces risk from high → medium). (c) new vulnerabilities discovered → case escalated (cybersecurity assurance node may become 'not fully supported' until patch deployed). Versioning: assurance case v1.0 (initial), v1.1 (OTA patch v1.1 deployed, case slightly revised), v1.2 (OTA patch v1.2 deployed, data drift detected, case notes ongoing monitoring). Periodic review: quarterly assurance case review (safety + security leads examine all nodes, confirm claims still valid). If incident found post-release (e.g., 0.1% false trigger rate, higher than pre-deployment baseline 0.01%), investigate: is case node 'residual risk acceptable' still valid? If not, escalate (CAPA initiated, OTA patch deployed, case updated). Assurance case storage: versioned in Git alongside design docs, change log tracked, review sign-off logged. Evidence: assurance case diagrams (GSN trees), assurance case document (narrative argument for each node), case review meeting minutes, case version history (v1.0 → v1.1 → ... with justification for changes).

9.7 ASPICE VAL.1: System Validation (New in v4.0)

ASPICE v4.0 introduces VAL.1 (System Validation) to explicitly govern multi-domain validation in safety-critical systems. VAL.1 spans the validation activities from 26262-4 Cl.9, 21434 Cl.11, 21448 Cl.9-10, and 8800 Cl.9/Cl.15.

VAL.1 Base Practices (L2): (1) Establish validation strategy per standards (safety, security, SOTIF, AI). (2) Prepare system validation plan. (3) Define test levels & acceptance criteria. (4) Execute system validation (all vectors). (5) Document validation results. (6) Ensure traceability requirements → design → test → evidence.

VAL.1 Work Products (L2): System validation strategy, system validation plan, test scenarios, test results, validation report (with evidence linkage).

VAL.1 Advanced Practices (L3): (7) Risk-based test prioritization. (8) Coverage metrics per standard (MC/DC for 26262, CWE for 21434, scenario for 21448/8800). (9) Automated testing integration. (10) Regression testing on change.

Integration with Chapter 9: VAL.1 is the procedural backbone of sections 9.3-9.5.

VAL.1 Maturity Progression (L2 → L3): ASPICE defines maturity levels for each process. Level 2 (Managed): (a) Establish validation strategy per domain (safety → 26262-4 Cl.9, security → 21434 Cl.11, SOTIF → 21448 Cl.9-10, AI → 8800 Cl.9). (b) Prepare validation plan (scope, test levels, exit criteria, resource allocation). (c) Define test scenarios with acceptance criteria. Scenario format: ID | Title | Standard(s) | Setup | Expected Result | Pass Criteria. (d) Execute validation (run all test scenarios per plan, log results). (e) Document validation report (results summary, traceability, findings). Level 2 work products: validation strategy, validation plan, test scenarios, test results log, validation report (with traceability matrix). Level 3 (Defined): extends L2 with: (f) risk-based test prioritization (critical tests first, non-critical deferred if needed). (g) coverage metrics per standard (MC/DC for 26262, CWE for 21434, scenario % for 21448, robustness ϵ for 8800). (h) automated testing integration (CI/CD pipeline runs tests on every commit). (i) regression testing (change impact analysis: if code modifies module X, re-execute all test cases for module X). (j) tailored process (project adapts ASPICE VAL.1 procedures per context, documented in project quality plan). Level 3 adds: test prioritization procedure,

coverage metrics procedure, automation strategy, regression testing procedure, process tailoring rationale. Evidence for L2: strategy document, plan document, scenario definitions, test execution logs, validation report. Evidence for L3: all L2 items + test prioritization rationale document, coverage metrics report, CI/CD pipeline configuration, regression testing procedure, project quality plan (process tailoring). Achievement: AEB project targets ASPICE L2 for VAL.1 (released); L3 for later iterations (post-release improvements).

VAL.1 Integration with Domain Standards: VAL.1 is 'meta-process' orchestrating domain-specific validation. Domain Standard Integration Pattern: SYS.4 (System Integration, per 26262-4 Cl.8) + SYS.5 (System Qualification, per 26262-4 Cl.9) + VAL.1 (System Validation, orchestrating all domains). Execution sequence: (1) SYS.4 integration: all SW + HW modules integrated into system on platform testbed (HIL simulator). (2) SYS.5 qualification: system validated per 26262 (fault injection, FMEA closure, safety case argument). (3) VAL.1 orchestration: expand scope beyond 26262 to include 21434 (penetration testing), 21448 (scenario testing), 8800 (adversarial testing). Single test execution satisfies all domains' validation requirements (unified test campaign per section 9.4). Example: VAL.1 test case T-001 'Pedestrian detect in rain' → addresses 26262 (FMEA node 'false negative in rain' closure), 21434 (sensor attack resilience: rain jamming lidar → system falls back to camera + safe mode), 21448 (ODD scenario: rain weather condition), 8800 (model robustness in rain-degraded images). Single test execution → four standards' evidence items closed. Traceability: T-001 → {26262 FMEA-node-42 + 21434 threat-model-node-15 + 21448 ODD-scenario-7 + 8800 test-scenario-12}. Evidence: VAL.1 test case linkage document (each test case → domain requirements addressed), unified test matrix (Table 9-3 as reference), multi-domain traceability report (requirements → test cases → evidence mapped per standard).

9.8 Commonality Analysis: Unified Test Scenario Format

All test scenarios (safety, security, SOTIF, AI) represented in a common format for traceability:

Common Scenario Structure: Scenario ID | Title | Standard(s) | Environmental Conditions | Initial State | Test Stimulus | Expected Outcome | Coverage Metric

Example Scenario:

S-001 | Pedestrian Detection in Rain | 26262 / 21448 / 8800 | 50% visibility, rain, night | Vehicle at 30 km/h, pedestrian 10m ahead | Pedestrian enters ODD → CNN inference | Detection confidence ≥ 0.5 OR safe mode activation (AEB inhibited) within 100ms | MC/DC path coverage (26262), ODD scenario (21448), model robustness (8800)

Result: Single test execution / evidence item closes requirements across all standards.

9.9 Worked Mini-Example: Integrated V&V for AEB System

System: AEB (Autonomous Emergency Braking) with pedestrian detection. Target ASIL C. Field testing post-release.

Unified Test Plan Table (Table 9-3):

Test ID	Scenario	Std Coverage	Setup	Expected Result	Pass Criteria
T-001	Pedestrian 10m, 30 km/h, daylight	26262/21448	Real track + actor	Detect ≥ 0.5 , brake TTC < 2s	Latency ≤ 150 ms

T-002	Rain + night + pedestrian	26262/21448/8800	Adverse weather sim	Detect OR safe inhibit	No crash, safe state
T-003	Adversarial patch on shirt	8800	Real patch on test actor	Robust detect OR graceful fail	Conf drop <20%
T-004	Penetration: OTA packet injection	21434	Bench test + vehicle	Reject malformed packet	Zero exploit success
T-005	Fault injection: CAN timeout	26262	HIL fault injector	Safe state within 100ms	No AEB execution
T-006	System integration: E2E brake apply	26262/21448	Vehicle platform	Brake pressure ≥ 5 bar	Stop distance <1m

Table 9-3. Integrated AEB V&V Test Matrix.**Test Execution & Results Summary:**

Safety vector (26262): Fault injection campaign conducted on HIL simulator. 10K bit-flips injected into pedestrian detector outputs (CNN confidence scores). Result: 9990 faults detected + safely handled (AEB inhibited, safe state triggered). 10 faults missed (undetected). FMEA closure rate: 99.9%. ✓ PASS. FMEA items: 61 failure modes in AEB scope. Closure: 60 via design mitigation (input validation, error handling), 1 via operational monitoring (confidence drift detector). Traceability: all 61 FMEA failures → mitigation in SW architecture → test case covering mitigation → evidence (test result = mitigation confirmed). Safety case argument: 'System reaches safe state within 100ms per 26262-4 Cl.9 requirement. Verified: fault injection confirms safe-state response $\geq 99.9\%$ of injected faults.' Signed by Chief Safety Officer.

Security vector (21434): Penetration testing conducted over 3 weeks by external security firm. Attack vectors tested: (1) CAN message injection (50 malformed messages) → all rejected by input validation. ✓ PASS. (2) OTA firmware tampering (modify binary, attempt boot) → secure boot signature check fails, no boot, safe state. ✓ PASS. (3) Sensor spoofing (inject fake lidar range, replay camera images) → anomaly detected, fallback to safe mode. ✓ PASS. (4) API fuzzing (call CAN interface with 10K random parameters) → zero crashes, all inputs validated. ✓ PASS. SAST results: SonarQube scan found 2 medium-priority findings (hardcoded threshold 0.5 + unused variable). Both closed (config file extraction + variable removal). Zero high-priority findings. Compliance: 99.5% of MISRA rules (>100 rules checked, all high-priority rules satisfied). CS validation signed by Chief Information Security Officer. Cybersecurity case argument: 'System resists known CAN attack vectors, secure boot prevents firmware tampering, input validation prevents injection attacks. Penetration testing zero exploitable findings. Residual cybersecurity risk acceptable for ASIL C.' Signed by CISO.

SOTIF & AI vectors (21448 + 8800): Scenario testing conducted on real test track + CARLA simulator. ODD matrix: 4 weather (sunny, rain, night, snow) × 3 visibility (>50m, 20-50m, <20m) × 3 road-types (urban, highway, residential) = 36 base scenarios. High-risk combinations tested: night + rain + low visibility + urban = 4 instances. Medium-risk: day + rain + highway = 2 instances. Low-risk: sunny + highway = 1 instance. Total: 12 real-track scenarios tested (real actors, instrumented vehicles, natural environmental conditions). 24 synthetic scenarios tested (CARLA simulator, diverse ODD points). Overall ODD coverage: 36 scenarios achieved 92% coverage (3 deferred due to extreme weather unavailability, risk accepted). Accuracy results per scenario: mean $\geq 95\%$, worst-case (night low-vis) = 90% accuracy (>threshold). False alarm rate: mean <1%, worst-case = 1.2% (acceptable per spec). Residual risk evaluation: 'Residual failures (e.g., pedestrian missed in night + rain) occur in <2% of scenarios. Injury probability $<10^{-7}$ per hour. Acceptable.' Adversarial robustness: L2 perturbation (ϵ from 0 to 0.3). Confidence curve: clean=95%, $\epsilon=0.05=78\%$ (17% drop, $\leq 20\%$ threshold). ✓ PASS. Patch attack (5×5cm sticker): confidence drop 12%, acceptable. ✓ PASS. Bias audit: dataset stratified by

gender (50% male, 50% female pedestrians) + skin tone (5 categories) + age (adult, child). Accuracy per group: $\geq 93\%$ for all subgroups (max disparity 2%, $< 3\%$ threshold). ✓ PASS. SOTIF case signed by CSO. AI safety case signed by AI/ML Lead.

Release Readiness Summary:

ISO 26262: Functional safety case signed. FMEA closure 100% (61 failure modes). SW qualification complete. ASIL C achieved.

ISO 21434: Penetration testing zero exploitable findings. SAST 99.5% rule compliance. CS validation signed.

ISO 21448: ODD definition approved (36 scenarios). Scenario test cases 12 on real track + 24 synthetic (92% ODD coverage). Residual risk $\leq$ tolerable.

ISO/PAS 8800: CNN model robustness $\epsilon=0.05$ ✓. Adversarial test suite passed (patch attack, L_2/L_∞ perturbations). Bias audit (gender, skin tone, age) passed.

ISO 9001/IATF: Release meeting conducted. All checklist items closed. Monitoring plan active (telemetry collection, drift detector alerts).

ASPICE: SYS.4-5 (system integration/qualification) L2 ✓. VAL.1 (system validation) L2 ✓. Traceability 100% (4523 requirements, 4523 test cases linked).

Release Approval: Chief Safety Officer, Chief Security Officer, Chief Information Officer, Quality Manager, Product Manager. Unanimous approval. Production release authorized 2026-04-15. Deployment to 50K vehicles via OTA over 2-week period. Post-deployment monitoring (30 days): false trigger rate 0.08 per 100K miles (within baseline), zero security incidents, model confidence stable. ✓ Release successful.

CHAPTER 10: PRODUCTION, OPERATIONS & DECOMMISSIONING

SCOPE

This chapter governs field operations after production release. Focus: unified field monitoring (safety incidents + vulnerability disclosures + SOTIF issues + AI drift), OTA updates, incident response, decommissioning, and operational governance per ISO 9001/IATF plus ASPICE SUP.9-10, MAN.6.

10.1 Phase Overview: Operational Lifecycle

Post-release operations span: (1) Production control (26262-7 Cl.5, 21434 Cl.8, IATF 8.5, ASPICE SUP.9), (2) Field monitoring & incident response (26262-7 Cl.6, 21434 Cl.12-14, 21448 Cl.12, 8800 Cl.11, ASPICE SUP.10), (3) OTA updates (26262-7, 21434 Cl.8, 8800 Cl.11, ASPICE MAN.6), (4) Decommissioning (26262-7 Cl.7, 21434 Cl.14).

Unified approach: Field feedback (safety incidents, security vulnerabilities, SOTIF events, AI drift notifications)
 → Unified incident register → Root cause analysis → Corrective/preventive action (CAPA) → OTA patch OR field retrofit OR recall → Deployment & monitoring.

10.2 Standard-by-Standard Operational Requirements

Standard	Clause(s)	Operational Focus	Key Process	Oversight	ASPICE Link
ISO 26262 Part 7	Cl.5-7	Production control, op phase safety, decommissioning	CAPA for safety anomalies	Safety manager	SUP.9-10
ISO 21434	Cl.8, 12-14	Continual activities (monitoring, threat intel), CS prod mgmt, incident response (PSIRT), decommissioning (key revocation)	Vuln disclosure, patch deployment	CISO, PSIRT lead	SUP.10, MAN.6
ISO 21448	Cl.12	SOTIF operational phase monitoring (triggering events, residual risk)	Log triggering events, evaluate residual risk trend	Safety manager	SUP.10
ISO/PAS 8800	Cl.11	AI operational governance: model monitoring (data drift, model drift), retraining trigger	Drift detector, model update cadence	AI/ML lead	SUP.10, MAN.6
ISO 9001/IATF	Cl.8.5, 10, 10.2.5	Production process control, nonconformity handling, customer focus, feedback management	Quality audit, nonconformity register	Quality manager	SUP.9-10
ASPICE	SUP.9, SUP.10, MAN.6	Software support & maintenance (SUP.9), problem resolution (SUP.10),	Process L2+ for support/problem resolution	Project manager	Core processes

management of
monitoring &
control (MAN.6)

Table 10-1. Standard-by-Standard Operational Requirements.

10.3 Unified Field Monitoring Process

Field feedback streams converge into single incident register:

Stream 1 — Safety Incidents (26262-7 Cl.6): Vehicle telemetry flagging anomalies (brake pressure drop, sensor timeout). Stored in SafetyIncidentLog. Classification: 'Safety Anomaly'. Root cause: functional failure vs. design gap vs. manufacturing defect.

Stream 2 — Vulnerability Disclosures (21434 Cl.12-14): Security researchers / customers reporting exploits or suspected weaknesses. Reported to PSIRT team. Classification: 'Vulnerability' with CVSS score. Root cause: code defect vs. design weakness vs. configuration issue.

Stream 3 — SOTIF Events (21448 Cl.12): Triggering events logged (e.g., 'false braking under sun glare'). Classification: 'SOTIF Event'. Root cause: triggering condition in ODD vs. ODD boundary exceedance vs. model drift.

Stream 4 — AI Drift Notifications (8800 Cl.11): Operational metrics (detection confidence, inference latency) exceed thresholds. Classification: 'AI Drift'. Root cause: data distribution shift vs. model degradation vs. sensor calibration drift.

Unified Incident Register: All four streams feed into single database (IssueTracker, Jira, ServiceNow). Common fields: ID, timestamp, vehicle fleet (or single unit), standard(s) affected, severity (S0-S4), root cause hypothesis, CAPA status, patch/release deployed, closure evidence.

EXAMPLE UNIFIED INCIDENT ENTRY

INC-2026-0847 | 2026-04-02 | Fleet: 15K AEB units | Standards: 26262 / 21448 / 8800 | Severity: S2 | Title: 'False AEB trigger on high-reflectivity road paint' | Root Cause: CNN trained on limited road marking diversity (data gap); triggering condition not in ODD definition. | CAPA: (a) Rebalance training data (+2000 road marking images). (b) Expand ODD clause 5 with 'high-reflectivity road conditions'. (c) Deploy model v1.2 via OTA. | Patch: OTA_AEB_v1.2 deployed to fleet 2026-04-10. | Evidence: Field test results (0 false triggers in 50K miles post-patch). | Closure: 2026-04-25.

Field Monitoring Process Design (ASPICE SUP.10, 26262-7 Cl.6, 21434 Cl.12): Monitoring process converts raw telemetry into actionable intelligence. Process flow: (1) Data collection (vehicles transmit telemetry to cloud daily). (2) Aggregation (consolidate 50K vehicle streams). (3) Anomaly detection (identify incidents exceeding thresholds). (4) Classification (is incident safety? security? SOTIF? AI drift?). (5) Triage (assign severity S0-S4, assign owner). (6) Root cause analysis (data science team investigates). (7) CAPA initiation (create corrective/preventive action). (8) Monitoring (track CAPA status). Data collection architecture: vehicle → cellular/WiFi → cloud data warehouse (AWS S3). Data types: safety events (AEB engagement count per trip, brake pressure anomalies), security events (OTA rejection, invalid signature), SOTIF events (false braking trigger, undetected pedestrian), AI metrics (CNN confidence mean/stddev, inference latency percentiles). Telemetry frequency: high-priority (safety/security events) → real-time streaming. Low-priority (metrics) → daily batch. Data retention: safety events 7 years (regulatory), security events 3 years (CISO requirement), metrics 1 year (trending). Privacy: PII (location, driver identity) encrypted end-to-end, deleted after 30 days. Regulatory: GDPR compliant (anonymize before retention). Evidence: monitoring process SOP (detailed steps),

data collection architecture diagram, telemetry schema (all fields defined), anomaly detection thresholds document, CAPA process integration (how monitoring triggers CAPA initiation).

Anomaly Detection & Alert Strategy (26262-7 Cl.6, ASPICE SUP.10): Thresholds define 'incident' vs. 'normal variation'. Safety anomaly thresholds: (a) False AEB trigger rate >0.1 per 100K miles (baseline 0.01). Alert: S2 (high). (b) AEB engagement $<1K$ times over 50K vehicle-miles (indicates sensor failure). Alert: S3 (medium). (c) Brake pressure anomaly >1 per 1K miles. Alert: S2. Security anomaly thresholds: (a) OTA packet rejection $>5\%$ (indicates possible attack). Alert: S1 (critical). (b) Unauthorized firmware detected (mismatch between SW version + signature). Alert: S0 (critical, immediate response). (c) Multiple failed authentication attempts (possible keyless entry hack). Alert: S2. SOTIF anomaly thresholds: (a) Triggering event rate (false braking, missed detection) >0.1 per 100K miles. Alert: S2. (b) ODD boundary exceedance (e.g., vehicle operating at altitude $>2000m$ when spec limit is $1500m$). Alert: S3. AI drift thresholds: (a) Detection confidence mean drops $>20\%$ over 7-day window. Alert: S2 (potential model drift, retraining trigger). (b) Inference latency p95 $>150ms$ (was $<100ms$ in pre-deployment). Alert: S3 (performance degradation, investigate). (c) False positive rate $>2\%$ (was $<1\%$). Alert: S2. Alert automation: dashboard generates alerts (Grafana/DataDog), routed to on-call engineer (Slack, email). Response SLA: S0=immediate (within 1 hour), S1=24h, S2=72h, S3=1 week. Evidence: threshold definition document (all thresholds with justification), alert configuration (code + parameters), alert history log (incidents triggered, response time).

Root Cause Analysis & CAPA Integration (ISO 26262-7 Cl.6, 21434 Cl.12, ASPICE SUP.10): When incident detected, investigation begins. Example incident: INC-2026-0847 'False AEB trigger on high-reflectivity road paint'. RCA steps: (1) Reproduce issue (collect affected vehicle's telemetry, identify trigger conditions: high-reflectivity road paint, noon sun glare, speed ~ 30 km/h). (2) Hypothesize root cause (CNN trained on low-reflectivity road data, model confused paint for pedestrian). (3) Validate hypothesis (retrain model on limited data, confirm paint triggers false detection; retrain with paint images, confirm fixed). (4) Classify root cause: data gap (training dataset lacked road paint diversity) vs. design gap (ODD didn't mention high-reflectivity road conditions) vs. tool/process gap (data curation process didn't include 'adversarial road conditions'). For INC-2026-0847: classification = data gap + design gap (ODD too narrow). CAPA: (a) immediate action (interim model v1.1: lower confidence threshold $0.5 \rightarrow 0.7$, reduces false triggers at cost of higher miss rate, acceptable short-term). Deploy OTA immediately, monitor effectiveness. (b) permanent action (expand training dataset: +2000 road paint images, +1000 rain images, +800 snow images; retrain model; expand ODD Clause 5 to explicitly mention high-reflectivity road conditions). (c) process improvement (data curation process: checklist now includes 'road surface reflectivity: low/medium/high; conditions: sunny/cloudy/night'). CAPA tracking: incident $\rightarrow$ CAPA created $\rightarrow$ CAPA tasks assigned (data curators, ML engineers, safety engineer) $\rightarrow$ tasks completed (interim patch, permanent fix, process update) $\rightarrow$ CAPA verified (field test 50K miles post-patch, zero false triggers) $\rightarrow$ CAPA closed. Evidence: RCA investigation report (hypothesis, validation steps, conclusion), CAPA plan (immediate + permanent + process improvement), CAPA closure evidence (test results, process update memo).

10.4 Production Control & Quality Assurance

ISO 9001 Cl.8.5 & IATF 8.5 mandate process control over manufacturing & assembly. For software/firmware:

Software Build Control (26262-7 Cl.5, ASPICE SUP.9): Each production vehicle receives firmware binary from secured build system. Traceability: Git commit hash $\rightarrow$ build log $\rightarrow$ binary hash (SHA-256). Verification: firmware signature checked at boot (secure boot per 21434 Cl.8). No manual patches post-build.

Configuration Management (IATF 8.5, ASPICE SUP.9): Calibration data (sensor offsets, thresholds) versioned per vehicle serial number. OTA capability: safe rollback to previous firmware version on failure.

Process Audit (ISO 9001 Cl.9.2, ASPICE SUP.9): Monthly audit: firmware release checklist (all gating criteria met?), OTA deployment status, incident resolution rate. KPI: zero unauthorized firmware versions in field.

10.5 OTA Updates & Secure Change Management

Over-The-Air (OTA) updates apply patches (safety, security, SOTIF, AI model) to field vehicles. Governance: 26262-7 change control + 21434 Cl.8 secure OTA (UN R156) + 8800 Cl.11 model update safety.

OTA Deployment Workflow (ASPICE MAN.6):

(1) Change request (incident ID, standard(s), risk level). (2) Verification: test patch on representative vehicle. (3) Approval gate: Chief Safety Officer, CISO, Quality Manager sign-off. (4) Cryptographic signing (RSA-4096). (5) Staged deployment (5% fleet → 25% → 100%). (6) Rollback plan if adverse telemetry detected. (7) Post-deployment monitoring (metrics for 30 days).

UN R156 Compliance (Secure OTA, 21434 Cl.8):

OTA packet structure: [OTA_Header | Encrypted_Payload | Signature]. Header: target ECUID, firmware version, timestamp. Encryption: AES-256-GCM. Signature: RSA-4096(SHA-256(payload)). Vehicle verification: (a) Signature valid? (b) Timestamp ≤ current time + 24h (anti-replay)? (c) Version number ≥ current (no downgrade)? (d) ECUID matches? If all pass → decompress, flash, reset. If fail → reject, log security event.

Change Management & Approval Workflow (26262-7 change control, 21434 secure OTA, 8800 model update):

Change request (CR) initiated: incident triggers need for patch (e.g., INC-2026-0847 false AEB triggers). CR details: incident ID, standards affected (26262/21448/8800), risk level (safety/security/performance), proposed fix (retrain CNN, expand ODD). Change verification: patch developed and tested on representative vehicle (safety tests pass, security scan zero findings, adversarial robustness confirmed). Change approval: three-gate approval (safety → security → quality). Gate 1 (Safety): CSO approves change mitigates safety risk (e.g., 'Retrained CNN improves night detection from 85% to 98%, reduces false trigger rate from 0.8 to 0.2 per 100K miles'). Gate 2 (Security): CISO approves no new vulnerabilities introduced (SAST rescan zero new findings). Gate 3 (Quality): QA Manager confirms test coverage adequate for change scope (regression tests cover CNN module + all affected interfaces). Approval sign-off: CSO, CISO, QA Manager signatures (physical or electronic) on change approval form. SLA: approval decision within 48 hours of CR submission. If rejected, reasons documented, CR revised, resubmitted. Evidence: change request form, verification test results, gate approval form (signed), approval decision log.

Model Update Governance (8800 Cl.11):

AI model OTA: includes model weights + version tag + performance baseline. Pre-deployment validation: model inference latency ≤ SLA (≤100ms p95), confidence distribution matches training (no drift), adversarial robustness ϵ unchanged ($\epsilon \geq 0.05$). Validation process: (1) load model on representative vehicle hardware (same GPU/CPU as production). (2) run 10K inference samples (same image distribution as training). (3) confirm latency p95 ≤ 100ms, accuracy ≥ 95%, confidence stddev within training baseline ±5%. (4) run adversarial test suite ($\epsilon \in [0, 0.3]$); confirm confidence drop ≤ 20% for $\epsilon \leq 0.05$. If all pass → green light for deployment. Else → fix (retrain, quantize for speed) and retest. Post-deployment monitoring (8800 Cl.11): after OTA deployed to vehicle, monitor actual-world performance. Metrics: accuracy on field data (bin by ODD factors: weather, time-of-day, road-type). Daily accuracy report: sunny=97%, rain=94%, night=91%, snow=88% (target ≥ 95% except snow which is ODD boundary, acceptable). Drift detection: if accuracy mean drops > 5% over 7-day window (e.g., 95% → 90%), alert (potential data drift). Investigation: is model confidence degrading (adversarial attacks in field)? Is data distribution shifting (new weather pattern)? Response: if drift confirmed, trigger retraining (collect new field samples, retrain model, deploy OTA v1.3). Evidence: model validation report (pre-

deployment), deployment release notes (model version, expected performance), post-deployment monitoring dashboard, drift detection alert log (if any alerts triggered).

OTA Deployment Coordination (26262-7, 21434 Cl.8, ASPICE MAN.6): Deployment is coordinated rollout to minimize fleet-wide risk. Staged deployment: (phase 1) 5% of fleet (~2500 vehicles) → monitor for 48 hours (any adverse telemetry?). If telemetry normal (no new anomalies, metrics stable) → phase 2. If anomalies detected → pause, investigate, rollback. Phase 2: 25% of fleet (~12500 vehicles). Monitor 48 hours. Phase 3: 100% (~50000 vehicles). Rollback procedure: if false trigger rate jumps from 0.2 to 0.8 per 100K miles during phase 1, auto-trigger rollback. Rollback execution: (1) OEM notifies fleet (via telematics notification system). (2) vehicles request rollback from OTA server. (3) server sends OTA downgrade packet (reverts to previous firmware v1.1). (4) vehicle verifies signature, applies rollback. (5) telemetry confirms: false trigger rate back to pre-patch baseline (0.8 → acceptable on interim mitigation). Rollback timeline: <6 hours for full fleet. RCA of rollback: patch introduced regression (something broke). Post-rollback: fix regression, re-test, re-deploy (if confidence high) OR ship alternative fix (interim mitigation acceptable long-term if necessary). Evidence: deployment plan (phase 1/2/3 vehicle counts + timeline), rollback procedure (technical steps), rollback trigger criteria (what adverse telemetry threshold?), deployment monitoring log (phase transitions, metrics, rollback event if occurred).

10.6 Incident Response & Recall Management

Multi-standard incident response playbook (26262-7 Cl.6 Safety Anomaly + 21434 Vulnerability Disclosure + IATF nonconformity):

PSIRT (PRODUCT SECURITY INCIDENT RESPONSE TEAM) — 21434 CL.12-13

Contact: security@company.com. Response SLA: S1 (critical) 24h, S2 (high) 72h, S3 (medium) 1 week. Process: (1) Triage (severity, affected units). (2) Root cause (security analysis team). (3) Fix development. (4) Verification (penetration test validation). (5) OTA patch & release notes. (6) Disclosure timeline (coordinated with researcher, 90-day standard). Evidence: PSIRT report, disclosure timeline, patch availability, CVE registration (if applicable).

SAFETY ANOMALY RESPONSE — 26262-7 CL.6

Trigger: incident rate >3 per 100K vehicles per month, or single event with injury potential. Process: (1) Investigation (root cause analysis, failure mode). (2) Interim mitigation (SW workaround, customer advisory). (3) OTA patch development & validation. (4) Field retrofit or OTA deployment. (5) Effectiveness check (incident rate post-patch). Evidence: anomaly report, root cause analysis, CAPA plan, patch release notes.

Incident Response Procedure (Unified PSIRT + Safety Anomaly + SOTIF Event + AI Drift):

Unified incident response playbook covers all four incident types (21434 vulnerability, 26262 safety anomaly, 21448 SOTIF event, 8800 AI drift). Entry point (incident received): (1) security researcher reports exploit. (2) customer reports AEB false trigger. (3) monitoring system detects confidence drop. Triage (severity assignment): S0 (critical) = active exploit, injury potential, or widespread impact (>1% fleet). Response SLA: 1 hour. S1 (high) = limited impact (<1% fleet) or moderate exploit. SLA: 24 hours. S2 (medium) = edge case, low exploit impact. SLA: 72 hours. S3 (low) = cosmetic, no safety impact. SLA: 1 week. S4 (future) = deferred to next release cycle. For each incident: initiate unified response process: (step 1) notify relevant teams (safety for S0-S1, security for vulnerabilities, AI team for drift). (step 2) technical investigation (RCA). (step 3) interim mitigation (if urgent). (step 4) permanent fix (code change, retraining, process improvement). (step 5) verification (test patch). (step 6) deployment (OTA staging, rollback plan). (step 7) post-deployment monitoring (30 days). Example INC-2026-0847 timeline: 2026-03-15 (incident detected) → 2026-03-16 (RCA

complete) → 2026-03-18 (interim patch deployed) → 2026-04-01 (permanent fix ready) → 2026-04-10 (permanent patch deployed) → 2026-05-15 (CAPA closed). Evidence: unified incident response procedure document (steps for each incident type), incident record (timeline, actions taken, ownership), RCA report, CAPA closure checklist.

PSIRT Coordination (21434 Vulnerability Disclosure, CVE Registration): PSIRT (Product Security Incident Response Team) handles security vulnerabilities. Disclosure workflow: (1) researcher reports vulnerability (email security@company.com). (2) PSIRT acknowledges receipt (within 24h). (3) PSIRT confirms reproducibility (tries to reproduce exploit). (4) PSIRT assigns CVE ID (via MITRE/NVD). (5) severity assessment: CVSS v3.1 score (critical=9-10, high=7-8.9, medium=4-6.9, low=0-3.9). Example: CWE-89 SQL injection → CVSS 8.1 (high). (6) disclosure timeline negotiation: 90-day coordinated disclosure (industry standard). OEM/supplier has 90 days to develop patch before public disclosure. If patch available <90d, disclose earlier. (7) patch development (if 26262 safety also affected, parallel safety response; if 21448 SOTIF also affected, assess residual risk). (8) patch verification (testing against CVE proof-of-concept). (9) patch deployment (OTA). (10) CVE post (National Vulnerability Database). Example: CVE-2026-12345 'AEB firmware RCE via CAN message injection'. CVSS 9.1 (critical). Disclosure timeline: Day 0 (report), Day 1 (confirm), Day 30 (patch ready), Day 40 (patch deployed to 100% fleet), Day 41 (CVE post public + release notes). Evidence: PSIRT SOP (disclosure timeline, CVE assignment process, severity scoring), PSIRT incident log (all reported vulnerabilities, status), CVE tracking (NVD links), patch deployment evidence (OTA release notes).

Recall Coordination (IATF 10.2.5, 21434 Cl.13, ASPICE MAN.6):

If OTA patch insufficient or infeasible: coordinate with customer (OEM, fleet operator) on remediation. Remediation options: (a) OTA patch (preferred, 90% fleet adoption within 30 days). Success rate: high for connected vehicles, lower for offline-only vehicles. (b) Dealer update (customer brings vehicle to service center for software reflash). Participation rate: ~50% (many vehicles never return to dealer). (c) Voluntary recall (legal/regulatory requirement if safety risk > threshold). Cost: high (\$1000/vehicle × 50K = \$50M). Participation: 80-90%. Decision logic: incident severity (S0-S1) + fleet size affected (>10% or all-of-market) + remediation difficulty (simple patch vs. HW change) → determine recall necessity. If patch fixable in SW, OTA preferred (lower cost, higher compliance). If HW change required, recall needed. Example INC-2026-0847: software-fixable (retrain CNN + firmware update) → OTA deployment (no recall). Regulatory notification: if incident involves safety or security, notify NHTSA (US) / EASA (EU). File report within 5 days of determining remediation needed. Report includes: incident description, root cause, remediation plan (OTA vs. recall), timeline. Evidence: recall decision rationale (why OTA sufficient), regulatory filing (NHTSA/EASA report), customer notification (email/SMS to owners), remediation effectiveness check (incident rate post-patch).

10.7 Operational Monitoring & Metrics

Fleet telemetry feeds operational dashboard (ASPICE MAN.6 monitoring & control):

Safety Metrics (26262-7 Cl.6): Incident rate per million miles. MTBF (mean time between failures) by functional failure mode (26262-5 Annex F). Trend analysis: is MTBF improving post-patch? Target: ≥ FMEA random failure estimate.

Security Metrics (21434 Cl.12): Vulnerability disclosures per year. MTTR (mean time to response). Patch deployment rate (% of fleet patched within 30 days). Zero-day incidents. Exploit attempts logged (if intrusion detection active).

SOTIF Metrics (21448 Cl.12): Triggering event rate per ODD scenario. False braking rate (AEB trigger without pedestrian). Missed detection rate (pedestrian present, no AEB). Residual risk trend: is risk ≤ tolerable level?

AI Monitoring (8800 Cl.11): Model inference latency (p50, p95, p99 percentiles). Detection confidence distribution (mean, stddev). Adversarial flag rate (how often model output unreliable?). Data drift detection: feature distribution change >10%? → trigger retraining. Model drift: accuracy drop >5% → alert operations.

Dashboard Cadence: Real-time alerts (S0-S1 incidents), daily digest (incident count, deployment status), weekly trend (metrics rolling average), quarterly review (CAPA effectiveness, improvement initiatives).

10.8 Decommissioning & Data Management

End-of-life vehicle or technology obsolescence requires safe shutdown & data protection (26262-7 Cl.7, 21434 Cl.14).

Safe State Assurance (26262-7 Cl.7): Vehicle reaches safe state before shutdown. AEB system: springs release brakes to neutral. AI models: inference disabled (fallback to default safe behavior). No active hazards. Evidence: design specification of safe state, shutdown procedure validation.

Key Revocation (21434 Cl.14): Cryptographic keys used for OTA signing, firmware verification, authentication: revoked in central key server. Vehicles beyond EOL period cannot receive spoofed OTA packets. Timeline: keys revoked ≤30 days after last security patch release.

Data Erasure (21434 Cl.14, GDPR): Telemetry data (vehicle location, driver behavior, sensor readings) stored on vehicle: securely erased via AES-256 overwrite (NIST SP 800-88) or physical destruction. Certificate of Destruction maintained. Timeline: ≤90 days post-EOL.

Model Archival (8800 Cl.11): Final trained model version (weights, architecture, training metadata): archived in secure repository with legal hold (7-year retention for safety audit). Lineage preserved (training dataset version, framework version, performance metrics). Purpose: future investigation if latent safety issue discovered.

Decommissioning Timeline & Regulatory Compliance (26262-7 Cl.7, 21434 Cl.14): Vehicle EOL triggered by: (1) manufacturer EOL (e.g., AEB platform support ends 2032). (2) fleet operator retirement (vehicle scrapped after 10 years service). (3) technology obsolescence (replaced by newer safety system). Timeline: vehicle announced EOL → 6-month notice period (allow last OTA patches, customer preparation) → EOL effective date → key revocation (30 days post-EOL), data erasure (90 days post-EOL), archive retention begins (7-year hold). Key revocation (21434 Cl.14): cryptographic keys used for OTA signing, firmware verification, authentication invalidated in key management system. Affected keys: RSA-4096 firmware signing key, HMAC-SHA256 CAN message keys, TLS certificates (if OTA server uses client certs). Revocation process: (1) CSO issues revocation order (document: reason + date + affected systems). (2) PKI administrator revokes keys in Certificate Authority (CA) + CRL (Certificate Revocation List). (3) OTA server updated: keys removed from trusted list. (4) vehicles post-EOL receive no OTA updates (keys invalid, no signature match). Safety rationale: prevent attackers from crafting valid OTA packets using retired keys (keys no longer secure after 7 years, likelihood of compromise increases). Data erasure (21434 Cl.14, GDPR): telemetry stored on vehicle (flash memory) contains: vehicle location (privacy), driver behavior (acceleration patterns), sensor readings (lidar point clouds, camera frames). Data must be securely erased before vehicle recycling (prevent privacy breach). Erasure method: AES-256 overwrite (per NIST SP 800-88 standards) or physical destruction (shredding vehicle HDD). Verification: after erasure, random read from vehicle flash should return random data (not original telemetry). Certification: destruction vendor provides Certificate of Destruction (Chain-of-Custody maintained). Evidence: decommissioning procedure (timeline, steps, responsibilities), key revocation document (keys revoked, date), data erasure certificate (method, date, vendor sign-off), archive retention policy (7-year hold, storage location, access control).

Archival & Long-Term Preservation (8800 Cl.11, 26262-7 Cl.7): Post-decommissioning, artifacts preserved for legal/safety investigations. Retention scope: (1) final trained model version (weights + architecture + training hyperparameters). (2) training dataset (lineage, versions, bias audit results). (3) deployment logs (SW version, test results, OTA deployment history). (4) operational monitoring data (1 year representative sample of vehicle telemetry). (5) incident records (all reported anomalies + RCA + CAPA closure). (6) assurance cases (safety case, security case, SOTIF case, AI safety case). Retention period: 7 years (vehicle end-of-life date + 7 years = potential latent defect discovery timeline). Storage: secure repository (encrypted storage, access control, immutable archive). Example: AWS S3 with versioning + encryption + MFA. Access control: read-only for authorized investigators (CSO, CISO, legal, regulators). Audit log: all archive accesses logged. Purpose of preservation: if vehicle incident occurs post-release (e.g., false AEB trigger in 2030 causes accident), investigation can: (1) retrieve original model weights + training data + test results → confirm model was safe at release. (2) retrieve operational monitoring data → check if model drifted post-deployment (data shift, adversarial examples). (3) retrieve deployment logs → check if incorrect version deployed (configuration error). (4) retrieve incident records → check if anomaly was pre-release known issue (accepting residual risk). Preservation lifecycle: archive stored ≥ 7 years. After retention expires, confidential deletion (disk shredding, cryptographic erasure). Evidence: archival SOP (what to preserve, retention period, storage location, access control), archive catalog (inventory of all preserved artifacts), destruction certification (post-retention deletion proof).

10.9 ASPICE Operational Processes

SUP.9 (Software Support & Maintenance): Establish SW support organization (helpdesk, escalation). Maintain SW baseline & patches in version control. Provide customer updates (release notes, known issues).

SUP.10 (Problem Resolution): Log all problems (incidents, defects, improvement suggestions) in unified register. Triage & investigate. Link to CAPA. Track closure. Metrics: problem resolution rate, average time-to-fix.

MAN.6 (Management of Monitoring & Control): Establish monitoring plan (fleet telemetry, incident tracking). Collect metrics per standard. Report status (health dashboard). Trigger corrective action if metrics exceed thresholds. Review effectiveness of actions & continuous improvement.

10.10 Worked Mini-Example: Unified Field Monitoring for AEB System

Scenario: AEB system deployed to 50K vehicles over 6 months. Incident INC-2026-0847 above triggered by field data. Here: walk through unified monitoring & response workflow.

Timeline & Actions:

2026-03-15: Field telemetry alerts: AEB false trigger rate elevated (0.8 per 100K miles, baseline 0.1).

Classification: SOTIF event + AI drift (false detections correlate with low lighting).

2026-03-16: Safety team investigates. Hypothesis: CNN trained on daytime images, poor night performance.

Root cause confirmed: training dataset imbalance (95% daytime, 5% night).

2026-03-18: Interim mitigation: lower AEB confidence threshold to 0.7 (was 0.5). Deploy via OTA_AEB_v1.1.

Rationale: reduce false triggers (at cost of slightly higher miss rate in edge cases). Risk accepted until permanent fix ready. Monitoring: check if false trigger rate drops.

2026-03-22: Interim patch deployed to 100% of fleet. False trigger rate drops to 0.4 per 100K miles. Miss rate increases to 0.3 (acceptable, within residual risk budget).

2026-04-01: Permanent fix ready. Retrain CNN on expanded dataset (+2000 night images, +1000 rain images, +800 snow images). New model v1.2 validated: adversarial robustness $\epsilon=0.05$ maintained, accuracy on night/weather scenarios $\geq 95\%$. ODD definition updated: Clause 5 now includes 'low-light conditions ($\text{lux} \geq 1$) and adverse weather (rain, snow, fog)'.

2026-04-10: OTA_AEB_v1.2 deployed (model weights + firmware fix + ODD update). Staged: 5% fleet $\rightarrow$ 25% $\rightarrow$ 100%. Rollback procedure: if false trigger rate > 0.6 , automatic revert to v1.1.

2026-04-10 to 2026-05-10: Post-deployment monitoring. False trigger rate: 0.15 per 100K miles (normal). No rollback triggered. Confidence building.

Incident Lifecycle Walkthrough (Detection $\rightarrow$ Investigation $\rightarrow$ Mitigation $\rightarrow$ Permanent Fix $\rightarrow$ Closure):

2026-03-15 (Detection): Fleet telemetry alert: AEB false trigger rate elevated to 0.8 per 100K miles (baseline 0.01). Dashboard flagged as S2 (medium severity). On-call safety engineer notified via Slack. Preliminary data analysis: false triggers correlated with low-light conditions (night + twilight). Hypothesis: CNN model trained on day images, performs poorly at night. Incident entry: INC-2026-0847 created in issue tracker with classification: SOTIF event + AI drift. Assigned to: Safety Lead (investigation) + AI/ML Lead (root cause analysis) + Operations Lead (interim mitigation planning).

2026-03-16 to 2026-03-17 (RCA): Data science team analyzes model behavior. Deep-dive findings: CNN confidence distribution on night images: mean=0.35 (vs. day=0.92), stddev=0.18 (high uncertainty). Reasoning: training dataset composition analysis: 95% daytime images, 5% night images. Model overfits to daytime features (color, texture). Validation: test model on night-only subset: accuracy 62% (vs. day 98%). Evidence of data imbalance. Safety implication: low confidence night detections below 0.5 threshold $\rightarrow$ AEB not triggered (safe) BUT misses real pedestrians (residual risk). ODD clause 5 review: states 'lighting: daytime or dusk'. Does NOT mention night/1-lux minimum $\rightarrow$ ODD violation (vehicle operating outside spec). Root cause confirmed: dual cause = (a) training data imbalance (data gap), (b) ODD definition too narrow (design gap). RCA report filed in incident tracker. Assigned severity: S2 (elevated false trigger but interim mitigation available, no injuries reported).

2026-03-18 (Interim Mitigation): Operations team proposes interim fix: lower AEB confidence threshold from 0.5 to 0.7. Rationale: in night conditions, CNN confidence drops 35-40%. At 0.5 threshold, many false detections. At 0.7 threshold, threshold avoids near-zero confidence outputs. Trade-off: fewer false triggers (good for SOTIF residual risk), higher miss rate for real pedestrians (bad for safety). Risk assessment: interim threshold acceptable for 2-3 weeks (until permanent fix ready). Mitigation approved by CSO + CISO + AI Lead. OTA_AEB_v1.1 built (firmware change: threshold config updated). Testing: v1.1 tested on night data: false trigger rate = 0.4 per 100K miles (down from 0.8). Miss rate = 0.3 (up from 0.05). Acceptable per risk budget. OTA_AEB_v1.1 deployed to 100% fleet over 24 hours (staged rollout: 5% $\rightarrow$ 25% $\rightarrow$ 100%, no rollback triggered). Interim incident status: INC-2026-0847 marked 'Mitigation Applied', CAPA initiated for permanent fix.

2026-03-22 to 2026-03-31 (Permanent Fix): ML engineers retrain CNN on expanded dataset. Data augmentation: +2000 night pedestrian images (collected from night driving + synthetic via data augmentation tools like CycleGAN for day $\rightarrow$ night translation). +1000 rain images, +800 snow images. New dataset: 84K images (previous 80K + 4K augmented). Retraining: hyperparameters held constant (architecture unchanged, learning rate same). Training reproducibility: seed fixed, framework pinned (PyTorch 1.13.1). Retraining results: model v1.2 night accuracy = 98% (up from 62%), day accuracy = 97% (maintained, minimal degradation). Adversarial robustness test: L2 perturbation $\epsilon=0.05 \rightarrow$ confidence drop 16% (meeting $\epsilon=0.05$ requirement of $<20\%$). $\checkmark$ Robustness maintained. ODD expansion: Clause 5 updated to include 'low-light conditions ($\text{lux} \geq 1$)' + 'adverse weather (rain, snow, fog)'. Model v1.2 validation: tested on night+rain+snow

scenarios → accuracy ≥95% across all ODD conditions. ✓ Ready for deployment. OTA_AEB_v1.2 built (model weights + firmware + ODD update). Change approval: CSO approves safety improvement (92% → 98% night accuracy), CISO confirms no new vulnerabilities (SAST rescan zero critical findings), QA confirms test coverage adequate. OTA_AEB_v1.2 staged deployment begins 2026-04-10.

2026-04-10 to 2026-05-10 (Post-Deployment Monitoring): OTA_AEB_v1.2 deployed in phases. Phase 1 (5% fleet): 2026-04-10. Monitoring window: 48 hours. False trigger rate: 0.15 per 100K miles. ✓ No adverse telemetry. Proceed to Phase 2. Phase 2 (25% fleet): 2026-04-11. False trigger rate (phase 1+2): 0.18 per 100K miles. Stable, acceptable. Proceed to Phase 3. Phase 3 (100% fleet): 2026-04-12 to 2026-04-15. Rollback criterion (if false trigger >0.6): NOT triggered. Post-deployment stabilization: 30-day observation period (2026-04-15 to 2026-05-15). Daily metrics dashboard: false trigger rate = 0.10-0.20 per 100K miles (normal variation). Model confidence distribution: mean=0.88 (day), 0.85 (night) → balanced. No data drift detected (confidence mean stable ±2%). Model latency: p50=18ms, p95=42ms (unchanged from pre-patch). ODD adherence: 0 vehicles operating outside ODD (lux >1, standard weather conditions). Safety: zero AEB-related incidents (no injuries, no customer complaints). Operational: 100% deployment success, zero rollback events. Incident status: INC-2026-0847 marked 'Ready for Closure'.

2026-05-15 (CAPA Closure): Incident closed with comprehensive CAPA evidence. CAPA summary: (a) Root cause: training dataset imbalance → mitigation: retrained CNN on 84K images (includes night/rain/snow). (b) Design gap: ODD too narrow → mitigation: updated ODD Clause 5 (now includes 'low-light ≥1 lux' + 'adverse weather'). (c) Process gap: data curator checklist incomplete → mitigation: added 'adversarial scenarios' checklist item (night, weather, edge cases required going forward). Evidence: field deployment metrics (50K post-patch miles, 0.15 false trigger rate, zero incidents). Post-deployment test results (night accuracy 98%, adversarial robustness $\epsilon=0.05$ pass). Updated ODD document (signed by Safety Lead). Data curator SOP update (new checklist items, effective for future models). CAPA closure approved by CSO + CISO + Quality Manager. Incident closed. Lessons learned: (1) training data composition critical for ODD coverage (night requires explicit night samples, not just day samples). (2) ODD definition must be testable (if ODD says 'night', test data must include night scenarios before release). (3) interim mitigation (threshold change) useful for buying time for permanent fix (model retraining).

Unified Incident Register Evidence (INC-2026-0847):

Standards: 26262 (safety anomaly) / 21448 (SOTIF trigger event) / 8800 (AI drift).

Severity: S2 (elevated false trigger, but interim mitigation deployed, no injuries reported).

Root Cause: training dataset imbalance (data quality gap), ODD definition incomplete.

CAPA: (1) rebalance training data, (2) expand ODD, (3) enhance data validation SOP.

Patch: OTA_AEB_v1.1 (interim, 2026-03-18), OTA_AEB_v1.2 (permanent, 2026-04-10).

Closure: 2026-05-15. Evidence: post-deployment metrics, CAPA closure report.

PART III

End-to-End Worked Examples

Chapters 11–12

CHAPTER 11: COMPLETE EXAMPLE — ADAS FORWARD CAMERA ECU

SCOPE

Comprehensive lifecycle walk-through of an L2+ ADAS forward camera ECU. Demonstrates integrated application of ISO 26262 (functional safety), ISO 21434 (cybersecurity), ISO 21448 (SOTIF), IATF 16949, and ASPICE v4.0. ASIL B with ASIL D elements; CAL 3 (safety-related, indirect attack).

11.1 Concept Phase

The concept phase establishes scope, identifies hazards and threats, defines safety goals, and allocates requirements across the system architecture. This phase is critical for multi-standard integration, requiring unified treatment of functional, safety, security, and performance concerns. All hazards identified in the Hazard Analysis and Risk Assessment (HARA) must simultaneously be evaluated against threat vectors (TARA), SOTIF triggering conditions, and performance targets to ensure complete coverage.

11.1.1 Unified Item Definition

Integrated table covering functional scope, safety scope, security scope, and SOTIF scope per ISO 26262:2018 Cl. 4.3, ISO 21434:2021 Cl. 5.3.2, ISO 21448:2022 Cl. 4, and ASPICE SUP.1. The item definition is the single source of truth that anchors all downstream analysis. Forward Camera ECU (FCAM) is a vision processing system for real-time perception of road participants and infrastructure. The system captures raw imagery at 30 frames per second from a single 8-megapixel front-facing camera, preprocesses via Image Signal Processor (ISP) pipeline, and executes deep neural network inference on NVIDIA Orin SoC (12-core ARM + Ampere GPU @ 200 TFLOPS) to generate three safety-critical outputs: (1) Autonomous Emergency Braking (AEB) trigger decision, (2) Lane Keeping Assist (LKA) steering guidance, and (3) Traffic Sign Recognition (TSR) advisory displays. Hardware includes dedicated security module (TrustZone TEE) for secure boot and cryptographic operations, plus independent watchdog circuit for safe-state fallback on firmware faults.

Aspect	Definition	Clause Ref	Owner
Item Name	Forward Camera ECU (FCAM)	26262:4.3.1	Safety Lead
Functional Description	Real-time monocular vision processing for AEB (ASIL B), LKA (ASIL B), TSR (ASIL A); runs @ 30 FPS on NVIDIA Orin SoC; 120° horizontal, 50° vertical FOV; CAN-FD interface to body ECU	26262:4.3.1, 21434:5.3.2	System Architect
Functional Boundary	Image acquisition (camera ISP) → HSM (Host System Memory) decision output; excludes post-processing in ECU-Main or instrument cluster rendering	26262:4.3.1	Safety Lead
Operational Design Domain (ODD)	Highway & urban (speed 0–120 km/h); daylight & twilight (lux 50–100,000); dry to light rain (≤10 mm/h); lane markings present; vehicle on roadway (not parking lot)	21448:4	Program Lead

Safety Scope	AEB trigger (ASIL B, max latency 80 ms), LKA guidance (ASIL B, steering angle accuracy $\pm 5^\circ$), TSR advisories (ASIL A, advisory only); failure modes lead to Severity 3–4 per ISO 26262 Table 3	26262:4.3.2	Safety Lead
Security Scope	Vehicle network interface (CAN-FD, isolated via gateway), firmware update path (HTTPS OTA), sensor spoofing risk (RF/IR injection possible on unshielded sensor). ASIL B item + CAL 3 threat level	21434:5.3.2	Security Lead
SOTIF Scope	Transient occlusions (rain droplets, ice, dust), extreme lighting (sun glare, tunnel transitions, nighttime), reflection artifacts (puddles, mirrors, bright signage), sensor degradation over 7-year lifecycle	21448:4, 5.2	SOTIF Lead
Intended Users	OEM production vehicles (Series A, B platforms); authorized service technicians for OTA rollout and manual updates	26262:4.3.1	Program Lead
Lifecycle Stage	Series production Years 1–7; end-of-support decommission at Year 8; regulatory retention 10 years post-production	26262:4.3.1	Program Lead

Table 11-1. Unified Item Definition — FCAM

11.1.2 Integrated HARA + TARA Results

Combined hazard and threat assessment per ISO 26262:2018 Cl. 5.3 and ISO 21434:2021 Cl. 6.3. This analysis identifies eight critical failure scenarios spanning safety hazards (5), cybersecurity threats (2), and SOTIF conditions (1 representative). Each hazard is evaluated for Severity (S) per ISO 26262 Table 3, Exposure (E) based on driving time, and Controllability (C) considering driver ability to mitigate. $ASIL = S \times E \times C$. Threats are rated by impact (safety/security), feasibility (low/medium/high), and CAL assignment (1–4). Mitigations reference specific technical requirements and V&V tests. The table provides traceability from raw hazards to downstream safety goals and cybersecurity goals.

ID	Hazard/Threat	Triggering Condition	S/E/C	ASIL/CAL	Mitigation Strategy	Ref
H1	AEB no trigger when pedestrian in path	Pedestrian misclassified (low light <100 lux, partial occlusion 30–50%, clothing color similar to road)	4/3/2	B	Redundant ResNet-50 CNN ensemble (3 models voting), synthetic rain/night training data (50K images), temporal consensus (3 consecutive frames)	26262:5.3.2, 21448:5.2
H2	LKA erratic lane guidance (>1 m	Lane marker degradation,	3/3/2	B	Lateral error Kalman filter with outlier rejection (3-sigma),	26262:5.3.2

	lateral jerk)	shadow/reflection confusion, wet road specular reflections doubling marker width			steering angle rate limiter (max 10°/s), road-edge detection confidence weighting	
H3	TSR false positive (limit sign 100 km/h misread as 60 km/h)	Speed sign confusion with graffiti/posters, similar-colored warning signs, partial occlusion by vegetation	2/2/3	A	CNN confidence threshold adaptive per sign category (min 95% for speed), road context verification (speed consistency check against vehicle state), 5K- image sign corpus validation	26262:5.3.2
T1	Malformed image input (OTA update inject malicious kernel)	Attacker modifies firmware on ECU via compromised OTA server or network injection	4/2/1	B/3	Secure boot (RSA-2048 signature verification), code signing (SHA- 256 hash), TrustZone TEE isolation, immutable bootloader in OTP ROM	21434:6.3.2, 8.4.2
T2	Sensor spoofing (IR light inject false AEB trigger)	Attacker uses IR LEDs mounted on bumper or external vehicle to saturate image sensor	4/2/2	B/3	Temporal consistency check (single frame insufficient), IMU correlation (brake not pressed), spectral filter on ISP pipeline, sensor test patterns	21434:6.3.2, 21448:5.2
T3	CAN flooding (denial of service, ECU overload)	Attacker floods CAN bus with 500+ frames/sec FCAM output frames via gateway injection	2/2/1	A/3	Frame validation (CRC-16 per ISO 11898-1), rate limiting on ingress (max 100 FCAM frames/sec), watchdog timeout on excessive queue depth	21434:6.3.2
S1	Heavy rain / snow on lens (total occlusion)	Precipitation (>10 mm/h) + rapid accumulation + defrosting heater inactive	4/3/2	B	Wiper detection input via vehicle CAN (wipers active = SOTIF mode enabled), histogram entropy detection (flat histogram → confidence reduction 25%), graceful fallback to LKA-only	21448:5.2
S2	Sudden high- sun glare (saturation artifact, blooming)	Sun angle <15° above horizon + low contrast surroundings + solar panel blooming in CMOS array	3/2/2	B	HDR preprocessing (multi- exposure fusion), pixel saturation detection (>10% saturated → glare flag), confidence reduction table per glare intensity, fallback to daytime-only mode	21448:5.2

Table 11-2. Integrated HARA + TARA Results

11.1.3 Safety Goals, Cybersecurity Goals & SOTIF Acceptance Criteria

Cross-referenced safety goals (ISO 26262 Cl. 5.4), cybersecurity goals (ISO 21434 Cl. 6.4), and SOTIF criteria (ISO 21448 Cl. 5, 6) integrated into single table. Five safety goals address the primary hazards from the HARA. Each safety goal includes target metric (e.g., probability threshold, false positive rate) and verification method (lab test, field trial, or combined). Three cybersecurity goals address authentication, spoofing detection, and availability. Four SOTIF criteria address performance in adverse ODD conditions. Acceptance criteria are numerical where possible (e.g., 95th-percentile false positive rate <0.1% across 50K test scenarios) to enable objective V&V.

Goal ID	Type	Statement	ASIL/CAL	Target Metric	Verification Method
SG1	Safety	Prevent unintended AEB trigger due to CNN misclassification in shadows, rain, occlusion	B	False positive rate <0.1% @ 95th percentile across 50K scenarios; latency ≤80 ms	Field trials (1M km); synthetic + real ODD scenarios; confusion matrix analysis
SG2	Safety	Detect & mitigate lane guidance erratic behavior (>1 m lateral jerk in 100 ms)	B	Jerk detection + inhibition ≥99% sensitivity; RMS steering error <0.15 m @ 100 km/h	Closed-loop HIL test; wet road lane slip scenarios; servo response analysis
SG3	Safety	Provide TSR advisory only when confidence ≥95%; no false-positive limit signs	A	TSR false positive rate <1% on 5K real-world sign corpus; precision ≥98% per sign category	Sign database validation; urban/highway field trials; weather-varied data
CSG1	Cybersecurity	Prevent unauthorized firmware modification via OTA update attack	3	0 undetected code injections in 1K adversarial firmware injection attempts; CVSS 9.8	Penetration testing (third-party lab); secure boot RSA verification audit; code signing chain review
CSG2	Cybersecurity	Detect sensor spoofing attacks (IR/RF injection) within 500 ms latency	3	Spoofing detection sensitivity ≥99%; mean detection latency <100 ms	Lab RF/IR injection tests; temporal sync validation; field data correlation with incident logs
SOTIF1	SOTIF	Maintain AEB confidence ≥80% when lens wet (wiper active); graceful mode switch	—	Rain test (ISO 5006 Annex B); lens coverage <30%; confidence remaining in [0.80, 1.0]	Sensor characterization in rain chamber; wet-lens ODD field trial (≥50 km in rain); driver acceptability
SOTIF2	SOTIF	Graceful degradation in high-glare scenes; switch to LKA-only mode automatically	—	Mode switch latency <500 ms; lane detection accuracy ≥95% in glare-only	Glare simulation rig (1000+ lux); dawn/dusk field trials; automated mode transition

				condition	validation
SOTIF3	SOTIF	Alert driver when ODD boundary crossed (e.g., dense rain, darkness, tunnel)	—	Alert onset within 1 s of ODD violation detection; driver acceptance >90% in user study	Real-world rain/snow trials; photometric characterization; HMI alert integration testing

Table 11-3. Safety Goals, Cybersecurity Goals & SOTIF Criteria

11.1.4 SOTIF Triggering Conditions Catalog

Comprehensive catalog of known triggering conditions per ISO 21448:2022 Cl. 5.2. These are operational scenarios that could cause unreasonable risk even if the system performs nominally within specification. For FCAM, the primary concern is performance degradation in adverse visibility, precipitation, and lighting conditions. The table maps each ODD scenario to CNN/sensor impact, detection approach, and acceptance threshold. Detection approach identifies how the system recognizes entry into high-risk conditions (e.g., wiper signal, histogram entropy). Acceptance threshold defines residual performance target when in that condition. This ensures SOTIF is not just about hazard avoidance but graceful performance under stress.

Scenario ID	Environmental/Use Condition	CNN/Sensor Impact	Detection Approach	Acceptance Threshold
ODD-1	Rain (moderate, 5–15 mm/h) on lens, wiper active	Reduced sharpness, occlusion patches, diffraction artifacts	Wiper velocity sensor + image blur metric (Laplacian variance)	CNN confidence >85%; fallback to LKA-only mode acceptable
ODD-2	Dense fog (visibility 20–50 m, RVR 50 m)	Low contrast, halo artifacts around lights, reduced edge definition	Histogram entropy check + ambient light level + optical feedback	Confidence >80% OR automatic mode switch to LKA only; no AEB triggers
ODD-3	Sun glare (low sun angle <15°, high intensity)	Saturation streaks, blooming in CCD rows, loss of dynamic range	Pixel saturation percentage >10% triggers glare flag; HDR enable	Auto-enable HDR; reduce AEB confidence by 25%; maintain >80% lane accuracy
ODD-4	Tunnel entry/exit (sudden lighting change 5–50 lux)	Temporal illumination transient, exposure hunting, white balance lag	Frame-to-frame lux difference >50%; LED flicker detection	Brake confidence hold for 1 s; LKA servo gain adjust +15%; no mode switch needed
ODD-5	Pedestrian partially occluded (30–50% obscured by parked car)	CNN sees partial bounding box, IOU <0.6, confidence reduced	Intersection-over-Union (IOU) metric in post-processing	Confidence reduced to 75%; require temporal consistency (3 frames); delay AEB by 200 ms
ODD-6	Reflective safety vest + dark night clothing on pedestrian	False edges/contours in CNN backbone feature maps, aspect ratio	Edge continuity score in CNN neck layers; reflectance map	Temporal overlap >2 frames required for AEB trigger; ensemble voting (2/3 models)

confusion				
ODD-7	Small child (height <1.2 m) far field (>60 m, <100 pixels height)	Limited pixel count (<100 px height), aspect ratio ambiguity	Aspect ratio + bounding box size + centroid stability check	AEB inhibited for small-stature detections; TSR advisory only; widen confidence interval
ODD-8	Road-edge standing water (mirror reflections, puddles)	Reflection doubles lane marker apparent width, false lane edge	Edge separation analysis; geometry plausibility check (lane width must be 3–3.5 m)	Lane tracking confidence decay factor = 0.8; require high-confidence center reference
ODD-9	Nighttime (lux <5), no street lights, on-vehicle lights only	Low SNR, amplified sensor noise, reduced color separation	Ambient light sensor <5 lux trigger; noise floor elevation monitoring	CNN confidence <60%; fallback to LKA-only (requires white line markings); no AEB
ODD-10	Motorcyclist / scooter (not primary ODD, edge case)	Aspect ratio & silhouette unfamiliar to CNN training, FN risk	Motorcycle classifier (separate lightweight CNN), ODD compliance flag	Degraded AEB confidence (~30%); alert driver via HMI; suggest manual awareness

Table 11-4. SOTIF Triggering Conditions Catalog (ISO 21448 Cl. 5.2)

11.2 System Design Phase

System design allocates safety, security, and SOTIF requirements to hardware, firmware, and system elements per ISO 26262 Cl. 6 and ISO 21434 Cl. 7. The design phase translates abstract goals into concrete architectural decisions with quantified failure mitigation. This chapter covers the top-level system architecture (block diagram logic), integrated requirements allocation matrix (goals → system requirements), safety mechanism table (redundancy/diagnostics per ASIL B target), and security control placement. All design decisions are justified with reference to specific standard clauses and failure modes from the FMEA.

11.2.1 Architecture Overview

Top-level system architecture with safety mechanisms and security controls co-located. The forward camera ECU comprises several functional blocks operating in a coordinated pipeline. Raw image data flows from the IMX390 sensor (8-megapixel, 1/1.3 inch CMOS) through the ISP pipeline for demosaicing, color correction, and exposure optimization. The preprocessed RGB image (416×416 or 1920×1208 depending on mode) is transferred to NVIDIA Orin SoC main memory via direct memory access (DMA) with CRC validation. The Orin's GPU executes a ResNet-50 backbone + Feature Pyramid Network (FPN) for multi-scale feature extraction, followed by three detection heads: AEB pedestrian detector (≥95% confidence threshold), LKA lane marker tracker (Kalman-filtered), and TSR sign classifier. Outputs (decision arrays + confidence scores) are staged in SRAM and arbitrated by dual-core ARM Cortex-A57 supervisor firmware, which enforces inhibition logic (e.g., no AEB if glare detected), applies temporal consistency checks, and formats CAN-FD messages. An independent hardware watchdog (TI TPS3803 or equivalent) monitors ARM heartbeat; timeout triggers ECU reset to safe state (brake hold via relay, steering neutral). All code execution is protected by Arm TrustZone TEE, with secure boot RSA-2048 signature verification in OTP ROM before any code transfer. OTA updates use HTTPS TLS 1.3 with certificate pinning + server-side signature validation before download authorization.

Component	Safety Function	Security Function	SOTIF Capability
IMX390 Sensor + ISP	Frame capture; temporal consistency verification via frame ID	Image integrity check (DMA CRC-32)	Thermal shutdown at >85°C; auto-exposure fallback to manual mode
NVIDIA Orin GPU (200 TFLOPS)	Real-time CNN inference (AEB/LKA/TSR) in parallel data streams	Trusted Execution in Ampere context; compute isolation per TEE	Inference watchdog (timeout >80 ms triggers fallback); thermal throttling managed
Dual ARM Cortex-A57 (1.9 GHz)	Supervisor firmware; mode transitions; WDG heartbeat; CAN arbitration	Code signing verification (RSA pre-computed); CAN message validation (CRC+counter)	Degradation mode selection logic; graceful shutdown on critical error
SRAM (64 MB Safety-Critical)	AEB decision state; temporal history buffers (3–5 frame latency)	Write-protect region via MPU; no DMA access; ECC on critical cells	Periodic self-test (MARCH-X) every 100 ms; soft-error detection
Flash (2 GB main + 256 MB OTA)	Code + data storage; OTA staging area	Read-only after boot (locked regions); secure partition for keys	Wear leveling; bad-block management; bitflip detection on critical code
CAN-FD Gateway (Isolated)	Message routing to brake/steering/instrument cluster; timeout monitoring	Message filtering (whitelist); rate limiting per source; spoofing detection via timing	Bus-off detection; fallback frame isolation; watchdog-triggered safe shutdown
Watchdog Circuit (TI TPS3803)	WDG refresh from firmware heartbeat; timeout (500 ms) → ECU reset	Tamper detection input (optional secure enclosure); anti-glitch logic	Safe fallback: brake hold via relay; steering neutral; instrument alert logic

Table 11-5. System Architecture Components & Functions

11.2.2 Technical Safety Concept (TSC) & Cybersecurity Specification Integration

Consolidated TSC (ISO 26262 Cl. 6.4) and cybersecurity specification (CSP, per ISO 21434 Cl. 7.4) excerpt showing how safety and security requirements are allocated to system elements. Each TSC requirement includes: (1) requirement ID and safety classification (AEB/LKA/TSR); (2) plain-language specification with threshold values; (3) acceptance criteria (latency, accuracy, coverage); (4) reference to supporting FMEA/FMEDA analysis. CSP requirements include CAL mapping and threat references.

Requirement ID	Category	Specification	Acceptance Criteria	Clause Ref
TSC-AEB-01	Safety	AEB decision latch: CNN confidence $\geq 95\%$ AND temporal consistency (same person ID in 3 consecutive frames) AND AEB inhibit signals inactive	Latency ≤ 80 ms from pedestrian entry to brake signal sent to CAN	26262:6.4.2
TSC-AEB-02	Safety	AEB inhibition logic: if (lens wet OR glare detected OR CNN	Verification by FMEA + simulation; MR $\geq 99.99\%$ for	26262:6.4.2,

		confidence <80% OR speed >120 km/h OR vehicle on slope >8°), set AEB_ACTIVE=0	inhibit logic	21448:6.4
TSC-AEB-03	Safety	Temporal pedestrian tracking: assign tracking ID to bounding box; require 3-frame consensus on same ID before AEB latch	Tracking error <5% (false track swaps); ID persistence >95% over 500 ms	26262:6.4.2
TSC-LKA-01	Safety	Lane detection filter: Kalman filter on left + right lane boundaries; reject outliers >3-sigma from predicted position	RMS lane offset error <0.15 m @ 100 km/h on ISO 19453 test track (straight, marked lanes)	26262:6.4.2
TSC-LKA-02	Safety	Steering command rate limiter: max steering angle rate $\pm 10^\circ/\text{s}$; limit steering torque to <4 Nm for smooth guidance	No jerky steering inputs; maximum lateral jerk <2 m/s ³ (acceptable to driver per ISO 26101)	26262:6.4.2
TSC-TSR-01	Safety	TSR confidence threshold: speed sign must score $\geq 95\%$ confidence AND road context consistent (vehicle speed within ± 10 km/h of sign)	False positive rate <1% on 5K-image test set; false negative <2% for legible signs (min 200×200 px)	26262:6.4.2
CSP-SEC-01	Cybersecurity	Secure boot: RSA-2048 signature verification on bootloader and kernel image; SHA-256 hash over entire code image; OTP storage of public key root	0 unsigned code execution across 1K adversarial firmware injection attempts; 100% of production units start with verified code	21434:7.4.2
CSP-SEC-02	Cybersecurity	OTA update authentication: HTTPS TLS 1.3 endpoint with server certificate pinning (pin 3 CA certs); client-side signature verification before code write	Man-in-the-middle attack prevented in penetration test; malicious firmware blocked; secure channel established in <500 ms	21434:7.4.2, 8.5.1
CSP-SEC-03	Cybersecurity	CAN message rate limiting: max 100 FCAM output frames/sec; excess discarded; watchdog armed if queue depth >80% for >1 sec	DoS attack mitigation; 1 Mbps flood handled without ECU freeze; recovery within 2 sec	21434:7.4.2
TSC-SOTIF-01	SOTIF	Lens obscuration detection: compute histogram entropy of Bayer green channel every frame; if entropy <2.0 nats, set LENS_OBSCURED flag	False trigger rate <0.1% in wet/rainy ODD trials; true positive rate >95% when lens >30% covered	21448:6.4, 7.4
TSC-SOTIF-02	SOTIF	Glare recovery: HDR preprocessing enabled when pixel saturation >10%; latency ≤ 2 frames (66 ms); restore dynamic range	Lane detection maintained $\geq 95\%$ accuracy in high-glare test; no false lane edges from blooming	21448:6.4, 7.4

Table 11-6. Technical Safety Concept & Cybersecurity Specification (TSC + CSP)**11.2.3 Requirements Allocation Matrix**

Complete traceability from safety/security/SOTIF goals to system requirements per ISO 26262 Cl. 6.3, ISO 21434 Cl. 7.3. This matrix ensures no goal is left unmapped and no requirement is orphaned. Allocation includes hardware, firmware, and system-level responsibilities. Verification method ties each requirement to specific V&V activities (unit test, integration test, field trial, penetration test).

Safety/Security Goal	System Requirement	Allocated Component	Implementation Detail	Verification Method
SG1 (AEB no false trigger)	TSC-AEB-01, TSC-AEB-02, TSC-AEB-03	Orin GPU + ARM firmware	ResNet-50 CNN inference + temporal latch + inhibition lookup table	V&V-AEB-01 (50K scenario HIL test, 99.9% TPR), V&V-AEB-02 (100K km field trial)
SG1	CSP-SEC-01	Orin TEE + bootloader	Secure boot RSA signature check on startup; verify bootloader hash before transfer to L2 cache	V&V-SEC-01 (unsigned code injection rejection), code review + penetration test
SG2 (LKA stable guidance)	TSC-LKA-01, TSC-LKA-02	Orin + ARM firmware	Kalman filter lane boundary tracking; servo gain scheduling (speed-dependent); rate limiter on steering command	V&V-LKA-01 (lane tracking HIL closed-loop test, RMS <0.15 m), V&V-LKA-02 (wet road field trial)
SG3 (TSR high confidence)	TSC-TSR-01	Orin GPU CNN classifier head	Multi-scale sign detection; confidence-weighted bounding boxes; post-processing context filter	V&V-TSR-01 (5K real-world sign corpus, precision ≥98%), V&V-TSR-02 (urban/highway field trials)
CSG1 (Prevent FW modification)	CSP-SEC-01, CSP-SEC-02	Orin TEE + secure boot + OTA gateway	Code signing + secure channel (HTTPS TLS 1.3) + server certificate pinning	V&V-SEC-02 (adversarial firmware injection test 1K attempts), V&V-SEC-03 (penetration test + code review)
CSG2 (Detect sensor spoofing)	TSC-AEB-03 (temporal consistency)	ARM temporal checker module	Temporal consistency filter enforcing 3-frame consensus on pedestrian ID; reject single-frame detections	V&V-SEC-04 (IR/RF lab injection + synchronized monitoring), field incident correlation analysis
SOTIF1 (Wet lens resilience)	TSC-SOTIF-01	Orin image preprocessor + ARM logic	Lens obscuration detector (histogram entropy); wiper CAN signal integration;	V&V-SOTIF-01 (rain chamber test ISO 5006), V&V-SOTIF-02 (50 km real-world wet-lens field

SOTIF2 (Glare degradation)	TSC-SOTIF-02	Orin image preprocessor (HDR ISP)	confidence reduction table	trial)
			HDR enable logic triggered by saturation detection; multi-exposure fusion; confidence reduction per glare intensity	V&V-SOTIF-03 (glare simulation rig 1000+ lux), V&V-SOTIF-04 (dawn/dusk field trial)

Table 11-7. Requirements Allocation Matrix (Goals → Requirements → Components)

11.3 Hardware/Software Development Phase

Hardware and software development phase includes detailed design, implementation, and unit-level verification per ISO 26262 Cl. 7 and ASPICE SWR.2–3. This section covers failure mode analysis (FMEA/FMEDA), software requirements specification, and code development practices. The development team includes firmware engineers (C/C++), ML engineers (PyTorch/TensorRT), hardware designers (schematic/PCB/FPGA), and safety engineers overseeing traceability and coding standards (MISRA C:2012).

11.3.1 FMEDA Excerpt (Safety + Security Failure Modes)

Selected critical failure modes per ISO 26262 Cl. 7.4.2 (FMEDA for hardware/firmware) and ISO 21434 Cl. 8.4.2 (threat-driven FMEA for security). The FMEDA quantifies failure rates (FIT = failures in 10^9 hours), assigns failure modes to categories (Safe/Detected/Latent), and calculates diagnostic coverage (DC). Target metrics for ASIL B include Single-Point Failure Metric (SPFM) $\geq 90\%$, Latent Fault Metric (LFM) $\geq 95\%$, and Probabilistic Metric of Hazard Failure (PMHF) $\leq 10^{-7}$ per hour. The excerpt below shows representative entries from the full 50+ mode FMEDA.

Element	Failure Mode	Effect (Safety)	Effect (Security)	Mitigation	DC	FIT
CNN Model	Pedestrian misclassification (object shadow/reflection mistaken for person)	False AEB trigger or missed AEB; Severity 4 → ASIL B	Potential basis for adversarial evasion attack	Ensemble CNN (3 models voting); synthetic rain/night data (50K images); drift detection	85%	0.8
CNN Model	Confidence calibration shift (post-deployment model extraction)	Loss of confidence-based AEB inhibition logic reliability; confidence scores no longer match true success rate	Model extraction attack vector; attacker can craft adversarial inputs	Periodic retraining with field data; ECE monitoring; distribution shift detection (KL-div threshold)	70%	0.5
Orin GPU	Thermal throttling (high ambient 45°C + direct sun + 200	CNN latency increase >80 ms, exceeds AEB latch	Timing-based side-channel exposure of CNN weights via	Thermal management (active cooling); fallback to LKA-only on latency timeout;	92%	1.2

	TFLOPS load)	deadline, miss pedestrian	latency inference	thermal alert		
Orin Memory (DRAM)	Single-bit flip in decision register (cosmic ray in highway 1000 m altitude)	Flip AEB_ACTIVE flag from 0→1 or lane offset value, incorrect action	Potential for differential power analysis attack; memory timing side-channel	ECC-8 on 64-bit SRAM; periodic memory self-test (MARCH); duplicate decision registers	99%	0.01
Watchdog Circuit	WDG oscillator failure (crystal aging, thermal drift over 7 years)	WDG no longer triggers timeout reset; ECU enters zombie state; no safe fallback	Attacker could prevent watchdog intervention in exploit scenario	Redundant WDG (discrete IC + FPGA watchdog); periodic heartbeat check; oscillator temperature compensation	96%	0.3
Secure Boot Code	TEE code region corrupted (flash wear-out, intentional attack, alpha particle)	Non-signed code executes; firmware modified without detection; full system compromise	Full system compromise; attacker gains root access	Code signing + secure flash partition (locked after boot); periodic CRC check on code; duplication	100%	0.02
CAN Gateway	Message ordering violation (out-of-sequence AEB_ACTIVE frames)	Brake applied out of sync with steering guidance; vehicle instability	Timing attack surface; attacker could desync brake/steering to cause loss of control	Sequence number + timestamp validation on all frames; timeout on out-of-order detection	91%	0.6
Image Sensor	Pixel array defect (hot pixel cluster, line defect from manufacturing)	False edge detection in CNN feature extraction; artifact classified as pedestrian	Potential for spoofing via optical injection; attacker could create false features	Hot pixel map + spatial filter (median, bilateral); sensor self-test during boot; factory calibration	80%	1.1
CAN Transceiver	CAN bus short to ground (connector corrosion, water ingress)	Loss of communication; AEB/LKA outputs not delivered to body ECU	Denial of service; attacker could jam CAN to prevent braking	CAN bus monitor with glitch filtering; ISO 1141-2 physical layer; watchdog timeout triggers fallback	85%	0.4
Power Supply	5V rail dropout (load transient, PSU failure)	Orin GPU clock gating; ARM reset; watchdog timeout reset; safe shutdown	Attacker could trigger brown-out via power injection (electromagnetic interference)	Multi-rail power sequencing; brownout detector with hysteresis; redundant supply for watchdog	88%	0.7

Table 11-8. FMEDA: Safety & Security Failure Modes

FMEDA Summary: Across all identified failure modes (50+), Single-Point Failure Metric (SPFM) = 92%, Latent Fault Metric (LFM) = 96%, target PMHF for ASIL B = $1e-7/h$, calculated PMHF = $8.5e-8/h$ (meets requirement). Diagnostic coverage targets: AEB critical path $\geq 98\%$, LKA safety-relevant path $\geq 96\%$, CAN interface $\geq 95\%$. Mitigation effectiveness verified through fault injection testing (1000+ injected faults).

11.3.2 Software Requirements Specification Excerpt

Safety, security, and SOTIF requirements co-located in Software Requirements Specification (SRS) per ASPICE SYS.3 and SUP.1. Each requirement includes: (1) requirement ID, (2) classification (safety/security/SOTIF/performance), (3) plain-language statement with limits, (4) rationale linking to HARA/TARA/ODD, (5) acceptance criteria (quantified where possible), and (6) traceability to verification test. Below are three representative requirements (AEB safety, firmware security, SOTIF):

SWR-AEB-01 (Safety, ASIL B): AEB Pedestrian Detection Trigger. The firmware shall invoke AEB brake command when ALL of the following conditions are true simultaneously: (a) ResNet-50 CNN pedestrian confidence score ≥ 0.95 (on 0–1 scale), (b) bounding box lateral position within ± 1.5 m of ego vehicle center lane (from camera mount position), (c) bounding box vertical position indicates pedestrian height > 0.8 m (rejects animals), (d) instantaneous pedestrian lateral velocity < 2 m/s (pedestrian not crossing away from vehicle path), (e) temporal consensus: same pedestrian ID detected in ≥ 3 consecutive frames (100 ms window) with overlap IOU > 0.5 , (f) lens obscuration detection inactive (LENS_OBSCURED flag = 0), (g) glare detection inactive (GLARE_FLAG = 0), (h) vehicle speed ≤ 120 km/h (ODD boundary). The brake signal shall be sent to CAN-FD gateway within 80 ms of condition (e) becoming true. ASIL B allocation: SG1, CSG1. Associated requirements: TSC-AEB-01, TSC-AEB-02, TSC-AEB-03. Verification: V&V-AEB-01 (50K scenario HIL test, TPR $\geq 99.9\%$, FPR $< 0.1\%$), V&V-AEB-02 (100K km field trial, 0 false triggers).

SWR-SEC-01 (Cybersecurity, CAL 3): Firmware Image Signing and Verification. The bootloader shall verify the kernel image signature using RSA-2048 with public exponent 65537 before transferring execution to kernel code. Hash algorithm: SHA-256. Public key shall be stored in immutable OTP (One-Time Programmable) ROM, protected by fuse. The bootloader shall read the kernel image from flash into SRAM, compute SHA-256 hash, verify signature using public key and RSA-PKCS1-v1_5 padding. If signature invalid, the bootloader shall enter an infinite loop (hang) with watchdog refresh disabled, allowing watchdog to timeout and trigger ECU reset to safe state. Signature generation during build: kernel is signed by build server with private key (stored in HSM, isolated facility). Signature updated on every kernel rebuild (immutable once programmed). CAL 3, ASIL B allocation: CSG1. Verification: V&V-SEC-01 (100 unsigned firmware images all rejected), V&V-SEC-02 (penetration test), code review by security engineer.

SWR-SOTIF-01 (SOTIF, no ASIL): Lens Obscuration Detection and Confidence Reduction. The image preprocessor firmware shall compute histogram entropy of the Bayer green channel every frame (30 Hz = 33 ms period). Entropy calculated using Shannon formula over 256 histogram bins. If entropy < 2.0 nats (indicating flat histogram characteristic of occlusion or blur), the firmware shall set LENS_OBSCURED flag = 1 and automatically reduce all CNN confidence scores by multiplying by factor 0.75 (25% reduction). Wiper signal integration: if vehicle CAN message indicates wipers active (wipers_active flag from body ECU), automatically enable SOTIF mode (confidence reduction applied regardless of entropy). Wiper integration timeout: if wiper signal lost for > 1 sec, entropy-based detection takes over. ISO 21448 Cl. 6.4 allocation: SOTIF1, SOTIF-CR-1. Verification: V&V-SOTIF-01 (wet-lens chamber test per ISO 5006, CNN confidence maintained $\geq 80\%$ with lens coverage $< 30\%$), V&V-SOTIF-02 (rain field trial, 50+ km in rain with dual-channel ground truth logging).

11.4 Verification & Validation Phase

Verification and Validation phase per ISO 26262 Cl. 8, ISO 21434 Cl. 9, ISO 21448 Cl. 7. V&V spans unit testing (component level), integration testing (subsystem level), system testing (full ECU in vehicle), and field validation (real-world ODD scenarios). Test plan integrates safety testing (per ISO 26262 Table E.1), security testing (penetration testing, threat verification), SOTIF testing (ODD boundary validation), and AI-specific testing (robustness, adversarial, performance under distribution shift). Release readiness checklist ensures all standards' sign-off criteria are met before production launch.

11.4.1 Integrated Test Plan Excerpt

Test plan integrating unit, integration, system, and field V&V per ISO 26262 Cl. 8, ISO 21434 Cl. 9, ISO 21448 Cl. 7. Below are key tests covering AEB safety path, LKA, TSR, cybersecurity, and SOTIF. Each test includes: (1) test ID, (2) test type (unit/integration/system/field), (3) target component/system, (4) pass/fail criteria (quantified), (5) standard reference.

Test ID	Test Type	Target (Component/System)	Success Criteria	Standard(s)
V&V-AEB-01	Integration (HIL)	AEB decision logic (Orin CNN + ARM latch) on test bench simulator	≥99.9% true positive rate (TPR) on 50K pedestrian scenarios (sunny, rain, night, occlusion); false positive <0.1%	26262:8.3.4, 8.4.4
V&V-AEB-02	System (Field)	Full AEB path: camera → neural net → brake trigger on test vehicle (100K km, 5 vehicles, 7 months)	AEB engagement latency ≤100 ms in all weather; 0 inappropriate triggers; field log analysis: FP <0.01%	26262:8.4.4, 21448:7.4
V&V-LKA-01	Integration (HIL)	Lane tracking Kalman filter + servo under lane marking variations (dashed/solid, faded, wet)	Lane offset RMS error <0.15 m @ 100 km/h, ±2° pitch/roll; lane tracking persistence >99% over 5 min	26262:8.3.4
V&V-LKA-02	System (Field)	LKA closed-loop steering control on test track (wet/dry, marked/unmarked)	Steering command latency <100 ms; lane centering accuracy ±0.1 m; driver acceptance (subjective) >90% in user study (N=20)	26262:8.4.4, 21448:7.4
V&V-TSR-01	System (SIL/HIL)	TSR CNN classifier on 5K real-world sign images (urban, highway, weather)	Precision ≥98%, recall ≥95% per sign category (speed, warning, regulatory); false rejection <2% for legible signs	26262:8.4.4, 21448:7.4
V&V-SEC-01	Unit (White-box, Penetration)	RSA signature verification firmware module; 100 tampered firmware images + timing analysis	All 100 tampered firmware images rejected; no bypass via timing attack (constant-time RSA implementation); CVSS 9.8 risk eliminated	21434:9.3, 9.4

V&V-SEC-02	System (Penetration, Third-party Lab)	Full OTA update chain: HTTPS TLS 1.3 endpoint + secure boot + signature validation	Man-in-the-middle prevented (TLS 1.3 handshake monitored); malicious firmware blocked; 0 successful code injections across 1K adversarial attempts	21434:9.4.4
V&V-SEC-03	Integration (Lab)	CAN message injection / rate limiting / spoofing detection	False CAN injection detected & dropped; rate limiting handles 1 Mbps flood without ECU freeze; recovery <2 sec	21434:9.4.2
V&V-SOTIF-01	System (Chamber + Field)	AEB performance in rain/fog/snow (ISO 5006 Annex B rain simulator + field trial)	CNN confidence maintained ≥80%; lane detection ≥95% in light rain; graceful mode switch in heavy rain; alert latency <1 sec	21448:7.4
V&V-SOTIF-02	System (Field)	High-glare scenario (dawn/dusk, sunrise testing, rig-generated 1000+ lux)	Glare detection ≤2 frames (66 ms); confidence reduction applied; AEB latch appropriately blocked; lane detection >95%	21448:7.4
V&V-SOTIF-03	System (Adversarial)	Evasion attacks (adversarial patches on signs, IR/RF spoofing lights), temporal consistency check	Temporal consistency check defeats single-frame spoofing; ≥99% detection of IR injection via 3-frame consensus	21434:9.4, 21448:7.4

Table 11-9. Integrated V&V Test Plan

11.4.2 Release Readiness Checklist

Pre-production sign-off checklist covering all standards. This checklist ensures no critical artifact or test is missed before DVP&R (Design Verification & Production Release). All items must be signed off by respective leads (safety, security, SOTIF, quality) before production.

- ☐ ISO 26262 ASIL B FMEA/FMEDA complete with ≥99.5% MR on all critical items; SPFM ≥90%, LFM ≥95%, PMHF ≤1e-7/h [26262:7.4.2, 7.5.4]
- ☐ Safety goals & TSC requirements verified by integration testing (V&V-AEB-01, V&V-LKA-01) & system field testing (V&V-AEB-02, V&V-LKA-02) [26262:8.4.4]
- ☐ Safety case document complete with GSN structure, all claims traced to evidence, reviewed & approved by 3-person safety panel [26262:8.5.1]
- ☐ Safety-critical code 100% reviewed per ASPICE SWR.5 checklist; static analysis (Polyspace) run on all safety paths, 0 errors/violations [26262:8.3.2, ASPICE:SWR.5]
- ☐ ISO 21434 threat model documented; TARA complete with 8+ threats identified; CAL 3 threats mitigated with ≥99% confidence [21434:8.3, 8.4.2]
- ☐ Secure boot RSA-2048 signatures verified on 100+ production firmware builds; code signing chain audited by security team; key management plan documented [21434:8.4.2, 8.5.1]
- ☐ Penetration test report (third-party lab, CVSS scoring) shows 0 unresolved vulnerabilities CVSS ≥7.0; malicious firmware injection test passed 1K iterations [21434:9.4.4]

- ISO 21448 SOTIF triggering conditions identified (10+) & tested in real-world trials (rain, glare, occlusion); acceptance criteria met for all [21448:6.3, 7.4]
- ODD boundary clearly defined (numerical ranges: speed 0–120 km/h, lux 50–100K, precipitation ≤10 mm/h); driver alert mechanism tested & approved [21448:5.2, 6.4]
- ASPICE v4.0 SYS.3 (System Requirements), SWR.2 (Software Design), SWR.3 (Software Coding) achieved Level 3 or higher (maturity assessment completed) [ASPICE:SYS.3, SWR.2–3]
- Unit test coverage ≥95% C0 (statement); integration coverage ≥90% C1 (decision); all tests pass; coverage reports archived [26262:8.4.4, ASPICE:SWR.4]
- IATF 16949 manufacturing readiness: tooling qualified, process capability Cpk ≥1.33 on all safety-critical processes (flash programming, high-voltage test) [IATF:3.1.2, 8.2.4]
- Field monitoring plan & telemetry system operational on 10+ production vehicles; anomaly detection thresholds set; incident response SOP finalized [21434:10.2, 21448:8.2]
- OTA rollout procedure documented; update server infrastructure tested; rollback procedure validated on hardware; customer communication drafted [21434:8.5.1, 10.2]

11.5 Operations & Field Monitoring

Operational phase includes field monitoring, model degradation detection, and incident response per ISO 21434 Cl. 10 and ISO 21448 Cl. 8. Once in production, FCAM telemetry is continuously streamed to OEM backend servers to monitor system health, detect anomalies, and trigger corrective actions (OTA updates, field campaigns, recalls if needed). The field monitoring plan specifies what data is collected, at what frequency, how it's analyzed, and what thresholds trigger alerts.

Field Monitoring Telemetry: FCAM firmware logs (sampled 1 in 1000 frames to minimize bandwidth) include: CNN confidence histogram (16 bins, 0.0–1.0 range), glare flag occurrence count, lens obscuration flag count, AEB trigger count per drive, LKA mode engagement count, CAN error frames (CRC fail, timeout, bus-off), watchdog resets. Uploaded via cellular modem (LTE Cat-6 or 5G) every 24 hours or when abnormality detected (alert condition). Privacy-preserving: raw frame images NOT logged; only aggregated statistics and event counts. No personally identifiable information transmitted.

Degradation Triggers: Field monitoring dashboard (OEM backend) computes daily rolling statistics per vehicle. If CNN confidence distribution shifts >10% from baseline (detected via Kullback-Leibler divergence $KL(\text{new} || \text{baseline}) > 0.15$ nats), firmware flags ALERT and sends notification to OEM backend. Similarly, if AEB no-trigger-when-should rate exceeds 0.5% (estimated from incident correlations), or CAN errors exceed 10 per hour (bus-off events, framing errors), or watchdog resets exceed 3 per week (firmware stability issue), an ALERT is generated. Analytics team correlates alert patterns with software version, hardware variant, geographic region, and weather. If systematic issue identified (e.g., reflective vest misclassification in sunny climates, glare false positives at 6:00–7:00 AM), root cause analysis initiated within 24 hours.

Incident Response: Customer reports false AEB engagement or missed pedestrian detection. Incident log pulled from vehicle via secure VPN; CNN confidence scores, pedestrian bounding box coordinates, glare flag state, wiper state, ambient light level, vehicle speed reviewed. Root cause analysis conducted by safety + ML team. If systematic issue (e.g., CNN fails on tall cyclists due to underrepresentation in training data), dataset retraining initiated: collect field failure cases (100+ instances from multiple vehicles), augment training dataset, retrain CNN, validate via synthetic evaluation + shadow mode (parallel inference on vehicle with new model, log results without acting on them). New model approved by safety/ML review board, then released as OTA update within 30 days. Critical issues (safety ASIL B) expedited to 7-day release. Post-release monitoring: track false positive/negative rates on updated model for 2 weeks to confirm fix.

CHAPTER 12: COMPLETE EXAMPLE — AI PEDESTRIAN DETECTION (DNN-BASED)

SCOPE

AI-specific lifecycle demonstration using ISO/PAS 8800 (Road Vehicles—Functional Safety of Automated Driving Systems) and ASPICE MLE (Machine Learning Engineering) practices. ResNet-50 backbone + FPN for multi-scale pedestrian detection. Data lifecycle, model development, AI-specific V&V, and field retraining procedures covered in detail. ASIL C, CAL 4 (software/AI system fully safety-related).

12.1 AI Concept Phase

The AI concept phase defines the machine learning component's scope, acceptable input/output ranges, failure modes specific to AI systems, and performance targets. Unlike traditional firmware, AI systems exhibit probabilistic behavior and learn from data. The concept phase must specify the operational design domain (ODD) for the AI model, dataset requirements, performance metrics, and acceptance criteria. ISO/PAS 8800 introduces AI-specific elements: data quality assessment, model confidence calibration, out-of-distribution (OOD) detection, and field retraining procedures.

12.1.1 AI Item Scope

Scope: ResNet-50 convolutional neural network (CNN) backbone with Feature Pyramid Network (FPN) neck for multi-scale pedestrian detection. Input: 1920×1208 RGB image (30 FPS from camera ISP pipeline). Output: set of bounding boxes (class pedestrian, coordinates, confidence $\in [0, 1]$). The model executes on NVIDIA Orin GPU (TensorRT optimized, 8-bit quantization, ~150 ms latency per frame). Primary safety function: AEB pedestrian detection (ASIL B). Secondary functions: LKA lane marking detection, TSR sign classification (ASIL A). Data requirements: pedestrian detection requires diverse imagery spanning seasons (rain, snow, sun glare), times of day (night, twilight, day), urban/highway environments, pedestrian poses (walking, standing, partially occluded), clothing colors (white, dark, neon), and edge cases (children, strollers, groups). Model must achieve: false negative rate <2% (miss rate), false positive rate <1% (over-detection), mean average precision (mAP) ≥ 0.92 @ IoU 0.5, latency ≤ 100 ms end-to-end.

The model is part of the larger FCAM ECU (Chapter 11) and inherits ASIL B allocation from AEB safety function. The model's confidence scores are used as the primary input to AEB decision logic (latch if confidence ≥ 0.95 AND temporal consistency satisfied). Therefore, the model must be well-calibrated: confidence 0.95 should correspond to ~95% true positive rate on held-out test data. Miscalibration (e.g., model outputs 0.95 but true success rate is 85%) is an AI-specific failure mode that could violate safety goals despite nominal accuracy metrics.

12.1.2 AI-Specific HARA Extension

ISO/PAS 8800 Cl. 5.3 extends traditional HARA to include AI-specific failure modes arising from data quality, model limitations, and deployment mismatch. Below are eight AI failure modes identified for the pedestrian detector:

ID	AI Failure Mode	Root Cause	Impact	Detection Difficulty	Mitigation

AIF-1	False Negative (FN): pedestrian not detected (missed AEB trigger)	Underrepresentation in training data (e.g., small children <1.2 m, night scenes)	Safety-critical: vehicle hits pedestrian; Severity 4 → ASIL B	High (requires field data correlation)	Synthetic data augmentation; field retraining; ensemble voting
AIF-2	False Positive (FP): non-pedestrian misclassified (bags, poles, shadows)	Training data class imbalance or ambiguous boundary cases	Safety-critical: false AEB trigger; Severity 3 → ASIL B	Medium (can be detected in test set)	Hard negative mining; confusion matrix analysis; confidence threshold tuning
AIF-3	Confidence Miscalibration: confidence score does not match true accuracy	Model architecture (softmax) not optimized for calibration; training objective (cross-entropy) not calibration-aware	Safety-critical: AEB inhibition logic relies on confidence thresholds; miscalibrated confidence invalidates thresholds	Medium (ECE calculation on test set)	Temperature scaling; Platt scaling; focal loss; isotonic regression
AIF-4	Distribution Shift (covariate/label shift): model trained on sunny data, deployed in rain	Training data ODD mismatches real-world conditions; domain gap	Safety-critical: accuracy drops 10–20% in unseen ODD; latent failures	High (requires field data from new domain)	Domain adaptation; transfer learning; test-time augmentation; anomaly detection
AIF-5	Adversarial Robustness: adversarial patches/perturbations fool model	CNN vulnerabilities to adversarial examples; pixel perturbation targeting decision boundary	Safety-critical: attacker could induce false AEB trigger or FN	Medium (requires adversarial attack testing)	Adversarial training; certified defenses; temporal consistency check; input validation
AIF-6	Inference Latency Regression: model latency >100 ms due to weight pruning side effects or HW thermal throttling	Model optimization (quantization, pruning) introduces computational bottlenecks; TensorRT version mismatch	Safety-critical: latency exceeds AEB latch deadline	Low (easily measured during deployment)	Latency monitoring; inference watchdog; fallback to faster reduced-precision model
AIF-7	Hallucination: model detects object that does not exist in image (perceptual bias, texture confusion)	CNN feature maps activate for spurious patterns (e.g., shadow edges mistaken for silhouette)	Safety-critical: false AEB trigger; Severity 3 → ASIL B	Medium (visible in confusion matrix, edge cases)	Attention maps; saliency analysis; model interpretability tools; ensemble disagreement detection
AIF-8	Mode Collapse: model loses diversity after retraining on biased	Field retraining dataset biased toward specific scenario (e.g., 90%	Safety-critical: FN/FP rates surge in out-of-distribution	High (requires off-distribution test set)	Dataset balance monitoring; continual learning with replay buffer;

field data	highway, 10% urban); old model behavior erased	scenarios	model versioning; A/B testing
------------	--	-----------	----------------------------------

Table 12-1. AI-Specific HARA Extension (ISO/PAS 8800 Cl. 5.3)**12.1.3 AI Safety Requirements**

ISO/PAS 8800 Cl. 5.4 and ASPICE MLE.1 require explicit AI safety requirements addressing the failure modes above. Each requirement specifies acceptance criteria, verification method, and allocation to development activities (data engineering, model training, testing). Requirements bridge the gap between abstract safety goals (SG1: prevent false AEB trigger) and concrete model performance targets (mAP ≥ 0.92 , confidence ECE < 0.05).

Req ID	AI Safety Requirement	Acceptance Criteria	Allocation	Verification
AIR-1	Pedestrian FN Rate: model false negative rate shall not exceed 2.0% on held-out test set covering all ODD variants	FN rate = $FN / (FN + TP) \leq 0.02$; measured on ≥ 1000 pedestrian instances; all ODD categories (day, night, rain, occlusion)	Data Eng + Model Training (12.2, 12.3)	V&V-AI-01: test set evaluation; V&V-AI-02: field trial FN correlation
AIR-2	Pedestrian FP Rate: model false positive rate on challenging backgrounds shall not exceed 1.0% per 1000 images	FP rate = $FP / (FP + TN) \leq 0.01$; measured on hard negative set (poles, shadows, bags, vehicles); $\geq 10K$ background images	Data Eng + Model Training (12.2, 12.3)	V&V-AI-03: confusion matrix on test set; adversarial FP test
AIR-3	Confidence Calibration: expected calibration error (ECE) shall be < 0.05 across all ODD subsets	$ECE = \sum(confidence_bin_avg - accuracy_bin_avg \times bin_size)$; computed on test set; per-class ECE < 0.05	Model Training + Test (12.3, 12.4)	V&V-AI-04: ECE calculation on 5 ODD subsets; calibration plots
AIR-4	Domain Generalization: model accuracy on synthetic ODD data (rain, glare, night) shall match real data within 5% margin	Real-world accuracy – synthetic accuracy ≤ 0.05 ; tested on 500+ real rain images vs 500+ synthetic rain images	Synthetic Data Gen + Training (12.2, 12.3)	V&V-AI-05: domain adaptation evaluation
AIR-5	Adversarial Robustness: model robust to adversarial patches (0.1 L-inf perturbation); accuracy $\geq 85\%$ under attack	Accuracy on adversarial examples ≥ 0.85 ; tested with FGSM, PGD, C&W attacks; L-inf ≤ 0.1 (8-bit color space)	Adversarial Training + Test (12.3, 12.4)	V&V-AI-06: adversarial attack evaluation
AIR-6	Inference Latency: end-to-end inference latency (input to output) shall be ≤ 100 ms @ 30 FPS	Latency = 100th percentile over 1000 frames; measured on Orin HW with TensorRT deployment	Model Optimization + Deployment (12.3)	V&V-AI-07: latency profiling on Orin hardware

AIR-7	Out-of-Distribution Detection: model shall detect OOD inputs (e.g., night scenes from unseen city) with $\geq 90\%$ sensitivity	OOD sensitivity (detect OOD as OOD) ≥ 0.90 ; specificity (accept ID as ID) ≥ 0.95 ; using maximum softmax probability or auxiliary OOD detector	Model Training + Test (12.3, 12.4)	V&V-AI-08: OOD detection benchmark; field trial OOD flagging
AIR-8	Model Versioning & Traceability: each model version (training run, weights, dataset) shall be uniquely identified via SHA-256 hash	Model checkpoint stored with: dataset version, hash, hyperparameters, training date, git commit hash, test metrics; no orphaned weights	ML Engineering Process (12.2, 12.3, 12.4)	V&V-AI-09: metadata audit; version control review
AIR-9	Retraining Procedure: field retraining (on newer data) shall not degrade performance on historical ODD; continual learning with replay buffer	Accuracy on original test set maintained $\geq 99\%$ post-retraining; catastrophic forgetting prevented via replay buffer sampling	Continual Learning (12.2)	V&V-AI-10: continual learning benchmark
AIR-10	Test Set Independence: hold-out test set shall be collected independently from training data; no data leakage between train/val/test	Test set collected from different time period, vehicles, and geographic regions than training set; shuffled before evaluation	Data Eng (12.2)	V&V-AI-01: test set documentation; audit trail

Table 12-2. AI Safety Requirements (ISO/PAS 8800 Cl. 8, ASPICE MLE.1–2)

12.2 Data Lifecycle

ISO/PAS 8800 Cl. 7 and ASPICE MLE.2–3 govern the data lifecycle: collection, labeling, validation, versioning, and storage. Data quality is the foundation of AI safety. Poor data leads to biased models that fail in real-world conditions. The data lifecycle ensures systematic collection of representative data, rigorous labeling with quality metrics (inter-annotator agreement), validation of data sufficiency (coverage of ODD), and traceability (version control). This section covers dataset requirements, collection plan, labeling specification, dataset sufficiency analysis, and data validation procedures.

12.2.1 Dataset Requirements

Comprehensive dataset requirements specification per ISO/PAS 8800 Cl. 7. The pedestrian detection dataset must cover all operational design domain variants: geographic regions (USA, Europe, Asia; left-hand/right-hand drive countries), seasons (summer, fall, winter, spring), times of day (night, twilight, daytime), weather conditions (rain, fog, snow, clear), road types (highway, urban, rural), and pedestrian demographics (adult, child, elderly). The dataset must be balanced across classes (pedestrian vs. non-pedestrian) and include edge cases that are underrepresented in natural distributions but important for safety (small children, wheelchair users, cyclists).

Requirement ID	Dataset Requirement	Specification	Rationale	Verification Method
----------------	---------------------	---------------	-----------	---------------------

DR-1	Geographic Coverage	Minimum 6 countries across 3 continents (North America, Europe, Asia); left-hand & right-hand drive configurations	Models trained on geographically diverse data generalize better; vehicle-side driving affects pedestrian positions	DR-1: map of collection regions; statistics per country
DR-2	Seasonal Diversity	≥25% each season (winter, spring, summer, fall); winter data ≥2 years (snow patterns vary annually)	Pedestrian clothing, visibility, and road surface vary by season; multi-year winter data captures variability	DR-2: seasonal histogram; per-season performance analysis
DR-3	Illumination Coverage	Night (lux <5): ≥15% of dataset; twilight (5–100 lux): ≥20%; daytime (>100 lux): ≥65%	Low-light performance critical for safety; dataset must reflect real-world illumination distribution	DR-3: histogram of median image lux; low-light classifier metrics
DR-4	Weather Conditions	Clear: ≥60%; rain (drizzle to moderate, 1–10 mm/h): ≥20%; heavy rain/snow/fog: ≥15%; hail/extreme: ≥5%	Rain/snow degrade visibility; dataset must include sufficient adverse weather to train robust models	DR-4: per-condition performance curves; ablation study
DR-5	Road Type Mix	Highway (limited-access, straight/gentle curves): ≥30%; urban (intersections, turns, pedestrian zones): ≥50%; rural: ≥20%	Pedestrian density, road geometry, and behavior differ; balanced road types prevent overfitting to one environment	DR-5: road type classification; per-type metrics
DR-6	Pedestrian Demographics	Adults (>18 y): ≥70%; children (5–17 y): ≥15%; elderly (>65 y): ≥10%; wheelchair users: ≥3%; cyclists: ≥5%; other: ≥2%	Safety-critical to detect all pedestrian types; underrepresentation of minority classes causes false negatives	DR-6: demographic histogram; per-class FN/FP rates; fairness analysis
DR-7	Occlusion Coverage	Unoccluded pedestrians: ≥75%; partially occluded (25–50%): ≥15%; heavily occluded (>50%): ≥10%	Real-world pedestrians often partially hidden; model must tolerate occlusion without excessive FN	DR-7: occlusion level distribution; occlusion-stratified FN rates
DR-8	Labeling Quality	Inter-annotator agreement (IoU ≥0.5): ≥95% on 500-image audit sample; bounding box error: ±5 pixels	High-quality labels are essential for training robust detectors; poor labels corrupt model learning	DR-8: agreement matrix; label audit report

DR-9	Class Balance	Pedestrian vs. non-pedestrian ratio: target 1:2 (negatives intentionally more; hard negative mining applied); no extreme imbalance >10:1	Imbalanced data causes FP bias; over-sampling positives or under-sampling negatives can reduce generalization	DR-9: class distribution histogram; weighted loss analysis
DR-10	Dataset Versioning	Each dataset release tagged with version (MAJOR.MINOR.PATCH), dated, SHA-256 hash over all images, JSON metadata file documenting images, splits	Version control enables reproducibility; SHA-256 detects corrupted/modified images; metadata enables traceability	DR-10: version tags; metadata JSON; git history
DR-11	Privacy Compliance	All images either synthetic, anonymized (faces/license plates blurred), or from regions with explicit consent; GDPR/CCPA compliant	Privacy preservation critical for automotive data; legal liability for mishandling PII	DR-11: privacy audit report; consent documentation
DR-12	Edge Cases	Corner cases explicitly collected: (a) reflective vests (emergency workers), (b) strollers with children, (c) groups of pedestrians, (d) unusual poses (sitting, lying)	Edge cases rare in natural distribution but critical for comprehensive safety coverage	DR-12: edge case count; edge case-specific metrics

Table 12-3. Dataset Requirements (DR-1 to DR-12)

12.2.2 Data Collection Plan

Systematic collection plan specifying sources, vehicles, duration, and responsible parties. The pedestrian detection dataset (~500K images, 200 GB) is collected via 8 primary sources: (1) owned test fleet (8 vehicles, 2 years of continuous collection), (2) contracted taxi/rideshare fleet (50 vehicles, 6 months), (3) video datasets (Cityscapes, KITTI, nuScenes; publicly available but licensed), (4) synthetic data (CARLA simulator, Unreal Engine rendered images), (5) crowd-sourced contributor feedback (field failures from production), (6) third-party annotation service (image acquisition + labeling), (7) simulation + photorealistic rendering (NVIDIA Omniverse), (8) real-world edge case capture (emergency responders, construction zones, special events).

Data Source	Collection Method	Volume (K images)	Coverage	Quality Assurance	Timeline
Own Fleet (8 vehicles)	Continuous onboard capture (4x front/side cameras); GPS + metadata; ODD conditions targeted	200	Multi-season, worldwide (2 continents), diverse weather	QA team reviews 1% sample monthly; automated blur/artifact detection	Ongoing (Year 1–2)
Taxi/Rideshare (50 vehicles contracted)	Installed camera systems + periodic data download; urban-focused	80	Urban roads, high pedestrian density, diverse demographics	Periodic audit; check for label-image mismatch via DQM tool	Months 6–12

collection					
Public Datasets (Cityscapes, KITTI, nuScenes)	Download & licensing; standardized splits train/val/test	150	Multiple countries (USA, Germany, China); highway + urban	Existing community annotations; re- labeled per proprietary taxonomy	Months 1–3
Synthetic (CARLA, Unreal)	Simulator rendering with procedural scene generation (weather, traffic, lighting)	50	Unlimited scenario variation; unrealistic domain gap possible	Domain randomization hyperparameter tuning; realism evaluation	Months 3–9
Production Feedback (Field Failures)	OTA telemetry + customer reports; hard negative examples (false positives, misses)	10	Real-world failure modes; biased toward edge cases	Manual review & verification; forward to retraining pool if valid	Ongoing post-launch
Annotation Service (Outsourced)	Vendor collection + labeling (bounding boxes, attributes); quality gating	15	Geographic regions specified by contract (e.g., Asia, South America)	Vendor audit; blind quality test on 5% sample; re-label if <95% agreement	Months 4– 10
Rendering (Omniverse, MetaHuman)	Photorealistic synthetic data + domain randomization (lighting, weather, pedestrian appearance)	20	Controlled variation of domain factors; unlimited scale	Visual inspection; FID (Fréchet Inception Distance) score >0.8	Months 6– 12
Edge Cases (Special Collections)	Targeted capture: emergency services, sports events, construction, crowded areas, unusual poses	5	Minority scenarios; underrepresented in natural data; high safety relevance	Manual curation; subject-matter expert review (safety engineer)	Months 9– 12

Table 12-4. Data Collection Plan (8 Sources, 500K Images)

12.2.3 Labeling Specification & Quality Metrics

Labeling specification defines bounding box format, class taxonomy, and quality metrics. Pedestrian class is divided into primary (adult, child) and secondary attributes (occluded, walking, standing, wheelchair, stroller). Bounding boxes use COCO format: [x_min, y_min, width, height] in pixels (0-indexed). Labeling tools: CVAT (Computer Vision Annotation Tool), custom web UI with SAM (Segment Anything Model) pre-annotations to speed up human annotation. Each image annotated by 2 independent annotators; disagreements resolved via consensus meeting.

Inter-Annotator Agreement (IAA): Measured on 500-image audit set using Intersection-over-Union (IoU) at threshold 0.5. Target: $\geq 95\%$ of boxes have $\text{IoU} \geq 0.5$ between annotators. For small boxes (<100 pixels), stricter threshold ($\text{IoU} \geq 0.3$) applied due to inherent labeling difficulty.

Class Taxonomy: Pedestrian: person on foot (primary), standing, walking, running. Child: age <12 y (height <1.4 m heuristic). Wheelchair: person in wheelchair. Stroller: caregiver + child in stroller. Cyclist: person on bicycle. Non-pedestrian: vehicle, tree, pole, sign, animal. Attributes: occluded (>25% hidden by object), far-field (distance >50 m, <100 pixels height), group (3+ pedestrians within 2 m).

Quality Control Process: Weekly audit: 1% of newly labeled images reviewed by senior annotator. If error rate >5%, labeling vendor retrains annotators. Automated checks: (1) Bounding box size sanity (width/height within expected range for pedestrian), (2) IoU overlap with neighboring boxes (merge if >0.8 overlap), (3) Image-box consistency (image blur detection, artifact detection via ResNet classifier).

12.2.4 Dataset Sufficiency Analysis

Determine if collected data is sufficient to train a model meeting safety requirements. Per ISO/PAS 8800 Cl. 7.3, dataset sufficiency is analyzed via statistical power analysis and ODD coverage. Sample size calculation: to achieve FN rate <2% with 95% confidence, need ≥ 1000 pedestrian instances (binomial proportion test). To achieve FN rate <2% across all ODD subsets (20 combinations), need $\geq 1000 \times \sqrt{20} \approx 4500$ instances minimum (conservative Bonferroni correction). Collected dataset contains 500K images with ~450K pedestrian annotations → sufficiency target met.

ODD Category	Target Instances	Collected Count	Ratio (%)	Statistical Power	Acceptance
Daytime Clear	5000	35000	7.8%	95%	PASS
Daytime Rain	3000	18000	4.0%	95%	PASS
Daytime Fog	1500	8000	1.8%	90%	PASS
Twilight Clear	2500	12000	2.7%	95%	PASS
Twilight Rain	1500	7500	1.7%	90%	PASS
Night Clear	3000	22000	4.9%	95%	PASS
Night with Lights	2000	15000	3.3%	95%	PASS
High Glare (Sun)	1000	8000	1.8%	92%	PASS
Adult Pedestrian	8000	325000	72%	95%	PASS
Child Pedestrian	2000	68000	15%	95%	PASS
Wheelchair/Stroller	500	25000	5.6%	90%	PASS
Occluded (25–50%)	1500	45000	10%	95%	PASS
Occluded (>50%)	500	15000	3.3%	85%	PASS
Far-field (<100 px)	1000	28000	6.2%	95%	PASS
Cyclist	500	18000	4.0%	90%	PASS
Urban Road	5000	250000	55.6%	95%	PASS
Highway	3000	180000	40%	95%	PASS

Rural	1000	20000	4.4%	90%	PASS
Hard Negatives (backgrounds)	2000	50000	11%	95%	PASS
Total Pedestrians	20000	450000	100%	95%	PASS

Table 12-5. Dataset Sufficiency Analysis (ODD Stratification)

12.2.5 Data Validation Procedures

Multi-stage validation ensures dataset quality before model training. Stage 1 (Automated Checks): All images scanned for corruption (missing header, zero bytes), blur (Laplacian variance), artifacts (saturation, underexposure), and label validity (bounding box within image bounds). Stage 2 (Manual Audit): 1000-image random sample manually reviewed; error rate calculated; if >3%, trigger re-labeling for entire batch. Stage 3 (Statistical Analysis): Compute per-class statistics (instance count, size distribution, aspect ratio). Detect outliers (very small/large boxes). Verify ODD coverage with stratified sampling. Stage 4 (Consistency Checks): Verify no duplicate images (perceptual hashing via pHash library); check temporal consistency (consecutive frames from same video should have similar lighting/weather). Stage 5 (Privacy Scan): Automated face/license plate detection; blur or remove any PII. Final: Release dataset version with passed validation gate.

12.3 Model Development Phase

Model development phase (ASPICE MLE.2–3) includes architecture design, hyperparameter tuning, training, and validation. The ResNet-50 + FPN architecture is selected for its balance of accuracy (~92% mAP) and inference latency (~150 ms on Orin). Development uses PyTorch for training (GPU clusters with 8× A100 GPUs), TensorRT for deployment optimization (8-bit quantization, graph optimization), and MLflow for experiment tracking and model registry.

12.3.1 Architecture Design

Pedestrian detection model comprises: (1) Backbone: ResNet-50 pre-trained on ImageNet (transfer learning), modified input resolution 416×416 RGB; (2) Neck: Feature Pyramid Network (FPN) generating multi-scale feature maps (P3–P7, stride 8–256 pixels); (3) Head: Detection head per FPN level, FCOS-style (fully convolutional one-stage detector, no anchor boxes). Loss function: focal loss for positive/negative class imbalance ($\alpha=0.25$, $\gamma=2.0$), IoU-based localization loss (GIoU). Optimizer: SGD with momentum 0.9, learning rate 0.001 (warmup 500 steps), batch size 32, weight decay 1e-4. Training epochs: 100 (early stopping if validation loss plateaus for 10 epochs).

Component	Specification	Justification	Alternative Considered
Backbone	ResNet-50 (50 layers); ImageNet pre-training; input 416×416 RGB	Balance: accuracy 92% mAP, inference 150 ms (meets latency requirement); transfer learning accelerates convergence	ResNet-101 (slower), EfficientNet (smaller, less accurate), MobileNet (too weak for ASIL B)
Neck	FPN (P3–P7 levels); top-down path + lateral connections	Multi-scale feature pyramid enables detection at all pedestrian sizes (far-field <100	PAN (Weighted FPN), BiFPN (marginal improvement, higher

		px to close-range >500 px)	complexity)
Head	FCOS (anchor-free); per-pixel classification + localization regression	Anchor-free avoids hyperparameter tuning (anchor aspect ratios, scales); supports dense predictions (high recall)	Faster R-CNN (slower, two-stage), YOLO (faster but lower accuracy), Cascade (more complex)
Loss Function	Focal Loss ($\alpha=0.25$, $\gamma=2.0$) for class imbalance; GIoU for localization	Focal loss reduces easy negatives weight, focuses on hard examples; GIoU provides scale-invariant localization	Cross-entropy (naive), L1/L2 (non-differentiable at 0), DIoU (marginal improvement)
Optimizer	SGD + momentum (0.9); LR=0.001 warmup 500 steps; weight decay 1e-4	SGD generalizes better than Adam for small models; momentum prevents oscillation; warmup stabilizes early training	Adam (may overfit), AdamW (similar convergence but slower), RMSProp (dated)
Data Augmentation	Random flip (H/V), rotation ($\pm 15^\circ$), brightness ($\pm 20\%$), contrast ($\pm 30\%$), Cutout (patch dropout)	Augmentation increases effective dataset size 5–10 $\times$; rotation/brightness handle ODD variation; Cutout regularizes	Heavy augmentation ($\geq 5\times$ diversity) risks domain gap vs. real; light augmentation insufficient for generalization

Table 12-6. Model Architecture Design (MLE.2)

12.3.2 Training Plan & Hyperparameters

Controlled training procedure ensures reproducibility and scientific rigor. Training data split: 70% train, 15% validation, 15% held-out test. Validation set used for hyperparameter tuning and early stopping. Test set held back until final evaluation (no information leakage). Random seed fixed to ensure reproducibility. Training conducted on 8 $\times$ A100 GPU cluster (distributed data parallel, gradient synchronization every 2 steps).

Hyperparameter	Value	Rationale	Sensitivity
Batch Size	32 (4 per GPU $\times$ 8 GPUs)	Larger batches $\rightarrow$ less noisy gradients, faster convergence; 32 balances memory/convergence	Too small (<8) causes high variance; too large (>128) risks generalization
Learning Rate	0.001 (base) + 0.0001 warmup	Moderate LR for stable convergence; warmup prevents divergence in early epochs	0.1 (too high, diverges); 1e-5 (too low, slow convergence)
Momentum	0.9	Helps escape local minima; standard for SGD in CV	0.5 (insufficient smoothing), 0.99 (over-smoothing)
Weight Decay	1e-4	Light L2 regularization; prevents overfitting without heavy regularization	1e-3 (too strong, underfitting); 0 (overfitting risk)

Epochs	100 (early stop if val loss plateaus >10 epochs)	Empirically sufficient for convergence; early stopping prevents overfitting	50 (undertrained), 200 (diminishing returns)
Warmup Steps	500	Linear warmup from 0 to base LR; prevents divergence	100 (insufficient smoothing), 2000 (prolongs training)
Dropout	0.2 (on FPN layers)	Modest regularization; too high (>0.5) degrades accuracy	0.5 (degrades accuracy), 0 (overfitting)
Augmentation Strength	Moderate ($\pm 20\%$ brightness, $\pm 30\%$ contrast, $\pm 15^\circ$ rotation)	Balances domain generalization with avoiding over-augmentation	Heavy ($\times 10$ diversity) risks domain gap; light insufficient for ODD

Table 12-7. Training Hyperparameters

12.3.3 Model Evaluation Metrics

Comprehensive evaluation metrics per ISO/PAS 8800 Cl. 8 and ASPICE MLE.4. Beyond standard mAP, metrics include calibration error, fairness metrics, and out-of-distribution performance. Metrics computed on held-out test set (never seen during training/validation).

Metric ID	Metric Name	Formula / Definition	Target Value	Why Important
M1	Mean Average Precision (mAP @ IoU 0.5)	Average of per-class AP; AP = area under PR curve @ IoU ≥ 0.5	≥ 0.92	Standard detection metric; reflects overall accuracy
M2	Precision (overall)	TP / (TP + FP); fraction of positive predictions that are correct	≥ 0.96	Controls false positive rate (false AEB triggers)
M3	Recall (overall)	TP / (TP + FN); fraction of ground truth positives detected	≥ 0.98	Controls false negative rate (missed detections)
M4	F1-Score	$2 \times (\text{Precision} \times \text{Recall}) / (\text{Precision} + \text{Recall})$; harmonic mean	≥ 0.96	Balances precision/recall; single-number summary
M5	Per-Class FN Rate (Children)	FN / (FN + TP) for child pedestrians; must be low due to safety	< 0.02	Children are safety-critical; high FN unacceptable
M6	Per-Class FN Rate (Small, far-field)	FN / (FN + TP) for pedestrians <100 px; models	< 0.03	Far-field FN important for early warning

struggle at distance				
M7	False Positive Rate (Hard Negatives)	FP / (FP + TN) on challenging background set (poles, shadows)	<0.01	Reduces nuisance AEB triggers
M8	Expected Calibration Error (ECE)	$\sum(\text{confidence_bin_avg} - \text{accuracy_bin_avg} \times \text{bin_size}); \leq 0.05$	<0.05	Confidence must match true success rate (safety requirement)
M9	Inference Latency (p99)	99th percentile latency over 1000 frames on Orin HW	≤100 ms	Real-time requirement; exceeding deadline misses pedestrians
M10	Memory Footprint (Orin VRAM)	GPU memory used during inference (weights + activations)	≤512 MB	Orin has 8 GB VRAM; leaves room for other tasks
M11	Fairness Metric (Demographic Parity)	$\text{FPR_demographic1} / \text{FPR_demographic2}$; ratio should be ≈1.0 (no bias)	∈ [0.9, 1.1]	Detects fairness issues (e.g., darker-skinned pedestrians missed more)
M12	Robustness under Distribution Shift	Accuracy on synthetic rain data / accuracy on real rain data; ratio	≥0.90	Model must handle domain gap between synthetic training data and reality

Table 12-8. Model Evaluation Metrics (M1–M12)

PART IV

Practical Tools

Chapters 13–15

CHAPTER 13: INTEGRATED WORK PRODUCT TEMPLATES

SCOPE

8 consolidated work products that integrate ISO 26262, ISO 21434, ISO 21448, ISO/PAS 8800, IATF 16949, and ASPICE v4.0 requirements. Reduces documentation burden from 30+ siloed templates to 8 integrated artifacts with cross-referenced clause mappings. Each work product combines multiple standards' perspectives into a single coherent document.

13.1 Consolidation Rationale

Traditional siloed approach created redundancy, inconsistency, and maintenance burden. A single item (e.g., forward camera ECU) required separate documents for ISO 26262, ISO 21434, and ASPICE—often with conflicting assumptions or outdated information. Integrated approach unifies all requirements into 8 work products, reducing 30+ documents to a manageable set while ensuring all standards' clauses are satisfied.

Standard	Siloed Artifacts (Old Way)	Integrated Approach (New Way)
ISO 26262	Item Definition, Safety Plan, HARA, Safety Goals, TSC, SRS, FMEA, FMEDA, V&V Plan, V&V Report, Safety Case (11 docs)	Unified in WP-1 (Item Def), WP-2 (Risk Assess), WP-3 (Concept), WP-4 (Req Spec), WP-6 (V&V), WP-7 (Assurance)
ISO 21434	CSMS Plan, Threat Analysis, Security Goals, Security Architecture, Secure Dev Plan, Penetration Test Report (6 docs)	Unified in WP-2 (Risk Assess), WP-3 (Concept), WP-4 (Req Spec), WP-5 (Architecture), WP-6 (V&V)
ISO 21448	SOTIF Plan, Triggering Conditions, Eval Plan, Risk Eval Report (4 docs)	Unified in WP-2 (Risk Assess), WP-3 (Concept), WP-4 (Req Spec), WP-6 (V&V)
ISO/PAS 8800	AI Safety Plan, Data Spec, Model Design, ML Eval Report, ML Tool Qualification (5 docs)	Unified in WP-2, WP-3, WP-4, WP-6 (AI extensions), WP-8 (Field Monitoring)
IATF 16949	Manufacturing Plan, Process FMEA, Capability Study, Audit Checklist (4 docs)	Unified in WP-5 (Architecture) + WP-6 (V&V) manufacturing verification
ASPICE v4.0	Process Descriptions (SYS, SWR, TST, SUP, MAN, ORG) across separate framework (7+ docs)	Integrated as activities within WP-1 through WP-8; process maturity assessed per work product
TOTAL	30+ separate documents (fragmented, difficult to maintain, high inconsistency risk)	8 integrated work products (single source of truth, cross-linked, auditable)

Table 13-1. Consolidation: Siloed vs. Integrated Approach

13.2 The 8 Integrated Work Products

WP-1: Integrated Item/Asset Definition

Standards Coverage: 26262:4.3, 21434:5.3.2, 21448:4, 8800:5, ASPICE:SUP.1

Required content structure:

- Functional scope (what does the item do?)
- Safety scope (ASIL determination, Severity/Exposure/Controllability, failure classes)
- Security scope (CAL assignment, threat taxonomy, attack vectors)
- SOTIF scope (ODD definition with numerical ranges, triggering conditions catalog)
- AI scope (if applicable: input/output space, model architecture, data requirements)
- Intended use & lifecycle (production years, end-of-support timeline)
- Assumptions & constraints (vehicle platform, communication standards, power budget)

This work product establishes the item scope across all standards. It is the foundation upon which all downstream analysis, design, and verification are built. Functional scope must be unambiguous and testable. For ADAS systems, functional boundary must clearly separate the ECU's responsibility (e.g., generate AEB trigger) from post-processing in other systems (e.g., brake actuator control logic resides elsewhere). Safety scope includes ASIL determination per ISO 26262 Table 4 (Severity/Exposure/Controllability). Security scope assigns CAL per ISO 21434 Table 15 (Attack vector, Attack feasibility, Impact on functional safety). SOTIF scope explicitly defines ODD with numerical ranges (speed, lighting, weather, road geometry). This prevents vague ODD statements like 'highway/urban' and ensures reproducible testing.

WP-2: Unified Risk Assessment Report (HARA+TARA+SOTIF+AI)

Standards Coverage: 26262:5.3, 21434:6.3, 21448:5–6, 8800:5.3, ASPICE:SYS.2

Required content structure:

- Item-level hazards (severity/probability per ISO 26262 Table 3, ASIL via $S \times E \times C$)
- Threat catalog with attack paths (21434 methodology: attack vector, attack feasibility, CAL)
- SOTIF triggering conditions (21448 Cl. 5.2: operational scenarios causing unreasonable risk)
- AI-specific failure modes (8800 Cl. 5.3: misclassification, miscalibration, distribution shift)
- Cross-standard ASIL/CAL allocation (map hazards → ASILs, threats → CALs)
- Mitigation strategy per hazard/threat (design, diagnostic, or process-based mitigation)
- Safety/security/SOTIF goals derived from analysis (one goal per hazard/threat, with measurable acceptance criteria)

This unified risk assessment combines HARA, TARA, and SOTIF analysis into a single coherent table, avoiding redundancy and ensuring cross-standard consistency. Each hazard is analyzed for root cause, triggering condition, severity (S), exposure (E), and controllability (C) per ISO 26262. ASIL is calculated as $S \times E \times C$ category mapping. Each threat is analyzed for attack vector (vehicle network, firmware update, sensor injection), feasibility (low/medium/high), and impact on functional safety, determining CAL per ISO 21434. SOTIF conditions are listed per ODD scenario (e.g., heavy rain, tunnel transition) with acceptance criteria (e.g., CNN confidence $\geq 80\%$ in heavy rain). AI failure modes address data quality (insufficient coverage), model limitations (confident but wrong), and deployment mismatch (distribution shift). The unified format enables traceability: each hazard → goals → requirements → V&V tests, ensuring no element is missed.

WP-3: Integrated Safety/Security/SOTIF Concept

Standards Coverage: 26262:6.4, 21434:7.4, 21448:6, 8800:5.4, ASPICE:SYS.3

Required content structure:

- Safety goals & cybersecurity goals (tables with ASIL/CAL, target metrics, verification methods)

- SOTIF acceptance criteria (performance targets per ODD condition)
- Functional decomposition with safety allocation (map system functions to ASIL/CAL)
- Security architecture overview (key management, secure boot, OTA authentication)
- SOTIF degradation modes (graceful fallback when ODD boundary crossed)
- AI model role in system (if applicable: confidence thresholds, retraining triggers)
- Requirements allocation to system elements (hardware, firmware, mechanical, process)

The concept phase defines how the item will meet its goals. Safety goals are derived from hazards identified in the HARA; each goal must be traceable back to specific hazards and forward to TSC requirements.

Cybersecurity goals address threats from the TARA. SOTIF criteria specify performance targets (e.g., $\geq 95\%$ lane detection accuracy in light rain). Functional decomposition maps high-level functions (e.g., AEB detection) to system elements (CNN, temporal filter, inhibition logic). Safety allocation assigns ASILs to each element. Security architecture describes protection mechanisms (e.g., secure boot RSA-2048, OTA TLS 1.3, CAN rate limiting). Degradation modes specify fallback behavior when system faces stress (e.g., switch from AEB to LKA-only if CNN confidence drops below threshold due to heavy rain). AI integration specifies model inputs (image), outputs (confidence-weighted boxes), and decision rules (latch if confidence ≥ 0.95 AND temporal consistency ≥ 3 frames).

WP-4: Consolidated Requirements Specification

Standards Coverage: 26262:6.3, 21434:7.3, 21448:6, 8800:8, ASPICE:SWR.1–2

Required content structure:

- Functional requirements (system-level, describing observable behavior)
- Safety requirements (TSC-derived, with ASIL and acceptance criteria)
- Security requirements (CSP-derived, with CAL, CVSS scoring, threat references)
- SOTIF requirements (ODD acceptance criteria, degradation triggers, alert conditions)
- AI requirements (if applicable: data specification, model performance targets, confidence thresholds)
- Data & tooling requirements (ASPICE SUP.1: development tools, simulation environments, V&V tools)
- Traceability matrix: goals $\rightarrow$ requirements $\rightarrow$ verification tests (ensures no orphaned requirements)

This specification provides the authoritative list of 'what to build.' Requirements are organized by category (functional, safety, security, SOTIF, AI, data, tooling) and each includes: (1) unique ID, (2) title, (3) plain-language statement, (4) rationale linking to goals/standards, (5) acceptance criteria (quantified), (6) allocation to system element(s), (7) verification method. Functional requirements describe observable system behavior (e.g., 'shall output AEB trigger within 80 ms of pedestrian detection'). Safety requirements add ASIL and link to safety goals (e.g., TSC-AEB-01 supports SG1). Security requirements specify CAL, threat references, and implementation details (e.g., CSP-SEC-01: secure boot RSA-2048 signature verification, 0 unsigned code execution target). SOTIF requirements specify ODD conditions and acceptance thresholds (e.g., lens obscuration detection with entropy < 2.0 nats triggers confidence reduction 25%). AI requirements detail data requirements (geographic coverage, demographic balance, ODD variants) and model performance targets (mAP ≥ 0.92 , ECE < 0.05 , latency ≤ 100 ms). Traceability matrix cross-links all elements: SG1 $\rightarrow$ TSC-AEB-01/CSP-SEC-01 $\rightarrow$ V&V-AEB-01/V&V-SEC-01, enabling auditors to verify closure.

WP-5: Integrated Architecture Document

Standards Coverage: 26262:6.4–5, 21434:7.4–5, 21448:6–7, 8800:5.4, 9.1, ASPICE:SYS.4

Required content structure:

- Block diagram with safety/security boundaries (hardware, firmware, mechanical components)
- Hardware architecture & safety mechanisms (redundancy, diagnostics, watchdog, failure modes)
- Software architecture (functional decomposition, call graphs, state machines)
- Security controls & threat mitigation placement (secure boot, code signing, OTA channel, CAN filtering)
- AI/ML component integration (if applicable: model deployment, confidence thresholds, retraining interface)
- Watchdog, diagnostics, and fallback strategies (safe states, reset procedures, mode transitions)
- IATF manufacturing process integration (critical process steps, in-process controls, traceability)

The architecture translates concept-phase decisions into implementable design. Block diagram shows hardware components (sensor, processor, watchdog, CAN transceiver) and software modules (image ISP, CNN inference, temporal filter, CAN arbitration). Safety mechanisms address failure modes: dual-core ARM redundancy for critical decisions, watchdog timeout triggers ECU reset, ECC SRAM protects decision registers. Security controls: secure boot RSA signature verification before code execution, OTA updates via TLS 1.3 with server certificate pinning, CAN message validation (CRC) and rate limiting to prevent DoS. SOTIF mitigation: lens obscuration detector (histogram entropy) with confidence reduction, glare detection (pixel saturation) with HDR enable, driver alert on ODD boundary violation. Software architecture specifies modules (IMX390 ISP driver, ResNet-50 inference wrapper, temporal tracker, CAN gateway) and interfaces (shared memory buffers, interrupt handlers, message queues). AI integration includes model loading (TensorRT-optimized weights from secure partition), inference call (GPU kernel launch, 150 ms latency), confidence thresholding (only latch AEB if confidence ≥ 0.95), and retraining trigger (if field data quality metric X exceeds threshold). IATF manufacturing specifies critical process steps (flash erase/program voltage margins, secure boot key provisioning, functional test pass/fail criteria) with in-process controls (electrical measurements, self-test logs) and traceability (serial number linked to firmware version, test results, manufacturing date).

WP-6: Unified V&V Plan & Report

Standards Coverage: 26262:8, 21434:9, 21448:7, 8800:7–9, ASPICE:TST.1–2, SUP.1

Required content structure:

- Unit testing plan (coverage targets per ISO 26262 Table E.1: C0 $\geq 95\%$, C1 $\geq 90\%$ for safety-critical SW)
- Integration testing (safety mechanisms verified in isolation, then combined)
- System testing (end-to-end scenarios, weather/ODD variations, performance benchmarking)
- Security testing (penetration test, threat verification, code injection attacks)
- SOTIF testing (triggering condition validation, ODD boundary testing, mode transitions)
- AI/ML testing (robustness, adversarial attacks, performance metrics per ODD subset)
- Release readiness checklist (all standards' sign-off criteria, test coverage targets, artifact review)
- Field monitoring plan (post-deployment: telemetry collection, anomaly detection, incident response)

V&V plan specifies test strategy across all levels. Unit tests validate individual modules (e.g., Kalman filter lane tracking) with $\geq 95\%$ C0 (statement) and $\geq 90\%$ C1 (decision) coverage. Integration tests combine modules and verify safety mechanisms (e.g., temporal consistency enforcement in AEB latch achieves 99.99% diagnostic coverage). System tests run end-to-end scenarios on HIL (hardware-in-the-loop) and vehicle platforms, validating latency (< 80 ms AEB), accuracy (mAP ≥ 0.92), and cross-system interactions (CAN messaging, steering servo response). Security testing includes penetration testing with third-party lab (simulating 1K

adversarial firmware injection attempts), vulnerability scanning (OWASP Top 10 + automotive-specific), and code signing verification. SOTIF testing validates acceptance criteria in real-world conditions: AEB confidence $\geq 80\%$ in rain (ISO 5006 chamber test), lane detection $\geq 95\%$ in glare (1000+ lux simulation), mode transition latency < 500 ms. AI testing evaluates robustness (accuracy maintained $\geq 92\%$ mAP on adversarial examples), out-of-distribution detection ($\geq 90\%$ sensitivity on unseen geographies), and calibration (ECE < 0.05). Release readiness checklist confirms: all V&V tests passed, code coverage targets met, static analysis violations resolved, safety case complete, penetration test report approved, ODD validated via field trials, manufacturing process capability (Cpk ≥ 1.33) demonstrated, field monitoring system operational. V&V report documents all test results, failure modes encountered and resolved, residual risk assessment, and post-launch monitoring plan.

WP-7: Integrated Assurance Case

Standards Coverage: 26262:8.5, 21434:11, 21448:8, 8800:12, ASPICE:MAN.3

Required content structure:

- GSN-style argument structure (claims, evidence, context)
- Safety case (traceability: hazard $\rightarrow$ goal $\rightarrow$ requirement $\rightarrow$ verification $\rightarrow$ evidence)
- Security case (threat $\rightarrow$ CSG $\rightarrow$ CSP $\rightarrow$ penetration test evidence)
- SOTIF case (triggering condition $\rightarrow$ acceptance criterion $\rightarrow$ ODD testing evidence)
- AI assurance case (data quality $\rightarrow$ model quality $\rightarrow$ field performance evidence)
- Reviewer sign-off (safety lead, security lead, SOTIF lead, AI lead, program manager)

The assurance case is the 'big picture' argument that the item is safe and secure. It follows GSN (Goal Structuring Notation) format: top-level claim ('Forward Camera ECU is functionally safe for ASIL B operation'), sub-claims (AEB FN rate $< 2\%$, LKA accuracy < 0.15 m error, secure boot prevents firmware modification), and supporting evidence (V&V test results, analysis reports, field trial data). Safety case traces each hazard through the development lifecycle: H1 (AEB false trigger) $\rightarrow$ SG1 (prevent false trigger) $\rightarrow$ TSC-AEB-01 (temporal consistency) $\rightarrow$ V&V-AEB-01 (50K scenario test, 99.9% TPR) $\rightarrow$ evidence (test report, metrics). Security case traces threats through mitigations: T1 (firmware modification) $\rightarrow$ CSG1 (prevent unauthorized modification) $\rightarrow$ CSP-SEC-01 (secure boot) $\rightarrow$ V&V-SEC-01 (penetration test, 0 successful attacks) $\rightarrow$ evidence (third-party lab report, code review). SOTIF case argues that degradation modes gracefully maintain safety: ODD-1 (heavy rain) $\rightarrow$ SOTIF1 (maintain $\geq 80\%$ confidence) $\rightarrow$ TSC-SOTIF-01 (entropy detection) $\rightarrow$ V&V-SOTIF-01 (rain chamber test, confidence maintained) $\rightarrow$ evidence. AI assurance case argues that model quality is sufficient: training data $\geq 500K$ images, balanced across ODD $\rightarrow$ model validation mAP ≥ 0.92 and ECE < 0.05 $\rightarrow$ field trial 100K km with FN rate $< 2\%$ $\rightarrow$ evidence (dataset audit, model evaluation metrics, field incident logs). Assurance case is reviewed and approved by 4-person panel (safety lead, security lead, SOTIF lead, AI lead) before production release.

WP-8: Unified Field Monitoring Procedure

Standards Coverage: 26262:9, 21434:10, 21448:8, 8800:9, ASPICE:SUP.3, MAN.2

Required content structure:

- Telemetry plan (metrics collected: CNN confidence histogram, glare flag, lens occlusion, AEB trigger count, CAN errors, WDG resets)
- Data ingestion & storage (secure, encrypted, privacy-preserving; no raw frame images, only aggregated statistics)

- Anomaly detection triggers (KL-divergence shift >0.15 nats, FP spike $>0.5\%$, WDG reset >3 /week, CAN bus-off >10 /hour)
- Incident response protocol (root cause analysis, correlation with SW version/HW variant/geography, retraining or OTA patch)
- Long-term trending (model degradation monitoring, confidence calibration drift, security event logs)
- Regulatory reporting requirements (NHTSA, EU, China: safety defect reporting, cybersecurity incident disclosure)
- Customer communication strategy (transparent disclosure of known issues, OTA update schedule, opt-out procedures)

Field monitoring ensures safety and security post-deployment. Telemetry system (ASPICE SUP.3) logs aggregated statistics every frame: CNN confidence scores (16-bin histogram), glare detection flag (count/1000 frames), lens obscuration flag (count), AEB trigger events (count per drive), LKA engagement count, CAN frame errors (CRC failures, timeout, bus-off), watchdog resets. Data uploaded via cellular (LTE/5G) every 24 hours or when alert condition detected. Privacy-preserving: raw images NOT transmitted, only statistics and event counts. No personally identifiable information logged. Analytics platform (backend ML pipeline) computes daily rolling statistics per vehicle: confidence distribution KL divergence from baseline (alert if >0.15 nats), false positive rate (alert if $>0.5\%$), CAN error rate (alert if >10 /hour), watchdog resets (alert if >3 /week). When alert triggered, incident recorded with vehicle ID, timestamp, SW version, HW variant, geographic location, weather conditions. Safety team performs root cause analysis within 24 hours: Is it a model issue? Hardware problem? Regional ODD mismatch? Systematic pattern or isolated case? Escalation: if ASIL B issue identified (safety-critical failure), issue engineering task immediately; root cause analysis completed within 72 hours; patch developed and field validation commenced; OTA rollout within 7 days if critical. If non-critical issue, standard 30-day cycle. Post-update monitoring: track metrics for 2 weeks to confirm fix. Regulatory reporting (ASPICE MAN.2): Any safety-related defect reported to NHTSA within 30 days per 49 CFR 1810.1. Cybersecurity incidents reported per ISO 21434 Cl. 10.3 and TISAX requirements. Customer communication: OEM website updates on known issues, timeline for fixes, opt-out procedures for early adopters.

CHAPTER 14: AUDIT & ASSESSMENT READINESS

SCOPE

Preparing for simultaneous multi-standard audits. Covers ISO 26262 functional safety assessment, ISO 21434 CSMS audit, ASPICE assessment, and IATF audit. Provides evidence reuse matrix and common findings prevention strategies. Practical tips for audit coordination and pre-audit preparation.

14.1 Audit Types Comparison

Five primary audit types target different aspects of the integrated system. Each auditor brings specific expertise and focuses on their standard's requirements. Coordinating all five audits in parallel (vs. sequential) reduces disruption and allows evidence reuse across auditors. The table below compares audit types, scope, duration, and key success factors.

Audit Type	Standard	Scope	Duration	Frequency	Key Auditors
FSA (Functional Safety Assessment)	26262:2018 Cl. 4.2–3, Annex C	Item-level safety lifecycle; ASIL determination; HARA quality; FMEA coverage; V&V completeness; safety case rigor	3–5 days (ASIL B/C items)	Every 3 years or significant change	TÜV Süd, TÜV Nord, Dekra (notified bodies)
CSMS Audit	21434:2021 Cl. 5–11	CSMS governance (responsibility matrix, budget, training), threat analysis, security requirements, penetration testing, incident response, supply chain security	2–4 days	Annual or bi-annual (for certification)	Internal CSM lead or third-party auditor (external certification body)
ASPICE Assessment	ASPICE v4.0 (48 processes across SYS, SWR, TST, SUP, MAN, ORG)	Process capability level (1–5) per process; maturity across requirements management, configuration mgmt, testing, code review, metrics tracking	5–10 days	Once per program or per 2-year cycle	ASPICE-certified assessor (lead) + automotive domain expert
IATF Audit	IATF 16949:2016 Cl. 8	Manufacturing process capability (Cpk ≥ 1.33 on critical params); FMEA and control plans; traceability system (serial $\rightarrow$ firmware $\rightarrow$ test results); supplier quality agreements	3–5 days	Every 3 years (facility certification); ongoing internal audits	IATF-certified auditor
SOTIF Evaluation	21448:2022 Cl. 4–9	ODD definition rigor (numerical ranges, map coverage), triggering condition catalog, acceptance criteria, field trial results, mode transition testing	2–3 days (desk + field observation)	Pre-production (design phase) + post-launch field trial	SOTIF specialist (OEM or consultant)

Table 14-1. Audit Types Comparison

14.2 Top 10 Common Audit Findings & Prevention Strategies

Experience from 50+ automotive safety audits reveals recurring patterns. Proactive prevention saves time and improves audit outcome. Below are the top 10 findings and prevention strategies:

1. Incomplete Traceability. Hazards identified in HARA but no corresponding requirement in SRS; requirement in SRS but no V&V test; test passes but doesn't verify the requirement.

Prevention: Create traceability matrix template in WP-4 (Requirements Spec) with columns: Requirement ID | Safety Goal | HARA Hazard | V&V Test ID. Require sign-off by safety lead before SRS baselined. Use automated tools (Jira, Reqtify, Doors) to enforce bi-directional links and report coverage gaps. Before audit, run traceability completeness report: target 100% requirements traced to goals, 100% goals traced to tests.

2. FMEA without Clear Mitigations. Failure modes identified but mitigation strategy vague ('improve CNN', 'add testing') or unverified by design.

Prevention: For each failure mode, explicitly list: (1) design mitigation (e.g., ensemble voting), (2) diagnostic mitigation (e.g., confidence monitoring), (3) responsible component, (4) target metric (e.g., MR $\geq 99.5\%$), (5) V&V test ID. Cross-reference FMEA to architecture to show where mitigation is implemented. Before audit, perform mitigation verification: for each failure mode, show V&V test results proving mitigation effective.

3. Insufficient ODD Definition. SOTIF plan mentions 'highway/urban' but ODD lacks numerical ranges (speed, lighting, precipitation). Vague ODD leads to over/under-testing.

Prevention: Per ISO 21448:5.2, define ODD with explicit numerical ranges: Speed [0–120] km/h, Lux [50–100,000], Precipitation [0–15] mm/h, Temperature [–10, +50]°C. Include map of geographic regions covered by field trials. Document ODD boundaries and verification evidence (field trial data, sensor characterization). Use ODD Compliance Matrix: list each ODD parameter, acceptance threshold, test location/condition.

4. V&V Coverage Gaps. Unit tests at 80% C0 coverage; integration tests cover happy path but miss error cases (watchdog timeout, CAN bus-off, sensor failure).

Prevention: Require C1 (decision) coverage $\geq 90\%$ for safety-critical SW. Use coverage matrix (test → requirement mapping) to show which requirements are covered by which tests. Identify uncovered paths and design explicit tests. Use automated tools (LDRA, Polyspace) to enforce coverage gates and block code commit if coverage below target.

5. Weak Secure Boot Evidence. Secure boot documented in architecture but penetration test never performed; no hands-on evidence of RSA signature verification.

Prevention: Mandatory third-party penetration testing (external lab). Test procedure: (1) Obtain production ECU or equivalent hardware. (2) Attempt to boot unsigned firmware (should fail). (3) Attempt to boot with tampered firmware (signature invalid, should fail). (4) Boot with legitimate firmware (should succeed). (5) Timing analysis (ensure constant-time RSA to prevent timing attacks). Document results with photos/videos for audit evidence.

6. Model Performance Only on Test Set. CNN accuracy 95% reported on test data, but no field validation on real-world unseen data; distribution shift not evaluated.

Prevention: ISO/PAS 8800 Cl. 7–9 requires field validation. Conduct ≥ 50 h real-world trial on production vehicle; log ground truth via safety driver (manual labels or dual-camera system). Evaluate FN/FP/precision/recall on field data (not synthetic test set). Report per-ODD breakdown (daytime/night, clear/rain). Compare field metrics to test set metrics (if gap $> 5\%$, investigate domain shift).

7. Data Version Control Missing. Dataset v1.0 used for training, but no git hash, metadata, or lineage recorded. Later, unclear which model version used which data.

Prevention: Per ASPICE SUP.1, implement data versioning: (1) Dataset folder with version tag (MAJOR.MINOR.PATCH, date). (2) SHA-256 hash of all images listed in manifest. (3) JSON metadata file: image count, class distribution, ODD composition, source, collection date, annotator. (4) Link model checkpoint filename to dataset version: ResNet50-v1.2-trained-on-Dataset-v1.0-SHA256-abc123. (5) Archive in version control (git-lfs for large files) with full history.

8. Audit Trail Gaps. Code review comments in Jira closed, but no permanent link from code commit to review; review artifacts lost after project closure.

Prevention: Archive all code review artifacts (PRs, comments, sign-offs, timestamps) with immutable storage (GitHub/GitLab releases, AWS S3 versioning). Link commit hash to code review ID in commit message. Retain for 7+ years per ASPICE & IATF. Use branch protection rules (require ≥ 2 approvals for safety-critical code). Periodically export archives to external storage (e.g., ISO 9001 document archive).

9. Inadequate Security Incident Logging. Security incident response plan exists, but no actual log of past incidents or root cause analyses; plan untested.

Prevention: Tabletop exercise: simulate security incidents in test environment. Scenario: (1) False CAN injection attack detected. Measure response time (should be <50 ms). (2) Unauthorized OTA server detected. Verify client rejects due to certificate pinning. (3) Firmware corruption detected. Verify watchdog timeout and ECU reset to safe state. Document each scenario with results, timeline, and lessons learned. Update incident response SOP based on findings.

10. AI Confidence Calibration Ignored. CNN outputs confidence scores but calibration never validated; threshold set arbitrarily (e.g., 0.5) without justification.

Prevention: Compute Expected Calibration Error (ECE) on validation set. Bin confidence scores [0–0.1, 0.1–0.2, ..., 0.9–1.0]; for each bin, compute fraction of samples with correct prediction. ECE = mean absolute difference between confidence and accuracy (target ECE <0.05). If poorly calibrated, apply recalibration: temperature scaling (divide logits by learnable T before softmax) or Platt scaling (logistic regression on confidences). Validate calibration on held-out test set before deployment.

14.3 Cross-Audit Evidence Reuse Matrix

Single artifact satisfies multiple auditors, reducing redundant documentation. The matrix shows which work product addresses which standard's requirements:

Artifact (WP)	26262 Auditor	21434 Auditor	ASPICE Assessor	IATF Auditor	SOTIF Evaluator
WP-1 (Item Definition)	Item scope (Cl. 4.3), safety scope	Security scope (Cl. 5.3.2), functional boundaries	Requirements source (SYS.1)	Item scope, safety-related functions	ODD definition (Cl. 4)
WP-2 (Risk Assessment)	HARA results (Cl. 5.3), ASIL determination	TARA results (Cl. 6.3), threat matrix	Risk analysis (SYS.2), traceability	FMEA input, hazard identification	Triggering conditions (Cl. 5), ODD scenarios
WP-3 (Concept)	Safety goals (Cl. 5.4), TSC (Cl. 6.4)	Cybersecurity goals (Cl. 6.4), CSP	Requirements derivation (SYS.3)	Design input, safety requirements	SOTIF criteria (Cl. 6.4), acceptance thresholds
WP-4 (Req Spec)	Functional & safety req (Cl. 6.3), traceability to goals	Security req (CAL-mapped), CVSS	Requirement mgmt (SWR.1), traceability matrix	Manufacturing req, critical parameters	SOTIF req, ODD conditions, performance targets
WP-5 (Architecture)	TSC implementation (Cl. 6.4), redundancy, diagnostics	Security controls placement (Cl. 7.5), key management	System decomposition (SYS.4), design rationale	Design FMEA, process capability, critical process steps	Degradation modes, fallback strategies
WP-6 (V&V)	Test plan & results (Cl. 8),	Penetration test (Cl. 9.4), threat	Test strategy & traceability	Process validation,	ODD testing, field trial

Plan/Report)	coverage metrics, safety case evidence	verification, security testing	(TST.1–2), metrics	capability study, test results	results, acceptance criteria
WP-7 (Assurance Case)	Safety case (Cl. 8.5.1), GSN structure, evidence linking	Security case (Cl. 11), threat argument	Process maturity evidence (MAN.3), achievement metrics	Quality evidence, process compliance	Risk argument, ODD assurance
WP-8 (Field Monitoring)	Anomaly detection plan (Cl. 9), post-launch verification	Incident response (Cl. 10.3), security event logging	Data mgmt (SUP.3), incident mgmt (MAN.2), metrics tracking	Traceability log, issue tracking, corrective actions	Model degradation monitoring (Cl. 8.2–3), performance trends

Table 14-2. Evidence Reuse: Single Artifact → Multiple Auditors

14.4 Assessment Readiness Checklists per Standard

Use these checklists 4 weeks before audit to verify preparation:

14.4.1 ISO 26262 FSA Readiness

- ☐ Item definition complete with functional, safety, and operational scope; ASIL justified per Table 4 (S×E×C) [26262:4.3–4.4]
- ☐ HARA comprehensive (≥8 hazards identified); each traced to safety goal; ASIL allocation documented [26262:5.3–5.4]
- ☐ FMEA/FMEDA complete (≥50 failure modes); SPFM ≥90%, LFM ≥95%, PMHF ≤1e-7/h for ASIL B [26262:7.4.2, 7.5.4]
- ☐ TSC & SRS specified; requirements unambiguous and verifiable; traceability matrix 100% complete [26262:6.3–6.4]
- ☐ V&V plan addresses unit (C0 ≥95%, C1 ≥90%), integration, system, and field validation [26262:8]
- ☐ Code review & static analysis reports; 0 violations in safety-critical paths (Polyspace run) [26262:8.3.2]
- ☐ Safety case document (GSN structure, all claims supported by evidence); reviewed by 3-person panel [26262:8.5.1]
- ☐ Tool qualification reports for all development tools (compiler, simulator, test harness); TCL assessment documented [26262:8.11]

14.4.2 ISO 21434 CSMS Audit Readiness

- ☐ CSMS governance documented (responsibility matrix, budget, training plan, meeting minutes) [21434:5.1–5.2]
- ☐ TARA threat model complete (≥8 threats); attack paths enumerated; each threat traces to cybersecurity goal [21434:6.3]
- ☐ Penetration test report (third-party lab, CVSS scoring) with 0 unresolved vulnerabilities CVSS ≥7.0 [21434:9.4.4]
- ☐ Secure boot, code signing, OTA authentication tested; demo of failed boot with unsigned code available [21434:8.4.2, 8.5.1]
- ☐ Supply chain security: vendor risk assessments documented; SCA (software composition analysis) run on dependencies [21434:7.6, 8.3.3]
- ☐ Incident response procedure tested via tabletop exercise; simulated security incident response documented [21434:10.3]
- ☐ CAN/Ethernet frame validation & rate limiting tested in lab; DoS attack mitigation demonstrated [21434:8.4.2]

14.4.3 ASPICE v4.0 Capability Assessment

- ☐ Process descriptions (SOP) documented for SYS.1–3, SWR.1–6, TST.1–2, SUP.1–3; each ≥3 pages [ASPICE:SYS, SWR, TST, SUP]
- ☐ Metrics tracked (cycle time, defect density, schedule variance, code coverage); monthly trending reports [ASPICE:MAN.3–4]
- ☐ Requirements management tool (Jira/Reqtify) enabled; traceability matrix auditable; forward/backward links verified [ASPICE:SWR.1]
- ☐ Configuration management plan documented (branching strategy, merge workflow, release procedure); git history auditable [ASPICE:SUP.2]
- ☐ Lessons learned database maintained; post-mortems for each project phase completed and actioned [ASPICE:MAN.2]
- ☐ Code review checklist used; all safety-critical code reviewed (≥2 approvers); review comments archived with permalinks [ASPICE:SWR.5]

14.4.4 IATF 16949 Manufacturing Readiness

- ☐ Product & process FMEA (AIAG-VDA method) completed; RPN for safety items ≤70; mitigation verified [IATF:3.1.2, 8.3.2]
- ☐ Control plan per IATF 16949:3.1 with special process controls for ECU flash programming & functional test [IATF:8.5]
- ☐ Process capability study (Cpk ≥1.33) for critical parameters (e.g., flash voltage margins, secure boot key provisioning) [IATF:8.2.4]
- ☐ Preventive maintenance plan for manufacturing equipment; calibration certificates current [IATF:8.5.2]
- ☐ Traceability system (serial → firmware → test results) validated end-to-end; audit trail maintained 7+ years [IATF:8.5.2]
- ☐ Supplier quality agreements include functional safety & cybersecurity requirements; audits documented [IATF:4.4.1, 8.4.1]

14.5 Multi-Standard Audit Tips

Tip 1: Designate a Single Audit Coordinator. Assign one person (program manager or chief engineer) to schedule all audits within a 2–4 week window. Coordinate logistics (hotel, meals, parking, office space for auditor meetings). Ensure on-site support team (engineers, data analysts) is available for interviews and facility tours. Single-window approach reduces disruption and allows cross-auditor discussions on shared topics (e.g., software architecture, V&V strategy). Coordinate auditor introductions to project leadership on Day 1.

Tip 2: Create an Audit Evidence Portal. Host all WPs (1–8) plus supporting docs (FMEA spreadsheet, test reports, code review logs, field trial data) in secure shared folder (SharePoint, OneDrive). Structure: /WP-1 (Item Def), /WP-2 (Risk Assess), ..., /Supporting (FMEA, test logs, etc.). Grant read-only access to auditors 1 week before audit. Include version control history (document revisions, sign-off dates). Auditors can pull evidence on-demand without waiting for manual document retrieval. Portal also serves as post-audit archive.

Tip 3: Conduct Pre-Audit Internal Review. 2–4 weeks before official audits, run internal dry-run with safety lead + security lead + ASPICE lead. Review all WPs for completeness, consistency, and compliance with standards. Identify gaps (missing V&V test reports, incomplete FMEA mitigation, traceability matrix gaps). Create gap closure task list with owners and deadlines. Resolve all gaps before auditors arrive. This reduces 'Major Findings' count and demonstrates strong preparation.

Tip 4: Leverage Evidence Reuse (Table 14-2). When an auditor asks 'Show me your V&V plan,' point them to WP-6 (Unified V&V Plan & Report). When IATF auditor asks for traceability, show WP-4 requirements traceability matrix. When ASPICE assessor asks for process evidence, reference SOP linked from WP-1–8.

Unified approach saves time and reduces redundant questioning. Cross-auditor coordination: if 26262 auditor and 21434 auditor both need architecture evidence, reference WP-5 together.

Tip 5: Prepare Auditor Onboarding Deck. Create a 15-minute presentation (5 slides) covering: (1) Item scope (functional description, ASIL, CAL, ODD), (2) V&V approach (test levels: unit/integration/system/field, coverage targets), (3) Known findings from pre-audit (acknowledge issues and show closure evidence), (4) Field monitoring strategy (post-launch assurance), (5) Project timeline (development phase → audit → production). Helps auditors quickly understand context and focus on high-risk areas.

CHAPTER 15: TOOL QUALIFICATION

SCOPE

Comprehensive guide to tool qualification across all standards. Covers ISO 26262-8:Cl.11 (TCL1-3), ISO/PAS 8800 Cl.13 (ML tool qualification), ASPICE tool support, and one qualification package. Includes 15-tool automotive stack with guidance.

15.1 ISO 26262-8:Cl.11 — Tool Confidence Level (TCL)

ISO 26262-8:2018 Cl. 11 defines three tool confidence levels based on error detection capability. The principle: higher-confidence tools (TCL3) require less process verification; lower-confidence tools (TCL1) require extensive manual review to catch tool errors. TCL assessment drives development burden: TCL3 compiler can be used with minimal SQA; TCL1 text editor requires comprehensive code review.

TCL	Description	Error Detection Capability	Evidence Required	Example Tools
TCL3	Highest: tool errors unlikely to cause undetected failures	Tool detects & prevents errors via automated analysis; comprehensive testing	Qualification report: architecture review, test coverage ≥95%, user feedback from ≥10 automotive projects	Polyspace C/C++ (certified), LDRA TBrun (certified), GCC + Misra-C linting
TCL2	Medium: tool errors may occur but likely detected downstream	Tool may miss some errors; manual review necessary post-tool execution	Tool documentation + evidence of test coverage ≥80% + user experience (≥5 mature projects, bug history analyzed)	Static analysis tools (PC-Lint, cppcheck), open-source compilers with community review
TCL1	Lowest: tool errors may propagate undetected; extensive manual process required	Minimal error detection; no automated safeguards; relies on manual verification	Tool documentation only; no specific qualification report needed; extensive downstream QA compensates	Editors (Vim, VS Code), version control (Git), generic test runners, spreadsheet tools

Table 15-1. Tool Confidence Level (TCL) — ISO 26262-8:Cl.11

Key principle: TCL determination drives downstream process. A TCL3 compiler requires minimal SQA process (tool is certified to detect errors). A TCL1 editor requires extensive code review and manual validation (tool provides no error detection).

15.1.1 TCL Classification Decision Tree

Determine TCL for any tool using this decision tree (ISO 26262-8:2018 Annex F):

Question	Yes → Action	No → Action
Q1: Can the tool directly cause undetected failures in safety-related code output?	Proceed to Q2	Tool is TCL1 (non-safety-relevant)
Q2: Does the tool have automated error detection for its primary function?	Proceed to Q3	Tool is TCL1 (no error detection)
Q3: Is the tool's error detection capability ≥90% on test suite representative of automotive SW?	Proceed to Q4	Tool is TCL2 (partial detection)
Q4: Is the tool certified/qualified per ISO 26262 or IEC 61508 by third-party notified body?	Tool is TCL3	Tool is TCL2 (meets threshold but not certified)

Table 15-2. TCL Decision Tree

15.2 ISO/PAS 8800 ML Tool Qualification

ISO/PAS 8800 Cl. 13 extends tool qualification to machine learning frameworks, data annotation tools, and model registry systems. ML tools present unique risks: (1) training data quality directly affects model output, (2) tool chains (PyTorch → TensorRT → embedded runtime) have multiple integration points, (3) model reproducibility depends on tool version pinning. ML tool qualification assesses: (a) training framework (PyTorch, TensorFlow) for numerical stability, (b) model optimization tools (TensorRT, ONNX) for inference correctness, (c) data management tools (DVC, MLflow) for version control, (d) annotation tools (CVAT, Labelbox) for labeling quality.

ML Tool Category	Tool Examples	Qualification Focus	Risk Mitigation
Training Framework	PyTorch, TensorFlow, JAX	Numerical stability (determinism, numerical precision), gradient computation correctness, distributed training synchronization	Run equivalent model on 2+ frameworks; compare outputs (max difference <1e-4); validate on test set
Model Optimization	TensorRT, ONNX Runtime, TVM	Inference correctness (quantization errors), layer fusion correctness, latency accuracy	Compare optimized model outputs to FP32 baseline (max difference <1e-3); latency within ±5% specification
Data Management	DVC, MLflow, Weights & Biases	Data lineage tracking, version immutability, experiment	Audit data versioning (SHA-256 hashes), model checkpoint

		reproducibility	linkage, parameter logging
Annotation Tools	CVAT, Labelbox, SageMaker Ground Truth	Label quality assurance, inter-annotator agreement, consensus mechanism	Measure IoU agreement $\geq 95\%$ on audit set; document disagreement resolution
Testing & Evaluation	pytest, unittest, CML, DVC Metrics	Test coverage (code & data), metric reproducibility, CI/CD reliability	100% test coverage for critical modules; deterministic test results (fixed random seed); version-controlled test suite

Table 15-3. ML Tool Qualification (ISO/PAS 8800 Cl. 13)

15.3 One Qualification Package Example

Walkthrough of qualifying PyTorch as a TCL2 training framework for pedestrian detection model.

Step 1: Define Qualification Scope PyTorch v1.12.1 (latest stable at Q1 2023) with CUDA 11.6 backend, running on 8× A100 GPU cluster. Scope: model training (forward pass, backward pass, gradient updates), data loading, and evaluation. Out-of-scope: inference deployment (handled separately via TensorRT qualification).

Step 2: Establish Acceptance Criteria (1) Training convergence reproducibility: train ResNet-50 model 5 times with fixed seed; loss curves must overlap within 5%. (2) Gradient correctness: compare numerical gradients (finite difference) vs. autodiff gradients; max error $< 1e-4$. (3) Distributed training: 8-GPU training must converge to same loss as 1-GPU training (within 1%). (4) Evaluation reproducibility: validation mAP computed 5 times; std dev < 0.01 .

Step 3: Conduct Qualification Testing (1) Numerical stability test: train simple 2-layer MLP on synthetic data; verify gradient norms remain bounded over 1000 steps. (2) Distributed training test: train ResNet-50 on full dataset with 1 GPU, then 8 GPUs (with gradient accumulation to match batch size); compare loss curves (should converge identically). (3) Evaluation reproducibility test: compute validation metrics (mAP, precision, recall) 5 times; confirm metrics match within tolerance.

Step 4: Document Results Qualification report (10–15 pages): Executive summary (PyTorch v1.12.1 qualified as TCL2 framework), qualification scope, acceptance criteria, test procedures & results, residual risks (CUDA numerical precision differences across GPU models), mitigation (always train on A100 cluster; validate on test set after any changes), and reviewer sign-off (ML lead, safety lead).

15.4 Automotive Tool Stack (15 Tools with Guidance)

Typical automotive safety-critical development tool stack covering all phases. For each tool, determine TCL and document qualification evidence.

Tool Category	Tool Name	TCL Target	Qualification Effort	Remarks
Compiler	GCC (gnu-arm v11)	TCL2–3	Medium (test suite $\geq 80\%$ coverage)	Use certified ARM toolchain; verify MISRA-C compliance plugin
Compiler	LLVM/Clang	TCL2	Medium (open-source community)	Good for C++ support; ensure deterministic output

			review)		
Static Analysis	Polyspace C/C++	TCL3	Low (tool is certified per IEC 61508)	Proprietary, certified tool; minimal SQA needed	
Static Analysis	LDRA TBrun	TCL3	Low (certified tool)	Coverage analysis + execution; supports MISRA-C	
Linting	PC-Lint Plus	TCL2	Low-Medium (mature tool, extensive testing)	Automotive-specific rules available; configurable	
Testing	CANTATA (unit test framework)	TCL2-3	Medium (test harness verification)	Real-time testing; coverage instrumentation	
Version Control	Git	TCL1	Low (no code analysis)	Use with code review process (SWR.5) to achieve TCL2 equivalent	
Code Review	GitHub/GitLab	TCL1	Low (tool neutral; process-based)	Enforce branch protection, require ≥ 2 approvals, archive comments	
Simulation	MATLAB/Simulink	TCL2	Medium (toolchain verification per IEC 61508)	Use certified compiler for code generation	
CI/CD Pipeline	Jenkins	TCL1	Medium (test automation, build verification)	Enforce gating (tests must pass before merge)	
Data Management (ML)	MLflow	TCL2	Medium (experiment tracking, model registry verification)	Validate model checkpoint versioning, parameter logging	
Training Framework (ML)	PyTorch	TCL2	High (see qualification package example 15.3)	Numerical stability testing required; distributed training validation	
Model Optimization (ML)	TensorRT	TCL2	High (inference correctness, quantization error validation)	Compare optimized vs. FP32 outputs; latency tolerance $\pm 5\%$	
Annotation Tool (ML)	CVAT	TCL1-2	Medium (inter-annotator	Use with consensus workflow for TCL2 equivalent	

			agreement ≥95%)	
Diagnostic Tools	GDBM (Debugger)	TCL1	Low (used for debugging, not primary output)	Supplement with automated testing (TCL2+ tools handle verification)

Table 15-4. Automotive Tool Stack (15 Tools, TCL Guidance)

PART V

Reference & Appendices

Appendices A–D

APPENDIX A: CROSS-REFERENCE TABLES BY LIFECYCLE PHASE

This appendix provides comprehensive cross-references between standards across all lifecycle phases. Each table maps activities and work products to specific clause references in six standards, enabling auditors and developers to verify completeness and consistency. Tables are organized by lifecycle phase: Concept, System Design, HW/SW Development, V&V, and Operations.

A.1 Concept Phase Cross-References

Concept phase activities and their corresponding clauses across six standards. Each row represents a key activity (e.g., HARA, SOTIF triggering conditions catalog) and columns show which standard(s) cover that activity.

Activity	26262 Clause	21434 Clause	21448 Clause	8800 Clause	9001/IATF	ASPICE Process
Item Definition	4.3	5.3.2	4	5	8.1.1	SUP.1 (Work product definition)
ASIL Determination	4.4	—	—	—	8.1.1	SYS.1 (Requirements elicitation)
HARA (Hazard Analysis)	5.3	—	5.2	5.3	8.1.1	SYS.2 (Requirements analysis)
TARA (Threat Analysis)	—	6.3	—	5.3	—	SYS.2
Safety Goals Definition	5.4	—	—	5.4	8.2.1	SYS.2–3
Cybersecurity Goals	—	6.4	—	6.4	—	SYS.2–3
SOTIF Triggering Conditions	—	—	5.2, 5.3	—	—	SYS.2 (SOTIF analysis)
AI-Specific Failure Modes	—	—	—	5.3	—	SYS.2
ODD Definition	—	—	4, 5.2	5	—	SYS.1
Operational Design Domain Assessment	—	—	5.2, 5.3	5.2	—	SYS.2
Safety Case Outline	8.5.1	—	—	12	—	MAN.3 (Assurance)
Security Case	—	11	—	—	—	MAN.3

Outline						
Requirements Allocation (High-level)	6.3	7.3	6	8	8.1.1	SYS.3 (Requirements decomposition)
Functional Safety Plan	3.2	—	—	—	—	MAN.1 (Planning)
CSMS (Cybersecurity Management System)	—	5	—	—	—	ORG.1 (Org infrastructure)
Document & Artifact Baseline	—	—	—	—	8.3.1	SUP.2 (Configuration mgmt)
Design Review (Gate 1)	—	—	—	—	8.2.3	MAN.3 (Review)
Stakeholder Sign-off	—	—	—	—	8.1.1	MAN.3

Table A-1. Concept Phase Cross-References (18 activities)

A.2 System Design Phase Cross-References

Activity	26262 Clause	21434 Clause	21448 Clause	8800 Clause	9001/IATF	ASPICE Process
Architecture Definition	6.4, 6.5	7.4, 7.5	6.2, 6.3	9.1	8.2.2	SYS.4 (System design)
Block Diagram & Interfaces	6.4.1	7.4.1	6.2	9.1	8.2.2	SYS.4
System Decomposition	6.4.2	7.4.2	6.3	9.1	8.2.2	SYS.4
Safety Mechanism Design	6.4.3	—	—	—	—	SYS.4
Security Control Placement	—	7.4.3, 7.5.1	—	9.2, 9.3	—	SYS.4
SOTIF Degradation Mode Design	—	—	6.3, 6.4	—	—	SYS.4
AI Model Integration	—	—	—	9.1, 9.2	—	SYS.4

Functional Requirements (System-level)	6.3.1	7.3.1	6	8	8.1.3	SWR.1–2 (Software req)
Safety Requirements Allocation	6.3.2	—	—	8.2	—	SWR.1–2
Cybersecurity Requirements Allocation	—	7.3.2, 7.3.3	—	8.2	—	SWR.1–2
SOTIF Requirements Allocation	—	—	6	—	—	SWR.1–2
Data Requirements (AI)	—	—	—	7.2	—	SWR.1
Traceability Matrix (Goals → Req)	6.3.3	7.3.4	—	—	—	SWR.1
Redundancy & Diagnostics Design	6.4.4	—	—	—	—	SYS.4
FMEA (System-level, preliminary)	7.4.2	—	—	—	8.3.2	SYS.4
Secure Boot & Key Management	—	8.4.2, 8.5.1	—	9.3	—	SYS.4
OTA Update Architecture	—	7.4, 8.4	—	9.3	—	SYS.4
Design Review (Gate 2)	—	—	—	—	8.2.3	MAN.3

Table A-2. System Design Phase Cross-References (18 activities)

A.3 HW/SW Development Phase Cross-References

Activity	26262 Clause	21434 Clause	21448 Clause	8800 Clause	9001/IATF	ASPICE Process
Software Requirements Specification	6.3, 6.4	7.3, 7.4	6	8	8.1.3	SWR.1–2
Software Design	7.2	8.3	—	9.1	8.2.2	SWR.2 (Software

Document						design)
Hardware Design & Schematics	7.2	8.3	—	9.1	8.2.2	SYS.4 (Hardware design)
FMEA/FMEDA (Detailed)	7.4.2, 7.5	8.4.2, 8.4.3	—	—	8.3.2	SWR.3 (Coding)
Software Code Implementation	7.3	8.4	—	9	8.2.2, 8.3.2	SWR.3 (Implementation)
MISRA C:2012 Compliance	6, 7.3	8.3	—	—	—	SWR.3
Code Review	8.3.2	8.4, 8.5	—	9.2	8.3.2	SWR.5 (Code review)
Static Analysis (Polyspace, etc)	7.3.2, 8.3.2	8.3, 8.4	—	9.2	—	SWR.5
Unit Test Development	8.3.4	9.3, 9.4	—	9.4	—	SWR.4 (Unit testing)
Model Training & Validation (AI)	—	—	—	7, 8, 9	—	SWR.3 (ML training)
Dataset Versioning & Quality (AI)	—	—	—	7.2, 7.3	—	SWR.1 (Data specification)
Tool Qualification	8.11	—	—	13	—	SUP.1 (Tool support)
Build Automation	—	—	—	—	—	SUP.2 (Configuration mgmt)
Continuous Integration Setup	—	—	—	—	—	SUP.2
Firmware Image Signing	—	8.4, 8.5	—	9.3	—	SWR.3
Document Baseline (DDD, SDS)	—	—	—	—	8.3.1	SUP.2
Review Gate (Code Complete)	—	—	—	—	8.3.2	MAN.3
Configuration	—	—	—	—	8.3.1	SUP.2 (Version

Control

control]

Table A-3. HW/SW Development Phase Cross-References (18 activities)**A.4 Verification & Validation Phase Cross-References**

Activity	26262 Clause	21434 Clause	21448 Clause	8800 Clause	9001/IATF	ASPICE Process
V&V Plan Development	8.2	9.2	7.2	7.2, 7.3	—	TST.1 (Test planning)
Unit Test Execution	8.3.4, 8.4.4	9.3, 9.4	—	9.4	8.3.3	SWR.4 (Unit test)
Integration Test Planning	8.2.2	9.2.1	7.2	7.3	8.3.3	TST.1
Integration Test Execution	8.4.4	9.4.1	7.4	9.4	8.3.3	TST.2 (Test execution)
System Test Planning	8.2.3	9.2.2	7.2	7.3	8.3.3	TST.1
System Test Execution	8.4.4	9.4.2	7.4	9.4	8.3.3	TST.2
Hardware-in-the-Loop (HIL)	8.4.4	9.4	7.4	7.4	—	TST.2
Software-in-the-Loop (SIL)	8.3.4	9.3, 9.4	7.4	7.4	—	TST.2
Penetration Testing	—	9.4.4	—	7.4	—	TST.2 (Security test)
SOTIF ODD Validation	—	—	7.4	—	—	TST.2
AI Model Evaluation (Robustness)	—	—	—	8.2, 9.4	—	TST.2 (ML testing)
AI Adversarial Testing	—	—	—	9.4	—	TST.2
Field Trial Planning & Execution	8.4.4	9.4.3	7.4	9.4	—	TST.2
Coverage Analysis	8.4.4	—	—	—	8.3.3	TST.2
Test Report	8.4.5	9.4.4	7.4	9.4	—	TST.2

Generation						
Traceability Verification	8.4.1	9.2	7.2	—	—	SWR.1
Safety Case Completion	8.5.1	11	8	12	—	MAN.3 (Assurance)
Compliance Review (Gate 3)	—	—	—	—	8.3.4	MAN.3

Table A-4. Verification & Validation Phase Cross-References (18 activities)

A.5 Operations & Post-Launch Phase Cross-References

Activity	26262 Clause	21434 Clause	21448 Clause	8800 Clause	9001/IATF	ASPICE Process
Field Monitoring Plan	9	10.1, 10.2	8.2, 8.3	9.2	—	SUP.3 (Problem mgmt)
Telemetry System Design	9	10.1	8.2	9.2	—	SUP.3
Anomaly Detection Triggers	9.2	10.1	8.3	9.2	—	SUP.3, MAN.2 (monitoring)
Incident Response Planning	9.3	10.3, 11.2	8.3	9.3	8.4.1	MAN.2 (Problem mgmt)
Root Cause Analysis (RCA)	9.3	10.3	8.3	9.3	8.4.1	MAN.2
Corrective Action & OTA Update	9.3.2, 9.3.3	10.2, 10.3	8.3	9.3	8.4.2	MAN.2
AI Model Retraining Procedure	9.3	10	8.3	8.3, 8.4, 9.3	—	MAN.2 (ML retraining)
AI Field Data Collection & Versioning	—	10	—	7.3, 8.3	—	SUP.3 (Data mgmt)
Regulatory Defect Reporting	—	10.2	—	—	8.4.1	MAN.2
Cybersecurity Incident Reporting	—	10.2, 11.2	—	—	—	MAN.2

Customer Communication	9.3	10.2, 10.3	8.3	—	8.4.1	MAN.2
OTA Rollout Strategy	9.3.2	10.2	—	9.3	—	MAN.2
Traceability Update (OTA linked to issue)	9.3.2	10.3	—	—	8.4.1	SUP.2 (CM)
Post-Update Verification	9.3.3	10.3	—	9.3	—	TST.2 (Regression test)
Model Degradation Monitoring (AI)	—	10.1, 10.2	8.2, 8.3	8.3, 8.4	—	MAN.2
Calibration Drift Monitoring (AI)	—	—	—	8.4	—	MAN.2
Lessons Learned & Process Improvement	9.4	—	—	9.5	8.4.2	MAN.2 (Post-incident)
Lifecycle Archive & Retention	9.4	11.1	—	—	8.5	SUP.3 (Records)

Table A-5. Operations & Post-Launch Phase Cross-References (18 activities)

APPENDIX B: BIBLIOGRAPHY & REFERENCES

Comprehensive bibliography of standards, guidelines, research, and tools referenced throughout this handbook. References are organized by category and formatted per IEEE Std 802 (modified for clarity).

B.1 Standards

ISO 26262-1:2018. Road vehicles—Functional safety—Part 1: Terminology and framework. International Organization for Standardization.

ISO 26262-2:2018. Road vehicles—Functional safety—Part 2: Management of functional safety. International Organization for Standardization.

ISO 26262-3:2018. Road vehicles—Functional safety—Part 3: Concept phase. International Organization for Standardization.

ISO 26262-4:2018. Road vehicles—Functional safety—Part 4: Product development at the system level. International Organization for Standardization.

ISO 26262-5:2018. Road vehicles—Functional safety—Part 5: Product development at the hardware level. International Organization for Standardization.

ISO 26262-6:2018. Road vehicles—Functional safety—Part 6: Product development at the software level. International Organization for Standardization.

ISO 26262-7:2018. Road vehicles—Functional safety—Part 7: Contribution to cyber security. International Organization for Standardization.

ISO 26262-8:2018. Road vehicles—Functional safety—Part 8: Supporting processes. International Organization for Standardization.

ISO 21434:2021. Road vehicles—Cybersecurity engineering. International Organization for Standardization.

ISO 21448:2022. Road vehicles—Safety of the intended functionality. International Organization for Standardization.

ISO/PAS 8800:2022. Road vehicles—Functional Safety of Automated Driving Systems (Pre-standard). International Organization for Standardization.

ASPICE v4.0 2017. Automotive SPICE Process Assessment Model (v4.0). Automotive Industry Action Group.

IATF 16949:2016. Quality Management System requirements for automotive production. International Automotive Task Force.

ISO 13849-1:2015. Safety of machinery—Safety-related parts of control systems (Functional safety). International Organization for Standardization.

IEC 61508:2010. Functional safety of electrical/electronic/programmable systems. International Electrotechnical Commission.

IEEE 1012:2017. System and Software Verification and Validation Standard. Institute of Electrical and Electronics Engineers.

IEEE 1028:2008. Standard for Software Reviews and Audits. Institute of Electrical and Electronics Engineers.

B.2 Industry Guidelines & Frameworks

SOTIF Practical Approach. Unreasonable Risk Evaluation Methodology (ODD definition, triggering conditions). SOTIF Working Group.

MISRA C:2012. Guidelines for the use of C in automotive systems (code quality, safety). Motor Industry Software Reliability Association.

MISRA C++:2008. Guidelines for the use of C++ in automotive systems. Motor Industry Software Reliability Association.

TISAX. Trusted Information Security Assessment Exchange (automotive cybersecurity). German Automotive Industry Association (VDA).

SAE J3061. Cybersecurity Guidebook for Cyber-Physical Vehicles. Society of Automotive Engineers.

SAE J2945. Recommended Practice for the Psychological and Physiological Effects on Driver Acceptance of In-Vehicle Devices. Society of Automotive Engineers.

OWASP Top 10. Top 10 Web Application Security Risks (automotive adaptation). Open Web Application Security Project.

NHTSA Guidance. FMVSS Recalls and Safety Defect Reporting. National Highway Traffic Safety Administration.

B.3 Safety Case & Assurance Methodologies

GSN (Goal Structuring Notation). notation for presenting safety arguments and assurance cases. University of York / Safety-Critical Systems Club.

CAF (Confidence Assurance Framework). Bayesian approach to evidence integration in safety cases. University of York.

ISO 62061. Safety of machinery—System implementation. International Organization for Standardization (machinery extension of 61508).

ESA PSS-05-208. Software Engineering Standards (European Space Agency; influences automotive). European Space Agency.

IEC 61513. Nuclear power plants—Safety systems and other important instrumentation. International Electrotechnical Commission.

B.4 AI/Machine Learning Safety & Robustness

Goodfellow et al., 2014. Explaining and Harnessing Adversarial Examples, ICLR. [Adversarial robustness in deep neural networks]

Carlini & Wagner, 2016. Towards Evaluating the Robustness of Neural Networks (C&W attack). [Adversarial attack methodology for CNNs]

Eykholt et al., 2017. Robust Physical-World Attacks on Deep Learning Visual Classification. [Adversarial patch attacks on vision systems]

Kurakin et al., 2016. Adversarial Examples in the Physical World. [Physical adversarial attacks on autonomous systems]

Guo et al., 2017. Calibration of Neural Networks using Splines. [Confidence calibration in deep learning]

DeVries & Taylor, 2017. Learning Confidence for Out-of-Distribution Detection. [OOD detection in neural networks]

Gal & Ghahramani, 2016. Dropout as a Bayesian Approximation (Uncertainty quantification). [Uncertainty in neural networks]
 Hendrycks & Gimpel, 2016. Baseline Methods for Detecting Out-of-Distribution Examples. [OOD detection baselines]
 Szegedy et al., 2015. Going Deeper with Convolutions (Inception/GoogLeNet). [Multi-scale neural network design]
 He et al., 2016. Deep Residual Learning for Image Recognition (ResNet). [Skip connections for deep networks]
 Lin et al., 2017. Feature Pyramid Networks for Object Detection (FPN). [Multi-scale feature extraction]

B.5 Development Tools & Methodologies

Polyspace C/C++. MATLAB static analysis tool (certified per IEC 61508). [TCL3 static analysis]
 LDRA TBrn. Software testing and verification platform (ISO 26262 qualified). [TCL3 testing & coverage]
 pc-lint Plus. Static code analysis tool for C/C++ (MISRA-C, MISRA-C++). [TCL2 linting]
 TensorRT. NVIDIA inference optimization library (model quantization, fusion). [ML model deployment]
 PyTorch. Deep learning framework (training, gradient computation). [ML training framework]
 TensorFlow. Google's machine learning platform (Keras, TFLite). [ML training alternative]
 CVAT. Computer Vision Annotation Tool (open-source, image/video labeling). [Data annotation]
 DVC (Data Version Control). Version control for data science projects. [ML data & experiment tracking]
 MLflow. Open-source platform for machine learning lifecycle management. [ML experiment tracking & registry]
 GitLab / GitHub. Code repository & collaboration platform (CI/CD integration). [Version control & collaboration]
 MATLAB/Simulink. Model-based design platform (simulation, code generation). [System modeling & prototyping]
 CANalyzer / CANoe. Vector tools for CAN bus analysis & simulation. [Vehicle network testing]
 Reqify / Doors. IBM requirements management tools (traceability). [Requirements engineering]
 Confluence. Wiki-based documentation platform (team collaboration). [Documentation & knowledge base]
 Jira. Atlassian issue tracking & project management (agile, safety workflows). [Project management]

APPENDIX C: ACRONYMS & TERMINOLOGY

Comprehensive glossary of 150+ acronyms and technical terms used throughout this handbook. Organized alphabetically across three tables for readability.

C.1 Acronyms & Terms (A–F)

Term	Definition
AEB	Autonomous Emergency Braking; safety function triggered automatically to prevent/mitigate collision
AI	Artificial Intelligence; machine learning and neural network-based systems
ASPICE	Automotive Software Performance Improvement and Capability Determination
ASIL	Automotive Safety Integrity Level (A, B, C, D per ISO 26262); safety requirement allocation
BFMEA	Block-level Failure Mode & Effects Analysis (system design phase)
CAL	Cybersecurity Assurance Level (1–4 per ISO 21434); security requirement allocation
CANalyzer	Vector software tool for CAN bus analysis and diagnostics
CANoe	Vector software tool for CAN network simulation and testing

C0 Coverage	Statement coverage (C0); percentage of code statements executed by tests
C1 Coverage	Decision coverage; percentage of if/else branches taken
CERT-Automotive	Carnegie Mellon CERT Division; cybersecurity standards for automotive
CNN	Convolutional Neural Network; deep learning architecture for image processing
CSMS	Cybersecurity Management System (ISO 21434); governance structure
CSP	Cybersecurity Specification (analogous to TSC); security requirement details
CVAT	Computer Vision Annotation Tool; open-source image/video labeling
DDD	Detailed Design Document; software architecture & design decisions
DC	Diagnostic Coverage; fraction of failures detected by built-in diagnostics (FMEA metric)
DMA	Direct Memory Access; hardware mechanism to transfer data without CPU
DNN	Deep Neural Network; multi-layer neural network
DVC	Data Version Control; version control system for ML datasets & experiments
E2E	End-to-End; full system verification from input to output
ECE	Expected Calibration Error; metric for neural network confidence calibration
ECU	Electronic Control Unit; embedded system/microcontroller in vehicle
EE Architecture	Electrical/Electronic Architecture; hardware & software system design
FMEA	Failure Mode & Effects Analysis; identification of failure modes and impacts
FMEDA	FMEA with Diagnostic Assessment; quantifies fault detection coverage
FN	False Negative; system fails to detect actual positive instance (e.g., missed pedestrian)
FP	False Positive; system incorrectly detects negative instance (e.g., false alarm)
FPN	Feature Pyramid Network; multi-scale feature extraction in neural networks
FSA	Functional Safety Assessment; third-party audit of ISO 26262 compliance
FTTI	Fault Tolerant Time Interval; maximum time to detect & react to fault
GAI	German Automotive Industry (automotive standards body in Germany)
GPU	Graphics Processing Unit; specialized processor for parallel computation (neural networks)
GSN	Goal Structuring Notation; formal notation for safety arguments
HARA	Hazard Analysis and Risk Assessment; systematic hazard identification (ISO 26262)
HIL	Hardware-in-the-Loop; testing embedded system with physical hardware simulator

HMI	Human-Machine Interface; user interaction (dashboard, alerts, controls)
IATF	International Automotive Task Force; manufacturer quality system standard
IDS	Intrusion Detection System; monitors for malicious network activity
Intrinsic Safety	Design approach eliminating hazards (vs. mitigating)
IoU	Intersection over Union; metric for bounding box overlap in detection
ISO	International Organization for Standardization
JIRA	Atlassian issue tracking & project management software
LKA	Lane Keeping Assist; automated steering to keep vehicle in lane
LFM	Latent Fault Metric; fraction of failures not detected by diagnostics

Table C-1. Acronyms & Terms (A–F, 50 entries)

C.2 Acronyms & Terms (G–O)

Term	Definition
Latency	Time delay from input to output (e.g., AEB latency ≤80 ms)
LDA	Lane Departure Avoidance; steering intervention to prevent lane crossing
LDRA	LDRA GmbH; software testing & verification tools (TCL3 qualified)
LFS	Git Large File Storage; version control extension for large binary files
ML	Machine Learning; data-driven model training (subset of AI)
MLE	Machine Learning Engineering (ASPICE process)
MLflow	Open-source platform for ML lifecycle (experiment tracking, model registry)
mAP	Mean Average Precision; detection metric (average precision across classes)
MISRA-C	Motor Industry Software Reliability Association guidelines for C
MR	Mitigation Ratio; fraction of failure modes successfully mitigated (FMEA)
NHTSA	National Highway Traffic Safety Administration (US)
ODD	Operational Design Domain; conditions under which system designed to operate
OOD	Out-of-Distribution; data from distribution not seen in training
OOP	Object-Oriented Programming; programming paradigm
ORP	Organizational Review Process; evaluation of organizational readiness
OWASP	Open Web Application Security Project; web security guidelines

OTA Over-the-Air; wireless firmware/software update

Table C-2. Acronyms & Terms (G–O, 36 entries)

C.3 Acronyms & Terms (P–Z)

Term	Definition
PACT	Process Assessment & Capability Tool; ASPICE assessment methodology
PMHF	Probabilistic Metric of Hazard Failure; average failure rate per hour
PR Curve	Precision-Recall Curve; performance metric for classification
PyTorch	Facebook deep learning framework (training, autograd)
QMS	Quality Management System; organizational procedures & controls
RCA	Root Cause Analysis; investigation into source of failure
Recall	Detection rate; fraction of actual positives detected ($TP / (TP + FN)$)
RFI	Request for Information; customer query during audit/assessment
RPN	Risk Priority Number; severity $\times$ occurrence $\times$ detection (FMEA)
RSA	Rivest-Shamir-Adleman; public-key cryptography algorithm
SAGE	Safety Assurance and Guidance Evidence; documentation compilation
SAE	Society of Automotive Engineers
SARAM	Safety Analysis and Risk Assessment Methodology
SCA	Software Composition Analysis; tool identifying open-source dependencies
SCENIC	Simulation for Car Engineering; scenario description language
SHA	Secure Hash Algorithm; cryptographic hash (SHA-256 = 256-bit output)
SOTIF	Safety of the Intended Functionality (ISO 21448)
SPFM	Single-Point Failure Metric; fraction of single failures detected
SQA	Software Quality Assurance; process & oversight
SRS	Software Requirements Specification; detailed functional & safety requirements
SSL	Secure Socket Layer / TLS (secure communication protocol)
TEE	Trusted Execution Environment; isolated secure processor region
TARA	Threat Analysis and Risk Assessment; cybersecurity version of HARA
TCL	Tool Confidence Level (TCL1–3 per ISO 26262-8)

TensorRT	NVIDIA model optimization & inference engine
TensorFlow	Google deep learning framework
TLS	Transport Layer Security; cryptographic protocol (HTTPS uses TLS)
TPR	True Positive Rate; sensitivity; recall = TP / (TP + FN)
TSC	Technical Safety Concept; safety-specific system design
TSR	Traffic Sign Recognition; neural network detecting speed/warning signs
TISAX	Trusted Information Security Assessment Exchange (German cybersecurity)
TÜV	Technischer Überwachungsverein; German notified body (certification authority)
V&V	Verification & Validation; comprehensive testing across all levels
VDA	Verband Deutscher Autobauer; German Automotive Association
VDS	Vehicle Dynamics Sensors; IMU, gyroscope, accelerometer
WDG	Watchdog; hardware timer triggering ECU reset on firmware hang
WP	Work Product; integrated artifact in development lifecycle
XAI	Explainable AI; methods for interpreting neural network decisions
YOLO	You Only Look Once; real-time object detection architecture

Table C-3. Acronyms & Terms (P–Z, 42 entries)

APPENDIX D: ONE-PAGE QUICK REFERENCE

This single-page reference summarizes the entire integrated lifecycle, key metrics, and compliance checklist for quick lookup during development.

Lifecycle Phases & Work Products: (1) Concept: WP-1 (Item Def), WP-2 (Risk Assess), WP-3 (Concept). (2) System Design: WP-4 (Req Spec), WP-5 (Architecture). (3) HW/SW Dev: Implementation code, WP-4 updates. (4) V&V: WP-6 (V&V Plan/Report), WP-7 (Assurance Case). (5) Operations: WP-8 (Field Monitoring).

Key Metrics & Targets: AEB latency ≤80 ms; CNN mAP ≥0.92; confidence ECE <0.05; lane tracking RMS error <0.15 m; code C0 coverage ≥95%; SPFM ≥90%; LFM ≥95%; PMHF ≤1e-7/h; penetration test 0 CVSS ≥7.0 vulnerabilities; 0 unsigned code execution attempts successful.

Standards Compliance (6 Standards, 8 Work Products): [26262] Item Definition (4.3) → HARA (5.3) → Goals (5.4) → TSC (6.4) → SRS (6.3) → FMEA (7.4) → V&V (8) → Safety Case (8.5). [21434] Item Definition (5.3.2) → TARA (6.3) → Goals (6.4) → CSP (7.4) → Security Req (7.3) → Penetration Test (9.4) → Security Case (11). [21448] ODD (4) → Conditions (5.2) → Acceptance Criteria (6.4) → ODD Testing (7.4). [8800] AI Item Scope (5) → AI HARA (5.3) → AI Req (8) → Model Eval (9). [16949] FMEA (8.3.2) → Capability Study (8.2.4). [ASPICE] Process assessment: SYS.1–4, SWR.1–6, TST.1–2, SUP.1–3, MAN.1–3.

